



NIST Cybersecurity Framework 2.0

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations aligning with the NIST Cybersecurity Framework (CSF) 2.0. The CSF organizes cybersecurity outcomes into six core functions (Govern, Identify, Protect, Detect, Respond, and Recover) and is applicable to organizations of all sizes and sectors. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for identifying the organization's risk profile and implementing the framework remains with the organization.

<https://www.nist.gov/cyberframework>

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.

- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control DE

[Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] Networks and network services are monitored to find potentially adverse events The physical environment is monitored to find potentially adverse events Personnel activity and technology usage are monitored to find potentially adverse events [Withdrawn: Incorporated into DE.CM-01, DE.CM-09] External service provider activities and services are monitored to find potentially adverse events [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09] [Withdrawn: Incorporated into ID.RA-01] Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events [Withdrawn: Incorporated into ID.AM-03] Potentially adverse events are analyzed to better understand associated activities Information is correlated from multiple sources The estimated impact and scope of adverse events are understood [Withdrawn: Moved to DE.AE-08] Information on adverse events is provided to authorized staff and tools Cyber threat intelligence and other contextual information are integrated into the analysis Incidents are declared when adverse events meet the defined incident criteria [Withdrawn: Incorporated into GV.RR-02] [Withdrawn: Incorporated into DE.AE] [Withdrawn: Incorporated into ID.IM-02] [Withdrawn: Incorporated into DE.AE-06] [Withdrawn: Incorporated into ID.IM, ID.IM-03]

SCF Controls: THR-01, THR-02, THR-03, THR-07, THR-09, THR-10

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters.

Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache. Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DE.AE

[Withdrawn: Incorporated into ID.AM-03] Potentially adverse events are analyzed to better understand associated activities. Information is correlated from multiple sources. The estimated impact and scope of adverse events are understood. [Withdrawn: Moved to DE.AE-08] Information on adverse events is provided to authorized staff and tools. Cyber threat intelligence and other contextual information are integrated into the analysis. Incidents are declared when adverse events meet the defined incident criteria. [Withdrawn: Incorporated into DE.AE] [Withdrawn: Incorporated into DE.AE-06]

SCF Controls: IRO-01, IRO-02, IRO-02.4, MON-01, MON-01.12, MON-01.8

Aggregate Coverage: Meets

VCF (Meets)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend provides structured classification and prioritization mechanisms for security detection events within the network security domain.

Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help security teams prioritize response actions. Security Intelligence also categorizes detected events by MITRE adversarial tactics and techniques, recording occurrence counts during the selected time period, which provides additional context for classification decisions.

Network Detection and Response (NDR) assigns impact scores to campaigns, with higher scores indicating higher priority for triage and response. Detection events are classified into impact levels; events with an impact score from 1 to 24 are classified as Informational, indicating the detected activity is not essentially malicious. NDR calculates impact scores from Confidence and Severity values, and contextual scoring logic may promote some Informational detections to a higher impact level. NDR also provides filtering of the unified event list by detection impact score using checkboxes, which allows security teams to focus investigation on higher-priority detections.

The Security Services Platform (SSP) Campaign view includes a Blueprint tab that visualizes correlated security events and key actors, supporting investigation of multi-stage incidents. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

VMware vDefend includes an Intelligent Assist triage capability: when responding to security incidents, security teams can select a Targeted Strategy for surgical, safer remediation with potentially lower effectiveness, or a Comprehensive Strategy for broader remediation with potentially lower safety. This capability helps match remediation scope to assessed incident severity.

IDS/IPS events are classified by severity level (Informational, Low, Medium, High, and Critical), and vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping non-critical severity data (Low and Informational) first, followed by Medium, then High and Critical severity events, with packet captures dropped only as a last resort. This built-in severity hierarchy reflects the product's internal classification model.

The broader incident classification process, including establishing organizational incident categories, defining triage protocols, and coordinating business continuity actions, remains an organizational function that extends beyond network-layer detection capabilities.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides data protection incident response capabilities through structured recovery plans, non-disruptive testing, and automated failover orchestration. Recovery plans define documented, repeatable response procedures that specify VM recovery sequences and reprotect operations following a recovery event, with reprotect process states displayed in the recovery plan user interface so operators can observe operation status. Test failover and planned

migration operations validate response readiness before an incident, and disaster recovery failover handles unplanned events when the protected site is unavailable.

PNR's event logging and alarm framework detects conditions that may indicate a data protection incident, including site connectivity loss, replication failures, and interrupted reprotect operations. PNR captures audit events that record user actions, including configuration changes and recovery plan executions, with the event name, user identity, and source IP address where the event was initiated. The PlanExecReprotectEnd event is signaled on the recovery site when a reprotect operation completes, supporting closure of the response lifecycle. Protection and Recovery Dashboards in VCF Operations provide consolidated visibility across vCenters, vSAN snapshot and replication sites, VCF Protection and Recovery Cloud regions, and protection and recovery site pairs to help incident responders see protection status at a glance.

For cyber-incident scenarios, PNR includes Cyber Recovery with a clean room at the recovery site to isolate recovered workloads during ransomware analysis. Cyber Recovery integrates with Carbon Black and CrowdStrike for security and vulnerability analysis: results include risk score details, environmental impact, CrowdScore severity (a CrowdScore of 100 indicates a critical threat level), and recommended remediation actions to support response decisions. When a disaster affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so organization users can return to running their workloads.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tdm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health,

node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control DE.AE-02

Potentially adverse events are analyzed to better understand associated activities

SCF Controls: IRO-02, IRO-02.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend provides structured classification and prioritization mechanisms for security detection events within the network security domain.

Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help security teams prioritize response actions. Security Intelligence also categorizes detected events by MITRE adversarial tactics and techniques, recording occurrence counts during the selected time period, which provides additional context for classification decisions.

Network Detection and Response (NDR) assigns impact scores to campaigns, with higher scores indicating higher priority for triage and response. Detection events are classified into impact levels; events with an impact score from 1 to 24 are classified as Informational, indicating the detected activity is not essentially malicious. NDR calculates impact scores from Confidence and Severity values, and contextual scoring logic may promote some Informational detections to a higher impact level. NDR also provides filtering of the unified event list by detection impact score using checkboxes, which allows security teams to focus investigation on higher-priority detections.

The Security Services Platform (SSP) Campaign view includes a Blueprint tab that visualizes correlated security events and key actors, supporting investigation of multi-stage incidents. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

VMware vDefend includes an Intelligent Assist triage capability: when responding to security incidents, security teams can select a Targeted Strategy for surgical, safer remediation with potentially lower effectiveness, or a Comprehensive Strategy for broader remediation with potentially lower safety. This capability helps match remediation scope to assessed incident severity.

IDS/IPS events are classified by severity level (Informational, Low, Medium, High, and Critical), and vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping non-critical severity data (Low and Informational) first, followed by Medium, then High and Critical severity events, with packet captures dropped only as a last resort. This built-in severity hierarchy reflects the product's internal classification model.

The broader incident classification process, including establishing organizational incident categories, defining triage protocols, and coordinating business continuity actions, remains an organizational function that extends beyond network-layer detection capabilities.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control

how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control DE.AE-03

Information is correlated from multiple sources

SCF Controls: IRO-02, IRO-02.5, MON-02, MON-02.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend Network Detection and Response (NDR) correlates detection events into campaigns, comparing new detection data against existing events to identify related activity. Campaigns provide a view of a threat by correlating detection events to identify the different stages of an attack, and security analysts can view and triage threat campaigns through a campaign timeline. NDR supports SIEM integration, sending campaign and event logs to a connected SIEM in real time, allowing network security event data to be exported for broader correlation with other enterprise data sources.

Security Intelligence detects and categorizes suspicious events using MITRE ATT&CK tactics and techniques, recording event occurrences during selected time periods, and provides a View Full Event History capability that displays all events associated with a given signature ID and intrusion severity. Security Intelligence also correlates IDS events from the same source and destination hosts to connect related events and build a broader picture of an attack. This structured, MITRE-tagged event data can support SIEM-based analysis and enterprise-wide threat correlation.

The Security Services Platform (SSP) can be configured to forward log messages to external syslog servers for centralized log collection. SSP syslog configuration supports TCP, TLS, and UDP protocols and allows administrators to specify server address and port, integrating with existing SIEM ingestion pipelines. NDR Sensors report metrics covering health, traffic trends, and data processing activity, available as point-in-time measurements or aggregated data over time.

vDefend correlates only technical network security data and has no capability to ingest or correlate non-technical information such as HR records, physical access logs, or operational data. Satisfying the full scope of this control, which requires correlation of both technical and non-technical information across the enterprise, requires an external SIEM or equivalent platform.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides multiple mechanisms for forwarding security-relevant event logs to external centralized collection systems, including SIEM platforms, syslog aggregators, and log analytics tools.

The Avi Controller exports logs through syslog forwarding, configured via the `configure systemconfiguration` CLI command or through the Controller Settings interface. The `syslog_servers` setting specifies one or more external syslog destinations. Syslog configuration is synchronized from the Controller to Service Engines, so data-plane events from Service Engines are also forwarded to the same targets.

For audit-focused event streaming, Avi provides Syslog-Audit-Persistence, a built-in alert action template that streams audit and security events to external syslog servers. Events forwarded in this mode are encoded in SYSLOG_RFC5425_ENHANCED format, which includes event type, object name, tenant identifier, timestamp, and the identity of the user who performed the action. Syslog transport supports both TCP (with TLS) and UDP with a configurable destination port (default 514 per RFC 5426). This covers administrative configuration changes, object-level audit events, and security alert notifications.

The Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk, providing complete traceability of encrypted communication lifecycle events. The Avi DataScript engine supports logging of security events such as blocklisted IP access attempts using the `log()` function, making application-layer policy enforcement decisions available to the central log collector.

Beyond the audit stream, Avi supports streaming client application logs to external syslog or logging servers for centralized monitoring and compliance audit trails. WAF Application Rule events are captured when a WAF rule fires, recording the type of attack detected and matched variable content, and these events can be forwarded to the same external collection targets. The Avi Controller also logs denial of service attack events with structured details including event ID, attack count, threshold values, and alert level.

Avi supports integration with VCF Log Management. A VCF Log Management Log Forwarder can be configured as a syslog destination in the Avi Controller to receive events. The VCF Log Management agent, installed on an external syslog server, can parse JSON log data and forward it to the Log Forwarder. The recommended integration pattern routes logs through an intermediate proxy for JSON parsing, enabling key extraction and facilitating querying of client logs. Note that virtual service client logs should not be sent directly from the Service Engine to a Log Forwarder; the recommended path routes through an intermediate syslog server.

The Avi Analytics Profile supports streaming of client logs to multiple external servers simultaneously, including IPv6 destinations. For assured retention of all logs, Avi documentation recommends streaming logs directly to an external server such as Splunk rather than relying on local storage. In air-gap environments, the remote syslog server must be located within the environment perimeter.

The Avi Event Log system records all system activities, configuration changes, and operational events, including who made each change and when. Global event logs are accessible via the Operations > All Events page in the Avi UI, covering all objects including deleted objects and sub-objects such as profiles and certificates. A REST API endpoint allows retrieval of event logs for a specific time period to support automated log collection workflows. Events can be filtered by type using parameters such as `event_id=CONFIG_CREATE` or `event_id=CONFIG_UPDATE` to identify configuration activity.

Note that system component debug logs are not sent to remote syslog servers and are available only through the Tech Support generation mechanism. Similarly, virtual service logs are not pushed automatically via syslog notification; they must be pulled from an external logging system through the API or configured separately to be pushed from the Controller.

To configure centralized log forwarding, navigate to Controller Settings and enter the target syslog server address in the Syslog configuration. For audit event streaming specifically, configure the Syslog-Audit-Persistence alert action template. For VCF Log Management integration, configure a Log Forwarder as a syslog destination in the Controller and optionally deploy the VCF Log Management agent on an intermediate syslog server for JSON parsing.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control DE.AE-04

The estimated impact and scope of adverse events are understood

SCF Controls: GOV-16, IRO-02, IRO-02.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend provides structured classification and prioritization mechanisms for security detection events within the network security domain.

Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help security teams prioritize response actions. Security Intelligence also categorizes detected events by MITRE adversarial tactics and techniques, recording occurrence counts during the selected time period, which provides additional context for classification decisions.

Network Detection and Response (NDR) assigns impact scores to campaigns, with higher scores indicating higher priority for triage and response. Detection events are classified into impact levels; events with an impact score from 1 to 24 are classified as Informational, indicating the detected activity is not essentially malicious. NDR calculates impact scores from Confidence and Severity values, and contextual scoring logic may promote some Informational detections to a higher impact level. NDR also provides filtering of the unified event list by detection impact score using checkboxes, which allows security teams to focus investigation on higher-priority detections.

The Security Services Platform (SSP) Campaign view includes a Blueprint tab that visualizes correlated security events and key actors, supporting investigation of multi-stage incidents. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

VMware vDefend includes an Intelligent Assist triage capability: when responding to security incidents, security teams can select a Targeted Strategy for surgical, safer remediation with potentially lower effectiveness, or a Comprehensive Strategy for broader remediation with potentially lower safety. This capability helps match remediation scope to assessed incident severity.

IDS/IPS events are classified by severity level (Informational, Low, Medium, High, and Critical), and vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping non-critical severity data (Low and Informational) first, followed by Medium, then High and Critical severity events, with packet captures dropped only as a last resort. This built-in severity hierarchy reflects the product's internal classification model.

The broader incident classification process, including establishing organizational incident categories, defining triage protocols, and coordinating business continuity actions, remains an organizational function that extends beyond network-layer detection capabilities.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control

how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control DE.AE-06

Information on adverse events is provided to authorized staff and tools [Withdrawn: Incorporated into DE.AE-06]

SCF Controls: IRO-02, IRO-02.4, IRO-04, IRO-07, IRO-09, IRO-10, MON-01.12, MON-01.8, MON-02, MON-02.1

Aggregate Coverage: Meets

VCF (Meets)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control DE.AE-07

Cyber threat intelligence and other contextual information are integrated into the analysis

SCF Controls: THR-01, THR-03, THR-10

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters.

Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache.

Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DE.AE-08

[Withdrawn: Moved to DE.AE-08] Incidents are declared when adverse events meet the defined incident criteria

SCF Controls: IRO-02, IRO-02.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control DE.CM

[Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09]
Networks and network services are monitored to find potentially adverse events. The physical environment is monitored to find potentially adverse events. Personnel activity and technology usage are monitored to find potentially adverse events. [Withdrawn: Incorporated into DE.CM-01, DE.CM-09] External service provider activities and services are monitored to find potentially adverse events. [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09] [Withdrawn: Incorporated into ID.RA-01]
Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events.

SCF Controls: IRO-03, MON-11.3, MON-16, THR-02

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides automated mechanisms for identifying and alerting on indicators of compromise through VCF Operations, VCF Operations for Networks, VCF Log Management, and VMware vCenter alarm capabilities. These tools allow administrators to define custom detection logic, monitor for anomalous conditions, and receive automated notifications when suspicious activity is detected.

VCF Operations supports the creation and configuration of alert definitions that monitor infrastructure events and conditions. Administrators can define metric event symptoms based on reported violations of metric thresholds from monitored systems, creating symptoms that feed into alert definitions. Each alert carries a Criticality attribute with possible values of Info, Warning, Immediate, or Critical, based on the level assigned when the alert definition was created or on the highest symptom criticality. Alert definitions also carry an Impact setting, which can be configured to Risk to flag problems requiring near-term investigation. When defined thresholds are violated, whether dynamic or static, VCF Operations triggers alerts and displays results in dashboards, views, and reports. The system highlights anomalous metric behavior for identification during incident investigation.

Log-based alerting in VCF Operations provides another detection layer. Log-based alerts are available through Symptom Definitions in Infrastructure Operations, enabling administrators to create detection rules that match patterns in log data. This capability supports identification of indicators of compromise that manifest as specific log entries, such as authentication failures, unauthorized configuration changes, or other suspicious events recorded in system logs. Administrators can compare changes to an object with symptoms and other data in VCF Operations to identify a possible cause for a generated alert, supporting root cause analysis during incident investigation.

VCF Operations event auditing provides visibility into platform interactions and generates audit events across the following categories: Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. The audit framework surfaces suspicious access events and policy violations, with each event providing a detailed view to help analyze suspicious user actions or system issues. Authentication and security-related events are specifically tracked, increasing user accountability by registering each action as an audit event. Audit events are accessible from the left menu under Security and are displayed in a tabular format.

Configuration drift detection in VCF Operations monitors for unauthorized changes by comparing current configurations against assigned template values. VCF Operations continuously evaluates collected data against defined policies and assigns a compliance score to each object or group based on how well they adhere to those policies. When a setting deviates from its desired value, the system generates a drift notification. Configuration drift from established baselines can indicate compromise, and VCF Operations generates alerts when compliance standards are violated. The platform also generates alerts for specific security-relevant changes, such as when any property of a Security Group is changed in NSX. vSphere Configuration Profiles extend this to the VMware ESX host layer, where administrators can configure alarms triggered by host

configuration out-of-compliance events (for example, the `com.vmware.vcIntegrity.ClusterConfigurationOutOfCompliance` event), with notifications delivered via email or SNMP trap.

VCF Operations for Networks extends monitoring with search-based alerts that can be configured with severity levels and tuned to detect anomalous network patterns. The Guided Network Troubleshooting feature creates a dependency graph of related entities, shows all relevant and correlated metrics and alerts, and highlights entities with anomalies for visual identification and root cause investigation. The Troubleshooting Workbench Anomalous Metrics card displays metrics that have shown drastic changes within a selected scope and time period, ranking results by degree of change with the most recent anomalous metric given the highest weighting. The Troubleshooting Insights widget displays the top three troubleshooting insights containing hints and metric details related to potential anomalies.

For automated notification delivery, VCF supports multiple outbound channels. VCF Operations can send alert notifications via SNMP trap to up to four SNMP trap destinations, with support for filtering when defining notifications. vCenter can send SNMP traps when alarms are triggered and also supports email notifications with configurable recipient addresses. vCenter SNMP trap notifications support SNMPv1, v2c, and v3, with v3 supporting all security levels to allow authenticated and encrypted trap delivery when integrating with external security monitoring infrastructure. These notification mechanisms allow integration with external security information and event management systems and security operations center workflows, so that indicator-of-compromise alerts reach the appropriate response teams without manual intervention.

VCF supports integration with external logging and monitoring solutions through syslog forwarding. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS protocol and requires port 6514 to be open for TLS-encrypted log transmission. VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture.

Administrators can build a library of recommendations in VCF Operations that include instructions or automated actions to resolve alerts, connecting indicator-of-compromise detection directly to response procedures. Alert definitions can be created from Infrastructure Operations under Alerts or Troubleshoot, allowing flexible construction of detection rules for particular object types or metrics. VMware vDefend, available as a separate product, extends these capabilities with network-layer threat detection including IDS/IPS and traffic analysis.

VMware vDefend (Meets)

VMware vDefend provides automated IoC identification and alerting through IDS/IPS signature matching, Network Detection and Response (NDR) event correlation, and Malware Prevention file analysis with threat scoring, all accessible through the Security Services Platform (SSP) interface.

The NDR Campaign Blueprint presents an interactive graph visualizing correlated security events that maps the different stages of an attack. Graph nodes represent Threats, Custom IDS Signatures, and Indicators of Compromise. The IoC Summary for each File IOC and Malware IOC presents file score, verdict, SHA hashes, and a View Reports link; directional arrows indicate when a workload is affected by an IoC, and node colors reflect severity based on the highest impact score from associated detections. The Campaign Blueprint's Triage and Investigate feature allows filtering detections by threat, affected workload, or MITRE tactics, enabling security teams to scope the impact of detected IoCs.

The IDS/IPS Monitoring page provides a timeline graph visualization of intrusion events, with colored dots indicating unique event types and dot size indicating event frequency over a selectable time span. Events can be filtered by severity rating: Critical, High, Medium, Low, or Suspicious. Security Intelligence within the SSP provides a visualization canvas displaying granular IDS/IPS event data, including a blast radius view that highlights affected connections and can be filtered by specific signature ID. The SSP also collects and provides IDS/IPS metrics to monitor the readiness and performance of vDefend IDS/IPS across the environment. vDefend IDS/IPS maintains a detailed event log on ESX hosts capturing all alerts, drops, and rejects with metadata including source port, destination IP, IP protocol, and timestamps.

The Threat Monitoring dashboard in the Security Services Platform displays file event statistics and recently detected threats, providing summary-level visibility into Malware Prevention activity. An alarm is triggered on the Security Overview dashboard

when dropped events are detected, alerting administrators via both the alarm page and a notification banner, and the alarm remains active until no dropped events are detected.

NDR integrates with external SIEM platforms, including VCF Log Management and Splunk, sending campaign and event logs as they occur. Events forwarded to the SIEM include new detections, detection updates, and new campaign creation, supporting automated alerting to organizational monitoring infrastructure. Security Intelligence also continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic.

To configure IoC monitoring in a vDefend deployment: enable IDS/IPS profiles on Distributed Firewall rules, configure NDR in the Security Services Platform, enable the Malware Prevention service, and configure SIEM integration under NDR settings to receive real-time event forwarding.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer detection of Indicators of Compromise (IoC) through its Web Application Firewall (WAF) and event-driven alert framework. When WAF Application Rules match incoming requests, App Log Analytics captures attack events and records information about the type of attack, such as SQL injection or cross-site scripting. The Application Security Report surfaces these findings as ranked lists of top attack types and top attacking IP addresses, with trend summaries showing total and flagged requests over time. In Evaluation Policy Mode, Avi WAF can generate a WAF Evaluation Report with WAF Statistics that provides a high-level overview of the application's security posture without blocking traffic. Avi's scan detection system also dynamically tunes client group membership in response to changes in traffic patterns to reduce false positives.

Avi's Alert framework processes system events and performance metrics against user-defined rules to generate alerts that trigger configured notification actions. Administrators can deliver alerts to multiple destinations configurable in the Operations > Notifications page of the Avi Controller UI: email, syslog, SNMP traps (SNMPv2c and SNMPv3), and custom APIs. SNMP notifications can be configured with TLS encryption and strict certificate verification. The Controller also monitors for denial-of-service attacks, with the Avi Service Engine generating DOS_ATTACK alert events that include attack type, attack count, source IP addresses, affected virtual service name, and report timestamp at configurable severity levels. Avi's alerting and reporting tools monitor over 500 real-time metrics for DDoS and attack mitigation activity.

For automated response, ControlScript alert actions allow Avi to react programmatically to detected security events without manual intervention. A ControlScript can add an offending client IP address to a blocklist IP group attached to a network security policy, blocking or rate-shaping traffic from attackers identified in DoS or other attack events. DataScripts provide additional capability for custom identification of suspicious traffic and execution of appropriate mitigation actions.

Avi's ICAP integration extends threat detection to content-level indicators by forwarding content to the vDefend sandbox analyzer. The response includes X-Infection-Found and X-Virus-ID headers containing threat scores, file hashes, and task UUIDs for analysis tracking. IP reputation events can be logged for monitoring and investigation.

Organizations seeking IoC detection across the full VCF environment should forward Avi alerts and application logs to a SIEM or external threat intelligence platform. Full infrastructure-wide IoC detection requires correlating Avi's application-layer signals with telemetry from other VCF platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DE.CM-01

Networks and network services are monitored to find potentially adverse events [Withdrawn: Incorporated into DE.CM-01, DE.CM-09] [Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09]

SCF Controls: MON-01, MON-01.1, MON-01.3, MON-01.4, MON-01.8

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides layered event logging, continuous monitoring, and alerting capabilities across all platform components, supporting ongoing review of security events and incident escalation.

VCF Operations delivers continuous monitoring through its event auditing capability, which provides visibility into platform interaction changes across the infrastructure and surfaces suspicious access events and policy violations. Audit events tracked by VCF Operations include user searches, logins, logouts, capability checks, and configuration modifications, with each interaction generating a corresponding audit record. A dedicated audit events view gives operators a consolidated perspective on authentication and security-related activity across the environment. The audit events framework captures interactions across vSphere, vSAN, and NSX resources, so security-relevant actions are registered for review.

Centralized log collection is handled by VCF Log Management, which collects log data from VMware vCenter, VMware ESX hosts, NSX, and other VCF components. Administrators can search and filter log events by timestamp, source, text, and structured fields. VCF Log Management includes content packs for VCF components that provide pre-built dashboards, alerts, and queries organized by use case, giving immediate visibility into authentication failures, privilege changes, configuration modifications, and other security-relevant events. A dedicated NSX content pack provides alerts for NSX environment monitoring. VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the `vpdx.event.syslog.enabled` option in the vCenter Management Interface, providing a direct path to external SIEM or log management systems. ESX hosts support configurable syslog log levels and can forward syslog messages to a remote log server using `esxcli` commands. The `Syslog.global.auditRecord.remote` parameter specifically controls whether ESX audit records are forwarded to the remote syslog host defined by `Syslog.global.logHost`, allowing auditors to verify that security-relevant audit records reach the centralized log collection infrastructure. NSX components record security-related events in audit logs stored at `/var/log/audit/audit.log` and send audit logs directly to configured remote syslog servers. NSX also provides security compliance events documented in the NSX Event Catalog. VCF Operations integrates its own audit log with syslog and can forward user activity audit logs to an external syslog server to support security auditing requirements.

Within VMware Kubernetes Service (VKS) clusters and vSphere Supervisor, the Kubernetes API server produces structured audit records for all API interactions. Each audit event captures the audit level, a unique audit ID, the requesting user, the target resource and namespace, the source IP address, the operation performed, and the stage of request handling at the time the record was generated. An audit policy controls which verbs and resource types are recorded and at what level of detail, allowing administrators to scope coverage to security-relevant operations. The Kubernetes audit logger records actions taken by the API for later analysis. Audit records can be written to a local file by mounting a policy at `/etc/kubernetes/audit-policy.yaml` with logs written to `/var/log/kubernetes/audit/`, and node log agents can collect and forward them to a central log store as part of the observability pipeline. Kubernetes system component logs, including those from the API server, controller manager, and scheduler, record cluster events with configurable verbosity, providing coarse-grained error reporting up to fine-grained step-by-step traces. Application and system logs together give a chronological record of events inside workloads and security-related activities, and should be routed to an external SIEM or log management platform to make ongoing review feasible at scale. Pod Security Admission, when configured in audit mode for VKS clusters running VKr 1.25 and later, adds an audit annotation to the audit log entry for each security policy violation without blocking the workload, creating a reviewable trail of policy deviations. The Kubernetes seccomp facility supports the `SCMP_ACT_LOG` action, which allows syscalls to execute while logging each to syslog or auditd; an `audit.json` seccomp profile can log all syscalls of a process for detailed syscall-level visibility. Audit rules can be written to alert on specific security-relevant events, such as concurrent reading of multiple Secrets by a single user.

For log forwarding from the VKS and consumption layer, administrators can apply the LogAgentConfiguration Custom Resource to a vSphere Namespace to stream workload logs to a remote syslog server. Syslog messages from vSphere Pods include metadata fields for namespace name, pod UID, pod name, container name, and ESX host name, providing the context needed to correlate pod events with platform-level audit records. VKS clusters support the Fluent Bit standard package, which can forward logs to Syslog, HTTP, Elasticsearch, Kafka, and Splunk endpoints, giving operators a direct path to route VKS log streams into external SIEM or log management systems alongside VCF platform logs. Fluent Bit on VKS clusters collects Kubernetes API Server audit logs in JSON format, Linux authentication logs, and container runtime interface logs through configurable parsers and filters. On vSphere Supervisor control plane nodes, Fluent Bit collects kube-apiserver audit output from `/var/log/vmware/audit/kube-apiserver.log` using the tag `audit.apiserver.*`, with local buffering at `/var/log/vmware/fluentbit/flb_audit_apiserver` before forwarding to configured destinations. VM Operator logs within VKS clusters record reconciliation events for VirtualMachineService resources and VM creation failures, extending operational event visibility to the workload layer.

For alerting and escalation, VCF Operations classifies alerts by impact into three categories: Health alerts indicate problems requiring immediate attention, Risk alerts indicate problems that must be addressed before they become health issues, and Efficiency alerts identify areas where resources can be reclaimed or optimized. The Platform Health Alerts page provides a centralized view of all health-related alerts across data sources and infrastructure nodes, and alerts can be filtered and sorted by severity on the dashboard. Alert definitions can be created against log events and metrics, and when an alert fires, it presents the triggering symptoms along with recommendations for resolution so operators can evaluate the event and take action. Custom alert definitions allow organizations to tailor monitoring to their specific escalation criteria. VCF Operations also activates alert definitions within compliance policies, assessing objects against selected compliance standards and triggering alerts when deviations are detected. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the alerting posture to organizational requirements.

VCF Operations supports multiple outbound notification methods for incident escalation: Standard Email, SNMP Trap, Webhook Notification, Slack, and ServiceNow Notification plug-ins all support notification rules. Notification rules can be configured with payload templates to route specific alert types to the appropriate teams or external incident management systems. Syslog forwarding from all VCF components enables integration with external SIEM platforms for organizations that centralize event review and incident escalation in those systems.

The Troubleshooting Incidents page provides a summary of all incidents, including status, entity counts for in-progress incidents, and counts of top root causes, giving operators a consolidated view for ongoing event review. Predefined dashboards are complemented with out-of-the-box customizable alerts and reports to assist with operational awareness.

VMware vDefend (Meets)

VMware vDefend generates security event logs across its Distributed Firewall (DFW), Gateway Firewall (GFW), and IDS/IPS components. In 9.1, vDefend integrates with VCF Log Management, which collects Unified Security Logs covering DFW, GFW, Identity Firewall, FQDN Analysis, TLS Inspection, IDPS, and URL Filtering events in a consolidated stream suitable for forwarding to external SIEM platforms.

The Security Overview Dashboard's Threat Event Monitoring tab provides ongoing visibility into security issues across the data center, displaying statistics on Malicious IPs, Top Blocked IPs, Top VMs Accessing Malicious IPs, and Top Blocked Categories. Administrators can filter the view by All Traffic, Distributed Only, or Gateway Only events, and a trend graph shows intrusion events over time categorized by Intrusion Severity.

The dedicated IDS/IPS Security Dashboard supports event monitoring for both Distributed and Gateway deployments. Intrusion events can be filtered by Attack Target, Attack Type, and CVSS score threshold to focus review on the highest-priority activity. IDS/IPS events can also be exported directly to syslog by enabling the `ids_events_to_syslog` setting on ESX hosts, providing centralized log collection through existing syslog infrastructure independent of the NDR component; this setting is disabled by default and must be explicitly enabled. In 9.1, vDefend IDS/IPS and Network Detection and Response (NDR) support date range filtering for event detail review through the Intelligent Assist triage interface, enabling temporal analysis of security events and intrusion attempts.

Security Intelligence, accessible through Security Explorer, provides a View Full Event History capability that surfaces all events associated with a given signature ID along with their intrusion severity, supporting focused review of specific threat patterns. File event statistics are available through the Threat Monitoring dashboard in Security Services Platform, with graphs filterable by configurable time period.

NDR collects and analyzes security event data for real-time monitoring and supports SIEM integration for centralized event management. The organizational processes of reviewing logs on an ongoing basis and escalating incidents in accordance with defined timelines and procedures must be established and managed outside vDefend through SIEM tooling and documented response procedures.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates structured audit events and alarm notifications across its disaster recovery components, providing the event sources and escalation mechanisms that support ongoing security event monitoring.

PNR supports event logging where each event type has a corresponding alarm that can trigger when the event occurs. Events carry three severity levels: Info for normal operational information, Warning for conditions requiring attention that do not affect system operation, and Error for failed operations. Event records include timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. Audit events for user actions include the event name, user identity, and source IP address. vSphere Replication maintains a dedicated audit log at `/opt/vmware/support/logs/hms/hms-audit.log` and records login events with timestamps, user identity, session keys, and locale information. Authorization error messages include timestamps and component information to support security event tracking.

PNR audits changes to protection configurations: it logs when consistency groups are added to protection groups as Info-level events and when protected consistency groups enter error or warning states as Error-level events. PNR monitors connections between sites by sending periodic ping requests and logging Site Status Events that reflect the connection state between protected and recovery sites. vSphere Replication generates typed audit events when virtual machines and hosts are configured or unconfigured for replication. The PNR health monitor service checks each health finding every five minutes and raises Warning-status alerts for expired snapshot schedules, replication errors such as missing VMs, and site connectivity issues.

Alarms can be configured to send email notifications, SNMP traps, or execute scripts when specified event conditions are met, allowing DR events to feed into established incident response and escalation procedures. PNR maintains an Alarms list that provides a searchable, severity-filterable history of notifications that required attention, supporting periodic review.

VCF Operations collects configuration, component health, and usage information from PNR servers and site pairs to populate Protection and Recovery dashboards. These dashboards display alerts about configurations requiring attention and health status for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites. The Inventory view provides object-level monitoring of health status, metrics, and alerts across all protected objects.

The Clean Room Orchestrator maintains a global collection of events, tasks, and alarms for ransomware recovery operations. Event forwarding from PNR to VCF Log Management (version 9.0 and above) is supported for centralized log collection and review.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several capabilities that support ongoing event log review. The primary interface for reviewing non-database-related operations is the System Audit Events view, accessible through the System Audit section of the Provider interface. This view records and displays DSM management-plane operations in a structured format, including the Component field (which DSM component performed the operation), Event Type (the type of audited event or operation), Event Details (operation-specific details for the event), Event Time in UTC, Status, and Source. The Source field records either a user identifier (Email ID) for user-initiated events or "System" for events initiated by DSM without user intervention. Administrators can review these events directly in the UI or export them in CSV or XLSX format using the

ACTIONS drop-down menu in the System Audit Events view. Exports include all audit events visible to the reviewing user, regardless of how many events appear on a single page, enabling complete off-platform analysis and reporting.

In addition to the System Audit Events view, DSM provides Gateway Audit Logs accessible through the Audit Logs section. Gateway Audit Logs track user read and write operations to DSM data services and infrastructure objects performed in the DSM UI or the DSM Gateway Kubernetes interface. Gateway audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and are retained for the last five days on the Provider VM. When a default S3 provider log repository is configured, DSM archives these files periodically to an S3 subpath named "gateway audit," supporting log retention for ongoing and retrospective review. The gateway audit logs contain standard Kubernetes audit events but do not record the content of secrets.

DSM generates a structured set of alerts to support proactive monitoring and help surface conditions that may require investigation. At the infrastructure level, DSM raises an `INFRASTRUCTURE_POLICY_VC_ALARMS` alert when one or more active infrastructure resource alarms are detected in VMware vCenter, and generates alerts for vCenterBinding API status and LicensingNotUpdated conditions. DSM also generates a `VCENTER_CONNECTIVITY` alert when vCenter connectivity fails; troubleshooting steps include verifying vCenter connectivity, checking vCenter authentication logs, and verifying that the service account is not locked. At the database level, DSM provides an Alerts pane in the Monitoring tab where administrators can monitor alerts triggered on databases, covering conditions such as CPU Health, Data Disk Health, System Disk Health, Max Connections, Custom Config Health, and Database Engine Health. Administrators can configure and edit alert threshold values and time limits for warning and critical severities on these conditions, allowing organizations to tune alerting sensitivity to their operational requirements. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations, enabling integration with external notification systems.

Organizations that deploy the VCF Operations integration can extend monitoring visibility. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state, displays active alerts and inventory items on the Data Services View dashboard, and surfaces performance data at three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for database-specific metrics such as Active Connections, Commits, Rollbacks, and Deadlocks.

DSM provides the audit event records, alert generation, export capabilities, log archival, and optional VCF Operations integration needed to support a log review program. The review cadence, escalation thresholds, escalation workflows, and incident management procedures are organizational responsibilities that must be defined and operated separately. Integration with a SIEM or centralized log management platform is also an organizational decision.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides a multi-layer event logging and alerting infrastructure that gives organizations the data needed to support ongoing security event review and incident escalation.

Avi's Event Logs record detailed information about system activities, configuration changes, and operational events, including the identity of users who made configuration changes and the timestamps of those changes. The Config Audit Trail provides a filtered view of this event stream, isolating configuration changes and user activity events over a selectable time period to support both real-time review and retrospective audit. The Avi Controller and Service Engine track health score changes and SSL certificate expiration events, extending automated monitoring beyond configuration activity.

At the application layer, the WAF captures security events through App Log Analytics when a WAF Application Rule is triggered, recording information about the type of attack detected. WAF logging supports granular audit log parts, including matched XSS data with variable name and matched content (using the `ctl:auditLogParts=+E` configuration). Avi DataScript supports logging of security events such as blocklisted IP access attempts using the `log()` function, enabling custom event capture for virtual services. Avi Controller also logs denial-of-service attack events with event details including event identifier, attack count, threshold values, and alert level.

For external integration, Avi forwards events to SIEM platforms and monitoring systems through multiple channels. The Syslog-Audit-Persistence alert action template streams audit events to external syslog servers to support audit compliance requirements. Alert notifications can be delivered by email, SNMP trap, or custom API webhooks, notifying administrators of

security events as they occur. Avi Controller and Service Engine log audit records for trusted channel initiation, termination, and failures to Events, Syslog, and Splunk. The Avi Application Security Report gives security teams a consolidated view of overall security posture, threat monitoring, and audit-ready records.

Administrators should be aware that debug logs and Event Logs are not forwarded through OS-level syslog configuration; Event Logs require the Avi-specific Syslog-Audit-Persistence mechanism to reach external syslog servers. Syslog notifications push alerts to syslog servers but do not automatically export virtual service logs; those must be pulled via API or scripted for delivery from the Controller to a remote log server.

Control DE.CM-02

The physical environment is monitored to find potentially adverse events

SCF Controls: PES-01, PES-03, PES-03.3, PES-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control DE.CM-03

Personnel activity and technology usage are monitored to find potentially adverse events [Withdrawn:
Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09]

SCF Controls: MON-01, MON-16, MON-16.1, MON-16.3, NET-18

Aggregate Coverage: Meets

VCF (Meets)

VCF contributes to monitoring internal personnel activity through user activity logging, audit event tracking, alerting, and anomaly detection across the platform's management components.

VCF Operations includes a User Activity Audit capability that provides traceability of user activities across the environment. Accessible from the Administration > Control Panel menu by selecting the Audit tile, this function tracks actions such as user logins and logouts, operations performed on clusters and nodes, changes to system passwords, and certificate activations. The resulting audit reports can be downloaded in PDF or XLS format for offline analysis and record-keeping. For centralized log management, VCF Operations can forward user activity audit logs to an external syslog server to support security auditing requirements. ESX hosts also support direct transmission of audit records to syslog collectors, allowing host-level security activity to be captured alongside VCF Operations events in a centralized logging infrastructure.

Beyond user activity auditing, VCF Operations captures administrative actions through its audit logging subsystem, including create, read, update, and delete operations as well as login and logout events. The platform reports on authentication and security-related audit events, which support security and compliance audits and provide details useful for conducting security forensics. The vSphere Client provides a task export function that allows administrators to filter and export tasks performed by a specific user during a defined time range, supporting focused investigation of suspicious activity. VCF Operations also monitors failed login attempts, surfacing potential security threats such as brute-force attacks or accounts with incorrect credentials, and allows analysis of the frequency and source of failed logins. When a user attempts an operation with insufficient privileges, VCF Operations generates a critical alert, providing visibility into potentially unauthorized access attempts.

VCF Operations for Networks captures administrative actions through its own audit logs, including CRUD operations and login/logout events. These audit logs can be viewed from the Settings page, with access controlled by user role, and can be included in backup operations for retention. Where vDefend is deployed alongside VCF, security policy changes are recorded in NSX Manager firewall audit logs with detailed attribution, including the username of the user making the change, the module name, operation type, operation status, request tracking identifiers, and timestamps. These audit logs also capture administrative metadata such as create user, last modified user, system ownership status, and protection status for security policy changes. vDefend is licensed separately from VCF.

The Security Operations dashboard in VCF Operations provides a consolidated view of the security posture across the VCF environment. Risk alerts flag problems that should be investigated, and compliance alerts notify administrators when the environment drifts from defined policies. VCF Operations generates alerts when security-relevant configuration changes occur, such as modifications to Security Group properties or Security Group membership changes. Alert ownership tracking allows administrators to take ownership of alerts and manage investigation accountability, supporting structured incident workflows. Administrators should continuously monitor user security aspects to detect security risks early, respond to potential threats, and verify that the right users have the right level of access.

Defining insider threat policies, categorizing personnel by risk level, and establishing a formal insider threat program are organizational responsibilities outside the scope of VCF's technical controls. A complete insider threat monitoring program also requires behavioral analytics, user and entity behavior analytics (UEBA) tools, correlation with HR and physical access systems, defined escalation procedures, and legal and privacy frameworks governing personnel monitoring. VCF contributes the platform-level audit trail and alerting but does not replace the broader organizational program needed to address insider threats.

VMware vDefend (Contributes)

VMware vDefend contributes to monitoring internal personnel activity for potential security incidents by providing network-level visibility into traffic patterns, anomaly detection, and threat correlation that can surface indicators of insider threat activity.

Security Intelligence, integrated within the Security Services Platform (SSP), continuously monitors east-west traffic flows within the VCF environment, alerting administrators to unauthorized or unexpected communication between workloads and environments. When an insider begins probing systems, moving laterally, or exfiltrating data, those activities generate network traffic that deviates from established patterns. Security Intelligence detects such deviations and categorizes them using MITRE ATT&CK adversarial tactics and techniques, recording the number of times each event occurred during the selected time period. The Security Overview Dashboard Suspicious Traffic tab displays statistics about suspicious or anomalous events when Security Intelligence is activated, and the Threat Event Monitoring tab provides IDS/IPS threat event summaries for the most recent 14 days. The Security Overview Dashboard also displays trends of malicious file events, suspicious file events, and suppressed file events in the data center, providing visibility into file-based activity that could indicate data exfiltration or malware associated with insider threats.

Network Detection and Response (NDR) aggregates and correlates security-related events across the environment, presenting a visualization of threats mapped to MITRE ATT&CK tactics and techniques. NDR can identify patterns spanning multiple individual events, such as a sequence of reconnaissance, credential use, and lateral movement that characterizes coordinated insider activity, and present them as a correlated campaign. Campaign details include a Blueprint tab that visualizes correlated security events and key actors, supporting security incident investigation. Security teams can investigate both individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

The Monitor and Plan Overview dashboard in SSP displays high-level information about the most recent state of network activities and objects managed by Security Intelligence. The threat visualization canvas in Security Intelligence supports rapid threat containment by identifying compromised assets and informing microsegmentation policy adjustments. The Security Segmentation Report assesses security posture by analyzing network traffic over a specified time range, giving security operations personnel insights to prioritize remediation efforts. Security Intelligence Environments Monitoring provides traffic flow analysis with protection status summaries for selected environment pairs within a specified time range.

In 9.1, vDefend IDS/IPS introduces behavior-based detection with a new 'suspicious' severity level, providing classification granularity beyond signature-based detection. IDS/IPS logs include the category of the detected threat, supporting post-incident forensic analysis of potential insider activity.

Security Services Platform defines a Security Operator role for monitoring security systems and responding to security incidents, establishing a defined access tier for personnel conducting insider threat detection activities.

The organizational components of an insider threat program, including defining threat policies, categorizing personnel by risk level, integrating with HR systems, and conducting behavioral analysis, remain outside vDefend's scope and are organizational responsibilities.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support monitoring for unauthorized activities and connections within its operational scope as a database-as-a-service platform. These capabilities address the activity and account dimensions of this control, though the broader device and software inventory monitoring dimensions fall outside DSM's scope.

DSM generates two categories of audit logs that record and expose user activity. System Audit Events track all user actions performed through the DSM UI and API, as well as actions that DSM initiates autonomously. These events are accessible through the System Audit Events view, which is the only DSM UI location for reviewing non-database-related operations and tasks. Gateway Audit Logs record read and write operations to DSM data services or infrastructure objects performed through the DSM UI or the DSM Gateway Kubernetes interface, and identify the source entity for each action as either the user's Email ID for user-initiated operations or "System" for DSM-initiated operations. This attribution supports identification of operations performed under unexpected or unauthorized accounts.

For database-level activity monitoring, DSM supports configurable connection logging and login auditing across managed database engines. PostgreSQL instances expose the `log_connections` advanced setting, which activates logging of connection attempts and the successful completion of authentication; this setting takes effect without a database restart when updated. For SQL Server instances, DSM can automatically create a simple audit for login events based on the Login Auditing option selected when provisioning a SQL Server cluster. Both mechanisms support detection of unauthorized or unexpected connection activity to managed databases.

DSM tracks failed login attempts and account lockout state for local user accounts through the `failed_login_count`, `last_failed_login_time`, and `locked_state_start_time` fields. This data is accessible when reviewing local user account records and supports identification of repeated unauthorized access attempts. DSM also maintains an audit capability for verifying password changes, and password reset links issued to local users expire after 20 minutes, limiting the window for unauthorized reuse of a reset credential.

DSM provides an Alerts pane in the Monitoring tab where administrators can review alerts triggered on databases. Webhook-based alerting for database monitoring events, triggered by threshold violations, allows organizations to route DSM alerts to external systems for automated detection. DSM monitoring also tracks active backend connections on each database node, providing continuous visibility into connection activity against managed services through VCF Operations.

Audit logs can be forwarded via syslog to external log management or SIEM systems, allowing organizations to aggregate DSM activity records with those from other platform components for broader unauthorized activity detection.

DSM's monitoring scope is limited to its own management plane and managed database services. It does not monitor for unauthorized software installation, hardware device attachment, or network-level lateral movement. Detecting unauthorized connections at the network layer requires capabilities provided by VMware vDefend or similar network security tools. A complete monitoring posture for this control requires the organization to integrate DSM audit data into a broader security monitoring program that covers the full scope of the control's requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides monitoring mechanisms for unauthorized activities at the application delivery layer. The Avi Controller tracks user login activity, recording the last login IP address and timestamp for each user account, and the Config Audit Trail records configuration changes and user activity events over a selected period, presenting a filtered view of system events that supports detection of unauthorized administrative actions. The AUDIT_COMPLIANCE_EVENT mechanism logs authentication failures for audit purposes.

At the application traffic layer, the Avi Service Engine logs significant events when a user is not authorized for access and records 401 Unauthorized responses as significant events in the Analytics profile. WAF App log analytics display requests blocked by WAF policies, including the offending parameter, source IP addresses, and the count of denied requests over time, providing visibility into unauthorized application-layer access attempts. WAF Statistics provides a high-level overview of an application's security posture at the virtual service level. Network security rules can be configured to log when a rule action is invoked, including traffic denied based on DDoS attack source IP detection, by setting the log parameter on DOS rules. Avi DataScript supports logging of security events such as blocklisted IP access attempts using the log() function, enabling custom detection and response to suspicious traffic patterns.

Application logs can include detailed client TLS fingerprint data, which is enabled through the collect_client_tls_fingerprint flag in the Application Profile; this fingerprint data supports identification of suspicious or unauthorized clients. Clients can be identified and blocked based on identifiers such as IP address, username, session cookie, or SSL client certificate. Security events are forwarded proactively via email, syslog, SNMP, or custom APIs, enabling integration with external SIEM and monitoring systems.

All access events to the Avi License Hub are logged in audit logs that are enabled by default and cannot be disabled. A dedicated Audit local user account with the auditor role is available within the License Hub for system auditing purposes.

The Application Security Report, accessible via Operations > Reports in the Controller UI and downloadable as a PDF, documents per-virtual-service security findings and pre-check validation results, supporting periodic review of the application-layer security posture for each load-balanced service.

Monitoring for unauthorized accounts, devices, and software at the infrastructure level is provided by the underlying VCF platform, not by Avi. Organizations must integrate Avi's event forwarding with a centralized monitoring or SIEM capability to achieve the full monitoring scope this control requires across both the application delivery layer and the infrastructure layer.

Control DE.CM-06

External service provider activities and services are monitored to find potentially adverse events

[Withdrawn: Incorporated into DE.CM-01, DE.CM-03, DE.CM-06, DE.CM-09]

SCF Controls: MON-01, MON-16.2, MON-16.4

Aggregate Coverage: Meets

VCF (Meets)

VCF provides technical capabilities for monitoring user activity across the infrastructure, which can be applied to third-party personnel who have been granted access to the environment. VCF does not distinguish between internal and third-party users at the platform level, so all accounts are subject to the same audit trail regardless of who operates them. The logging, auditing, and forwarding features supply the data needed to support a third-party monitoring program.

VCF Operations includes a User Activity Audit capability, accessible from the Administration > Control Panel menu under the Audit tile. This feature provides traceability of user activities including logging in, actions on clusters and nodes, changes to system passwords, activating certificates, and logging out. User Activity Audit reports can be generated and downloaded in PDF or XLS format, allowing security teams to review and archive records of actions taken by any user, including third-party personnel. VCF Operations can forward user activity audit logs to an external syslog server, enabling integration with a centralized security information and event management (SIEM) platform where third-party activity can be correlated with other data sources and monitored against organization-defined thresholds.

VCF Operations for Networks provides additional audit logging that captures administrative actions carried out in the system, including regular CRUD operations and login/logout events. These audit logs record actions from the API, the user interface, and the CLI. Access to audit logs in VCF Operations for Networks is controlled by user role, with Admin role users able to view and manage Personally Identifiable Information settings within the audit logs.

Event auditing in VCF Operations provides visibility into platform interaction changes across the VCF infrastructure, surfacing suspicious access events and policy violations. This capability is relevant for detecting anomalous behavior by third-party accounts, such as unexpected login times, unauthorized configuration changes, or access to resources outside the third party's scope of work. Authentication and security-related audit events are captured to support security forensics, increasing user accountability by registering each action as an audit event. When VCF Operations detects non-compliance with a defined policy, it can generate alerts or notifications for follow-up.

VMware vCenter Events provide an additional layer of forensic analysis and auditing capability, capturing a record of user actions across the virtual environment at the infrastructure layer. At the host level, VMware ESX (ESX) hosts can transmit audit messages directly to syslog collectors, with audit records tracking security-related activity on individual ESX hosts, extending the audit trail down to the hypervisor layer.

The Security Operations dashboard in VCF Operations provides a consolidated view of the security posture across the VCF environment. VCF Security Operations helps security stakeholders gain visibility and proactively plan for risk management. The security dashboard complements the Compliance capability by surfacing core aspects of VCF security in one place. Combined with proactive monitoring capabilities, these tools allow operations teams to maintain awareness of activity patterns and identify deviations that may indicate a security incident involving third-party accounts.

VCF also monitors user security aspects on a continuous basis, providing ongoing visibility into user-related security events across the environment. Role-based dashboard access allows differentiated visibility for various user roles, so that security teams responsible for third-party oversight can be granted appropriate views without exposing unrelated operational data.

To fully satisfy this control, the organization must establish policies that define which accounts belong to third-party personnel, configure role-based access so that third-party users operate under least-privilege principles, and implement monitoring rules or alerts in the SIEM that specifically target third-party account activity. Defining acceptable use boundaries, conducting periodic reviews of third-party activity, and establishing activity baselines are organizational responsibilities outside the scope of VCF's technical controls. Forwarding audit logs to an external syslog server is recommended when third-party monitoring

requires centralized correlation with access from other systems. VCF provides the logging, auditing, and forwarding infrastructure, but the identification of third-party personnel and the definition of acceptable activity patterns require organizational processes.

VMware vDefend (Contributes)

VMware vDefend Security Services Platform maintains role-based access control across five defined administrative roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role is a read-only administrative identity that can view and track platform activity without making changes, supporting oversight of administrative actions within vDefend's own management scope.

Component-level activity is written to syslog on ESX hosts by the Guest Introspection Platform Host Agent (MUX), with log messages formatted with a timestamp, ContextMUX identifier, thread ID, and message content. On vDefend appliances, syslog messages conform to RFC 5424; on ESX hosts, they conform to RFC 3164. These logs can be forwarded to centralized collection systems for retention and review.

The Identity Firewall feature includes Event Log Sources that collect authentication events from Active Directory domain controllers, either through direct event log scraping or Guest Introspection. Event Log Source configuration supports integration with VCF Log Management for centralized log collection. The Gateway Firewall can also send Identity Firewall event logs to VCF Log Management. This captures identity-based events such as logins that can reflect account activity across the environment.

While vDefend provides these logging mechanisms for its own administrative scope and identity-based network events, permissions change logging for the broader VCF environment is handled by VMware vCenter and VCF SSO infrastructure rather than vDefend alone.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint

detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) records system-level operations through its gateway audit logs and the System Audit Events view in the Provider interface. These logs capture non-database-related operations and tasks, including administrative actions such as account and role management within DSM. Each audit record includes the Event Type (identifying the type of operation performed), Event Time (timestamp in UTC), Event Details (operation-specific information), the Component (the DSM component involved), Status, and Source fields. The Source field identifies the DSM user who initiated the operation by Email ID, or System when the operation was initiated by DSM itself.

When DSM administrators or users perform operations in the Permissions view to create, modify, or remove DSM accounts and role assignments, those actions are captured as events in the gateway audit log. The System Audit Events view in the DSM Provider UI is the designated location for reviewing these non-database system events. DSM also generates service account rotation logs that can be checked to verify service account management activities. DSM has its own two-tier role model with DSM Admin and DSM User roles backed by local user accounts and LDAPS, distinct from VCF SSO. Audit log files are stored on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`, and the most recent five days of logs are retained locally. When a default S3 provider log repository is configured, DSM periodically archives gateway audit log files to the S3 repository under a dedicated 'gateway audit' subpath, supporting longer-term retention than the local five-day window.

DSM audit logs also contain standard Kubernetes audit events, which capture API-level operations against DSM's Kubernetes-native resources. The content of secrets is not logged. Audit event data can be exported in CSV or XLSX format from the ACTIONS dropdown menu in the System Audit Events view, supporting review by auditors or transfer to a security information and event management system.

For SQL Server clusters provisioned through DSM, administrators can configure Login Auditing and enable audit logging to select the level of event capture for system logins and set the log retention period. This extends DSM's audit coverage to SQL Server-engine authentication and login events beyond the control-plane gateway audit log.

DSM logs only the permissions changes that occur within the DSM control plane. When DSM authenticates users through LDAPS, account creation, group membership, and password changes occur in the directory server and appear in directory-server audit logs rather than in DSM's gateway audit log. The dedicated VMware vCenter service account that DSM creates during plug-in deployment is managed in vCenter, and changes to that account are recorded in vCenter audit logs. Database-engine privilege changes performed inside provisioned PostgreSQL or MySQL databases are recorded in database engine logs rather than in the DSM gateway audit log; PostgreSQL clusters in DSM support the `insert_username` extension, which tracks who changed a table and can supplement engine-level accountability for row-level changes. Organizations need to combine DSM audit logs with directory-server, vCenter, and database engine logs to achieve full coverage of permissions changes affecting DSM privileged accounts and groups.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This

supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control DE.CM-09

[Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09]
[Withdrawn: Incorporated into DE.CM-01, DE.CM-09] [Withdrawn: Incorporated into DE.CM-01, DE.CM-03,
DE.CM-06, DE.CM-09] Computing hardware and software, runtime environments, and their data are monitored
to find potentially adverse events

SCF Controls: END-01, END-04, END-06, MON-01, MON-01.7

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into

tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF

Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the `PAISConfiguration` custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over `http/protobuf` or `gRPC`, providing distributed tracing for AI model inference activity. The `observability.llmTraces` configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The `controller-pod-metrics-streaming` setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the `vmware-system-monitoring` namespace uses a `telegraf-user-config` ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports

suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT_ENOUGH_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range

adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert

notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

Control GV

The organizational mission is understood and informs cybersecurity risk management. Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered. Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and civil liberties obligations - are understood and managed. Critical objectives, capabilities, and services that external stakeholders depend on or expect from the organization are understood and communicated. Outcomes, capabilities, and services that the organization depends on are understood and communicated. Risk management objectives are established and agreed to by organizational stakeholders. Risk appetite and risk tolerance statements are established, communicated, and maintained. Cybersecurity risk management activities and outcomes are included in enterprise risk management processes. Strategic direction that describes appropriate risk response options is established and communicated. Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties. A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated. Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions. Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving. Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced. Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies. Cybersecurity is included in human resources practices. Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced. Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission. Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction. The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks. Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed. A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders. Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally. Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes. Suppliers are known and prioritized by criticality. Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties. Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships. The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship. Relevant suppliers and other third parties are included in incident planning, response, and recovery activities. Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle. Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement.

[Withdrawn: Incorporated into GV.RR-02, GV.SC-02] [Withdrawn: Incorporated into GV.OC-05] [Withdrawn: Incorporated into GV.OC-01] [Withdrawn: Incorporated into GV.OC-04, GV.OC-05] [Withdrawn: Incorporated into GV.OC-04] [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Moved to GV.OC-03] [Withdrawn: Moved to GV.RM-04] [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03] [Withdrawn: Incorporated into GV.RM-02, GV.RM-04] [Withdrawn: Moved into GV.RM-02] [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Moved to GV.SC-05] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-08, ID.IM-02] [Withdrawn: Moved to GV.RR-04] [Withdrawn: Incorporated into GV.RR-02]

SCF Controls: GOV-01, GOV-05, PRM-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OC

The organizational mission is understood and informs cybersecurity risk management Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and civil liberties obligations - are understood and managed Critical objectives, capabilities, and services that external stakeholders depend on or expect from the organization are understood and communicated Outcomes, capabilities, and services that the organization depends on are understood and communicated [Withdrawn: Incorporated into GV.OC-05] [Withdrawn: Incorporated into GV.OC-01] [Withdrawn: Incorporated into GV.OC-04, GV.OC-05] [Withdrawn: Incorporated into GV.OC-04] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Moved to GV.OC-03] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10]

SCF Controls: AST-01.1, AST-01.2, CPL-01, GOV-08, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OC-01

The organizational mission is understood and informs cybersecurity risk management [Withdrawn:
Incorporated into GV.OC-01]

SCF Controls: GOV-08, RSK-01.1, TDA-06.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OC-02

Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10]

SCF Controls: AST-01.2, TPM-05, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OC-03

Legal, regulatory, and contractual requirements regarding cybersecurity - including privacy and civil liberties obligations - are understood and managed [Withdrawn: Moved to GV.OC-03]

SCF Controls: CPL-01, CPL-02, PRI-01, TPM-05, TPM-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OC-04

Critical objectives, capabilities, and services that external stakeholders depend on or expect from the organization are understood and communicated [Withdrawn: Incorporated into GV.OC-04, GV.OC-05]

[Withdrawn: Incorporated into GV.OC-04]

SCF Controls: BCD-02, GOV-08, PRM-01.1, TPM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OC-05

Outcomes, capabilities, and services that the organization depends on are understood and communicated
[Withdrawn: Incorporated into GV.OC-05] [Withdrawn: Incorporated into GV.OC-04, GV.OC-05]

SCF Controls: BCD-02, TDA-04.2, TPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support the identification and documentation of critical technology assets, applications, services, and data within a virtualized infrastructure.

VMware vCenter maintains a real-time inventory of all managed objects, including hosts, VMs, clusters, datastores, and networks, and supports linking multiple vCenter instances for centralized inventory management. The vCenter inventory tracks multiple instances of ClusterComputeResource, ComputeResource, Datacenter, Datastore, DistributedVirtualSwitch, and Folder objects, providing a structured view of all infrastructure components. VCF Operations can export lists of resources, such as powered-off virtual machines, to CSV files for offline documentation and review.

VCF Operations includes a Business Applications feature that allows administrators to group related infrastructure objects and assign business criticality classifications. Each Business Application can be tagged with a criticality level of Critical, Medium, or Low, with Medium as the default. The Object Summary card within VCF Operations displays details including the application's source, application tag, environment, and business criticality rating. This classification capability allows infrastructure teams to maintain a structured view of which applications and their underlying resources are most important to the organization.

VCF Operations Service Discovery automatically detects running services across the environment. Service Discovery displays a list of all supported services that can be discovered and those currently discovered on VMs once configured. It also discovers performance metrics for individual service objects and service type objects, maintaining a catalog of known services and their relationships to underlying infrastructure. This automated discovery reduces manual effort in maintaining an accurate asset inventory.

VCF Operations also provides alert definitions with configurable Impact and Criticality metadata. The Impact setting can be configured to values such as Risk to indicate potential problems, while the Criticality setting can be set to values like Immediate for proper alert prioritization. Alert notifications can be filtered by impact category and criticality level, helping teams classify infrastructure resources by their importance and focus attention on the most important infrastructure components. VCF Operations Insights data tracks resource capacity and can notify project owners of changes affecting their assets.

VCF Automation provides complementary asset identification capabilities through its resource discovery and tagging system. The discovery process automatically identifies machines, storage volumes, networks, load balancers, and security groups for each cloud account region that has been added. Once discovered, these resources can be organized using tags that facilitate search and identification. Tags placed on cloud zones, network profiles, storage profiles, and individual infrastructure resources function as capability tags that define desired capabilities and support governance by expressing capabilities and constraints. Using logical, human-readable tags for storage, network, and infrastructure items is recommended to facilitate search and identification functions.

VCF Automation organizes infrastructure through projects, which link users, catalog items, and IaaS resources to the locations where items are deployed. The Overview tab displays infrastructure and consumption metrics, providing a consolidated view of resource usage. Resource details views support filtering based on attributes such as project membership, enabling administrators to locate and review specific subsets of the infrastructure.

Blueprints in VCF Automation allow users to model complex IT services by visually designing infrastructure components such as VMs, networks, storage, and software components. Resource objects in blueprints represent the infrastructure components and services that are provisioned and managed, providing an architectural record of how assets support business functions.

Together, these inventory, discovery, classification, tagging, and visualization capabilities give operations teams the tools to identify, classify, and document the technology assets that support essential business functions. However, VCF provides the technical tooling for asset identification and classification rather than the organizational processes needed to define which assets are critical to the business mission. Establishing criticality criteria, maintaining asset documentation, and conducting periodic reviews of critical asset designations require organizational processes that operate alongside the platform's capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OV

Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction
The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks
Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed

SCF Controls: GOV-01.1, GOV-01.2, GOV-03, GOV-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OV-01

Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction

SCF Controls: GOV-01.1, GOV-01.2, GOV-03, GOV-05, GOV-08, PRM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OV-02

The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks

SCF Controls: GOV-01.1, GOV-03, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.OV-03

Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed

SCF Controls: GOV-01.1, GOV-01.2, GOV-05, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.PO

Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02]

SCF Controls: GOV-02, HRS-05.7, HRS-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.PO-01

Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02]

SCF Controls: GOV-02, HRS-05.7, HRS-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.PO-02

Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02]

SCF Controls: GOV-03, HRS-05.7, HRS-07

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RM

Risk management objectives are established and agreed to by organizational stakeholders. Risk appetite and risk tolerance statements are established, communicated, and maintained. Cybersecurity risk management activities and outcomes are included in enterprise risk management processes. Strategic direction that describes appropriate risk response options is established and communicated. Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties. A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated. Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions. [Withdrawn: Moved to GV.RM-04] [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03] [Withdrawn: Incorporated into GV.RM-02, GV.RM-04] [Withdrawn: Moved into GV.RM-02] [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

SCF Controls: GOV-04, PRM-01, PRM-01.1, RSK-01, RSK-01.1, RSK-01.3, RSK-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RM-01

Risk management objectives are established and agreed to by organizational stakeholders [Withdrawn:
Incorporated into GV.RM-01, GV.RM-06, GV.RR-03]

SCF Controls: GOV-01, GOV-01.1, GOV-05.2, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RM-02

Risk appetite and risk tolerance statements are established, communicated, and maintained [Withdrawn:
Incorporated into GV.RM-02, GV.RM-04] [Withdrawn: Moved into GV.RM-02]

SCF Controls: RSK-01.3, RSK-01.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RM-03

Cybersecurity risk management activities and outcomes are included in enterprise risk management processes

SCF Controls: GOV-01, GOV-01.1, RSK-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RM-04

Strategic direction that describes appropriate risk response options is established and communicated
[Withdrawn: Moved to GV.RM-04] [Withdrawn: Incorporated into GV.RM-02, GV.RM-04]

SCF Controls: RSK-01, RSK-01.1, RSK-06, RSK-06.1, RSK-06.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RM-05

Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

SCF Controls: GOV-04, GOV-04.1, HRS-03, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RM-06

A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03]

SCF Controls: RSK-01, RSK-01.1, RSK-04, RSK-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RM-07

Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions

SCF Controls: RSK-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RR

Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving. Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced. Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies. Cybersecurity is included in human resources practices. [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03] [Withdrawn: Moved to GV.RR-04] [Withdrawn: Incorporated into GV.RR-02]

SCF Controls: HRS-03, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RR-01

Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving

SCF Controls: GOV-01, GOV-01.1, GOV-04, GOV-04.1, RSK-01, RSK-01.3, RSK-01.4, RSK-01.5, RSK-12

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RR-02

Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Incorporated into GV.RR-02]

SCF Controls: GOV-04, HRS-02, HRS-03, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RR-03

Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03]

SCF Controls: PRM-01, PRM-02, PRM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.RR-04

Cybersecurity is included in human resources practices [Withdrawn: Moved to GV.RR-04]

SCF Controls: HRS-01, HRS-03.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC

A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders. Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally. Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes. Suppliers are known and prioritized by criticality. Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties. Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships. The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship. Relevant suppliers and other third parties are included in incident planning, response, and recovery activities. Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle. Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement.

[Withdrawn: Incorporated into GV.RR-02, GV.SC-02] [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Moved to GV.SC-05] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-08, ID.IM-02]

SCF Controls: GOV-01, GOV-01.1, GOV-01.2, GOV-05, RSK-01, RSK-09, RSK-09.1, TPM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-01

A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

SCF Controls: GOV-01, GOV-01.1, GOV-02, RSK-01, RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-02

Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally [Withdrawn: Incorporated into GV.RR-02, GV.SC-02]

SCF Controls: TPM-05, TPM-05.2, TPM-05.4

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-03

Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10]

SCF Controls: GOV-01, GOV-01.1, GOV-02, GOV-08, GOV-09, RSK-01, RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-04

Suppliers are known and prioritized by criticality [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10]

SCF Controls: AST-01, AST-01.1, TPM-01, TPM-01.1, TPM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-05

Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties
[Withdrawn: Moved to GV.SC-05]

SCF Controls: CPL-01, CPL-01.2, IAO-03.2, PRI-07.1, RSK-01, RSK-09, TPM-05, TPM-05.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-06

Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

SCF Controls: TPM-01, TPM-02, TPM-03, TPM-03.2, TPM-03.3, TPM-04, TPM-04.1, TPM-04.3, TPM-04.4, TPM-05, TPM-05.2, TPM-05.3, TPM-05.4, TPM-05.5, TPM-05.6, TPM-05.7, TPM-06, TPM-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-07

The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship
[Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn:
Incorporated into GV.SC-07, ID.RA-10]

SCF Controls: TPM-01, TPM-01.1, TPM-02, TPM-03, TPM-03.2, TPM-03.3, TPM-04, TPM-04.1, TPM-08, TPM-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of access control, identity federation, tenant isolation, and monitoring to mitigate risks associated with third-party access to infrastructure assets, applications, services, and data.

VCF SSO integrates with federated identity providers through standards-based protocols, supporting SAML 2.0, OIDC, and AD/LDAP as authentication sources. LDAP-based directory services such as Active Directory are supported for identity management across the platform, including NSX Manager, which supports both Active Directory over LDAP and Open LDAP as identity sources. This allows organizations to extend their existing identity governance to VCF rather than maintaining separate credential stores for third-party users.

Role-based access control enforces least-privilege principles across the platform. VCF local accounts support configurable roles such as superAdmin, and VCF Automation assigns host switch-level permissions through the Cloud Administrator group (Cloudadmin role). The administrators role in VCF Operations is restricted to specific users who need access to objects and actions across the entire environment. For Kubernetes workloads, vSphere Supervisor namespaces support role-based access control with EDIT, VIEW, and OWNER roles that grant specific privileges to users or groups. The Namespace Owner/Edit/View role scopes consumers of a vSphere Namespace to provisioning VKS clusters and vSphere Pods using kubectl, while vSphere Administrator and Supervisor Administrator roles have broader access to cluster and namespace resources. This layered role model restricts third-party access to specific workload boundaries.

VCF Automation implements a provider-and-consumer model that separates the operators of services from the organizations that consume them. Partner services from external vendors are integrated through this model, where providers manage services and organizations consume the resulting business outcomes such as self-service provisioning of Kubernetes clusters, databases, and other resources. Service providers control the publication scope of service instances to selected organizations and decide which roles, rights bundles, and UI plug-ins to include when publishing services. Provider Consumption Organizations offer additional administrative capabilities on top of standard organizations, allowing provider administrators to provision workloads while maintaining separation from consumer tenants. This architectural separation limits third-party visibility and access to only the resources they need to operate.

For third-party application integration, VCF Automation supports dedicated service accounts that automate access for third-party applications. Organizations can generate and issue API access tokens that applications use on their behalf, providing a controlled mechanism for programmatic access rather than requiring shared user credentials. The VCF Operations orchestrator presents an open architecture for plugging in external third-party applications, with integration points managed through the platform rather than through direct infrastructure access.

Tenant isolation is enforced through VCF Automation Organizations, which provide secure infrastructure isolation, quotas, and chargeback across multiple tenants. Within each organization, further isolation exists at the project and namespace levels. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through these organizations while network isolation at the NSX segment level restricts lateral movement between tenants. An Enterprise Admin can share resources with projects in a controlled manner, making objects available for consumption only within designated boundaries. App isolation policies in VCF Automation allow deployments that require on-demand security groups to enforce vDefend firewall rules at the application level. Data-in-transit communications default to TLS encryption for platform services.

VCF Operations monitors resource usage and policy compliance across the environment, providing visibility into third-party activity. VCF Operations supports firewall hardening that restricts network access to internal services, limiting the network paths available to third-party integrations. Service Discovery identifies permanent listening TCP ports and established UDP connections, and service discovery dashboards provide ongoing visibility into the services operating in the environment. VCF also provides capabilities to discover objects that are not compliant with a security standard, supporting ongoing risk identification for configurations affected by third-party access.

VMware Private AI Services (PAIS) provides technical mechanisms that contribute to mitigating risks associated with third-party access to AI-related assets, services, and data. These mechanisms operate at the trust validation, authentication, authorization, and content approval layers.

Trust Establishment for External Integrations

PAIS uses a CA trust bundle to establish secure HTTPS communication with external services and databases. Administrators must import CA trust bundles for the OIDC provider, Private Harbor registry, content management systems used as data sources in Data Indexing and Retrieval, MCP servers providing tools for agents, and the database server when those entities are not supplied at activation. Without an explicitly configured CA trust bundle, PAIS will not establish connections to those services, so third-party integrations require deliberate administrative action rather than automatic open access. PAIS supports updating certificate content for trusted entities through the same trust bundle mechanism, allowing administrators to refresh trust material as provider certificates change.

Access Control for Services and Data

PAIS access is controlled through OIDC group-based authorization. User accounts must be members of specified authorized groups (configured via the `authorizedGroups` setting) to access the service, and the `oidc-groups-claim` setting controls which OIDC claim is consulted for group identification in the organization namespace. PAIS requires HTTPS-based communication for OIDC provider integration. SharePoint data sources used as Knowledge Base inputs require user name and password authentication, with support limited to SharePoint On-Premises deployments, so the credential and connectivity posture for that integration is explicit rather than implicit.

Harbor Access and Model Storage

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. These controls help administrators scope which users and workloads can push to or pull from a registry used by PAIS.

Model Validation Before Deployment

Before uploading a model to a PAIS Model Gallery, the platform recommends evaluating the model's performance and safety for the intended business use case, including examining inference requests for malicious behavior and performing hands-on functional tests. PAIS guidance directs administrators to distribute models within the organization that have been validated on a Deep Learning VM rather than models pulled from the Internet, which could contain malicious code or be tuned for malicious behavior. This workflow helps administrators verify third-party or externally sourced models before they become available for production use.

VMware vDefend (Contributes)

VMware vDefend (DFW) microsegmentation and zero-trust policy enforcement limit lateral movement by adversaries who may have introduced threats through compromised supply chain components, containing potential damage at the network layer. The Security Assessment stage produces Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows, giving security teams the information needed to prioritize protection coverage across infrastructure, environment, and application layers before threats propagate.

In 9.1, privileged labels provide a tamper-proof mechanism for administrators to enforce security policies by anchoring firewall rules to immutable labels that prevent virtual machines from leaking out of security groups. This mechanism restricts an adversary's ability to manipulate policy scope after gaining a foothold through a compromised supply chain component.

Security Intelligence generates microsegmentation recommendations automatically by analyzing inventory assets in the environment, creating or updating vDefend sections with structured guidance for tightening policy where supply chain-sourced threats may be active. Security teams can investigate individual threat events and correlated campaigns through the Security Services Platform to assess impact, identify root causes, and take appropriate mitigation actions.

vDefend IDS/IPS and Malware Prevention provide several mechanisms for targeting threats from known-compromised supply chain components. Custom signatures can be uploaded as a .zip bundle, added manually as individual signatures, or created by cloning and customizing system signatures. In 9.1, each IDS/IPS signature bundle includes a SHA-256 checksum for integrity verification of the downloaded file, and the system validates custom signatures before publication to identify signatures flagged as Invalid or Warning. Signatures can be updated automatically from the vDefend Threat Intelligence Service (vTIS) portal or loaded manually through offline bundle upload for air-gapped environments. Malware Prevention signature bundles also support file hash matching using MD5, SHA-1, and SHA-256 checksums, as well as file magic matching to identify files by their binary signatures, enabling detection of known-malicious files that may have entered the environment through compromised supply chain components.

vDefend does not assess or govern the supply chain itself; organizational processes for vendor vetting, software integrity verification, and supply chain risk management remain outside its scope.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-08

Relevant suppliers and other third parties are included in incident planning, response, and recovery activities [Withdrawn: Incorporated into GV.SC-08, ID.IM-02]

SCF Controls: BCD-01, BCD-01.2, IRO-01, IRO-02, IRO-02.5, TPM-01, TPM-01.1, TPM-02, TPM-09, TPM-10, TPM-11

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-09

Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle

[Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

SCF Controls: GOV-01, GOV-01.1, GOV-01.2, GOV-05, PRM-07, RSK-01, RSK-09, RSK-09.1, SEA-07.1, TDA-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control GV.SC-10

Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10]

SCF Controls: RSK-09, TPM-01, TPM-05.2, TPM-05.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID

Inventories of hardware managed by the organization are maintained Inventories of software, services, and systems managed by the organization are maintained Representations of the organization's authorized network communication and internal and external network data flows are maintained Inventories of services provided by suppliers are maintained Assets are prioritized based on classification, criticality, resources, and impact on the mission [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] Inventories of data and corresponding metadata for designated data types are maintained Systems, hardware, software, services, and data are managed throughout their life cycles Vulnerabilities in assets are identified, validated, and recorded Cyber threat intelligence is received from information sharing forums and sources Internal and external threats to the organization are identified and recorded Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization Risk responses are chosen, prioritized, planned, tracked, and communicated Changes and exceptions are managed, assessed for risk impact, recorded, and tracked Processes for receiving, analyzing, and responding to vulnerability disclosures are established The authenticity and integrity of hardware and software are assessed prior to acquisition and use Critical suppliers are assessed prior to acquisition Improvements are identified from evaluations Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties Improvements are identified from execution of operational processes, procedures, and activities Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved [Withdrawn: Incorporated into GV.OC-05] [Withdrawn: Incorporated into GV.OC-01] [Withdrawn: Incorporated into GV.OC-04, GV.OC-05] [Withdrawn: Incorporated into GV.OC-04] [Withdrawn: Incorporated into GV.PO, GV.PO-01, GV.PO-02] [Withdrawn: Incorporated into GV.OC-02, GV.RR, GV.RR-02] [Withdrawn: Moved to GV.OC-03] [Withdrawn: Moved to GV.RM-04] [Withdrawn: Incorporated into GV.RM-01, GV.RM-06, GV.RR-03] [Withdrawn: Incorporated into GV.RM-02, GV.RM-04] [Withdrawn: Moved into GV.RM-02] [Withdrawn: Incorporated into GV.RM-05, GV.SC-01, GV.SC-06, GV.SC-09, GV.SC-10] [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Moved to GV.SC-05] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-08, ID.IM-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Incorporated into ID.AM-08] [Withdrawn: Incorporated into ID.IM, ID.IM-03] [Withdrawn: Moved to ID.IM-03] [Withdrawn: Moved to ID.IM-04] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02] [Withdrawn: Incorporated into ID.RA-01] [Withdrawn: Incorporated into ID.AM-03] [Withdrawn: Incorporated into ID.IM-02] [Withdrawn: Moved to ID.RA-08] [Withdrawn: Incorporated into ID.RA-06] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

SCF Controls: GOV-01.1, GOV-01.2, RSK-01, RSK-01.1, RSK-03, RSK-03.1, RSK-04, RSK-04.1, RSK-05, RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.AM

Inventories of hardware managed by the organization are maintained Inventories of software, services, and systems managed by the organization are maintained Representations of the organization's authorized network communication and internal and external network data flows are maintained Inventories of services provided by suppliers are maintained Assets are prioritized based on classification, criticality, resources, and impact on the mission [Withdrawn: Incorporated into GV.RR-02, GV.SC-02] Inventories of data and corresponding metadata for designated data types are maintained Systems, hardware, software, services, and data are managed throughout their life cycles [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into ID.AM-08] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02] [Withdrawn: Incorporated into ID.AM-03]

SCF Controls: AST-01, AST-01.1, AST-01.2, AST-02, AST-03, AST-03.1, HRS-01, HRS-03, HRS-05, HRS-05.1, PES-01, RSK-02, TPM-01, TPM-01.1, TPM-05.4, TPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The `SimpleClient` sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. `ResourceAttribute` elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected

attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources

discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-O2 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.AM-01

Inventories of hardware managed by the organization are maintained

SCF Controls: AST-02, TPM-01.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.AM-02

Inventories of software, services, and systems managed by the organization are maintained

SCF Controls: AST-02, TPM-01.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.AM-03

Representations of the organization's authorized network communication and internal and external network data flows are maintained [Withdrawn: Incorporated into ID.AM-03]

SCF Controls: AST-04, AST-04.2, DCH-19

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that contribute to maintaining network architecture diagrams and data flow documentation, though the organizational process of creating, maintaining, reviewing, and governing formal diagram artifacts remains a customer responsibility.

VCF Operations for Networks includes an end-to-end interactive network map that displays a detailed model of both physical and virtual devices in the environment, including physical switches, physical firewalls, routers, load balancers, transport nodes, and NSX virtual entities. The Network Map Summary presents a view of the data center that includes these entities along with an alert chart showing alert status across the inventory. Users can scope the view to focus on specific portions of the network. Because the map updates based on data collected from configured sources, it reflects the discovered state of the monitored infrastructure rather than a static diagram, providing a foundation for understanding the current network architecture and validating formal network diagrams.

NSX network connectivity workflows include a built-in topology visualization that correlates user configuration inputs with the resulting network topology, helping administrators understand the architecture before committing changes and reducing the risk of misconfiguration by providing a view of the entire setup. The NSX Manager Network Topology feature allows users to view network connectivity by zooming in to see details about logical entities and their logical paths, along with the services configured on those entities. The NSX Main Dashboard displays the topology of a selected object and how it connects to elements in the network, with a view of related alerts. The vSphere Client provides topology views of compute, storage, and network relationships, displaying logical and physical components such as segments, transport zones, and resource dependencies. The vSphere Distributed Switch topology diagram specifically shows information about the physical adapter connecting virtual adapters to the external network, with filters that default to displaying up to 32 port groups, 32 hosts, and 1,024 virtual machines.

The vSphere Network Inventory Dashboard provides a dedicated topology view of the vSphere network inventory, including information related to vSphere environments, vCenter instances, data centers, distributed vSwitches, distributed port groups, virtual machines, and associated properties and metrics. The Network Configuration Dashboard displays key configuration information including bar charts focused on critical security settings for vSphere distributed switches, providing visibility into the security-relevant configuration state of the network infrastructure.

For data flow analysis, VCF Operations for Networks collects flow data defined by 5-tuple values: source IP address, source port, destination IP address, destination port, and protocol. At the virtual switch level, vSphere Distributed Switches also support NetFlow export, configured with an Observation Domain ID that identifies the switch within the flow collection infrastructure, so flow data can be sent to external collectors for analysis alongside data collected by VCF Operations for Networks. The Access Flow Insight page in Network Operations allows analysis of all flows available in the environment, where each dot in the graph represents multiple flows and users can drill into individual flow details. The Custom Analysis section within Flow Insight provides two-dimensional visualization of flow data on user-selected dimensions to identify outliers in network traffic patterns. Flow metrics display traffic flow data collected from flow-enabled data sources, aggregated to show metrics such as total bytes and traffic rate. Flow analytics can also be run to understand bandwidth and packet rates.

VCF Operations for Networks supports flow-based application discovery, accessible by navigating to Infrastructure Operations, then Analyze, and selecting the Flows tab. This allows administrators to discover applications by analyzing traffic patterns and network flows in the environment, with the ability to modify the scope, naming preference, and duration of the discovery process. The application topology map displays traffic flows between application tiers, internet endpoints, shared services, and other applications, showing how data moves between workload groups. The map shows tier overviews, lists of

members (including VMs, Kubernetes services, and physical IPs), flows between tiers, and the physical IPs and shared services that applications depend on.

VCF Operations for Networks also provides a Security Planning capability that analyzes flows and displays traffic flow patterns and micro-segmentation views. This feature supports security assessment by making it possible to see how traffic moves through the environment, which is directly relevant to documenting sensitive or regulated data flows and assessing the security posture of the network architecture. The platform also provides planning and recommendations for implementing micro-segmentation security, and the micro-segmentation flow analysis interface allows filtering by protection status to view allowed and blocked flows.

VCF Operations for Networks includes a PCI Compliance page that presents a network flow diagram showing data flow paths, firewall placements, connections, and other details associated with the network. This built-in visualization is oriented toward compliance assessment and can supplement organizational network architecture documentation.

For multi-site environments, VCF Operations for Networks supports flow visualization for SDDC-to-SDDC communication through VMware Transit Connect via the VMware Managed Transit Gateway (VTGW), providing visibility into cross-data-center network flows. The Streaming Databus supports cross-data center network flow analysis by grouping query results by source data center, destination data center, and flow type.

Firewall rules can be exported to CSV files using the `run_fw_rule_export` CLI command, producing files that can be transferred via secure copy for integration into formal documentation. VCF also documents its own internal network ports and protocols at ports.broadcom.com, which provides reference material for documenting the platform's own communication paths.

While VCF provides tools for network topology visualization, flow analysis, application discovery, and security-oriented network views, the control requires a formal organizational process for maintaining network architecture diagrams and data flow diagrams that are kept current and contain sufficient detail for security assessment. VCF's capabilities provide the underlying data and visualization tools that inform these diagrams, but the creation, review, approval, and maintenance lifecycle of the formal documentation is an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend's Security Intelligence capability, delivered through the Security Services Platform (SSP), provides live network traffic flow visualization and security posture mapping that directly support the creation and maintenance of network architecture diagrams and data flow documentation. While maintaining formal network diagrams is an organizational responsibility, Security Intelligence generates interactive visualizations of network traffic patterns, security group relationships, and Distributed Firewall (DFW) rule coverage that serve as authoritative inputs to those diagrams.

Security Intelligence collects and displays network flow data through a visualization canvas covering groups, computes, destination ports, and Layer 7 application IDs. The visualization displays network traffic flows with color-coded indicators: red-hued dashed lines for unprotected flows, blue-hued solid lines for blocked flows, and green-hued solid lines for allowed flows. The Flow Details dialog shows completed network flows and the firewall rules in effect associated with each flow, linking observed traffic patterns to the policies governing them. Flow data includes the groups flows belong to, services used, Layer 7 application ID, and FQDN information. Network flow data is analyzed within a 15-minute window for near-real-time security status, and administrators can select a time period parameter to examine historical traffic flow data for architecture documentation.

Network traffic flows displayed in Security Intelligence are based on DFW rules in effect and observed traffic during the selected period, covering all traffic matching stateful Layer 4 DFW rules using IPv4 or IPv6. This directly supports the control's requirement that architecture diagrams reflect the current network environment and document how traffic flows through it. The Flow Insights Dashboard categorizes network objects into Rules, Groups, Computes, Destination Ports, and Layer 7 Application IDs, providing a structured multi-dimensional view of the environment's traffic architecture. Security Intelligence also monitors network flows between application pairs and tracks Policy Protection Status to indicate which application communication paths are being monitored.

Security Intelligence generates DFW security policy recommendations for application and environment categories based on analysis of traffic flows over a specified time period. These recommendations, grounded in observed traffic patterns, provide data-driven support for documenting how data flows through the environment and what security controls apply to those flows.

Network Detection and Response (NDR) extends this visibility by collecting and presenting detection events representing security-relevant activity in the network, helping security analysts understand threat patterns and the paths through which activity traverses the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to network architecture and data flow documentation through its network mapping capabilities, which record the topology between protected and recovery sites and provide programmatic access to that information for inclusion in formal diagrams.

PNR supports site-wide network mappings that define how networks on the protected site correspond to networks on the recovery site. These mappings can specify a different network to use during recovery plan tests, capturing the separate set of data flows that apply during DR exercises. For stretched storage environments, network mappings can be configured manually to override automatic mapping behavior between sites.

The Protection and Recovery Plug-In for the VCF Operations orchestrator provides API workflows that enumerate these mappings programmatically. The Get Network Mappings workflow lists all networks on a local site with existing mappings. The Get Network Mapping Pairs workflow retrieves the full set of mapping pairs for a specified site. The Get Test Network Mapping Pairs workflow lists test network mappings between corresponding objects across the remote site, and can query both protected and recovery sites when both are registered as local, providing a complete picture of the site-to-site network topology. An Add Test Network Mapping to Recovery Plan workflow maps a remote network to a test network within a specific recovery plan. IP customization workflows allow per-mapping customization of IP mapping rules and can remove customization rules from existing mappings.

The Plug-In also supports inventory mapping workflows that span folder mappings, network mappings, resource pool mappings, and test network mappings, providing a unified interface for enumerating all inter-site relationships.

Organizations should incorporate PNR's network mapping data and Plug-In workflow outputs into their formal network architecture diagrams to document DR topology, test network configurations, and the data flows that traverse the replication paths between sites.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer geographic visibility that supports the data flow documentation this control requires. Its Global Server Load Balancing (GSLB) feature maintains an explicit record of where application services are deployed geographically. Geographic information for geolocated services is loaded into the GSLB leader Controller either in bulk or on a location-by-location basis, then converted to geo-DB format and distributed to all DNS Service Engines in the group. GSLB service members can be configured with geolocation data drawn from three sources: the geo-DB, user-configured values, or values inherited from the site. This configuration is a machine-readable registry of which application endpoints are active at which geographic locations. Operators configure geolocation-based load balancing through a Geo Profile, created in the Avi UI at Infrastructure > GSLB > Geo Profile, where a previously created geo-DB file object is selected as the Geo-DB Entries source.

At the application traffic level, Avi maintains geo-DB files that map IP addresses to region, city, latitude, and longitude data. The GSLB geo-DB supports multiple files as input, with a priority mechanism that determines which data takes precedence when multiple sources define a location for the same IP address. Custom geo-DB files can be uploaded to the Avi Controller and consumed by Service Engines for geolocation-based decisions. The Avi Service Engine Geo-DB implementation includes a System-LocationDB-File object stored at /var/lib/avi/geo_db/admin containing region, city, latitude, and longitude data for IPv4 addresses. Avi Service Engines report geolocation information for client IP addresses, including latitude, longitude, and

geographic location names at the country, region, and city level, and this data appears in traffic logs and troubleshooting checklists.

The DataScript API function `avi.utils.get_geo_from_ip` retrieves geolocation data for a queried IP address, returning autonomous system (AS) number, country code, country name, continent name, continent code, latitude, longitude, region, and city. The DNS DataScript location API similarly returns a table containing validity status, longitude, latitude, location name, and client location tag. These APIs let operators build custom data flow reporting that identifies the geographic origin of application traffic programmatically.

Geolocation-based policies in WAF, the HTTP Policy Set, and Network Security Policy can reference geo-DB data to apply rules based on client geographic origin. Avi WAF Policy allows selection of a Geo Location Mapping Database from a drop-down menu. The HTTP Policy Set supports Geo-DB selection for use in the geolocation algorithm. Together, these capabilities let operators document which geographic regions application services serve and apply enforcement policies based on that geography.

Organizations should use GSLB site configuration and Avi's traffic analytics as inputs to a broader data flow inventory. The full inventory must extend to the compute, storage, and network layers of VCF that Avi's application delivery scope does not cover.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ID.AM-04

Inventories of services provided by suppliers are maintained

SCF Controls: TPM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.AM-05

Assets are prioritized based on classification, criticality, resources, and impact on the mission

SCF Controls: AST-04.1, BCD-02, DCH-02, TPM-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several capabilities that support the identification and documentation of critical technology assets, applications, services, and data within a virtualized infrastructure.

VMware vCenter maintains a real-time inventory of all managed objects, including hosts, VMs, clusters, datastores, and networks, and supports linking multiple vCenter instances for centralized inventory management. The vCenter inventory tracks multiple instances of ClusterComputeResource, ComputeResource, Datacenter, Datastore, DistributedVirtualSwitch, and Folder objects, providing a structured view of all infrastructure components. VCF Operations can export lists of resources, such as powered-off virtual machines, to CSV files for offline documentation and review.

VCF Operations includes a Business Applications feature that allows administrators to group related infrastructure objects and assign business criticality classifications. Each Business Application can be tagged with a criticality level of Critical, Medium, or Low, with Medium as the default. The Object Summary card within VCF Operations displays details including the application's source, application tag, environment, and business criticality rating. This classification capability allows infrastructure teams to maintain a structured view of which applications and their underlying resources are most important to the organization.

VCF Operations Service Discovery automatically detects running services across the environment. Service Discovery displays a list of all supported services that can be discovered and those currently discovered on VMs once configured. It also discovers performance metrics for individual service objects and service type objects, maintaining a catalog of known services and their relationships to underlying infrastructure. This automated discovery reduces manual effort in maintaining an accurate asset inventory.

VCF Operations also provides alert definitions with configurable Impact and Criticality metadata. The Impact setting can be configured to values such as Risk to indicate potential problems, while the Criticality setting can be set to values like Immediate for proper alert prioritization. Alert notifications can be filtered by impact category and criticality level, helping teams classify infrastructure resources by their importance and focus attention on the most important infrastructure components. VCF Operations Insights data tracks resource capacity and can notify project owners of changes affecting their assets.

VCF Automation provides complementary asset identification capabilities through its resource discovery and tagging system. The discovery process automatically identifies machines, storage volumes, networks, load balancers, and security groups for each cloud account region that has been added. Once discovered, these resources can be organized using tags that facilitate search and identification. Tags placed on cloud zones, network profiles, storage profiles, and individual infrastructure resources function as capability tags that define desired capabilities and support governance by expressing capabilities and constraints. Using logical, human-readable tags for storage, network, and infrastructure items is recommended to facilitate search and identification functions.

VCF Automation organizes infrastructure through projects, which link users, catalog items, and IaaS resources to the locations where items are deployed. The Overview tab displays infrastructure and consumption metrics, providing a consolidated view of resource usage. Resource details views support filtering based on attributes such as project membership, enabling administrators to locate and review specific subsets of the infrastructure.

Blueprints in VCF Automation allow users to model complex IT services by visually designing infrastructure components such as VMs, networks, storage, and software components. Resource objects in blueprints represent the infrastructure components and services that are provisioned and managed, providing an architectural record of how assets support business functions.

Together, these inventory, discovery, classification, tagging, and visualization capabilities give operations teams the tools to identify, classify, and document the technology assets that support essential business functions. However, VCF provides the

technical tooling for asset identification and classification rather than the organizational processes needed to define which assets are critical to the business mission. Establishing criticality criteria, maintaining asset documentation, and conducting periodic reviews of critical asset designations require organizational processes that operate alongside the platform's capabilities.

VMware vDefend (Contributes)

VMware vDefend contributes to identifying and documenting critical technology assets through the Security Services Platform (SSP) and its Security Intelligence feature, which provide asset inventory, classification, and visualization capabilities oriented toward network security segmentation planning.

Security Services Platform maintains a Platform Inventory of infrastructure assets, collecting status information for each asset including identification of assets that are timed out or out of sync. The inventory view provides filtering by Name and Status to locate specific infrastructure assets and identify their operational state. Tags assigned to each infrastructure asset are displayed for verification of tag assignments.

Security Intelligence gathers infrastructure services and servers from CSV files and discovers additional services and servers based on traffic flows analyzed from ESX hosts. During CSV import, Security Intelligence parses and validates the content format and inventory asset data. Security Intelligence also maps discovered unique assets during segmentation analysis, including workloads, groups, IP addresses, distributed virtual port groups (DVPGs), segments, tiers, infrastructure services, and infrastructure servers.

Security Services Platform identifies and publishes application assets, classifying them as either critical or regular applications. This criticality classification supports the identification of mission-critical technology assets within the environment. The inventory hierarchy spans regions, zones, environments, applications, and tiers, with each level displaying the total number of assets within its scope.

Security Intelligence organizes discovered and imported assets into structured Asset Collections: groups, infrastructure assets, environments (such as Production, Non-Prod, DMZ, PCI, and Development), applications, and application tiers. The Environment Asset Collection maps security zones to the operational contexts that support business functions. Application Asset Collections group workloads that provide enterprise functionalities, linking infrastructure resources to the business services they support. The Infrastructure Asset Collection node covers core networking services that enterprise workloads depend on, including LDAP, DNS, NTP, and DHCP. An Unknown Asset Collection surfaces compute entities that are not in the NSX inventory but are present in the data center and communicating to NSX entities, supporting discovery of assets that should be formally inventoried.

Security Intelligence Workload Classification can be set to "Infrastructure Service" to indicate that a compute entity provides infrastructure services such as DNS, DHCP, LDAP, and Syslog. Inferred infrastructure classifications for compute entities can be reviewed, accepted, or modified through the Monitor & Plan > Security Explorer interface.

These capabilities contribute to the control but do not fully satisfy it. vDefend's asset identification is scoped to network security segmentation planning rather than the enterprise-wide technology asset catalog this control requires. Identifying all critical technology assets, applications, services, and data across an organization requires broader inventory and configuration management capabilities within VCF, such as VCF Operations business application views, VMware vCenter inventory exports, and VCF Automation project tagging, which provide the enterprise-wide asset catalog that vDefend's security-focused inventory complements.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) organizes its protection model around identifying which assets are critical enough to warrant disaster recovery protection. Protection groups are an explicit declaration of critical assets, organizing virtual machines into logical units based on their replication and recovery requirements. Placing a workload in a protection group is a deliberate act of classifying it as essential to business operations.

Inventory mappings document how each protected-site asset (resource pools, folders, networks, datastores) corresponds to recovery-site resources, creating a structured record of the infrastructure that supports critical workloads. Site-wide inventory

mappings apply defaults across all protected VMs, while per-VM customizations document specific recovery configurations for workloads with unique requirements.

The Protection and Recovery Configuration Import/Export Tool exports a complete record of the DR asset inventory, including site names, inventory mappings, placeholder datastores, advanced settings, array managers with SRA information, protection groups, and recovery plans. This export provides a structured, portable document of which assets are protected and how they are configured for recovery. The export is produced in XML format, enabling automated processing and retention as a configuration record.

PNR generates and exports reports documenting each run of a recovery plan, each test of a recovery plan, and each test cleanup operation. These reports provide an auditable record of which recovery plans executed and which protected workloads were involved.

PNR tracks site metrics including paired sites, pair names, vCenter addresses, site connectivity status, and counts of protection groups, recovery plans, protected virtual machines, and array managers. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, providing consolidated visibility into the DR infrastructure as a class of managed assets.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.AM-07

Inventories of data and corresponding metadata for designated data types are maintained

SCF Controls: DCH-06, DCH-06.2, DCH-06.3, PRI-05, PRI-05.5

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.AM-08

Systems, hardware, software, services, and data are managed throughout their life cycles [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into ID.AM-08] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02]

SCF Controls: AST-01, AST-01.2, DCH-01, DCH-01.1, PRM-07, SEA-07, SEA-07.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated lifecycle management capabilities that address the full span of technology assets, applications, and services from initial deployment through ongoing maintenance to decommissioning.

At the platform level, VCF lifecycle management simplifies and automates the process of applying updates and patches to the software components within the VCF stack. It manages different versions of software components across the infrastructure, tracking compatibility and stability as components are updated. Administrators can plan updates, schedule maintenance windows, and apply changes with minimal disruption to running services. This centralized approach covers the core VCF infrastructure components and coordinates updates across the stack to maintain interoperability between dependent products. VCF building-block services have independent lifecycles, so updates to one service do not require coordinated changes across the entire environment, supporting practical lifecycle management without forcing broad impact assessments for routine updates.

VCF Operations provides a dedicated lifecycle management interface, accessible through Fleet Management and then Lifecycle, where administrators can upgrade individual VCF management components. Starting with VCF 9, lifecycle management for all core components is performed through the VCF Operations UI. The upgrade planner allows administrators to select target versions for each VCF core component, download upgrade bundles, and run pre-upgrade prechecks that validate component connectivity, version compatibility, and environment readiness before any changes are applied. VCF Operations coordinates the actual upgrade process across vCenter, NSX, ESX, and vSAN, running version-specific prechecks against components that have available upgrade bundles. VCF Operations also provides lifecycle management actions for monitoring agents and application services through the Infrastructure Operations Configurations page, where administrators can activate, deactivate, and manage Telegraf agents and discovered application services.

For the hypervisor layer, vSphere Lifecycle Manager (vLCM) manages the lifecycle of ESX hosts at the cluster level using a desired-state image model. Administrators define a single software specification for each cluster that includes the ESX base image, firmware add-ons, vendor add-ons, and third-party solution components. vLCM checks host compliance against this specification and remediates hosts that have drifted from the approved image. This includes installing firmware on new hosts, applying software updates, performing version upgrades, and decommissioning hosts when they reach end of life. vLCM consumes software updates from its depot, providing a structured mechanism for tracking available updates and applying them systematically across host clusters. vLCM can also manage the lifecycle of standalone ESX hosts that are part of a vCenter inventory, extending this coverage beyond cluster-managed hosts. In environments using vSphere Distributed Services Engine, vLCM extends lifecycle management to the software and firmware running on DPU (Data Processing Unit) devices within those servers. Hardware Support Manager (HSM) plugins extend this model to vendor-specific firmware and driver management, so that hardware components are kept at validated versions alongside software. vSphere Configuration Profiles provide a complementary desired-state mechanism for host configuration settings, with drift detection and remediation. VCF Operations monitors vSphere Configuration Profiles drift status through a collection cycle that runs every 8 hours, giving administrators visibility into configuration consistency across clusters.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides self-service lifecycle management of VKS clusters. Updating a Supervisor triggers rolling updates of the VKS clusters deployed on it, including Kubernetes software versions, VM configurations, and supporting infrastructure such as vSphere Namespaces and custom resources. Kubernetes version updates follow the upstream sequential update policy, meaning minor versions cannot be skipped. After all Supervisor control plane VMs are updated, worker nodes are updated in a rolling fashion. VKS supports running different Kubernetes versions in

separate clusters, allowing staged rollouts and version-specific testing. The VCF CLI provides a cluster upgrade command for upgrading workload clusters to a specified Kubernetes release version. VKS cluster lifecycle is managed through three layers of controllers: Virtual Machine Service, Cluster API, and Cloud Provider Plugin, supporting the full lifecycle from cluster creation through upgrade and decommissioning. VM Service manages the lifecycle of virtual machines within a vSphere Namespace, covering both stand-alone VMs and VMs that comprise VKS clusters. The vSphere Automation SDKs for Java and Python provide programmatic interfaces for automating the creation and lifecycle management of vSphere Namespaces, enabling scripted and auditable namespace lifecycle transitions. VM classes in vSphere Supervisor set guardrails for policy and governance of VMs by anticipating development needs and accounting for resource availability and constraints.

At the application and workload level, Kubernetes Deployments manage application lifecycle through declarative configuration that specifies container images, replicas, and runtime parameters. Rolling updates, rollback capabilities, and revision history allow platform operators to move applications through update and retirement phases in a controlled manner, with Pods carrying updated specifications created while old Pods are terminated to maintain application availability. The Kubernetes Container Lifecycle API enables the management system to take actions in response to container lifecycle events, allowing workload owners to hook into start, stop, and termination events for coordinated transitions. Kubernetes Finalizers provide a mechanism for controlling lifecycle cleanup of resources owned by deleted objects, preventing premature deletion before dependent resources have been properly retired. For stateful and third-party services, Kubernetes operators implement automation logic that responds to custom resource lifecycle events, handling snapshot creation, StatefulSet and Volume management, backup scheduling, and version upgrades for the services they manage. Supervisor Services that include an operator provide API and graphical interfaces that DevOps engineers can use to create and manage service instances within a vSphere Namespace throughout each service's lifecycle. Harbor, available as a standard package on VKS clusters, supports artifact lifecycle management by providing a centralized repository for storing, versioning, and managing container images. Image retention policies and versioning in Harbor support tracking the lifecycle of deployed software components and restricting which image versions remain in active use.

For consumer-facing workload management, VCF Automation provides a self-service catalog through which consumers deploy IT resources and independently manage workloads. Catalog items include blueprints, VM images, storage, networks, and other infrastructure resources scoped to projects and available for self-service deployment. Consumers can request and deploy infrastructure on a self-service basis and perform day-2 actions such as updates and patches independently. The Tenant Portal resource management interface allows filtering deployed resources by project and other attributes, and executing day-2 actions specific to resource type and state, covering the operational lifecycle of deployed workloads. The IaaS Services Console and Local Consumption Interface provide snapshot management for VMs, with options for memory capture and guest file system quiescence, supporting point-in-time restore capabilities as part of workload lifecycle management. Lifecycle and day-2 actions for custom resources in a VCF Automation deployment must be shared with all projects to maintain continued management when deployments are moved between projects.

VCF also exposes lifecycle management through its APIs. The vCenter Lifecycle Management API provides discovery operations for listing VMware products that can be associated with vCenter, managing product associations, and creating interoperability reports. It supports operations to retrieve the product catalog, associate and update products, and download reports generated by interoperability and pre-check operations, allowing administrators to verify compatibility before applying changes. The vCenter patching API provides its own pre-check operation that validates upgrade readiness before applying updates.

For application lifecycle extension, VCF Automation integrates with VCF Operations Orchestrator Client to extend the lifecycles of applications through workflows. This integration enables custom automation around deployment, maintenance, and retirement processes, using hosted workflows to manage application lifecycle events.

VMware Private AI Services (PAIS) supports the management of AI technology asset lifecycles through the Model Gallery and its integration with VCF Automation. The Model Gallery is a dedicated repository where AI application developers and MLOps engineers upload models for automated CI/CD-based deployment of model runtimes. Models can be distributed for continuous delivery across organizations or promoted between platforms and environments to support staged deployment workflows. The Model Gallery stores model metadata in the Open Container Initiative (OCI) format to describe the contents

and dependencies of ML models, enabling identification of platforms that can run a target model and helping reduce redundant copies while maintaining model integrity within a controlled environment. Before publishing a model, evaluators can examine inference requests for malicious behavior and perform hands-on functional tests to assess suitability for the intended business use case.

VCF Automation extends lifecycle management to AI applications and services through a self-service catalog. Private AI Services catalog items include AI Workstation, VMware Data Services Manager (DSM) Database, Triton Inferencing Server, and AI Kubernetes Cluster, created in the VCF Automation catalog for deployment by users in selected namespaces. Catalog provisioning supports retrieval-augmented generation (RAG) clusters on VMware Kubernetes Service (VKS) with a vector database in a single request, and the storage policy and VM class for DSM databases supporting RAG workloads are selected to suit the target workload. The Model Runtime component enables MLOps engineers to run models as model endpoints for use in Agent Builder and for indexing knowledge bases in Data Indexing and Retrieval, creating a path from model storage through active service delivery. Data Indexing and Retrieval also implements an MCP server that exports a set of search tools for each knowledge base. For disconnected deployments, the artifact mirroring tool (AMT) distributed with the pais CLI plug-in mirrors components into the air-gapped environment, and the VCF Consumption CLI 'vcf context create' command establishes an authenticated namespace context against VCF Automation using endpoint, CA certificate, API token, and context type parameters.

Private AI Services includes observability mechanisms to support monitoring of active AI assets. A Prometheus server is deployed in the Private AI Services namespace with its own metrics database backed by a Persistent Volume, with storage size inferred from the metrics retention property in the PAISConfiguration custom resource. The storage class and metrics retention period are configurable to control how long metrics are stored. LLM traces from agents and knowledge base indexing can be forwarded to an OpenTelemetry Collector for analysis. DevOps engineers can visualize health and performance metrics for Private AI Services components running in a VCF Automation namespace using an observability platform such as Grafana, and MLOps engineers and application developers can perform monitoring and diagnostics of models used in agents to track health, quality, and behavior of AI applications. For organizations using VCF Operations, a Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for Private AI Services controller metrics.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to technology lifecycle management by providing built-in tooling for managing the versions, update schedules, and operational states of the database services it provisions. Lifecycle management capabilities are accessible through the DSM UI, which gives administrators and users the ability to create, update, and deprovision data services. In DSM, supported engines include PostgreSQL, MySQL, MinIO, and Microsoft SQL Server.

For the DSM platform components themselves, the DSM UI provides version and upgrade management capabilities that give administrators visibility into current data service versions and options for upgrading or deactivating them. Database management capabilities accessible through DSM include operating system and database engine upgrades. The DSM

controller manages component dependencies through status monitoring and automated remediation, helping keep platform components in a consistent operational state.

DSM provides a maintenance policy mechanism to control when automated software updates are applied to the DSM plug-in. Administrators can configure the maintenance policy through either the DSM UI or the vSphere Client. The policy settings include a start date, a start time, and a duration that limits how long the update window may run, allowing organizations to schedule updates during low-impact periods. The `maintenance_policy` setting is accessible under the plug-in software update section.

For individual database instances, DSM supports a separate maintenance window configuration and a maintenance policy that administrators can set at database creation and adjust throughout the database's operational lifetime. The default maintenance window is six hours, beginning each Saturday at 23:59, and it is configurable via the `maintenance-window` setting. DSM adds a `Monthly Occurrences` setting that refines the maintenance schedule from a standard weekly cadence to specific weeks within a month, allowing selection of a particular day and one or more occurrences of that day. This granular scheduling is available for MySQL, SQL Server, and other supported engines, and is also accessible to tenants through the VCF Automation interface.

Infrastructure governance is supported through the Data Services Manager Consumption Operator, which automates database deployments based on predefined infrastructure and backup policies. The Consumption Operator applies infrastructure policy and backup location bindings to namespaces matching a configured selector, helping align deployed services with approved infrastructure configurations across their operational lifetime.

A vSphere administrator plans, administers, and secures resources for databases by creating and managing infrastructure policies in DSM. DSM deploys Telegraf agents on the provider appliance and on each database workload cluster to collect VM-level and engine-specific metrics, supporting operational awareness across the service lifecycle.

Technology lifecycle management at the organizational level requires processes beyond what DSM directly provides. DSM does not maintain a centralized inventory of all technology assets across the broader environment, nor does it manage end-of-support or end-of-life calendars for the infrastructure it depends on. Organizations must establish their own processes for tracking asset lifecycles, consulting vendor roadmaps, and making upgrade or retirement decisions within a formal change management framework. DSM's maintenance and version management capabilities are most effective when integrated into those broader organizational lifecycle processes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer has built-in mechanisms for managing the lifecycle of its own technology components. The Avi Controller is the central management plane responsible for deploying, configuring, and decommissioning Service Engine VMs. In vCenter and NSX environments, the Controller automatically manages the Service Engine lifecycle, provisioning new Service Engine VMs when a Service Engine VM or its ESX host fails.

The Avi Controller REST API supports application lifecycle automation, providing programmatic visibility into all configured virtual services and enabling create, update, and delete operations across the application delivery estate. Infrastructure-as-code integrations build on this API: Avi Ansible modules allow operators to define, create, and manage Virtual Services, Pools, and Health Monitors consistently across deployments. Avi automation integrates with DevOps workflows and infrastructure-as-code practices to streamline operations and reduce manual errors.

VCF introduces a dedicated Avi Load Balancer integration for VCF. The VCF Automation Provider Management portal supports resource governance and capacity planning to help prevent organizations from over-consuming shared Avi Load Balancer resources. Organization and project administrators can define blueprints that act as reusable designs for deploying Layer 4 and Layer 7 virtual services; blueprints can be scoped to a single project or shared across projects within an organization. Service Engine Groups can be assigned to projects, enabling a self-service model for application teams while retaining administrative control over capacity allocation.

Avi also manages the lifecycle of associated security artifacts. The Avi License Hub manages the Platform CA certificate lifecycle and automatically initiates certificate refresh processes. The Controller license ledger tracks consumed and available licensing values and displays consumption metrics for Service Engines.

The control asks whether the organization manages the lifecycles of technology assets, applications, and services broadly. Avi contributes the mechanisms for lifecycle management of the application delivery layer, but the organizational governance process of tracking all technology assets across the environment, defining end-of-life criteria, and executing planned decommissioning activities extends beyond what any single tool provides.

Control ID.IM

Improvements are identified from evaluations Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties Improvements are identified from execution of operational processes, procedures, and activities Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved [Withdrawn: Incorporated into GV.SC-08, ID.IM-02] [Withdrawn: Incorporated into ID.IM, ID.IM-03] [Withdrawn: Moved to ID.IM-03] [Withdrawn: Moved to ID.IM-04] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Incorporated into ID.IM-02] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

SCF Controls: OPS-01, OPS-01.1, RSK-01, RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.IM-01

Improvements are identified from evaluations

SCF Controls: CPL-03, CPL-03.2, IAO-02, IAO-02.4, IAO-05, TDA-09, TDA-09.1, TPM-04.1, TPM-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection,

and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ID.IM-02

Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties [Withdrawn: Incorporated into GV.SC-08, ID.IM-02] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Incorporated into ID.IM-02]

SCF Controls: BCD-05, CPL-03, CPL-03.2, IAO-02, IAO-02.4, IAO-05, IRO-13, TDA-09, TDA-09.1, TPM-04.1, TPM-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides configuration-state review and continuous compliance monitoring capabilities that contribute to regular functional reviews of cybersecurity and data protection controls across the infrastructure stack, though the organizational review process, schedule, and corrective action procedures must be established and maintained outside the platform.

VCF Operations includes a compliance management capability that continuously monitors infrastructure against industry-standard security benchmarks and custom policies. Rather than relying solely on periodic manual reviews, VCF Operations flags configuration drift and policy deviations as they occur, giving auditors and administrators ongoing visibility into the compliance posture of technology assets and services running on the platform. When VCF Operations detects non-compliance with a policy, it can generate alerts or notifications, and depending on the severity, administrators can configure automated remediation actions to bring the object back into compliance. Compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations.

VCF Operations calculates a compliance score for each managed object based on the ratio of compliant objects to total objects assessed by a given benchmark, expressed as a percentage. The most critical violated standard determines the overall compliance score for a given object, making it straightforward to identify which assets need attention first. Compliance score cards display the number of non-compliant objects and the total number of objects affected by each hardening guide. Administrators manage all compliance-related tasks from the Security > Compliance page, where they can discover non-compliant objects, review associated violations, and take remedial action.

To support structured reviews against recognized standards, VCF provides pre-built compliance packs available as native packs from the compliance repository. These include packs aligned with ISO security standards and the DISA Security Technical Implementation Guide (STIG), among others. Organizations can apply these packs to evaluate their VCF deployment against established security baselines, identify gaps, and track remediation progress. The vSphere Security Configuration Guide and the vSAN Security Configuration Guide provide additional hardening guidance and address compliance considerations, and are references for what settings and configurations to verify during a functional review. The NSX Security Configuration Guide provides recommendations for securing NSX components such as NSX nodes, NSX Controllers, and NSX Edge nodes.

Beyond the built-in benchmarks, organizations can create custom compliance benchmarks that codify their own cybersecurity and data protection policies. Custom benchmarks are configured through a multi-step process that includes naming, selecting compliance alerts to monitor, and activating policies. VCF Operations supports up to five custom compliance score cards. Custom benchmarks can be exported from one VCF Operations instance and imported to another, providing consistent policy enforcement across multiple deployments.

At the host layer, VCF Operations Configuration Drifts provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. vSphere Configuration Profiles must be enabled on clusters to view drift status, and the feature applies to deployments running VCF or later. The Configuration Drift dashboard allows administrators to view and monitor drift statuses, detecting when hosts fall out of their desired-state configurations. vSphere Lifecycle Manager can check the compliance of a cluster or host against the desired state and determine whether additional remediation steps are required.

NSX provides its own compliance status reporting. NSX Manager offers a Compliance Status Report accessible from the Monitoring Dashboards that displays the number of affected resources and compliance status. The report identifies non-

compliant configurations by non-compliance code, description, compliance standard violated, affected resource name or ID, and resource type. Organizations can use the NSX compliance report to configure their NSX environment to adhere to IT policies and industry standards.

The VMware Kubernetes Service (VKS) layer of VCF extends compliance review capabilities to containerized workloads and the Kubernetes control plane. Pod Security Admission (PSA) is the built-in Kubernetes admission controller that evaluates pod specifications against defined security standards at the point of deployment. PSA operates in three modes: enforce blocks non-compliant pods from running, audit records security violations as audit events without blocking deployment, and warn returns warnings to the caller without blocking. Organizations can configure PSA to enforce a baseline standard cluster-wide while operating the restricted standard in audit and warn modes, producing an ongoing stream of compliance findings about workloads that do not meet the stricter profile without disrupting existing workloads. PSA can be configured per namespace using the podSecurityStandard API, allowing different review stringency to be applied to different teams or workload types. Pods' security contexts should be separately reviewed to identify any privileges or capabilities that exceed what the predefined security standards permit for a given use case.

VKS Cluster Management provides out-of-the-box security policy templates that mirror the Kubernetes Pod Security Standards profiles, including baseline and restricted. The baseline template mitigates common privilege escalation risks while maintaining compatibility with standard containerized workloads. Custom security policy templates extend these defaults, allowing organizations to fine-tune individual security context parameters in support of governance requirements specific to their environment.

For Kubernetes RBAC review, the Kubernetes documentation distributed with VKS notes that the default RBAC rights provided in clusters should be reviewed to identify opportunities for security hardening. Auditors reviewing a VKS deployment should examine ClusterRole and ClusterRoleBinding objects for overly broad permissions as well as namespace-scoped Role and RoleBinding objects for each team or namespace. IAM role trust policies should be scoped to specific service accounts and namespaces to support least-privilege enforcement.

STIGs for VKS system components, including Supervisor and VMware Kubernetes Release (VKr) components, are available through Tanzu STIG Hardening and provide a recognized baseline against which deployed VKS environments can be compared during periodic compliance reviews.

Harbor Registry, available as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based replication to help evaluate the security of the container image supply chain. Harbor's role-based access controls and artifact policies can themselves be audited to confirm that only approved images are accessible to workloads. Within CI/CD pipelines integrated through Harness, the Harness Security Testing Orchestration (STO) capability enforces policy based on CVE data and severity thresholds, and Wiz integrates with the pipeline to authenticate to the artifact registry, pull container images, and perform vulnerability scanning before workloads are promoted to production. Wiz can also be deployed as a service on VKS clusters to continuously monitor the cloud environment and deployed workloads for security risks and compliance deviations.

Third-party policy engines such as Kyverno and OPA Gatekeeper can be deployed on VKS clusters to implement policy-as-code compliance review. These tools evaluate cluster resources against defined policies and can generate compliance reports identifying violations across the cluster, extending the platform's built-in review instrumentation.

For auditors evaluating a VCF environment against this control, the key areas to examine are: whether VCF Operations compliance monitoring is enabled and configured with benchmarks that map to the organization's policies; whether compliance packs appropriate to the organization's regulatory environment have been applied; whether the Configuration Drifts feature is active for vSphere clusters; whether PSA is configured in audit and warn modes on VKS namespaces to produce ongoing compliance findings; whether RBAC bindings across VKS clusters have been reviewed against least-privilege expectations; and whether the compliance dashboard and NSX compliance reports are being reviewed on a regular cadence with findings triaged and remediated.

These capabilities verify that infrastructure configurations match desired baselines and that compliance benchmarks are met, but they do not functionally test whether security controls are actively operating as intended. Organizations should

supplement VCF's configuration-state reviews with periodic functional validation such as security assessments or controlled test scenarios. The review schedule, escalation procedures, and corrective action processes are organizational responsibilities that VCF does not enforce on its own.

VMware vDefend (Contributes)

VMware vDefend contributes to the functional review of cybersecurity controls by providing network security-specific compliance assessment, policy analysis, and segmentation scoring capabilities. While the broader review of all technology assets against organizational policies is handled by VCF Operations and its compliance management features, vDefend provides the network security dimension of that review.

Security Services Platform includes a Security Segmentation score and report generation capability that helps compliance officers meet security audit requirements and demonstrate adherence to network security best practices. This scoring mechanism evaluates the current state of microsegmentation policy enforcement across the environment, providing auditors a quantitative measure of alignment between network security controls and policy objectives. The Security Segmentation Score Breakdown report details total environments and pairs, protection rule actions, and highlights environment pairs that lack inter-environment policies, providing specific visibility into coverage gaps in the microsegmentation posture. The Security Policies window within Security Services Platform displays all firewall rules applied for environment pairs, and administrators can change the action of published environment pair protection rules directly from this view.

The metrics service within Security Services Platform collects key performance indicators and operational data points across vDefend components including Distributed Firewall, Gateway Firewall, IDS/IPS, and TLS Inspection, providing the data foundation for ongoing compliance reviews. Viewing the TLS Inspection dashboard requires Security Services Platform to be deployed with the Metrics feature enabled. Security Services Platform Inventory monitoring allows administrators to view the infrastructure hierarchy including regions, zones, and VMs to verify correct definition, supporting periodic reviews of Technology Assets.

Security Services Platform's Security Intelligence capability provides policy recommendation analysis that compares recommended rules, groups, and services against the current environment to identify gaps between desired and actual security policy. Administrators use the Monitor & Plan interface to review, filter, and manage policy recommendations, identifying where current firewall rules diverge from what traffic analysis suggests is appropriate. Recommendations can be filtered by Status and Ready to Publish state, and scoped to selected groups and VMs. Policy Recommendations can be exported in JSON format with resource_type, id, and children elements for infrastructure and domain configuration, allowing compliance teams to analyze recommended rule sets outside the platform.

The Security Overview dashboard in Security Services Platform provides summary-level statistics of file inspections, and the platform provides monitoring of current deployment status and platform-related alarms that highlight errors requiring attention. Security Services Platform support bundles collect diagnostic information from all controller and worker nodes in the deployment for troubleshooting and compliance documentation. Security Services Platform also supports assessment of control effectiveness by enabling comparison of the ratio of detected versus prevented events, providing reviewers a quantifiable measure of security control activity relative to observed threats.

Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The dedicated Auditor role is designed for personnel performing compliance and security reviews, allowing compliance teams to access review and assessment capabilities without requiring administrative privileges.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in mechanisms that support regular review of database infrastructure assets for adherence to security, compliance, and resilience policies.

The most direct compliance review mechanism in DSM is the Compliance tab, available on each data service policy detail page. This tab displays compliance reports for data service policies and allows administrators to expand policy violations to

identify noncompliant databases, data services, namespaces, and resource configurations. Administrators can use this view to assess which database instances are operating outside defined policy parameters and take corrective action.

Infrastructure policies in DSM create a framework of standards against which deployed database resources are evaluated. Administrators define data service policies that govern resource consumption limits, storage placement, VM class selection, and IP range assignments. These policies apply to PostgreSQL, MySQL, and SQL Server databases and can be enforced across different tenants to maintain a consistent security and compliance posture. The Infrastructure Policies view in the DSM administrator UI lists all policies in the environment and shows which databases are associated with each policy, providing a consolidated view for compliance assessment.

DSM generates infrastructure policy compliance alerts, including `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, to flag when cluster configurations drift from policy requirements. The monitoring framework also raises metrics-based and status-condition-based alerts to identify critical failure conditions across database engines, including engine degradation, non-operational status, and backup failures for PostgreSQL, MySQL, and SQL Server databases. These alerts provide ongoing visibility into the compliance and resilience state of database resources without requiring manual inspection.

For resilience review specifically, DSM requires that High Availability be activated on VMware vCenter clusters as a prerequisite for infrastructure policy compliance. The resiliency of the DSM Provider Appliance itself is provided through vSphere HA. These requirements are surfaced through the policy compliance alerting mechanism, making infrastructure resilience status an integrated part of policy compliance reporting.

Organizations should supplement DSM's built-in compliance reporting with documented review schedules, assigned review responsibilities, and a process for tracking and remediating identified violations. DSM provides technical visibility into policy adherence for database infrastructure, but the organizational governance processes that constitute a complete functional review program remain the responsibility of the operating organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports organizational reviews of application-layer security, compliance, and resilience through its built-in reporting capabilities.

The Application Security Report generates audit-ready records of WAF findings, statistics, and overall security posture accessible to both technical teams and executive stakeholders. The report is available as a downloadable PDF, making it suitable for sharing findings with auditors and compliance reviewers. Security teams can use this report to assess whether Avi-managed applications are aligned with organizational security policies and to track posture over time.

The WAF Evaluation Report provides structured recommendations for strengthening an application's security posture, giving reviewers a concrete basis for identifying and remediating configuration gaps across virtual services.

In 9.1, Positive Security configuration has been consolidated under Virtual Service > Positive Security Policy, a change from its prior location within the WAF Policy. This mechanism determines which learned application behaviors are promoted to enforced security rules. Periodic review of the Positive Security Policy is part of maintaining the application security posture across Avi-protected services.

User-Defined Metrics extend Avi's reporting capabilities by allowing administrators to define and extract customized telemetry data required for specific enterprise compliance or reporting needs through API calls. This capability supports integration of Avi-specific application metrics into broader compliance dashboards and review workflows.

Avi's contribution to this control is bounded by its role as an application delivery controller. The review program this control requires, encompassing all technology assets and services across the organization, is an organizational governance responsibility that extends beyond the application-layer reporting and validation capabilities Avi provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ID.IM-03

Improvements are identified from execution of operational processes, procedures, and activities

[Withdrawn: Incorporated into ID.IM, ID.IM-03] [Withdrawn: Moved to ID.IM-03] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

SCF Controls: BCD-05, GOV-05, IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.IM-04

Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved [Withdrawn: Moved to ID.IM-04] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04]

SCF Controls: BCD-01, BCD-06, IRO-04, IRO-04.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a broad set of infrastructure-level capabilities that support business continuity and disaster recovery planning. While VCF does not itself constitute a Business Continuity Management System, it supplies the technical mechanisms that underpin resilient deployments and contingency operations.

vSAN stretched clusters allow organizations to extend a single vSAN datastore across two geographically separated sites with an independent witness host. When configured with site mirroring, a stretched cluster can tolerate the complete loss of one site while maintaining data availability. vSphere HA, when enabled on a stretched cluster, automatically restarts virtual machines on the surviving site during a site failure. To support this, vSphere HA admission control should be configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, and site-specific isolation response addresses should be defined so that vSphere HA can validate host isolation even when network connectivity between sites is lost. The admission control setting for host failures the cluster tolerates should also be updated after cluster expansion to reflect the correct host count per availability zone. When stretching a workload domain cluster, the default management vSphere cluster must already be stretched. vSphere HA uses network heartbeats to validate the state of VMware ESX hosts, and can also use heartbeat datastores mounted to more than one host (excluding vSAN datastores) for cluster membership monitoring.

vSphere HA also operates at the individual cluster level independent of stretched clusters. The HA configuration remediation mode can be set to quarantine mode, maintenance mode, or mixed mode to handle host failures in a controlled manner, helping maintain workload availability during hardware events. vSphere Fault Tolerance provides a higher tier of availability for individual virtual machines by maintaining a secondary VM in continuous lockstep with the primary, enabling instantaneous failover with no data loss if the primary host fails.

vSAN Data Protection provides snapshot-based protection through the vSAN Snapshot Service. Protection groups support configurable snapshot scheduling with adjustable intervals and retention policies that define retention duration and time units. This allows organizations to define data protection policies aligned with their recovery point objectives. The Snapshot Service API also supports operations such as restoring deleted virtual machines from snapshots and creating linked clones from snapshots.

vSphere Replication provides asynchronous replication of virtual machines with a configurable Recovery Point Objective (RPO), allowing organizations to replicate workloads to a secondary site and define acceptable data loss windows as part of their contingency planning.

VCF requires all management components, including VCF Operations, VMware vCenter, NSX, and VCF Automation, to be configured with a regular backup schedule and retention policy. VCF Operations configures NSX Manager backups during the initial deployment, with a recommended backup frequency of hourly and 7-day retention. Backup jobs for VCF Operations and all vCenter instances should start within the same 5-minute window to capture a consistent state. The VMware Infrastructure Health adapter within VCF Operations monitors backup job retention for management components, including NSX Manager. Changed Block Tracking (CBT) tracks modified disk sectors on virtual machines to support incremental backups, reducing backup windows and storage requirements for VM-level backup operations. vCenter itself also supports a High Availability configuration with Active and Passive nodes whose configuration files are continuously replicated, providing management-plane resilience independent of the backup schedule.

VMware HCX provides workload mobility capabilities for migrating and replicating VMs between sites. HCX supports multiple migration types through its Mobility Agent service, including vMotion, Cold Migration, Bulk Migration, and Replication Assisted

vMotion (RAV), each addressing different scenarios from large-scale parallel migrations to zero-downtime live migrations. HCX also includes appliance-level backup and restore capabilities for the HCX Manager, including certificate backup and restore, supporting planned migrations and recovery scenarios as part of broader BC/DR operations.

VCF Operations monitors infrastructure health and surfaces alerts when conditions threaten availability, giving operations teams early warning of potential failures. The Platform Health Alerts page provides a centralized view of alerts across data sources and infrastructure nodes. VCF Automation provides alerts through the associated VCF Operations application for capacity, performance, and availability monitoring. VCF Operations also includes infrastructure planning and what-if analysis capabilities that help organizations forecast capacity requirements and plan for contingency scenarios. Committed scenarios reserve capacity by setting aside resources for new, upcoming, or planned workloads, helping stakeholders understand capacity requirements across the environment. Integration with IT Service Management and Configuration Management Database platforms is supported through VCF Automation, enabling organizations to tie their infrastructure management into broader service continuity workflows.

Lifecycle management tools allow administrators to plan updates and schedule maintenance windows to make changes with minimal disruption to services, supporting the operational continuity aspect of business continuity planning.

While VCF provides these technical capabilities, a complete BCMS requires organizational elements that fall outside the platform: documented continuity of operations plans, recovery time and recovery point objectives defined by business stakeholders, regular testing and exercise of recovery procedures, communication plans, and management oversight of the continuity program. VCF supplies the infrastructure resilience and recovery mechanisms that such plans depend on, but the planning, governance, and procedural components must be established and maintained by the organization.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides the technical execution layer for contingency planning in virtualized infrastructure. Recovery plans define the sequence, priority, and configuration for failover operations, acting as executable BC/DR playbooks. Protection groups organize virtual machines into logical units aligned with application tiers or business functions, establishing the scope of each contingency plan.

Recovery plans support non-disruptive testing before use in planned migration or disaster recovery, allowing organizations to validate their contingency procedures without affecting production workloads. Recovery plan configuration differs between emergency scenarios at the protected site and planned migration of services from one site to another, with PNR supporting both modes. A forced recovery function is available during disaster recovery plan execution for scenarios requiring immediate failover.

vSphere Replication provides host-based replication with configurable Recovery Point Objectives (RPO), allowing organizations to set per-workload data loss tolerances. vSphere Replication supports up to 200 point-in-time recovery instances per virtual machine using the Latest Instances option, enabling recovery to specific earlier states. This capability is relevant to contingency scenarios involving data corruption or ransomware events. When the source site is accessible at the time of recovery, vSphere Replication can synchronize recent changes from the source site to the target site before completing the operation, reducing data loss.

In 9.1, PNR extends to multi-tenant disaster recovery through integration with VCF Automation. The product implements role-based access control with Organization Administrator, Project Administrator, and Project Advanced User roles, each with defined authorization levels for disaster recovery operations. Role assignments must be configured on both the primary and secondary PNR sites to maintain consistent access control across the DR environment. A multi-region deployment topology places separate management domains in each region to contain disaster impact to one region, while enabling service recovery in an alternate management domain when VCF Automation and VCF Operations are affected. The VCF Operations Orchestrator Plug-In for PNR provides Configuration, Inventory Mappings, Protection Groups, and Storage predefined workflow categories for workflow-driven recovery operations.

Cyber recovery deployments support a standard VCF topology where the workload domain is isolated from the management domain, providing separation between management and user workloads in clean-room recovery scenarios.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ID.RA

Vulnerabilities in assets are identified, validated, and recorded Cyber threat intelligence is received from information sharing forums and sources Internal and external threats to the organization are identified and recorded Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization Risk responses are chosen, prioritized, planned, tracked, and communicated Changes and exceptions are managed, assessed for risk impact, recorded, and tracked Processes for receiving, analyzing, and responding to vulnerability disclosures are established The authenticity and integrity of hardware and software are assessed prior to acquisition and use Critical suppliers are assessed prior to acquisition [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.RA-01] [Withdrawn: Moved to ID.RA-08] [Withdrawn: Incorporated into ID.RA-06]

SCF Controls: GOV-01, GOV-01.1, GOV-02, RSK-01, RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.RA-01

Vulnerabilities in assets are identified, validated, and recorded [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.RA-01]

SCF Controls: IAO-01, IAO-02, IAO-05, RSK-04, RSK-04.1, TDA-09, VPM-01, VPM-06

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

VMware vDefend (Contributes)

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides patch management and monitoring capabilities that support an organization's vulnerability management program as it applies to the database services DSM manages.

For patch management, DSM exposes a Maintenance Policy that administrators configure in the vSphere Client. The Maintenance Policy controls when and for how long the platform applies automatic minor software updates to DSM appliances. Configurable settings include the start date (maintenance-policy-start-date), start time in hours and minutes (maintenance-policy-start-time), and duration of the update window (maintenance-policy-duration). The default maintenance window starts each Saturday at 23:59 with a six-hour duration, and administrators should always set a future date and time when configuring the policy. Upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements. Per-database maintenance windows follow the same structure and can be adjusted during database creation or subsequent operations.

DSM requires that at least one complete chain of software updates for appliances be attempted, irrespective of the configured maintenance window duration. Patch cycles cannot be indefinitely deferred through policy configuration alone. Within the configured maintenance duration, plug-in software updates attempt up to three times with a 10-minute interval between attempts. The maintenance policy can be edited during the 10-minute interval between attempts, which cancels the next scheduled attempt and applies the newly configured policy. Administrators can view available upgrades and the upgrade history through the Version & Upgrade interface, accessible from the vSphere Client under the VMware vCenter Configure tab. The vSphere Administrator role is explicitly responsible for managing DSM VM updates and creating and managing

infrastructure policies, which supports assigning patch management responsibilities to designated personnel. Both a vSphere administrator and a DSM user in the admin role can manage plug-in and database template software updates.

The DSM controller manages feature dependencies through status monitoring and automated remediation. When an upgrade requires resolution of VKS release dependencies, the controller automatically resumes the provisioning process after those dependencies are resolved, helping maintain patch state consistency during VCF environment upgrades.

DSM also provides monitoring capabilities that help identify conditions requiring remediation. The Global Alerts page, accessible in both the plug-in UI and the standalone UI, displays non-catastrophic alerts and system status. The Administrator UI Dashboard surfaces the same Global Alerts view for environment-wide visibility. DSM generates alerts for authentication failures, backup and restore corruptions, and certificate errors. The monitoring framework supports metrics-based and status-condition-based alerts covering conditions such as database engine degradation, non-operational status, and backup failure. Administrators and database users can configure alert thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections, each with separate warning and critical thresholds. DSM supports webhook-based alerting for database monitoring events triggered by threshold violations. DSM also provides mitigation suggestions alongside database alerts to help administrators resolve issues without disrupting database services. SQL Server administrators can define maintenance windows for operating system patching of SQL Server instances.

For diagnostics, DSM generates system support bundles containing system logs and diagnostic information, with a configurable retention duration before the system automatically deletes them. The Monitoring tab in the DSM UI displays monitoring data for individual database instances, including an Alerts pane and an Operations view for tracking operations targeted on database VMs. DSM can also be monitored using VCF Operations for troubleshooting and status visibility, with VCF Operations providing a view of PostgreSQL and MySQL cluster health within the DSM environment.

The overall vulnerability management program, including scanning, prioritization, remediation timelines, and organizational governance, is an organizational responsibility outside DSM's scope. DSM contributes by providing the update scheduling mechanisms and monitoring visibility needed to act on vulnerability management decisions within the scope of the database services it manages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ID.RA-02

Cyber threat intelligence is received from information sharing forums and sources

SCF Controls: GOV-07, THR-03

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters. Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache.

Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.RA-03

Internal and external threats to the organization are identified and recorded

SCF Controls: THR-01, THR-02, THR-03, THR-04, THR-05, THR-07, THR-09

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend contributes to this control through its threat intelligence consumption and detection infrastructure. The IDS/IPS engine applies knowledge-based signatures that encode specific patterns corresponding to known attack types, detecting intrusions based on known malicious instruction sequences at distributed and gateway enforcement points within vDefend-protected segments. Threat metadata feeds for Network Detection and Response are distributed and can be refreshed from online sources, or downloaded and applied manually in air-gapped environments through NSX Manager or a workstation connected to the Security Services Platform.

Network Detection and Response (NDR) correlates related detection events into campaigns and organizes them into a chronological timeline for security analyst review and triage. The Campaign view displays total detections and threats identified under Malicious Activity, and Campaign Correlation Rules provide structured visibility into how individual detections relate to broader attack patterns.

Security Intelligence maps detected suspicious events to adversarial tactics and techniques from the MITRE ATT&CK framework, recording the count of each tactic and technique observed during a selected time period. This TTP-level categorization supports the situational awareness the control describes for traffic traversing vDefend-protected segments. The threat visualization canvas aids rapid containment, identification of compromised assets, and adjustment of microsegmentation policies in response to detected activity. The blast radius analysis capability displays which communication paths a threat has affected, helping analysts determine whether an attack targets specific systems or represents a wider campaign.

Security Intelligence also collects related IDS events across the same source and destination hosts to connect relevant events and build a fuller picture of an attack sequence. The vDefend Security Assessment generates Security Segmentation Reports and Blast Radius Reports that break down at-risk workloads, communication chains, and flows to support protection planning. Security teams investigate individual events and correlated campaigns through the Security Services Platform interface to assess impact, identify root causes, and take mitigation actions.

While vDefend delivers technical mechanisms for consuming threat intelligence feeds and mapping observed behavior to adversarial TTPs at the network layer, the broader organizational threat intelligence program, including sourcing intelligence from external providers, integrating with threat sharing platforms, and disseminating findings to other teams and tools, requires complementary processes and tooling outside the product.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) contributes to situational awareness of evolving threats at the application delivery layer through its Live Security Threat Intelligence service, which delivers security threat feeds for multiple attack vectors in real time to protect applications from continuously changing threats. The Live Security Threat Intelligence service encompasses four components: an IP Reputation Service, an Application Rules Service, a WAF Signatures Service, and a Bot Management Service. The service is opt-in and must be explicitly enabled through Cloud Services configuration on the Avi Controller.

The IP Reputation Service classifies incoming client IP addresses against a regularly updated database, covering threat categories including botnets, phishing, spam sources, and DoS/DDoS attack sources. The service performs real-time automatic IP Reputation updates and operates across globally distributed Avi Load Balancer Controller clusters.

Administrators attach an IP Reputation database to virtual services, and enforcement actions such as blocking or rate-limiting are applied per classification result.

The Application Rules Service provides rules specifically designed to block attacks on known application vulnerabilities, many of them mapped to CVEs, covering protection for over 5,000 applications including WordPress, Drupal, and Apache.

Application Rules are automatically updated on the Avi Controller, and administrators can enable auto-sync to receive Application Rules Database updates automatically when new rules are published.

The WAF Signatures Service allows Avi to receive notifications when new Core Rule Set (CRS) data is available and to automatically download updated WAF CRS rules. This keeps application-layer defenses aligned with current vulnerability intelligence without requiring manual administrator action.

The Bot Management Service delivers a real-time feed for the User-Agent database, a core bot detection component. User Agent Database Sync can be enabled to receive continuous User-Agent updates for threat detection. Traffic is classified into categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot, and HTTP security policy rules apply enforcement actions including connection termination for dangerous bot classifications.

When Avi detects security events such as SYN flood or DDoS conditions, its alerting and ControlScript framework supports automated compensating responses. Alert actions can invoke a ControlScript that adds offending client IP addresses to a blocklist IP group attached to a network security policy for rate shaping or blocking. ControlScripts receive alert parameters including attack count, event ID, and alert level, and can execute automated remediation in response to system events rather than requiring manual intervention. The DDoS Policy within the Network Security policy detects and mitigates a range of Layer 4 through Layer 7 network attacks.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.RA-04

Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded

SCF Controls: THR-09, THR-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.RA-05

Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization

SCF Controls: RSK-01.1, RSK-02.1, RSK-04, RSK-05, RSK-06, RSK-06.1, THR-02, THR-09, THR-10

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.RA-06

Risk responses are chosen, prioritized, planned, tracked, and communicated [Withdrawn: Incorporated into ID.RA-06]

SCF Controls: RSK-01.1, RSK-02.1, RSK-05, RSK-06, RSK-06.1, RSK-06.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control ID.RA-07

Changes and exceptions are managed, assessed for risk impact, recorded, and tracked [Withdrawn:
Incorporated into PR.PS-01, ID.RA-07]

SCF Controls: CHG-01, CHG-02, CHG-02.1, CHG-02.2, CHG-03, CHG-04, GOV-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides mechanisms that enforce organization-defined change authorization through approval workflows, role-based access controls, policy hierarchies, allowlist-based action restrictions, and configuration drift detection. These mechanisms require organization-approved change requests before modifications take effect.

VCF Automation includes approval policies that require designated administrators to review and approve changes before they are applied. These policies can be configured to require project administrator review of all changes to deployed catalog items, particularly those used by multiple teams. When approval policies are active, change requests that remain unapproved after a defined period can be configured to be automatically rejected, blocking deployment or modification of cloud resources without explicit authorization. An enforced policy can also be set to automatically approve or reject a request if the approver does not take action within the configured timeframe. Custom user roles can be created to grant specific permissions, including the ability to review and respond to approval requests, allowing organizations to designate appropriate change approvers.

Day 2 action policies in VCF Automation further restrict what modifications users can make to existing deployments and their component resources. These policies operate by creating a list of permitted actions, so any change not explicitly listed is prohibited by default. Project administrators can selectively entitle project members to specific operations, such as snapshot and revert actions, without requiring administrator intervention for those particular operations while still restricting all other changes. This keeps the approval process proportionate to the risk of each action.

Role-based access controls restrict which users can initiate changes at multiple levels of the platform. NSX Manager applies role-based access control to restrict system access to authorized users by assigning roles with specific permissions. Organization administrators cannot edit global roles published to their organizations, and organization users can exercise only those rights from their roles that have been published to their organizations, limiting the scope of changes any individual can perform. Runtime defined entities can only be modified by users who hold both the appropriate Edit right and a change-level ACL entry. Access to specific entity types can be granted only to designated users and organizations. System administrators with the Manage General ACL right can create, modify, and remove specific access control lists through the accessControls API, providing granular control over who can make what changes. These authorization controls apply consistently regardless of operational context.

VCF enforces a policy hierarchy that restricts unauthorized weakening of security controls. A restrictive security policy created by an organization administrator at the organization level cannot be overwritten by a less restrictive policy at the project level. Inherited policies cannot be modified or deleted at lower levels, though direct policies for a given object can be edited or removed. This hierarchy maintains consistent change controls across the environment and restricts lower-level administrators from circumventing organization-wide restrictions.

The Consumption layer of VCF, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends these change controls into Kubernetes workload environments. The Kubernetes API server is the single supported path for all resource changes in a cluster, with every write operation requiring authentication followed by authorization. Kubernetes RBAC Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings define precisely which subjects can perform which verbs on which resources, and the RBAC API includes built-in privilege escalation protection that helps prevent users from editing roles or role bindings to obtain permissions they do not already hold, enforced at the API level regardless of the authorizer mode in use. VKS Cluster Management Policies apply a strict hierarchical enforcement model where policies can only be modified or deleted at their source of origin; inherited policies are immutable at the tenant level, extending the platform-level change restriction hierarchy into Kubernetes workload management. Cluster administrators can

deploy `ValidatingAdmissionPolicy` to declaratively restrict what changes can be made via the Kubernetes API, protecting platform namespaces from deletion and restricting write actions on specific resource types beyond what RBAC alone covers. When `ValidatingAdmissionPolicy` is configured with a match policy of `Equivalent`, it applies to requests regardless of which API group or version was used to access the resource, maintaining consistent enforcement as APIs evolve. For sensitive workloads, `ValidatingAdmissionPolicy` can further narrow the permitted change surface; `ValidatingAdmissionPolicy` is also the recommended mechanism for protecting specific resources such as `ResourceQuota` objects from unauthorized modification. Admission control modules, including admission webhooks, can reject or modify requests to create, modify, delete, or connect to objects at the API boundary before they take effect. VKS Cluster Management Mutation Policies can enforce pod specification conformance at admission time, and because mutation policies follow the same hierarchical enforcement model, inherited mutation policies cannot be modified at child levels. VKS Cluster Management Policy Templates are the source blueprints for policies across the cluster estate; they can only be created and managed through their full lifecycle by Organization Administrators. Project Administrators can apply these templates within their projects and clusters but cannot modify the original templates. VKS Cluster Management custom policies can only be edited or deleted by users assigned the Organization Administrator or Project Administrator role, restricting policy modification to designated roles. Pod security policies on system namespaces (`kube-system`, `tkg-system`, and `vmware-system-cloud-provider`) cannot be changed, establishing a baseline that tenant operations cannot override. VKS local content libraries support Security Policy enforcement that controls access to and usage of vSphere Kubernetes releases. Supervisor enforces vSphere Namespace RBAC to restrict connections to Supervisor and VKS clusters based on user permissions, applying consistent authorization at the Consumption layer boundary. The Consumption layer also supports immutable infrastructure patterns, where automated processes overwrite unauthorized changes or systems are configured to reject changes outright, making unauthorized modifications easier to detect and remediate. Where organizations deploy the Argo CD Supervisor Service for GitOps-based change delivery, Argo CD enforces access controls across all components and manages secrets securely outside of Git, providing a controlled delivery pipeline through which changes are tracked and deployed consistently. Organizations should separately restrict access to underlying cluster components such as etcd and node-level configurations, as direct access to those layers bypasses API server controls.

At the infrastructure level, VCF validates proposed changes against compliance requirements before applying them. vSAN rejects storage policy changes immediately when they violate policy compliance or when the underlying storage capabilities do not support the requested change, such as attempting a RAID-5 to RAID-6 change on a cluster that cannot support it. At the virtual networking layer, the default security policy of a distributed virtual switch is to reject MAC address changes. Both standard and distributed virtual switches can be configured to accept or reject promiscuous mode, MAC address changes, and forged transmits, giving administrators explicit control over which network-level configuration changes are permitted on virtual switch ports.

VCF Operations provides configuration drift detection that compares the current state of VMware vCenter and cluster objects against desired-state configuration templates. Drift detection can be scheduled to run automatic checks at a configurable interval, and drift reports can be viewed and downloaded for each vCenter instance. When configuration templates are managed in source control, VCF Operations tracks whether the current template reflects the desired state and detects divergence. This allows administrators to identify unauthorized or unintended configuration changes and take corrective action.

User permission changes are tracked to provide an audit trail of when such changes were made and who made them, supporting after-the-fact review of change authorization.

VMware vDefend (Contributes)

VMware vDefend provides several mechanisms that help prohibit unauthorized changes to network security policy within its domain, contributing to an organization's broader change control process.

The Distributed Firewall (DFW) includes a policy locking feature: when a security policy section is locked, no other user can modify the policy until the lock is released by the user who applied it. This restricts concurrent or unauthorized edits to active firewall policy sections and is configurable per section, allowing administrators to protect policies during change freezes or maintenance windows. Within project-based deployments, Organization Admin ownership of firewall rules prevents project

members from accessing firewall rule modifications entirely, providing a role-based structural constraint on who can modify network security policy.

Security Services Platform (SSP) enforces immutability on published security policies: once initial policies have been published through SSP, they cannot be modified from the user interface. This requires administrators to follow a defined workflow for any policy updates rather than directly editing production policies. SSP also surfaces a change-detected indicator in Security Intelligence Policy Recommendations when input entities used to generate prior recommendations change, giving administrators visibility into modifications that could affect security posture.

DFW system-generated rules produced by applying a security strategy cannot be edited individually through the API or UI (except for logging settings and log labels), and new rules cannot be added to those sections. DFW policy numbers cannot be changed after initial creation, providing a stable reference for change tracking and audit purposes.

DFW and Gateway Firewall policy changes follow a realization workflow: after a create, update, or delete operation on a policy or rule, the change must be explicitly realized on the transport nodes where the policy applies. Changes are not propagated to enforcement points without deliberate action, providing an additional checkpoint between policy definition and enforcement.

For IDS/IPS, signature bundle updates can be configured in either automatic or manual mode. Manual mode gives administrators explicit control over which signature bundle versions are deployed to each site, supporting change approval workflows where updates require review before deployment. The Global Signature Management interface records signatures changed globally by users, including excluded signatures, providing an audit trail of signature-level changes.

These capabilities operate within vDefend's network security policy domain. Broader organizational change management processes, approval workflows, and integration with IT Service Management platforms are provided by other components of the VCF stack, such as VCF Automation.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides role-based access controls, audit logging, and operational safeguards that contribute to change management programs for disaster recovery configurations.

PNR separates change authority through role-based access that restricts who can modify DR infrastructure. The Protection and Recovery Appliance Management Interface requires admin credentials to access reconfiguration and service management functions, controlling administrative-level changes to the appliance itself, including hostname changes, certificate changes, and patch application. In VCF Automation deployments, namespace network mappings can only be edited by an Organization Administrator in the VCF Automation Organization UI. Provider Administrators with the system administrator predefined role install PNR in regions, pair regions, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. These access controls restrict modification of DR infrastructure to authorized personnel.

PNR logs configuration change events to support traceability. Array Manager reconfiguration events are recorded when a user edits Array Manager properties, capturing changes to storage replication infrastructure. The Appliance Management Interface provides an authenticated path for appliance-level configuration changes, requiring admin credentials for all reconfiguration and service management operations.

Recovery plans in PNR support structured and auditable change to DR workflows. Plans can be edited to modify the recovery site, protection groups, and test network selection, and can be organized into folders and edited from either the protected site or the recovery site. Recovery plan steps run in a specific order that cannot be changed, but custom steps that display messages and run commands can be added to extend the workflow. Array managers can be edited to modify settings such as IP address, user name, and password without rebuilding dependent protection groups.

A configurable setting, `replication.updateVmProtectionOnPlacementChange`, controls whether VM protection is updated automatically when VM placement changes. Setting this to false prevents infrastructure placement operations from triggering protection reconfigurations outside of an intentional change workflow.

VMware Data Services Manager (Contributes)

CHG-02.1 requires mechanisms to prohibit unauthorized changes unless organization-approved change requests have been received. VMware Data Services Manager (DSM) contributes to this control through role-based access controls, policy enforcement, and system-level immutability protections that restrict who can make changes and what changes are permissible.

DSM's access control model scopes configuration authority to specific roles. For databases created in the default namespace, only the database owner can modify compute resource allocations. DSM's internal management login (`dsm_mgmt`) restricts users from accessing or modifying system-level objects in SQL Server, keeping administrative operations within an isolated context. DSM grants the SQL Server cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing rather than full administrative access. For MySQL, DSM revokes the create and update privileges on objects in the `mysql` system schema for database users.

Data service policies provide a framework for defining and enforcing approved configurations across tenants. DSM requires review of policy violations before applying policies to databases, allowing administrators to assess the impact before committing changes. Policy names and the applicable data service cannot be edited after creation for MySQL, PostgreSQL, or SQL Server policies, which limits the scope of post-deployment modifications. If an in-use policy is deleted, associated data services become non-compliant, making the effect of such actions visible.

Infrastructure policies actively used by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added. VM classes associated with an infrastructure policy and actively used by a database cannot be edited or deleted. Infrastructure policy names cannot be changed after creation. These immutability constraints collectively reduce the surface area for unauthorized or accidental configuration drift. MySQL on DSM automatically overwrites user changes to non-editable advanced database settings back to their configured defaults, enforcing DSM-managed baseline configurations.

What DSM does not provide is a formal change management workflow with approval gates, ticketing integration, or change advisory board controls. Fully prohibiting unauthorized changes requires organizational processes: a change management policy, defined approval authorities, and integration with change management tooling. DSM's controls support this objective by scoping who can make which changes, but the approval workflow itself must be maintained outside the platform.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer includes several mechanisms that support change management practices for application delivery configurations.

The Avi Controller generates configuration event codes for all changes: `CONFIG_CREATE`, `CONFIG_UPDATE`, and `CONFIG_DELETE`. `CONFIG_UPDATE` events capture the resource name, status, and prior resource data, giving administrators and auditors a traceable record of changes to virtual services, pools, WAF policies, Service Engine Groups, and other Avi-managed objects. These events are accessible via Operations > Events > Config Audit Trail. Administrators can also use the Config Events overlay in Service Engine analytics to correlate traffic behavior changes with specific configuration modifications, identifying whether a shift in traffic was caused by a change to virtual service security settings, pool membership, or other configuration parameters.

Configuration changes made through the web interface, CLI, or REST API are automatically propagated to all Controller cluster members, so all nodes maintain a consistent and current configuration state.

Avi supports infrastructure-as-code tooling for controlled deployment workflows. Terraform integration includes a plan phase that shows administrators what changes will be made to Avi Controller deployment before they are applied, allowing review and approval prior to execution. Ansible can be integrated with CI/CD pipelines to trigger automated, repeatable Avi Controller deployments, supporting consistent and auditable change procedures. In VCF environments, new Avi installations must be performed through VCF Lifecycle Management, adding a structured change governance layer to the deployment lifecycle itself.

The Avi CLI provides a `configure upgrade profile` command for setting parameters that govern Controller and Service Engine upgrade sequencing, and a rollback capability allows reverting to a prior state if a change introduces problems.

Avi Contributes rather than Meets because the control asks whether the organization facilitates a change management program. A program of this kind includes formal approval workflows, change advisory processes, scheduling policies, and governance documentation that Avi does not provide independently. The configuration audit trail and automation integrations support the technical aspects of change traceability, but the governance program itself must be established and operated by the organization.

Control ID.RA-08

Processes for receiving, analyzing, and responding to vulnerability disclosures are established

[Withdrawn: Moved to ID.RA-08]

SCF Controls: THR-01, THR-02, THR-03, VPM-01, VPM-02, VPM-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query

effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined

organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ID.RA-09

The authenticity and integrity of hardware and software are assessed prior to acquisition and use
[Withdrawn: Incorporated into ID.RA-09, DE.CM-09]

SCF Controls: AST-15, AST-18, TDA-01, TDA-01.2, TDA-14, TDA-14.1, TDA-14.2

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several layers of hardware integrity verification that contribute to satisfying this control, though the organizational requirement to mandate integrity verification from technology developers falls outside the platform itself.

VCF's primary hardware integrity verification mechanism is Secure Boot and Trusted Platform Module (TPM) support on ESX hosts. ESX host hardening includes enabling Secure Boot and TPM as part of the recommended security configuration in the vSphere Security Configuration Guide. Secure Boot verifies the integrity of the boot chain by validating cryptographic signatures on firmware and boot loaders before execution, helping to detect unauthorized modifications to host software. Each vSphere Installation Bundle (VIB) package carries an associated acceptance level that governs which packages may be installed on an ESX host, providing software integrity verification for all components added to the hypervisor. TPM provides a hardware root of trust that stores platform measurements and supports cryptographic attestation of the host's boot state. ESX hosts should run TPM 2.0 firmware when TPM modules are in use. vCenter provides API endpoints to retrieve and manage host TPM information, including configured endorsement keys, allowing administrators to programmatically verify the hardware trust state of hosts in the environment.

TPM key persistence allows ESX hosts to persist encryption keys in the TPM across reboots, maintaining encrypted storage operations even when the key server is temporarily unavailable.

vSphere extends hardware integrity attestation to individual virtual machines through Intel Trust Domain Extensions (TDX) and AMD Secure Encrypted Virtualization-Secure Nested Paging (SEV-SNP). Intel TDX enables the generation of signed attestation reports for virtual machines backed by Intel hardware. AMD SEV-SNP virtual machines can generate attestation reports signed by a key accessible only to AMD hardware; these reports include Trusted Computing Base (TCB) version information covering microcode, SNP firmware, TEE, and boot loader versions, and must be verified against certificates obtained from the AMD Key Distribution Service.

VCF enforces hardware compatibility verification through multiple mechanisms. Storage I/O controllers, drivers, and firmware versions must be certified and listed in the Broadcom Compatibility Guide before use. ESX driver and firmware versions should be verified for hardware compatibility, as mismatches can affect performance and stability. VCF Operations performs hardware compatibility checks during cluster remediation pre-checks and reports any incompatibilities found. The `enforce_hcl_validation` property in vSAN remediation policies controls whether detected hardware compatibility issues block cluster remediation or are reported as warnings. Hardware health status must be healthy and free of errors before a host can be commissioned into a VCF management domain, and VCF requires verification of the server fingerprint for each ESX host during commissioning before activation.

vSphere Lifecycle Manager supports desired-state management for host hardware, firmware, and driver components. Administrators can define a desired state that includes a specific ESX version along with compatible partner software and firmware components. vSphere Lifecycle Manager validates the actual host hardware against this desired state to detect discrepancies in firmware, drivers, and installed components, and can perform firmware updates when authorized. vSphere Lifecycle Manager also validates compliance of OEM add-ons and base images against expected configurations.

At the storage layer, vSAN requires certified hardware components, drivers, controllers, and firmware. vSAN uses end-to-end checksums to verify data integrity by confirming that each copy of a file matches the source. If a checksum mismatch is detected, vSAN automatically repairs the data by overwriting the incorrect copy with correct data. For vSAN ESA, object checksum is always enabled and cannot be deactivated. Proactive Hardware Management (PHM) monitors for hardware

failure events by collecting vendor hardware information from the Hardware Support Manager. PHM generates alarms that appear in vSAN Skyline Health when it detects events indicating a failing device.

VCF Operations diagnostics provides ongoing integrity monitoring through more than 600 property-based and log-based diagnostic rules. The Findings Catalog displays the complete list of signatures checked in the environment at any given time, covering vCenter, ESX, NSX, VCF Operations, vSAN, and VCF Automation components. These checks detect configuration drift from known-good baselines, providing a form of continuous integrity verification across the platform stack. vSphere Configuration Profiles enable desired-state configuration with drift detection at the cluster level, and VCF Operations monitors drift status through a collection cycle that runs every eight hours.

Auditors should verify that Secure Boot and TPM are enabled on all ESX hosts in the environment, that HCL validation is enforced rather than set to warning-only mode, and that the hardware commissioning process enforces health checks before hosts enter production. The VCF Operations Findings Catalog should be reviewed to confirm that diagnostic signatures are active and that findings are being addressed.

While VCF provides these technical verification mechanisms, requiring technology developers to enable integrity verification for their own products and services is an organizational policy outside VCF's scope.

VMware vDefend (Contributes)

VMware vDefend provides integrity controls for its own security component updates through IDS/IPS signature bundle management and Security Services Platform upgrade validation.

vDefend IDS/IPS includes configurable signature bundle update modes. In automatic mode, the system retrieves signature updates through the cloud-hosted vDefend Threat Intelligence Service (vTIS) portal, which notifies administrators when new bundle versions are detected. In manual mode, administrators disable the Auto Update toggle and select a specific signature bundle version for deployment. For air-gapped environments, vDefend IDS/IPS supports offline download and upload of signature bundle files. Signature Bundle Version Management allows administrators to view available versions and set the active signature set; by default, the latest version is selected for automatic updates. Signature Bundle Realization Status tracks whether updates were successfully applied across transport nodes and Edges, confirming that the selected version is in use. In federated deployments, Local Manager sites can independently select manual bundle versions when Auto Update is disabled. Administrators can also publish validated custom signatures directly to transport nodes and Edges. Both IDS/IPS and Malware Prevention share the Auto Update toggle, so the configured mode applies across both detection features.

Security Services Platform (SSP) performs prechecks of its components, including metrics components, during upgrade validation before proceeding. The SSP upgrade manager handles updates to Workload and Management clusters and the installer VM. The deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. SSP monitors deployment status and raises alarms for errors that require attention during upgrade operations.

These mechanisms operate alongside the broader VCF platform integrity controls, which include upgrade bundle checksum verification through VMware vCenter and cosign-based image signature verification via the VCF CLI.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports integrity mechanisms for software updates through certificate-based trust validation for update sources, a controlled staging workflow for applying updates, and signature verification for operator package deployments.

For the Consumption Operator, DSM includes Signature Verification validation as part of the deployment process to confirm package integrity before components are installed. This capability applies when deploying or uninstalling the Data Services Manager Supervisor Service in VCF Automation environments.

DSM supports configuration of private container registries with CA certificate validation for untrusted registries, restricting update package sources to those that can be authenticated against a trusted certificate authority. Administrators manage the trusted root certificates used for these validations through the DSM certificate store, where certificates can be added,

updated, or removed. In version 9.1, DSM introduces a "latest" certificate validation mode as the default, which enforces strict cryptographic and KeyUsage validations for all endpoints including the Provider VM and data service clusters. DSM also supports validation of trust bundles for self-signed certificates in image registry connectivity. As part of upgrading to version 9.1, DSM requires that all existing certificates be reviewed and replaced to confirm compliance with updated cryptographic algorithm requirements before the upgrade proceeds.

For platform-level software updates, DSM implements a staged upgrade workflow. Update bundles uploaded to the system progress through a defined status sequence from "available" to "Ready to Install" before installation proceeds. This staged approach provides an explicit review point between update availability and installation. Administrators can check for available upgrades and review upgrade history through the Version and Upgrade interface in the vSphere Client, accessible under the VMware vCenter Configure tab. The DSM plug-in supports a configurable Maintenance Policy that controls when automatic updates are applied, with settings for start date, start time, and duration.

Satisfying this control fully requires organizational processes beyond what DSM provides directly. DSM supports signature verification for operator packages, certificate-based validation of update sources, and controlled staging for applying updates, but the control's Process categorization requires organizations to establish procedures for verifying that update bundles are obtained from authorized VMware sources, maintaining a managed set of trusted CA certificates, and documenting the integrity validation steps applied before updates are approved for installation.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer contributes to integrity validation for software and firmware updates through mechanisms built into its Controller upgrade pipeline, its application-security rule management, and FIPS 140-3 module integrity controls.

Before any upgrade or patch is applied, the Avi Controller runs mandatory pre-upgrade checks that cannot be bypassed when errors are present. In 9.1 VCF-integrated deployments, these checks include verification of image checksums or digital signatures to confirm file integrity before the upgrade proceeds. The checks also verify that required patch packages and system packages are present on disk, that Service Engines are reachable, and that system resource requirements meet minimum thresholds. A dry-run mode is available via the UI (Administration > Update > System) or through the /api/upgrade API endpoint using the `prechecks_only` flag; this runs the full pre-check suite before committing to a maintenance window. Dry-run operations generate transcript logs capturing all pre-check operations and their outcomes, providing a reviewable record before the upgrade is approved.

After an upgrade completes, Avi supports post-upgrade validation. For VCF-integrated deployments, the post-upgrade checklist specifies that Management Plane alarms, alerts, and dashboards must be confirmed operational. Pre- and post-upgrade object operational state verification should be performed on virtual services and pools to detect any unintended state changes during the upgrade process. Avi GSLB Services generates operational snapshots during upgrade and rollback operations to support state comparison.

For application-layer security content, the Avi Cloud Console provides an Application Rules service that automatically distributes rules targeting known application vulnerabilities, including CVE-tracked threats, without requiring a Controller upgrade. A Live Security Threat Intelligence feed keeps WAF Core Rule Set content current on the same continuous basis. Both channels allow security-relevant updates to the Avi data plane to be applied independently of the main software upgrade cycle.

Avi supports rollback of both full upgrades and patch upgrades. The `enable_patch_rollback` setting on Service Engine groups controls whether patch rollback is permitted during an operation. Patch rollback transitions the system to the version without the specific patch; it does not revert to a prior major version. The Controller blocks upgrade operations when the license has expired, preventing upgrades in an unlicensed state.

Deployments operating in FIPS 140-3 mode gain enhanced controls over software and firmware module integrity and module updates, providing a higher-assurance path for environments that require validated cryptographic module integrity.

Tracking applicable security advisories, scheduling updates within organizational patch windows, and establishing remediation procedures before re-attempting upgrades after rollback are organizational responsibilities that extend beyond Avi's automated pipeline.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control ID.RA-10

Critical suppliers are assessed prior to acquisition [Withdrawn: Incorporated into GV.OC-02, GV.SC-03, GV.SC-04, GV.SC-07, ID.RA-10] [Withdrawn: Incorporated into GV.SC-07, ID.RA-10]

SCF Controls: TPM-01.1, TPM-02, TPM-04.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PR

Identities and credentials for authorized users, services, and hardware are managed by the organization. Identities are proofed and bound to credentials based on the context of interactions. Users, services, and hardware are authenticated. Identity assertions are protected, conveyed, and verified. Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties. Physical access to assets is managed, monitored, and enforced commensurate with risk. Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind. Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind. [Withdrawn: Incorporated into PR.AT-01, PR.AT-02] [Withdrawn: Incorporated into PR.AT-02] The confidentiality, integrity, and availability of data-at-rest are protected. The confidentiality, integrity, and availability of data-in-transit are protected. [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Moved to PR.IR-04] [Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10] [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into PR.IR-01] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] The confidentiality, integrity, and availability of data-in-use are protected. Backups of data are created, protected, maintained, and tested. Configuration management practices are established and applied. Software is maintained, replaced, and removed commensurate with risk. Hardware is maintained, replaced, and removed commensurate with risk. Log records are generated and made available for continuous monitoring. Installation and execution of unauthorized software are prevented. Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle. Networks and environments are protected from unauthorized logical access and usage. The organization's technology assets are protected from environmental threats. Mechanisms are implemented to achieve resilience requirements in normal and adverse situations. Adequate resource capacity to ensure availability is maintained. [Withdrawn: Incorporated into PR.AA-01, PR.AA-05] [Withdrawn: Moved to PR.AA-06] [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.AA-05] [Withdrawn: Moved to PR.AA-02] [Withdrawn: Moved to PR.AA-03] [Withdrawn: Incorporated into PR.PS-01] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Moved to PR.DS-11] [Withdrawn: Moved to PR.IR-02] [Withdrawn: Incorporated into ID.AM-08] [Withdrawn: Incorporated into ID.IM, ID.IM-03] [Withdrawn: Moved to ID.IM-03] [Withdrawn: Moved to ID.IM-04] [Withdrawn: Incorporated into ID.IM-02, ID.IM-04] [Withdrawn: Moved to GV.RR-04] [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02] [Withdrawn: Incorporated into PR.PS-04] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01] [Withdrawn: Moved to PR.IR-03] [Withdrawn: Incorporated into PR.AT-01]

SCF Controls: CPL-01, GOV-01, GOV-01.1, RSK-01, RSK-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PR.AA

Identities and credentials for authorized users, services, and hardware are managed by the organization. Identities are proofed and bound to credentials based on the context of interactions. Users, services, and hardware are authenticated. Identity assertions are protected, conveyed, and verified. Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties. Physical access to assets is managed, monitored, and enforced commensurate with risk. [Withdrawn: Incorporated into PR.AA-01, PR.AA-05] [Withdrawn: Moved to PR.AA-06] [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.AA-05] [Withdrawn: Moved to PR.AA-02] [Withdrawn: Moved to PR.AA-03] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01]

SCF Controls: IAC-01, IAC-01.2, PES-01, PES-02, PES-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered identity and access management architecture spanning centralized identity services, role-based access control, group-based access policies, identity provider federation, and programmatic access management through APIs.

VCF SSO is the centralized authentication service. VCF SSO issues security tokens that grant authenticated users access to VMware vCenter, NSX Manager, VCF Operations, and other platform components without requiring separate credentials for each service. VCF Operations supports importing users and groups from VCF SSO for consistent identity management across the stack. VMware Identity Manager provides a platform for managing users and groups, managing resources and user authentication, and configuring access policies and resource entitlements. vCenter also supports built-in identity source authentication using local domain credentials. The built-in identity provider can also be configured to use Active Directory as an identity source through LDAP/S, OpenLDAP/S, or Integrated Windows Authentication (IWA), depending on the directory environment.

VCF supports federation with enterprise identity providers. vCenter can be federated to providers such as Microsoft Entra ID, ADFS, and Okta, which enables multifactor authentication and automatic user synchronization with the organization's directory. PingFederate is also supported as a federated identity provider; for these integrations, vCenter uses System for Cross-domain Identity Management (SCIM) to automate the exchange of user and group identity information between the external identity domain and vCenter. VMware Identity Broker allows principals to authenticate to vCenter through an external identity provider. NSX Manager can be configured to authenticate users from identity management providers and can be integrated with Workspace ONE Access for identity management services. The Supervisor component supports registration of OIDC-compliant external identity providers for authentication to VMware Kubernetes Service (VKS) clusters; supported providers include Okta, Workspace ONE Access, and Dex, configured by supplying the Supervisor callback URL to the identity provider.

Role-based access control is enforced across all VCF components. In vCenter, permissions associate a user or group with a role on a specific inventory object, and predefined roles cover common administrative functions. Custom roles can be created with only the minimum required privileges for a given workflow. Managing identity provider configuration in vCenter requires the VcIdentityProviders Manage privilege. VCF Operations supports group-based access control, allowing administrators to configure groups and assign roles that control access to dashboards, reports, policies, alerts, and administration functions, as well as granular role-based controls for platform operations including approvals, audits, certificates, and content libraries.

VCF Automation extends access management through organization-level and project-level controls. The VCF Automation Access Control service supports identity operations for managing groups and users, including editing user names, passwords, and role assignments. The organization portal enforces role-based access control, requiring either Organization Administrator or Organization Auditor roles to manage policy templates. Organization administrators can distribute infrastructure and

configure group-level access through the organization management functionality. Project access is governed by predefined roles. Users and groups can be disabled at the organization level to revoke access without deleting accounts. The System Administrator role has the right to manage and view Access Control Lists, and the accessControls API allows administrators to view and manage ACL entries for defined entities.

For Kubernetes workloads within the VCF consumption layer, VKS supports two authentication methods: VCF SSO and OIDC-compliant external identity providers. The OIDC path is implemented through Pinniped and supports providers including Okta, Workspace ONE Access, Dex, GitLab, and Google OAuth. Configuring an external provider requires setting up an OpenID Connect ID Token with a Groups claim type filter to enable group-based access control tied to the organization's directory. Custom ClusterClass configurations allow clusters to authenticate developers using existing corporate identity systems. VKS supports namespace permission roles: Owner (full control including deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). These roles map to Kubernetes ClusterRoles through RoleBindings, and RoleBinding objects can reference VCF SSO users and groups directly to integrate SSO identities with Kubernetes role-based access control. A user with the Namespaces.Edit privilege on a user-created Namespace folder can perform CRUD operations on Kubernetes API resources in the Supervisor. Namespace Self-Service permissions control which users can self-provision namespaces through kubectl.

Kubernetes RBAC is the primary authorization mechanism within VKS, using Roles, ClusterRoles, RoleBindings, and ClusterRoleBindings to bind permissions to users, groups, or service accounts. Kubernetes Attribute-Based Access Control (ABAC) is also available, defining access rights through policies that combine user, namespace, resource, and access mode attributes. Authorization webhooks can interpret field and label selectors to enforce fine-grained access control based on resource attributes such as node names and labels.

Service accounts provide namespaced workload identity within VKS clusters. For Windows containers, the Group Managed Service Account (gMSA) Webhook allows containers to run as Active Directory identities. VKS service accounts can be annotated with IAM role ARNs to enable pod identity and role assumption for cloud resource access through OIDC federation, replacing long-lived static credentials with short-lived, least-privileged credentials on demand. IAM role trust policies can be scoped to specific service accounts and namespaces to enforce least privilege.

Several supplementary services within the VKS layer extend the IAM surface. Harbor Registry, available as a standard package on VKS clusters, enforces role-based access control to manage access to container image artifacts. The Secret Store Supervisor Service enforces RBAC for administrators, DevOps engineers, and application tenants managing sensitive data. Argo CD supports both OIDC configuration for external identity providers and local account configuration with global RBAC policies that define role-based access through policy rules and group mappings. The Istio service mesh package includes a pluggable policy layer supporting access controls, rate limits, and quotas at the service-to-service level.

Programmatic access management is available through several APIs. The Identity API authenticates and manages the authorization provider. The Identity Service and Infrastructure as a Service APIs are used to acquire access tokens for REST API authentication. Principal Identity users authenticate using client certificates for service-to-service communications between VCF components.

NSX integrates with LDAP and external identity management services for administrative access to networking configuration. NSX Manager enforces role-based access control with roles such as auditor and network administrator assignable to LDAP users. vDefend, a separate product that extends NSX with security capabilities, offers an Identity Firewall that integrates with Active Directory for identity-based firewall rules.

VMware Private AI Services (PAIS) provides OIDC-based authentication and group-based authorization for AI workloads, the primary IAM mechanisms controlling access to model endpoints, the model runtime, Agent Builder, and Data Indexing and Retrieval capabilities. PAIS authentication is configured with an issuer URL, a client ID (pais-authentication-id), and the openid, groups, and offline_access scopes. The OIDC provider must support the .well-known/openid-configuration discovery endpoint. Authorization restricts access to user accounts that are members of named groups listed in the authorizedGroups setting (such as group-for-pais-access-01 or group-for-pais-access-02). A groups claim is included in the Access Token and a corresponding groups scope is created in the OIDC configuration, while the oidc-groups-claim setting selects which claim

name carries group membership when the OIDC provider uses a non-default name. The `oidc-extra-audiences` setting accepts additional OAuth 2.0 client identifiers that PAIS will accept when validating Access Tokens, supporting integration with downstream clients that present their own audience. Activating PAIS in an organization namespace requires coordination with the OIDC provider administrator and an organization administrator account in VCF Automation.

Identity provider integration for PAIS deployments is configured at the Supervisor level under Workload Management > Supervisors > Configure > Identity Providers. When a PAIS region is created for a Supervisor, an identity provider entry is automatically created in VMware vCenter for that Supervisor, linking the Supervisor namespace to the configured OIDC source.

The Model Gallery, the curated repository for ML models in PAIS, restricts access to model artifacts and the training data used to tune them through Harbor project access controls. These controls scope which users and service accounts can read, push, or manage sensitive model data, adding an IAM enforcement layer to the model supply chain. A Harbor registry is recommended for PAIS deployments, and OCI-compliant registries from other vendors are also supported.

PAIS Knowledge Bases extend IAM to ingested data sources. Confluence data sources authenticate with a user name and password or a personal access token, while Microsoft SharePoint On-Premises data sources authenticate with a user name and password. Personal access tokens for Knowledge Bases are generated from user account settings and used for programmatic access to linked data sources.

PAIS integrates with Grafana for metrics visualization using the same OIDC provider, extending the IAM model to the observability layer so that operators authenticate through the configured identity provider before accessing PAIS dashboards.

VMware vDefend (Contributes)

VMware vDefend contributes to identity and access management by providing identity-aware network enforcement through Identity Firewall, which integrates with Active Directory to apply firewall policy based on authenticated user identity rather than IP address alone. Identity Firewall supports assigning Active Directory users and groups as source criteria in both distributed firewall rules and gateway firewall rules, applying to tier-0 and tier-1 gateways. This allows organizations to enforce network access policy by user or group membership rather than relying solely on IP-based controls.

Within its management plane, the Security Services Platform implements role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. These roles govern access to security policy management, analytics, incident response, and diagnostic functions across the platform. Network Detection and Response enforces the same five-role RBAC model for triage operations such as viewing detections and campaigns, and for configuration operations including SIEM integration management. For authentication, the Security Services Platform supports Active Directory and OpenLDAP as external identity sources, with one identity source configurable at a time. The License Hub integrates with external identity providers to store and manage user and group information for access delegation.

Centralized IAM for organizational users, including VCF SSO, MFA, and directory lifecycle management, is handled by VCF and falls outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the `AutoprotectEnabledRpEvent` entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) incorporates multiple identification and access management mechanisms that support organization-wide IAM controls within the data services layer.

DSM implements role-based access control with two defined roles: the DSM Admin role, which can create, monitor, and manage all data services in the environment, and the DSM User role, which is restricted to managing and monitoring data services within the namespaces to which the user has been granted access. These roles are assigned at user creation time and govern what each user can see and do within the DSM interface. The Permissions view in the DSM dashboard provides administrators with a centralized location for creating, monitoring, and managing all configured users.

DSM supports two identity sources, which can be used independently or together. Local users are created directly within DSM, with credentials validated by matching email address and password. LDAPS users are sourced from a configured LDAP identity provider, allowing organizations to extend their existing directory service into DSM. When LDAPS is configured, administrators can import users from the directory provider and assign them DSM Admin or DSM User roles. DSM also supports group-based access control: Directory Service Groups from the LDAP provider can be assigned roles directly, so group membership in the external directory determines access level in DSM without requiring per-user assignments.

At the database level, DSM extends authentication controls beyond the platform management layer. MySQL database instances support LDAPS authentication using Active Directory. PostgreSQL and other database instances support host-based authentication (HBA) rule configuration, which determines which clients are permitted to authenticate to a given database instance. SQL Server instances support Windows Authentication through Active Directory integration, enabling Kerberos-based authentication so that clients such as SQL Server Management Studio running on domain-joined machines can authenticate via single sign-on. SQL Server also uses contained database users, where identity information resides within the database itself rather than at the server level. Administrators can configure SQL Server instances with either a SQL User or Windows Principal as the primary administrator identity, with Windows Principal available for Active Directory-integrated clusters. An internal `dsm_mgmt` management login restricts users from accessing or modifying system-level objects, keeping administrative operations within an isolated context.

Namespace isolation adds a further access boundary. DSM namespaces enforce role-based access control that allows multiple users to work jointly on data services within a namespace while remaining isolated from data services in other namespaces. This supports least-privilege access within multi-tenant deployments.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides a dedicated administrative identity and access management plane through the Avi Controller, supporting multiple authentication methods and fine-grained authorization controls that allow organizations to implement IAM policies across both the management plane and the application delivery layer.

For administrative access, the Avi Controller supports local user accounts, LDAP and LDAPS directory integration, SAML-based federated authentication (including integration with Workspace ONE Access for catalog-based application access), basic authentication, and OAuth/OIDC for API access. Auth Mapping Profiles allow organizations to map external directory

groups to specific roles and tenants, so that group membership in an external identity provider directly controls what a user can access within Avi.

Authorization is handled through role-based access control (RBAC) with object-level granularity. Avi's extended granular RBAC uses markers, which are labels assigned to objects, to enable fine-grained authorization based on object ownership and classification. Permission categories cover Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management). This allows restrictions so that a user's permissions apply only to the specific resources matching the markers assigned to their role. RBAC covers object categories including Virtual Services, Application Profiles, SSL/TLS Certificates, Certificate Management Profiles, Cloud definitions, TCP/UDP Profiles, Persistence Profiles, Health Monitors, Analytics Profiles, IP Address Groups, String Groups, SSL/TLS Profiles, PKI Profiles, and Authentication Profiles, with distinct read and write access levels configured per object type.

For multi-tenant deployments, Auth Mapping Profiles support tenant isolation with configurable user group to role mappings, allowing organizations to enforce separation between teams or business units operating within the same Avi Controller.

The Avi License Hub supports role-based access control through an external identity provider, with three predefined roles: Enterprise Admin (full access for all operations, including upgrades and authentication configuration), Auditor (view-only access for tracking activity without making changes), and Support Bundle Collector (restricted to collecting system logs and diagnostics). Management interface access is further controlled through restrictions on allowed ciphers and HMACs for management sessions.

For deployments involving the Avi Kubernetes Operator (AKO), Kubernetes RBAC policies can be applied to AKO Custom Resource Definitions (CRDs) to enforce stricter access control over routing configuration for specific user groups. The Avi Controller also implements RBAC at the Kubernetes and OpenShift cluster level by assigning tenants and roles to user accounts.

At the application layer, Avi can enforce client authentication using OAuth, SAML, JWT token validation, and mutual TLS with client certificates, extending access control to the traffic flowing through virtual services rather than only to the management interface.

Organizations are responsible for defining roles, mapping directory groups to permissions, establishing naming conventions for markers, and maintaining user lifecycle processes. Avi provides the technical mechanisms; the governance and operational processes for identity management must be organized by the teams managing the deployment.

Control PR.AA-01

Identities and credentials for authorized users, services, and hardware are managed by the organization
[Withdrawn: Incorporated into PR.AA-01, PR.AA-05]

SCF Controls: IAC-02, IAC-03, IAC-04, IAC-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a centralized identity federation architecture that supports authentication, authorization, and auditing of both organizational and non-organizational users. Third-party users and service accounts can be uniquely identified and managed through integration with external identity providers, giving administrators a single point of control over who accesses the platform and what they can do.

VCF SSO is the central authentication service for the platform. All user authentication flows through VCF SSO, which issues tokens that establish identity and trust with API endpoints. VCF SSO supports federation with enterprise identity providers through OIDC, OAuth 2.0, and Generic SAML 2.0, so organizations can connect their existing directory services and enforce their own authentication policies, including multifactor authentication. Federating VMware vCenter to an enterprise identity provider alleviates the burden of identity management and provides flexible options such as multifactor authentication and automatic registration and termination of users across services. This federation model allows organizations to manage third-party user identities in their existing identity provider and have those identities flow through to VCF without creating local accounts. The VCF Identity Broker provisions users and groups from the configured identity provider, enabling centralized access control across the platform. vCenter also supports the System for Cross-domain Identity Management (SCIM) protocol for automating user and group synchronization from external identity providers, with explicitly documented federation configurations for Okta and PingFederate as named OIDC partners.

Multiple VCF components support external identity provider integration. NSX Manager can be configured to authenticate users from identity management providers and integrates with LDAP, vIDM, and OIDC to verify user identities and determine access to services based on user group membership. NSX Manager also exposes API endpoints for authentication policy settings, allowing administrators to validate authentication configuration across nodes programmatically. The Supervisor component supports registration of external identity providers using OAuth 2.0 and OIDC protocols, and uses the Pinniped Supervisor and Concierge components to facilitate federated authentication for users and groups when an external identity provider is configured. Supervisor can be configured with any OIDC-compliant identity provider such as Okta, Workspace ONE Access, or Dex to authenticate users connecting to VMware Kubernetes Service (VKS) clusters, and custom ClusterClass configurations can authenticate developers using their existing corporate identity systems. Once authenticated via OIDC, third-party users are subject to Kubernetes RBAC; ClusterRoleBindings grant roles to OIDC-authenticated users via identifiers in the format `oidc:user@example.com`, giving administrators precisely scoped access to specific namespaces or resources without extending broader platform privileges. Kubernetes OIDC authentication produces a `UserInfo` object derived from the token subject and roles claims, and `userValidationRules` can enforce constraints on mapped identities, such as preventing the reserved `system:` prefix in usernames. For production clusters with multiple users accessing the Kubernetes API directly, OIDC is the recommended authentication mechanism; OIDC tokens are short-lived and subject to the identity provider's revocation mechanisms, so deprovisioning a user in the upstream identity provider removes their ability to authenticate to the cluster. VCF Automation allows each organization to define an identity provider that it shares with other applications, so that users authenticate to the identity provider to obtain a token they can use to access the organization. VCF Automation also supports importing provider users from SAML, OIDC, or VCF SSO identity providers, with configurable authentication mechanisms including redirections to external identity providers. Imported users log in with the credentials established in their OIDC identity provider. The vCenter Client Credentials grant type allows application-to-identity-provider authentication without a human user present, supporting machine-to-machine authentication scenarios.

For environments using Microsoft Active Directory, organizations can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure, providing another path for centrally managing third-party user identities through an established directory service. VCF SSO also supports user and group import for access

control from configured identity sources. VMware ESX and vCenter validate user credentials against configured identity stores.

For programmatic and service-to-service access, Principal Identity users authenticate using certificates, providing unique identification and auditability for automated processes. A Principal Identity user's certificate must be SHA256 based. NSX Federation creates dedicated Principal Identity users with specific roles (such as Auditor) on each Global Manager when a Local Manager is registered, demonstrating how even automated inter-component communication uses uniquely identifiable accounts. The VCF Automation API supports endpoints for retrieving organizational context for authenticated users, and the Identity API authenticates and manages the authorization provider, giving programmatic control over identity and access management. Valid session identifiers establish trust with API endpoints, providing traceability for each authenticated session.

For non-human processes running inside VKS clusters, Kubernetes ServiceAccounts provide a distinct, namespaced identity separate from human user accounts. Each ServiceAccount authenticates with the username `system:serviceaccount:(NAMESPACE):(SERVICEACCOUNT)` and is assigned to namespace-scoped groups, enabling RBAC policies to authorize specific API operations without sharing human user credentials. Scoping IAM role trust policies to specific ServiceAccounts and namespaces enforces least privilege for workloads that access external services. Where VKS clusters integrate with AWS cloud services, IAM Roles for Service Accounts (IRSA) replaces long-lived static access keys with an OIDC-based identity federation model that provides workloads with short-lived, least-privileged credentials on demand. Separating ServiceAccount creation from human user onboarding supports differentiated audit strategies, since audit events carry the ServiceAccount identity rather than a generic shared credential. Third-party security software running in the cluster can use ServiceAccount identities to group pods into distinct security contexts for access control purposes. ArgoCD, deployable as a VCF Service on VKS clusters, supports OIDC authentication with global RBAC policies for federated identity and role-based access control, with both OIDC and local account authentication available depending on deployment requirements.

On the authorization side, VCF enforces role-based access control where authenticated users can view objects or invoke operations on the server depending on the permissions associated with their account. The vCenter authorization model provides consistent security control regardless of how users connect to the environment. Organization owners and Enterprise Admins can add, manage, and remove users, controlling what level of access each user receives. NSX Manager local user accounts are created with a default Auditor role, and role assignments can be changed as needed. NSX authentication best practices include defining access controls based on user roles and permissions and integrating with identity providers.

Each organization within VCF Automation has its own identity source and organization portal where users log in to consume resources and services. This multi-tenant isolation helps organizations maintain separation between internal and third-party user populations while still leveraging centralized identity infrastructure.

Audit logging captures authentication and authorization events across VCF components, providing a record of third-party user activity for review and compliance purposes. All API calls to NSX Manager are subject to authentication and authorization and generate audit logs. NSX generates audit logs for events such as logon, logoff, and access to resources, with each audit log containing the timestamp, source, result, and a description of the event. NSX Manager and NSX Edge both include a dedicated audit role with separate credentials; the NSX Manager audit user has read-only privileges to the NSX environment and is not active by default, requiring explicit activation after installation by an admin through the CLI. This separation of the audit role from administrative roles supports segregation of duties for audit functions. VCF Operations generates audit events across categories including access, access control, account management, configuration, data access, network, notification, permissions, session, system, policy, and firewall actions, which can be filtered, searched, and reviewed in detail. VCF Operations Orchestrator tracks the user who initiated each workflow run, providing audit accountability for automated management tasks executed against the platform. At the Kubernetes layer, the cluster API server records authentication events, API requests, and authorization decisions for all users and ServiceAccounts. Kubernetes audit annotations include `authorization.k8s.io/decision` to record each authorization decision; for OIDC-authenticated third-party users, audit entries capture the username and groups asserted by the identity provider, enabling traceability back to the individual; for ServiceAccounts, entries capture the service account name and namespace. Organizations can configure the Kubernetes audit policy to define which request types and API verbs are logged and at what verbosity, and route those events to a centralized log collector.

While VCF provides the technical infrastructure for centralized AAA of third-party users, the organization is responsible for defining policies that govern which third-party users receive access, establishing onboarding and offboarding procedures, conducting periodic access reviews, configuring the external identity provider with appropriate authentication strength requirements, and determining which AAA solutions to approve and how to handle AAA for external service providers.

VMware Private AI Services (PAIS) supports identification and access management for third-party and non-organizational users of AI services through OpenID Connect (OIDC) integration. PAIS activation requires coordination with the OIDC provider administrator, and the PAISConfiguration resource specifies an issuer URL, an OIDC client ID (the pais-authentication-id value provided by the OIDC administrator), and the scopes openid, groups, and offline_access. The OIDC client ID, the groups claim name, and additional accepted OAuth 2.0 audiences are individually configurable so that PAIS can interoperate with an external provider's existing tenant model rather than requiring a PAIS-specific identity store.

Authorization for PAIS is enforced through OIDC group membership. The authorizedGroups setting in the PAISConfiguration restricts access to user accounts whose OIDC Access Token includes membership in one or more designated groups, with example group names such as group-for-pais-access-01. The groups claim is included in the Access Token, and a corresponding groups scope is created in the OIDC configuration. This is the primary PAIS-native mechanism for uniquely identifying non-organizational users by OIDC identity claims and authorizing their access based on group membership in the external provider.

The Grafana observability interface for PAIS authenticates through the same OIDC provider, so visualization of PAIS metrics for monitoring and audit purposes is gated by the same identity and group controls. PAIS metrics can be exported to observability platforms to support monitoring and audit review of third-party user activity. Audit recording of authentication and authorization events at the platform layer is provided by the underlying VCF infrastructure rather than by PAIS-native audit trails dedicated to non-organizational user activity.

For third-party data sources and registries, PAIS Knowledge Bases authenticate to Confluence using either a user name and password or a personal access token, and to Microsoft SharePoint On-Premises using a user name and password. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval, and the oras login command authenticates to a private Harbor registry using user name and password credentials for catalog and image operations. These mechanisms address the identification and access control dimensions of the control for the third-party services that PAIS itself reaches out to.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic, replay-resistant authentication for its own inter-site components. When two sites are paired for recovery operations, PNR validates the identity of each peer through certificate-based authentication and supports importing certificate-authority-signed server certificates through the PNR Appliance Management Interface. Site pairing, site reconnection, and site pair break operations all require credential authentication, and the PNR Appliance Management Interface itself requires authentication as the admin user for service configuration, network configuration, hostname changes, and disconnection from the PNR Global Console.

For inter-site service authentication, PNR servers acquire a holder-of-key SAML token from VCF SSO using token-based authentication, then send cryptographically signed requests carrying that token to remote services. The remote service validates the token to establish the identity of the calling service before the connection proceeds, supplying bidirectional, replay-resistant authentication between PNR components without transmitting passwords across site boundaries. The VMware vCenter appliance handles authentication between the PNR server and vCenter at the VCF SSO level, and in an Enhanced Linked Mode environment the remote site reuses the same service account to authenticate to local services.

PNR also implements an OAuth 2.0 flow for remote site authentication, with a configurable authorization request lifetime through the `oauth2.authRequestLifetime` setting (default 60 seconds). The Cyber Recovery Connector authenticates with an OAuth app secret that Broadcom rotates every three months. Management communications are carried over TLS, with the minimum protocol version configurable through the `envoy-proxy-config.json` file. The PNR user interface maintains logs that record certificate validation errors and connection failures during authentication attempts, supporting the audit dimension of AAA for PNR's own management traffic.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports authentication and authorization of users who access database services, including third-party users and service accounts that connect to managed databases. DSM's identity mechanisms apply to all user types, and authentication controls can be configured to restrict access based on identity, source address, and authentication method.

For administrative access to the DSM management plane, DSM supports both local user accounts and LDAPS integration with an enterprise directory service (LDAP or Active Directory). An installation can choose to use one or both identity sources, and DSM manages them independently. DSM can be configured to use an LDAP server for both authentication and authorization. When Directory Service credentials are unavailable, DSM falls back to local user authentication.

For PostgreSQL database instances, DSM provides host-based authentication (HBA) configuration. The `pg_hba.conf` file controls which clients may connect to a database by specifying connection type, client address, requested database, and user name. Each connection attempt is matched against an ordered list of rules, and the first matching record determines the authentication method applied. Default entries use SCRAM-SHA-256 for local accounts including the `pgadmin` and `postgres_exporter` service accounts, and administrators can add LDAP entries to authenticate database users through Active Directory. Database instances can also be configured to use directory service authentication after initial creation using the `directory-service-authentication` setting. MySQL instances similarly support Active Directory authentication via LDAPS.

DSM adds SQL Server as a managed database type with its own authentication model. SQL Server clusters use contained database users, where users authenticate directly against the database and identity information resides within the database rather than at a server level. SQL Server clusters can be integrated with Active Directory, enabling Kerberos-based authentication and Windows Authentication for server-level logins. Windows Principals can be authorized as cluster administrators through T-SQL or the DSM API. Active Directory integration also supports single sign-on for clients that use Kerberos authentication, such as SQL Server Management Studio running on a Windows machine joined to the same domain. SQL Server Authentication logins can be created for clusters that do not require Windows Authentication. DSM supports two primary administrator user identities for SQL Server: SQL User or Windows Principal, with Windows Principal available for clusters integrated with Active Directory.

Third-party processes and service integrations that receive DSM event notifications through webhooks are authenticated using credentials. DSM webhooks support basic authentication with an Authorization User and Authorization Password, restricting webhook delivery to authorized endpoints.

Metrics forwarding to Prometheus-compatible endpoints supports configurable authentication, including certificate-only, basic authentication, or a combination, allowing organizations to control which external monitoring systems can pull DSM metrics.

The DSM Consumption Operator, which enables self-service database provisioning through Kubernetes-native interfaces, authenticates with DSM infrastructure using an authentication secret named `dsm-auth-creds`.

DSM audit logs track user actions performed through the UI and API, recording the source of each operation as either a user identifier (Email ID) for user-initiated events or System for events initiated by DSM without user intervention. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention, and can create a simple login event audit based on the Login Auditing option selection.

DSM does not itself categorize users as organizational versus non-organizational. Meeting this control fully requires organizational processes beyond what DSM provides: identifying which users or processes are third-party, ensuring they receive appropriately scoped accounts or directory entries, and reviewing audit logs to confirm that third-party access remains within authorized boundaries. DSM provides the authentication and access control mechanisms that support those organizational processes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) maintains its own administrative identity plane with mechanisms covering all three AAA elements: authentication, authorization, and audit. User accounts fall into two categories: local users and remote users. Remote users are authenticated through external AAA servers, with support for LDAP, TACACS+, and SAML-based authentication profiles. The product documentation recommends federated authentication as the preferred approach, delegating the authentication process to an organization's central identity provider rather than managing credentials locally within Avi.

For authorization, the Avi Controller evaluates authorization mapping rules on every user login, updating the user record with tenant and role pairs. Auth Mapping Profiles can map multiple user groups to different roles with tenant isolation, supporting both simple single-role assignments and multi-tenant configurations where a single user requires access across multiple administrative boundaries. The admin user is authorized and responsible for the highest-level configuration operations, including user creation and authorization and tenant management. The admin account is maintained as a locally authenticated account even in a system configured for remote authentication, providing a break-glass path for Controller access.

The Avi Controller License Hub provides dedicated role-based accounts for administration and auditing. The Admin account holds the `enterprise_admin` role with full access to deploy and manage security services, perform upgrades, and configure authentication and authorization. The Audit account holds the `auditor` role with full access to APIs and services for system auditing. LDAP can be configured as an identity provider for License Hub authentication, and the Admin user can reset the Audit user's password.

Avi also supports OAuth and OpenID Connect (OIDC) for client authentication at the application proxy layer. When configured, the Controller acts as a resource server and retrieves identity information from the OIDC UserInfo endpoint or from ID token claims, enabling per-user identity context to be associated with proxied application traffic. DataScript can check if a user ID is in an approved group list and redirect unauthenticated users to a login page, providing identity-based access control at the virtual service layer.

In the Avi for VCF Organization-Managed Mode, the organization administrator must be authenticated to edit Service Engine Groups and manage their own infrastructure configurations, reinforcing role-based access enforcement at the VCF integration layer.

The control asks whether the organization centrally manages AAA across its environment. Avi provides the mechanisms for its own administrative plane and supports integration with a central identity provider, but the organization must configure that integration, maintain the identity provider, and establish processes for reviewing audit log output.

Control PR.AA-02

Identities are proofed and bound to credentials based on the context of interactions [Withdrawn: Moved to PR.AA-02]

SCF Controls: IAC-28

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PR.AA-03

Users, services, and hardware are authenticated [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.AA-03]

SCF Controls: IAC-01.2, IAC-02, IAC-03, IAC-04, IAC-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides a centralized identity federation architecture that supports authentication, authorization, and auditing of both organizational and non-organizational users. Third-party users and service accounts can be uniquely identified and managed through integration with external identity providers, giving administrators a single point of control over who accesses the platform and what they can do.

VCF SSO is the central authentication service for the platform. All user authentication flows through VCF SSO, which issues tokens that establish identity and trust with API endpoints. VCF SSO supports federation with enterprise identity providers through OIDC, OAuth 2.0, and Generic SAML 2.0, so organizations can connect their existing directory services and enforce their own authentication policies, including multifactor authentication. Federating VMware vCenter to an enterprise identity provider alleviates the burden of identity management and provides flexible options such as multifactor authentication and automatic registration and termination of users across services. This federation model allows organizations to manage third-party user identities in their existing identity provider and have those identities flow through to VCF without creating local accounts. The VCF Identity Broker provisions users and groups from the configured identity provider, enabling centralized access control across the platform. vCenter also supports the System for Cross-domain Identity Management (SCIM) protocol for automating user and group synchronization from external identity providers, with explicitly documented federation configurations for Okta and PingFederate as named OIDC partners.

Multiple VCF components support external identity provider integration. NSX Manager can be configured to authenticate users from identity management providers and integrates with LDAP, vIDM, and OIDC to verify user identities and determine access to services based on user group membership. NSX Manager also exposes API endpoints for authentication policy settings, allowing administrators to validate authentication configuration across nodes programmatically. The Supervisor component supports registration of external identity providers using OAuth 2.0 and OIDC protocols, and uses the Pinniped Supervisor and Concierge components to facilitate federated authentication for users and groups when an external identity provider is configured. Supervisor can be configured with any OIDC-compliant identity provider such as Okta, Workspace ONE Access, or Dex to authenticate users connecting to VMware Kubernetes Service (VKS) clusters, and custom ClusterClass configurations can authenticate developers using their existing corporate identity systems. Once authenticated via OIDC, third-party users are subject to Kubernetes RBAC; ClusterRoleBindings grant roles to OIDC-authenticated users via identifiers in the format `oidc:user@example.com`, giving administrators precisely scoped access to specific namespaces or resources without extending broader platform privileges. Kubernetes OIDC authentication produces a `UserInfo` object derived from the token subject and roles claims, and `userValidationRules` can enforce constraints on mapped identities, such as preventing the reserved `system:` prefix in usernames. For production clusters with multiple users accessing the Kubernetes API directly, OIDC is the recommended authentication mechanism; OIDC tokens are short-lived and subject to the identity provider's revocation mechanisms, so deprovisioning a user in the upstream identity provider removes their ability to authenticate to the cluster. VCF Automation allows each organization to define an identity provider that it shares with other applications, so that users authenticate to the identity provider to obtain a token they can use to access the organization. VCF Automation also supports importing provider users from SAML, OIDC, or VCF SSO identity providers, with configurable authentication mechanisms including redirections to external identity providers. Imported users log in with the credentials established in their OIDC identity provider. The vCenter Client Credentials grant type allows application-to-identity-provider authentication without a human user present, supporting machine-to-machine authentication scenarios.

For environments using Microsoft Active Directory, organizations can use user identities contained in a Windows Server domain controller or Active Directory service across their virtual infrastructure, providing another path for centrally managing third-party user identities through an established directory service. VCF SSO also supports user and group import for access

control from configured identity sources. VMware ESX and vCenter validate user credentials against configured identity stores.

For programmatic and service-to-service access, Principal Identity users authenticate using certificates, providing unique identification and auditability for automated processes. A Principal Identity user's certificate must be SHA256 based. NSX Federation creates dedicated Principal Identity users with specific roles (such as Auditor) on each Global Manager when a Local Manager is registered, demonstrating how even automated inter-component communication uses uniquely identifiable accounts. The VCF Automation API supports endpoints for retrieving organizational context for authenticated users, and the Identity API authenticates and manages the authorization provider, giving programmatic control over identity and access management. Valid session identifiers establish trust with API endpoints, providing traceability for each authenticated session.

For non-human processes running inside VKS clusters, Kubernetes ServiceAccounts provide a distinct, namespaced identity separate from human user accounts. Each ServiceAccount authenticates with the username `system:serviceaccount:(NAMESPACE):(SERVICEACCOUNT)` and is assigned to namespace-scoped groups, enabling RBAC policies to authorize specific API operations without sharing human user credentials. Scoping IAM role trust policies to specific ServiceAccounts and namespaces enforces least privilege for workloads that access external services. Where VKS clusters integrate with AWS cloud services, IAM Roles for Service Accounts (IRSA) replaces long-lived static access keys with an OIDC-based identity federation model that provides workloads with short-lived, least-privileged credentials on demand. Separating ServiceAccount creation from human user onboarding supports differentiated audit strategies, since audit events carry the ServiceAccount identity rather than a generic shared credential. Third-party security software running in the cluster can use ServiceAccount identities to group pods into distinct security contexts for access control purposes. ArgoCD, deployable as a VCF Service on VKS clusters, supports OIDC authentication with global RBAC policies for federated identity and role-based access control, with both OIDC and local account authentication available depending on deployment requirements.

On the authorization side, VCF enforces role-based access control where authenticated users can view objects or invoke operations on the server depending on the permissions associated with their account. The vCenter authorization model provides consistent security control regardless of how users connect to the environment. Organization owners and Enterprise Admins can add, manage, and remove users, controlling what level of access each user receives. NSX Manager local user accounts are created with a default Auditor role, and role assignments can be changed as needed. NSX authentication best practices include defining access controls based on user roles and permissions and integrating with identity providers.

Each organization within VCF Automation has its own identity source and organization portal where users log in to consume resources and services. This multi-tenant isolation helps organizations maintain separation between internal and third-party user populations while still leveraging centralized identity infrastructure.

Audit logging captures authentication and authorization events across VCF components, providing a record of third-party user activity for review and compliance purposes. All API calls to NSX Manager are subject to authentication and authorization and generate audit logs. NSX generates audit logs for events such as logon, logoff, and access to resources, with each audit log containing the timestamp, source, result, and a description of the event. NSX Manager and NSX Edge both include a dedicated audit role with separate credentials; the NSX Manager audit user has read-only privileges to the NSX environment and is not active by default, requiring explicit activation after installation by an admin through the CLI. This separation of the audit role from administrative roles supports segregation of duties for audit functions. VCF Operations generates audit events across categories including access, access control, account management, configuration, data access, network, notification, permissions, session, system, policy, and firewall actions, which can be filtered, searched, and reviewed in detail. VCF Operations Orchestrator tracks the user who initiated each workflow run, providing audit accountability for automated management tasks executed against the platform. At the Kubernetes layer, the cluster API server records authentication events, API requests, and authorization decisions for all users and ServiceAccounts. Kubernetes audit annotations include `authorization.k8s.io/decision` to record each authorization decision; for OIDC-authenticated third-party users, audit entries capture the username and groups asserted by the identity provider, enabling traceability back to the individual; for ServiceAccounts, entries capture the service account name and namespace. Organizations can configure the Kubernetes audit policy to define which request types and API verbs are logged and at what verbosity, and route those events to a centralized log collector.

While VCF provides the technical infrastructure for centralized AAA of third-party users, the organization is responsible for defining policies that govern which third-party users receive access, establishing onboarding and offboarding procedures, conducting periodic access reviews, configuring the external identity provider with appropriate authentication strength requirements, and determining which AAA solutions to approve and how to handle AAA for external service providers.

VMware Private AI Services (PAIS) supports identification and access management for third-party and non-organizational users of AI services through OpenID Connect (OIDC) integration. PAIS activation requires coordination with the OIDC provider administrator, and the PAISConfiguration resource specifies an issuer URL, an OIDC client ID (the pais-authentication-id value provided by the OIDC administrator), and the scopes openid, groups, and offline_access. The OIDC client ID, the groups claim name, and additional accepted OAuth 2.0 audiences are individually configurable so that PAIS can interoperate with an external provider's existing tenant model rather than requiring a PAIS-specific identity store.

Authorization for PAIS is enforced through OIDC group membership. The authorizedGroups setting in the PAISConfiguration restricts access to user accounts whose OIDC Access Token includes membership in one or more designated groups, with example group names such as group-for-pais-access-01. The groups claim is included in the Access Token, and a corresponding groups scope is created in the OIDC configuration. This is the primary PAIS-native mechanism for uniquely identifying non-organizational users by OIDC identity claims and authorizing their access based on group membership in the external provider.

The Grafana observability interface for PAIS authenticates through the same OIDC provider, so visualization of PAIS metrics for monitoring and audit purposes is gated by the same identity and group controls. PAIS metrics can be exported to observability platforms to support monitoring and audit review of third-party user activity. Audit recording of authentication and authorization events at the platform layer is provided by the underlying VCF infrastructure rather than by PAIS-native audit trails dedicated to non-organizational user activity.

For third-party data sources and registries, PAIS Knowledge Bases authenticate to Confluence using either a user name and password or a personal access token, and to Microsoft SharePoint On-Premises using a user name and password. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval, and the oras login command authenticates to a private Harbor registry using user name and password credentials for catalog and image operations. These mechanisms address the identification and access control dimensions of the control for the third-party services that PAIS itself reaches out to.

VMware vDefend (Contributes)

VMware vDefend contributes to this control through two mechanisms: management plane authentication for its Security Services Platform (SSP) and Identity Firewall (IDFW) for network policy enforcement.

SSP provides two built-in local user accounts configured during deployment: an admin account with the Enterprise Admin role, which has full privileges to deploy, manage, upgrade, and configure authentication and authorization settings, and an audit account with the Auditor role, which provides read-only visibility into system activity and API access for auditing without the ability to make configuration changes. The SSP License Hub implements role-based access control with three defined roles: Enterprise Admin, Auditor, and Support Bundle Collector. Roles can be assigned to individual users or groups defined in an external identity provider, allowing organizations to integrate Active Directory or LDAP group membership into access control for the platform.

SSP supports directory-backed authentication through Active Directory over LDAP and OpenLDAP in addition to local accounts. The platform uses Authelia, an open-source authentication and authorization server, to provide two-factor authentication and single sign-on capabilities for management access, allowing organizations to require multiple authentication factors for access to vDefend's security management functions.

Identity Firewall processes user identity at the source workload to enforce DFW and gateway firewall rules based on Active Directory user and group membership. This allows AD users and groups to be used as source criteria in firewall rules, enabling network access controls based on authenticated user identity rather than IP address. Security administrators are directed to distinguish between two primary administrative personas when managing vDefend access, maintaining security boundaries between different projects and the broader organization.

Centralized AAA for organizational users across the broader VCF environment, including single sign-on and multi-factor authentication for all users, is provided by VMware vCenter and VCF SSO and is outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the `AutoprotectEnabledRpEvent` entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports authentication and authorization of users who access database services, including third-party users and service accounts that connect to managed databases. DSM's identity mechanisms apply to all user types, and authentication controls can be configured to restrict access based on identity, source address, and authentication method.

For administrative access to the DSM management plane, DSM supports both local user accounts and LDAPS integration with an enterprise directory service (LDAP or Active Directory). An installation can choose to use one or both identity sources, and DSM manages them independently. DSM can be configured to use an LDAP server for both authentication and authorization. When Directory Service credentials are unavailable, DSM falls back to local user authentication.

For PostgreSQL database instances, DSM provides host-based authentication (HBA) configuration. The `pg_hba.conf` file controls which clients may connect to a database by specifying connection type, client address, requested database, and user name. Each connection attempt is matched against an ordered list of rules, and the first matching record determines the authentication method applied. Default entries use SCRAM-SHA-256 for local accounts including the `pgadmin` and `postgres_exporter` service accounts, and administrators can add LDAP entries to authenticate database users through Active Directory. Database instances can also be configured to use directory service authentication after initial creation using the `directory-service-authentication` setting. MySQL instances similarly support Active Directory authentication via LDAPS.

DSM adds SQL Server as a managed database type with its own authentication model. SQL Server clusters use contained database users, where users authenticate directly against the database and identity information resides within the database rather than at a server level. SQL Server clusters can be integrated with Active Directory, enabling Kerberos-based authentication and Windows Authentication for server-level logins. Windows Principals can be authorized as cluster administrators through T-SQL or the DSM API. Active Directory integration also supports single sign-on for clients that use Kerberos authentication, such as SQL Server Management Studio running on a Windows machine joined to the same domain. SQL Server Authentication logins can be created for clusters that do not require Windows Authentication. DSM supports two

primary administrator user identities for SQL Server: SQL User or Windows Principal, with Windows Principal available for clusters integrated with Active Directory.

Third-party processes and service integrations that receive DSM event notifications through webhooks are authenticated using credentials. DSM webhooks support basic authentication with an Authorization User and Authorization Password, restricting webhook delivery to authorized endpoints.

Metrics forwarding to Prometheus-compatible endpoints supports configurable authentication, including certificate-only, basic authentication, or a combination, allowing organizations to control which external monitoring systems can pull DSM metrics.

The DSM Consumption Operator, which enables self-service database provisioning through Kubernetes-native interfaces, authenticates with DSM infrastructure using an authentication secret named `dsm-auth-creds`.

DSM audit logs track user actions performed through the UI and API, recording the source of each operation as either a user identifier (Email ID) for user-initiated events or System for events initiated by DSM without user intervention. For SQL Server clusters, DSM provides configurable server auditing with preset audits for login tracking and log retention, and can create a simple login event audit based on the Login Auditing option selection.

DSM does not itself categorize users as organizational versus non-organizational. Meeting this control fully requires organizational processes beyond what DSM provides: identifying which users or processes are third-party, ensuring they receive appropriately scoped accounts or directory entries, and reviewing audit logs to confirm that third-party access remains within authorized boundaries. DSM provides the authentication and access control mechanisms that support those organizational processes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several mechanisms that address identification and authentication of third-party technology assets, applications, and services at the application delivery layer.

For administrative access to the Avi Controller, TACACS+ authentication profiles integrate with enterprise identity systems such as Cisco Identity Services Engine (ISE) backed by external identity sources including OpenLDAP. Authentication requests sent to the TACACS+ server include service, user, and remote address fields. Authorization attributes returned by the server can be configured as name-value pairs to map Avi administrators to specific roles and tenants, enabling centralized identification and role-based authorization. The TACACS+ service attribute is required to identify and authorize an Avi user within ISE. Successful authentications return `PASS_ADD` or `PASS_REPL` status with attribute value pairs; unauthorized users are rejected with `FAIL` status. Controller admin authentication is configured under User Authentication and Authorization in the Avi Controller UI, where mapping rules assign users to tenants and roles based on TACACS+ attributes.

Avi also operates as a SAML Service Provider. When a user authenticates through a third-party Identity Provider, the IdP validates credentials and returns a SAML Response containing the information Avi needs to establish the authenticated session. This allows Avi to integrate with enterprise single sign-on infrastructure where identification and authentication are handled by an external system.

Avi supports certificate lifecycle integration with Venafi Trust Protection Platform. The Onboard Discovery feature automates importing certificates from network devices into Trust Protection Platform, where they can be monitored, validated, and provisioned, supporting ongoing identity assurance for application endpoints.

The Avi License Hub supports importing trusted CA bundles to establish trust for communicating with external services, providing a mechanism to validate the identity of third-party services at the licensing and management layer.

When Avi is deployed with the Avi Kubernetes Operator (AKO), Controller certificates and their chains are uploaded and managed in Templates > Security > TLS Certificates, extending certificate-based authentication to Kubernetes environments.

Control PR.AA-04

Identity assertions are protected, conveyed, and verified

SCF Controls: IAC-01.2, IAC-02.2, IAC-03.5

Aggregate Coverage: Meets

VCF (Meets)

VCF provides several authentication mechanisms that are inherently resistant to replay attacks across its management interfaces, APIs, and service-to-service communication paths.

VCF SSO supports SAML 2.0 as its primary authentication protocol for identity provider integration and user access to management interfaces. SAML assertions are digitally signed, time-bounded, and scoped to a specific audience, which makes captured assertions unsuitable for reuse by an attacker. Administrators can configure VCF SSO to use Generic SAML 2.0 or specific SAML context options depending on the identity provider in use. The PasswordProtectedTransport authentication context method requires credentials to be transmitted over HTTPS, providing transport-layer replay protection. Identity federation with external identity providers through SAML or OIDC inherits whatever replay-resistant mechanisms the enterprise identity provider implements, including nonce-based challenges and time-bound assertions.

VMware Kubernetes Service (VKS) clusters, running on the vSphere Supervisor, inherit the platform's replay-resistant authentication framework at the Kubernetes workload layer. VKS clusters support VCF SSO and OIDC-compliant external identity providers for cluster access. For external OIDC providers, VKS clusters use the Pinniped authentication service to broker connections between the Kubernetes API server and the identity provider, inheriting the provider's replay-resistant properties such as time-bounded tokens and nonce binding. The VKS API server includes an authentication webhook pod that validates user authentication tokens on every API request, rejecting any token whose expiry has passed regardless of its cryptographic validity. The VCF Consumption CLI automatically renews access token credentials using a refresh token, keeping the active access token window short-lived without requiring manual reauthentication.

The VMware vCenter API infrastructure supports holder-of-key security tokens through the LoginByToken method. Holder-of-key tokens embed security artifacts that tie the token to the presenting party, requiring proof of possession of a private key associated with the token. Intercepting the token alone is insufficient for authentication because the presenting party must demonstrate it holds the corresponding key material. This mechanism is used for programmatic and service-to-service authentication within the VCF platform.

VCF also supports Kerberos authentication in environments integrated with Active Directory. Kerberos uses time-stamped tickets and session keys that are bound to specific client-server pairs, making replayed tickets detectable. VCF documentation recommends synchronizing system clocks across the environment to avoid Kerberos authentication failures caused by clock skew, with a default tolerance of 5 minutes. This confirms that Kerberos ticket validation, including its time-based replay protections, is actively enforced. VCF Operations orchestrator plug-ins can be configured with Kerberos authentication through the krb5.conf file.

The VCF SSO client API provides challenge-response authentication through the Security Support Provider Interface (SSPI). In SSPI authentication, the client sends an issue request containing credentials, the server uses its security provider to authenticate the client, and if additional negotiation is required, the server embeds a challenge in its response. The client then sends a challenge request back to complete the exchange. Challenge-response protocols generate unique values for each authentication exchange, so a captured response from one session cannot be replayed in another.

NSX Manager supports session-based authentication using JSESSIONID cookies, which reduces repeated credential transmission while maintaining authenticated state. NSX Manager authentication mechanisms are designed to resist replay attacks.

VMware ESX (ESX) supports bidirectional CHAP authentication for iSCSI and iSER storage adapters, where both the storage initiator and the target authenticate each other using challenge-response exchanges. This extends replay-resistant

authentication to storage fabric access paths, which auditors should verify are using mutual CHAP rather than one-way authentication or no authentication.

For webhook and API security, VCF Automation secures webhook behavior requests using hash-based message authentication codes (HMAC), a mechanism that validates the authenticity and integrity of HTTP requests. HMAC-authenticated requests include a computed signature that is tied to the request content, so replaying or tampering with requests is detectable.

For service account and API access, VCF uses access tokens that rotate after each use. Access tokens normally last one hour and are derived from a refresh token that normally lasts 90 days but can be revoked earlier. If rotation is activated, making a refresh token grant call returns both a new access token and a new refresh token, and the original refresh token is invalidated. This rotation pattern limits the window during which a captured token remains valid and, when single-use rotation is enabled, renders captured tokens useless after their first use. The VCF Automation API uses authentication tokens (csp-auth-token) for API requests, and users can revoke API tokens through the User preferences page.

VCF Operations supports single sign-on authentication, allowing token reuse within a session without re-entering credentials while relying on the underlying replay-resistant token exchange. VCF Operations for Networks supports token-based authentication for its management interfaces, providing replay-resistant access control for network management operations.

For CI/CD workloads running through the Argo CD Supervisor Service, OIDC authentication supports PKCE (Proof Key for Code Exchange) through the enablePKCEAuthentication field in the Argo CD spec.oidc configuration. PKCE binds each authorization code exchange to the specific client session that initiated the flow, blocking authorization code interception and replay in OAuth 2.0 authorization code flows. Service-to-service authentication within Kubernetes workloads on VKS clusters can use the Kubernetes TokenRequest API to generate short-lived credentials scoped to a specific audience and time window; Kubernetes hardening guidance recommends implementing short token lifespans to reduce the replay window if a credential is captured. Where workloads integrate with HashiCorp Vault through the Harness CI/CD Supervisor Service, Vault can generate dynamic short-lived credentials rather than long-lived static tokens, limiting exposure to credential replay.

Across management interfaces, APIs, service-to-service communication paths, Kubernetes workloads, and storage fabric access, VCF provides native replay-resistant mechanisms that include digitally signed and time-bounded SAML assertions, holder-of-key security tokens, Kerberos time-stamped tickets, SSPI challenge-response exchanges, HMAC-signed webhook requests, rotating API access tokens, bidirectional CHAP, Pinniped-brokered OIDC flows with per-request token validation, PKCE-bound authorization code exchanges for CI/CD, TokenRequest API short-lived credentials, and Vault-generated dynamic secrets. VCF documentation recommends migrating API, SDK, and CLI access from Simple Authentication to token-based authentication where possible. The VCF SSO configuration pages in VCF Operations and VMware vCenter provide the settings for selecting the authentication protocol in use.

VMware vDefend (Contributes)

VMware vDefend contributes to AAA governance through built-in controls in Security Services Platform (SSP) and through network-layer enforcement capabilities in the Distributed Firewall.

SSP implements authentication using local accounts or directory-managed accounts. The platform uses Authelia, an open-source authentication and authorization server that provides two-factor authentication (2FA) and single sign-on (SSO) capabilities, alongside an Authserver that handles authentication requests and manages credentials. For directory integration, SSP supports Active Directory over LDAP or OpenLDAP, with only one identity source configured at a time. These capabilities apply across both the SSP platform itself and its License Hub component.

For authorization, SSP ships with two predefined local user accounts that enforce separation of duties: an admin user with the Enterprise Admin role for full management access, and an audit user with the Auditor role for read-only access to APIs and services for system auditing. These accounts are present in the SSP platform, the SSP Installer, and License Hub. The audit user's password must meet required criteria and can be reset by the admin user through the User Management interface.

For auditing, SSP provides a purpose-built audit user account scoped to compliance review and system inspection. All access events to License Hub are logged in audit logs that are enabled by default and cannot be disabled, providing a persistent access record for that management component.

At the network enforcement layer, vDefend microsegmentation policies restrict which systems can reach AAA infrastructure such as identity providers, directory services, and authentication servers, reducing the exposure of those services to lateral movement. Identity Firewall (IDFW) extends enforcement by using Active Directory user and group membership directly as the basis for firewall rule decisions. IDFW detects user logins by monitoring login events in domain controller event log servers, then applies security policies based on AD group membership. This allows network access rules to follow user identity across virtual desktops (VDI), Remote Desktop Sessions (RDSH), and physical machines. IDS/IPS profiles can detect attempts to exploit vulnerabilities in authentication services.

These controls do not replace organizational AAA governance policies or manage AAA solutions across the broader environment. They implement authentication, authorization, and audit mechanisms within the vDefend management layer and provide network-layer protection for AAA infrastructure that supports organizational governance objectives.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) implements authenticate, authorize, and audit (AAA) mechanisms for replication and recovery operations. Authentication uses VCF SSO. The PNR server acquires a holder-of-key SAML token from VCF SSO and presents it in a cryptographically signed envelope when establishing authenticated communication channels to remote services such as VMware vCenter. PNR uses service account authentication for server-to-vCenter communication, and a domain-level service account created by vCenter is used when PNR runs in an Enhanced Linked Mode environment. When connecting peer vCenter instances that reside in different or the same SSO domains, PNR also supports credential-based authentication. The PNR Appliance Management Interface requires authentication as the admin user for service management, network configuration, time zone settings, storage replication adapter configuration, and site unregistration workflows. The default admin password is set during initial deployment and is expected to be changed by the operator. PNR exposes Authentication APIs as part of its REST API gateway, including a REST endpoint to log out an authenticated session.

Authorization is enforced through PNR's privileges, roles, and permissions model. PNR performs operations using the user credentials supplied when the protected and recovery sites are connected, and permission checks apply at both sites for cross-site operations. The configuration import and export tool accepts the `--localAuthUseSA` and `--remoteAuthUseSA` parameters, which select whether a Service Account file is used for authentication to the local or remote site. PNR and later supports Service Account authentication for importing or exporting configuration data.

Audit logging records replication and recovery operations and security-relevant events. PNR records operational information in log files that do not contain private keys or passwords. Authorization errors and certificate verification errors are written with timestamps and component information to security-related log files for audit trail purposes. Replication lifecycle events generate audit log entries, for example the `AutoprotectEnabledRpEvent` entry that indicates Automatic Protection has been activated for a replication provider.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides built-in authentication, authorization, and audit capabilities that support an organization's AAA governance requirements for the database-as-a-service layer.

For authentication, DSM supports two user authentication modes for access to the management interface: local user accounts and LDAPS-integrated accounts. Local users authenticate using an email address and password. LDAPS users authenticate with their directory service credentials at the DSM login screen, and DSM falls back to local user authentication when directory service credentials are non-functional. Organizations can integrate DSM with an LDAP or Active Directory server for both authentication and authorization, with the DSM appliance communicating with directory service servers for credential validation. This configuration is available under Managing LDAP Users in the DSM administration interface.

At the database level, DSM supports configurable host-based authentication (HBA) rules for PostgreSQL database instances. PostgreSQL instances use an ordered rule set in `pg_hba.conf` that matches connection type, client address, requested

database, and user name to determine the authentication method applied. Custom HBA entries support the scram-sha-256, reject, and cert authentication methods; both a UI and an API are available for configuring these options. SQL Server databases use contained database users that authenticate directly against the database, with identity information stored within the database itself.

For authorization, DSM can be configured to use an LDAP server for both authentication and authorization, allowing role assignments and access decisions to be managed through the organization's existing directory infrastructure. Data service policies can be enforced consistently across different tenants, supporting a uniform security posture. Integration channels for metrics forwarding support configurable authentication: VCF Operations integration requires mutual TLS (mTLS) authentication, while Prometheus forwarding supports no authentication, certificate-only, basic authentication, or a combination of certificate and basic authentication. Webhook integrations support basic authentication with configurable Authorization User and Authorization Password credentials, so event notification channels can be secured. The DSM Consumption Operator uses a dedicated authentication secret (dsm-auth-creds) to authenticate with the DSM infrastructure for Kubernetes-native consumption paths.

For audit, DSM provides a System Audit capability on the Provider VM that monitors system audit events, accessible through the DSM administration interface. PostgreSQL database instances include the pgaudit extension, providing database-level audit logging of query and object access activity. SQL Server deployments include configurable server auditing with preset audits for login tracking and log retention; the Login Auditing option can automatically create an audit for login events.

Governing the use of these AAA mechanisms, establishing organizational policies for when LDAPS integration is required versus local accounts, defining retention and review requirements for audit logs, and extending governance to any External Service Provider hosting components of the AAA infrastructure remain organizational responsibilities. DSM provides the technical controls; organizational processes determine how strictly they are applied and monitored.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) operates at the application delivery layer and provides multiple mechanisms that support replay-resistant authentication for both management plane access and application workloads traversing the load balancer.

For management plane access, the Avi Controller supports remote authentication via LDAP, TACACS+, and SAML, with the ability to deactivate local user login when remote authentication is enabled. SAML authentication delegates to a centralized identity provider (IdP), verifying user identity without storing credentials on client devices. SAML assertions carry timestamps and unique assertion IDs that the IdP and Avi use to detect and reject replayed assertions. The Avi Controller also supports token-based and session-based authentication for REST API access through the Avi Python SDK. In the Avi for VCF deployment, the Avi Controller provides a POST /api/authtoken endpoint for generating authentication tokens with configurable validity duration in hours, bounding the window during which a captured token could be reused.

For secure channel communication between the Avi Controller and Service Engines, Avi enforces configurable token timeouts via the secure_channel_controller_token_timeout setting, limiting the lifetime of authentication tokens used in the control plane. When the Avi Controller cluster enters a manual recovery state, secure channel credentials for all Avi Service Engines are revoked, requiring fresh authentication before those engines can resume normal operation.

For web applications and API traffic, SAML authentication can be enforced at the virtual service boundary. Authentication rules support Default Authentication (enforce SAML on rule match) and Skip Authentication (bypass for specified paths), allowing operators to apply path-specific policies. WAF authentication rules also support configurable custom actions when rule conditions are matched.

The Auth Credentials Cache Expiration setting controls the maximum allowed lifetime of cached client authentication state, limiting the window during which stale cached credentials could be reused. Avi Controller also provides the AUDIT_COMPLIANCE_EVENT mechanism to log authentication failures for audit purposes, supporting detection of replay attempts.

Control PR.AA-05

Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties [Withdrawn: Incorporated into PR.AA-01, PR.AA-05] [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.AA-05]

SCF Controls: HRS-02, HRS-11, IAC-01, IAC-01.2, IAC-02, IAC-03, IAC-04, IAC-05, IAC-08, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF enforces role-based access control across all major platform components, restricting access to technology assets, applications, services, and data based on assigned roles with defined permissions. RBAC is applied consistently throughout the stack, covering compute management, networking, storage, operations management, automation services, and Kubernetes workloads.

VMware vCenter provides fine-grained authorization through a permissions model that associates roles with users or groups on objects in the vCenter inventory hierarchy. Roles are sets of privileges, and vCenter defines three authorization levels: operator (read-only access to configuration, the most restricted level), administrator (read and write access to configuration but cannot manage user accounts, intended for users who alter vCenter configuration or exercise control functions), and super administrator (full control). When a predefined role is modified, the updated privilege set applies immediately to all users assigned that role. New roles are created with three default system-defined privileges (System.Anonymous, System.Read, System.View), and administrators add specific privileges to match the intended access level. vCenter also supports creation of custom roles with granular privilege assignment and permission propagation to vSphere objects in the inventory hierarchy.

NSX implements RBAC by assigning users predefined roles with specific permissions. The platform includes 15 built-in roles: Enterprise Admin, Admin, Network Admin, Network Operator, Security Admin, Security Operator, Cloud Admin, Cloud Operator, Cloud Project Admin, Load Balancer Admin, Load Balancer Operator, VPN Admin, GI Platform Admin, NSX Platform Admin, and Support Bundle Collector. These roles follow the principle of least privilege, with each role carrying only the permissions needed for its functional area. NSX RBAC applies across multiple operational domains including inventory, plan and troubleshoot, and system management functions. NSX also supports project-scoped RBAC, where Network Admin, Network Operator, Security Admin, and Security Operator roles assigned within a project have permissions limited to that project's scope rather than the entire NSX system. This project-scoped model extends to VPCs and subnets within the NSX networking hierarchy. For organizations that need role definitions beyond the built-in set, NSX allows creation of custom roles tailored to specific operational requirements. Only an Enterprise Administrator can assign the role management permission to a custom role. NSX Federation extends RBAC to multi-site deployments, applying the same access control model across federated NSX instances. Principal identities, which are used for service-to-service authentication local to NSX, also support RBAC role assignment, so automated integrations operate under the same access control model as human users.

VCF Operations enforces RBAC through the assignment of service roles to users and groups. Administrators configure role-based permissions through the Roles tab under Infrastructure Operations, where individual permissions can be selected or deselected to define what each role is authorized to do. The System Administrator role includes rights covering approvals, audits, certificates, datastores, edge clusters, integrations, LDAP settings, namespaces, proxy rules, system settings, tokens, and truststore operations. Administrative operations such as password management require authentication with a user assigned the ADMIN role. VCF Operations also defines its own roles within vCenter, with privileges named using a convention that appends the role to the product name (such as VCF Operations ContentAdmin Role and VCF Operations PowerUser Role). The PowerUser role has privileges to perform the actions of the Administrator role except for user management and cluster management. A further restricted PowerUserMinusRemediation role excludes remediation actions in addition to those limitations. A vCenter administrator assigns these roles to users, and VCF Operations maps vCenter users to the appropriate role.

vSAN supports RBAC and permissions management for authentication and authorization of storage operations. The vSAN Security Configuration Guide provides guidance on configuring these role-based controls for storage infrastructure.

VCF Automation governs access through multiple RBAC mechanisms at different scopes. At the organization level, rights bundles assign specific API permissions to roles including Organization Administrator, Organization Auditor, and Organization User. Group membership and role assignment are managed through the Access Control interface, and organization administrators can edit role assignments for groups at any time. At the project level, VCF Automation defines three distinct roles: administrators, members, and viewers, providing tiered access to project resources and operations. VCF Automation also governs blueprints, catalogs, content libraries, and custom entities through its role model. The Assembler Administrator role has read and write access to the entire user interface and API resources, while other roles have progressively narrower permissions.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), VCF enforces RBAC through two complementary control layers. At the vSphere layer, vSphere Namespaces assign three permission roles: Owner (full control including namespace deletion), Can Edit (provisioning and operating workloads), and Can View (read-only access). At the Kubernetes layer, the Kubernetes RBAC authorization framework governs access to all API server requests through four core objects: Roles define permissions scoped to a single namespace, ClusterRoles define permissions applying cluster-wide, and RoleBindings and ClusterRoleBindings associate those roles with authenticated subjects such as users, groups, or ServiceAccounts. Permissions are purely additive with no deny rules, and administrators can restrict access to individual resource instances by name using the resourceNames list in role rules.

VKS clusters integrate with VCF SSO so that Kubernetes RoleBinding objects grant RBAC permissions directly to VCF SSO users and groups. This means the same identity provider that governs VMware vCenter access also governs Kubernetes cluster access, providing a consistent identity model across both the platform and workload layers. Cluster operators use kubectl or the Kubernetes API to assign role permissions to developers and other personas with defined responsibilities.

Kubernetes RBAC also governs ServiceAccounts, which provide discrete identities for pods and automation processes. This separation allows human access and workload access to be governed independently, with each scoped to the minimum permissions required for its function. ServiceAccounts follow the principle of least privilege by receiving only the minimum set of permissions required to function correctly, and RBAC should be applied to Secret objects to enforce least-privilege access to sensitive data stored within namespaces.

The Kubernetes RBAC API includes built-in controls against privilege escalation: the API prevents users from editing roles or role bindings to gain permissions beyond those they already hold, and this enforcement applies at the API level regardless of the authorization mode in use. Role-binding authority can be explicitly delegated by granting a user permission to perform the bind verb on a specific Role or ClusterRole, limiting the roles that identity can delegate to others.

In multi-tenant VKS deployments, RBAC is the primary mechanism for isolating tenants within a shared cluster. Administrators use Role and RoleBinding objects at the namespace level to restrict each tenant's access to its assigned namespaces, and ClusterRole and ClusterRoleBinding objects to control access to cluster-level resources, blocking unprivileged users from crossing tenant boundaries.

Supervisor services deployed on VKS clusters extend RBAC to their own access models. The Secret Store Supervisor Service enforces role-based access control across administrator, DevOps engineer, and application tenant roles, controlling who can manage and retrieve sensitive data. The Argo CD Supervisor Service implements RBAC through a configurable policy field using Casbin syntax, with the spec.rbac.policy setting defining role assignments and permission rules; policy rules (p rules) control account permissions including the ability to grant admin roles to specific local accounts, and group mappings (g rules) assign accounts to role groups.

VMware Private AI Services (PAIS) provides role-based access control scoped to its AI services and AI workload delivery components. The central mechanism is OIDC group-based authorization for PAIS. When activating PAIS in an organization namespace, administrators populate the authorizedGroups setting with one or more OIDC group identifiers so that only users who belong to those groups can access the service. The OIDC configuration supports a configurable groups claim name through the oidc-groups-claim setting, with the groups claim carried in the Access Token and evaluated at access time. PAIS

requires an OIDC provider configured as a public client application with Authorization Code and Refresh Token grant types, and it can be configured with one OIDC provider. Additional OAuth 2.0 client identifiers can be accepted by configuring Extra Audiences through the `oidc-extra-audiences` setting when the OIDC provider issues tokens for multiple audiences.

PAIS extends the same identity model to the Grafana observability platform used for PAIS metrics. Grafana role assignment is configured through the `grafana-oidc-role-mapping` property using an expression such as `contains(groups['*'], 'pais-access-group') && 'Admin' || 'Viewer'`, so OIDC group membership maps automatically to Grafana Admin or Viewer roles. PAIS uses the same OIDC provider for Grafana authentication that it uses for service access.

For machine learning model storage, the Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as the model storage backend and requires authentication and certificate-based trust for model retrieval. PAIS is compatible with OCI-compliant registries from other vendors when deployed in a disconnected or air-gapped environment, and the project-scoped access controls apply to the chosen registry.

Access to PAIS catalog items for GPU-accelerated VKS clusters and other AI workloads is governed through project-based permissions in VCF Automation. PAIS custom forms in blueprints can be modified to control user inputs at request time, scoping which configuration choices a requester can make when provisioning AI workloads. Knowledge Base data sources used by PAIS retrieval augmented generation require authenticated access to external repositories, including user name and password authentication for SharePoint On-Premises data sources and access keys with list and read permissions on the target bucket for Amazon S3 compatible stores. PAIS uses a CA trust bundle for secure communication with external services and databases.

These PAIS-specific controls operate at the AI services and workload layer. Access to the underlying compute, storage, and networking infrastructure is governed by platform-level RBAC in VCF, including VCF SSO and VMware vCenter role assignments, and database-level access for vector and operational data is governed by Data Services Manager. PAIS adds service-level and workload-level RBAC for AI-specific assets on top of the VCF platform foundation rather than replacing those platform controls.

VMware vDefend (Contributes)

VMware vDefend (vDefend) enforces role-based access control across its security management interfaces to restrict access to firewall policy administration, threat analysis functions, and monitoring capabilities based on assigned user roles.

The vDefend distributed firewall (DFW) implements RBAC to control who can create or modify firewall rules, limiting policy changes to authorized personnel. Access to DFW monitoring features, including Firewall Insights, requires one of three designated roles: Enterprise Admin, Security Admin, or Security Operator. Rule Analysis operations within the platform are also role-gated across the five defined role types.

Security Services Platform (SSP) implements RBAC with five defined roles governing access to platform operations: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Each role carries differentiated permissions; Full Access grants create, read, update, and delete capabilities, while Read-only access is available for monitoring-oriented roles such as Auditor and Support Bundle Collector. Role assignments can be applied to individual remote users or to remote user groups managed through a directory service, allowing administrators to align vDefend access with existing organizational structures. Multiple roles can be assigned to a single user or group to meet varying operational requirements. SSP's RBAC model also applies to License Hub operations, restricting licensing management actions to authorized roles.

Security Intelligence RBAC in 9.1 uses the same five-role model as SSP (Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector), aligning Security Intelligence access governance with SSP's permission model and providing consistent role boundaries across both the detection and platform layers.

For organizations using VCF Automation for vDefend firewall management, VCF Automation provides a dedicated Firewall category under RBAC rights, controlling access to the management and viewing of DFW rules, Tenant Gateway Firewall policy, VPC Gateway Firewall policy, and VPC Security Profiles. This allows organizations to scope firewall administration

rights independently of other VCF Automation capabilities, supporting separation of duties between network automation and security policy management.

vDefend's RBAC controls complement the broader VCF RBAC model by restricting access to network security policy management independently of compute, storage, or platform configuration access. An administrator with VMware vCenter privileges does not automatically gain the ability to modify firewall rules or security analytics configurations unless explicitly granted the appropriate vDefend roles. This separation of duties between infrastructure administration and security policy management supports distinct team structures for network security management.

VCF Protection and Recovery (Contributes)

Protection and Recovery (PNR) implements role-based access control through purpose-built roles registered in VMware vCenter and through a multi-tenant administrative model for Protection and Recovery for VCF Automation. The SRM Administrator role allows users or user groups to perform all PNR configuration and administration operations. The Protection and Recovery Administrator role can be assigned to user groups to manage permissions. Default roles provide the privileges users require to manage protection groups and perform recoveries, while restricting access to resources belonging to other users.

For automatic protection of virtual machines within a protection group, administrators assign either the SrmAdministrator or SrmProtectionGroupsAdministrator role to the automatic protection user or user group. This scopes the protection actions performed on the user's behalf to the privileges of the assigned role.

Each role is a collection of privileges that defines the actions a user can perform on the protection and recovery site. A user can have at most one role on an object, but roles combine when the user belongs to multiple groups that all have roles on the object. PNR supports propagating roles to child objects in the inventory hierarchy, so administrators can extend privileges from parent objects such as folders to all virtual machines within them.

Protection and Recovery for VCF Automation introduces a multi-tenant role model with Provider Administrator, Organization Administrator, Project Administrator, and Project Advanced User. Each role has specific authorization levels for disaster recovery operations. Provider Administrators select which replication classes each Organization can use, restricting organizational access to specific recovery configurations. Organization Administrators manage the pairing of namespaces and assignment of replication classes within their tenancy.

Underlying directory services, authentication, and enterprise identity governance are provided by VCF SSO and the broader VCF platform. PNR consumes those identities and layers its protection and recovery roles on top of them.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) implements role-based access control natively, with two defined role types that govern access to all data service resources. The DSM Admin role is a super-user role with full access to create, monitor, and manage all data services across the environment. The DSM User role is a restricted role that limits a user to viewing and managing only the data service deployments they own. This separation is enforced at the console level: the views and available actions in the DSM interface differ based on the assigned role, so users with the DSM User role cannot see or act on resources outside their own scope.

Access control is further refined through namespace scoping. DSM User role assignments can be restricted to one or more specific namespaces, limiting access to data services within those assigned namespaces only. Administrators can modify a user's assigned role and namespace access after initial provisioning. DSM namespaces enforce role-based access control that allows multiple users to work on data services within a shared namespace while maintaining appropriate permission boundaries between them.

DSM supports both local user accounts and directory service integration for identity management. Local users are created through the DSM UI, where administrators specify the user's role, email address, and password. For enterprise directory integration, DSM supports LDAPS-based authentication with Directory Service Group mapping, allowing administrators to assign users to either the DSM Admin or DSM User role based on their LDAP group membership. This group-based mapping is configured through the vSphere Client during DSM setup or through the DSM UI after deployment.

Access control extends to storage and database resources as well. DSM IAM policies for S3-compatible storage support granular access control through policy statements that allow specific S3 actions, including PutObject, GetObject, DeleteObject, and ListMultipartUploadParts. At the database level, PostgreSQL instances support the CREATE ROLE command to create database roles for LDAPS users with configurable login capabilities, and administrators can configure Host-Based Authentication (HBA) rules to restrict which clients and authentication methods may connect to a PostgreSQL instance. For SQL Server instances, DSM applies least-privilege access by granting the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full administrative access. Data service policies also support allowlist configuration to restrict users to selecting only from a specific set of approved parameters when provisioning databases.

The DSM Permissions view provides a centralized interface for administrators to create, monitor, and manage configured users. This view supports ongoing governance of who has access to what within the DSM environment, making it straightforward to audit and adjust role assignments as business needs change.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides a native, multi-tiered Role-Based Access Control (RBAC) framework that governs all administrative access to the Avi Controller. At the base level, Avi roles assign one of four privilege types to each resource category: Write (full create, read, modify, and delete access), Read (view-only access to configuration, health, and analytics data without modification capability), Assorted (a mixed access level combining permissions across specific operations), and No Access (no access to the resource at all, including the inability to read or list it). Roles are combined with tenants to define the complete authorization settings for each user, scoping what resources a user can interact with and what actions they may take.

Beyond base privilege levels, the Extended Granular RBAC feature refines access using markers, which are key-value label pairs assigned to Avi objects. A role definition specifies that a user may access only objects bearing labels that match the role's marker set. The `allow_unlabelled_access` parameter controls whether a user can view objects that lack matching labels, allowing administrators to restrict visibility to labeled objects only. Label groups can be associated with tenants to enforce label-based access policies across the tenant boundary. Multiple label values can be mapped to a single key, enabling flexible classification schemes. This mechanism enables resource-level scoping across tenants and teams: for example, restricting a group of operators to only the virtual services labeled with their team's identifier, without granting visibility into other teams' objects.

At the finest granularity, Avi implements sub-resource (field-level) RBAC, which scopes which specific fields within a configuration object a given user is authorized to modify. Sub-resource definitions can be combined so that a user can configure multiple fields or features within a single object while remaining restricted from updating others. Label-based permissions for cloud objects extend this field-level control to infrastructure resources managed by the Avi Controller. Virtual service configuration exposes RBAC directly: the RBAC tab in the Virtual Service advanced setup provides label-based access control for health monitors and associated objects, extending role enforcement down to individual service configuration items.

For GSLB deployments, the Avi Controller enforces RBAC through role references such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` that can be assigned to user accounts with tenant-level scope. These role references apply to follower sites configured with federated JWT profiles, scoping which accounts can modify GSLB configuration.

The Avi Controller applies RBAC within the License Hub, limiting which users can perform specific actions based on their assigned role.

For deployments using the Avi Kubernetes Operator (AKO), the Avi Controller implements RBAC by assigning tenants and roles to user accounts at the Kubernetes or OpenShift cluster level. AKO Custom Resource Definitions (CRDs) can leverage Kubernetes RBAC policies to restrict which user groups can configure routing rules, extending the Controller's authorization model into the Kubernetes control plane.

For deployments on Microsoft Azure, Avi integrates with Azure IAM to control which Azure identities have access to Avi Load Balancer resources hosted in Azure. Administrators can use built-in Azure roles such as Reader (read-only access) or Owner (full access), or define custom roles for finer control over specific resources.

RBAC configuration is managed through the Users section of the Avi Controller UI. Roles are defined per resource type and then assigned to users within a tenant. Extended Granular RBAC markers are attached to individual Avi objects (virtual services, pools, health monitors, and others) and referenced in the role definition. Sub-resource RBAC is configured as part of the Extended Granular RBAC object, combining field-level restrictions as needed.

Control PR.AA-06

Physical access to assets is managed, monitored, and enforced commensurate with risk [Withdrawn: Moved to PR.AA-06] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01]

SCF Controls: PES-01, PES-02, PES-02.1, PES-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PR.AT

Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind. Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind. [Withdrawn: Incorporated into PR.AT-01, PR.AT-02] [Withdrawn: Incorporated into PR.AT-02] [Withdrawn: Incorporated into PR.AT-01]

SCF Controls: SAT-01, SAT-02, SAT-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PR.AT-01

Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind [Withdrawn: Incorporated into PR.AT-01, PR.AT-02] [Withdrawn: Incorporated into PR.AT-01]

SCF Controls: SAT-02, SAT-03, SAT-03.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PR.AT-02

Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind [Withdrawn: Incorporated into PR.AT-01, PR.AT-02] [Withdrawn: Incorporated into PR.AT-02]

SCF Controls: SAT-03, SAT-03.5, SAT-03.6, SAT-03.7

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control PR.DS

The confidentiality, integrity, and availability of data-at-rest are protected The confidentiality, integrity, and availability of data-in-transit are protected [Withdrawn: Incorporated into ID.AM-08, PR.PS-03] [Withdrawn: Moved to PR.IR-04] [Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10] [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into PR.IR-01] [Withdrawn: Incorporated into ID.RA-09, DE.CM-09] The confidentiality, integrity, and availability of data-in-use are protected Backups of data are created, protected, maintained, and tested [Withdrawn: Moved to PR.DS-11] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01]

SCF Controls: DCH-01, DCH-01.1, DCH-01.2, DCH-01.3, DCH-01.4, DCH-02, DCH-03

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage &

Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label, and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The etcdctl snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During kubeadm upgrades, backup folders for etcd state and cluster manifests are written automatically to /etc/kubernetes/tmp with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides VolumeSnapshotContent and VolumeSnapshot resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a PersistentVolumeClaim using a VolumeSnapshotClass that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new PersistentVolumeClaim with the target VolumeSnapshot as its dataSource, referenced via the snapshot.storage.k8s.io API group. Kubernetes PersistentVolumes have a configurable reclaim policy; setting the policy to Retain preserves volume data in a Released state after the associated PersistentVolumeClaim is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time

recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to protecting sensitive and regulated data by maintaining replicated copies at geographically separated sites and providing orchestrated recovery when primary copies are compromised or corrupted. Bidirectional protection is implemented by protecting datastore groups or storage policies using array-based replication, or by

protecting individual virtual machines using vSphere Replication, allowing organizations to keep regulated workloads recoverable across paired sites.

Protection groups allow administrators to organize regulated workloads and apply consistent replication and snapshot policies across the virtual machines and datastores subject to the same data protection requirements. PNR protection groups support an immutability mode that, when enabled, prevents the data protection group from being modified or deleted, which addresses tamper resistance for the configuration that governs how regulated workloads are protected. For multi-tenant or shared recovery scenarios, PNR maps resources, networks, folders, and datastores on protected sites to separate datacenters, networks, folders, and placeholder datastores on the shared recovery site, preserving customer data isolation across the recovery boundary.

vSAN Snapshots and Replication provides VM restore and clone operations from existing snapshots, supporting recovery of regulated workloads to a known-good point in time. PNR records operational information into log files that do not contain sensitive information such as private keys or passwords, which limits the recovery tooling itself as a source of disclosure. The Protection and Recovery dashboards in VCF Operations provide cross-site visibility into protected and recovery sites, vSAN snapshot and replication state, and VCF Protection and Recovery Cloud regions, supporting monitoring of regulated workload protection.

Encryption at rest for primary storage, data classification, granular access controls at the data layer, and key management are provided by the underlying VCF platform rather than PNR itself.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control PR.DS-01

The confidentiality, integrity, and availability of data-at-rest are protected [Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10] [Withdrawn: Incorporated into PR.DS-01, DE.CM-09] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01]

SCF Controls: CRY-01, CRY-01.1, CRY-05, DCH-01

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple cryptographic mechanisms for protecting data at rest across its infrastructure stack, primarily through vSAN data-at-rest encryption and vSphere Virtual Machine Encryption.

vSAN data-at-rest encryption is the primary mechanism for protecting stored data within VCF. When enabled on a vSAN cluster, vSAN encrypts everything in the vSAN datastore, including all files, virtual machines, and their corresponding data. This protection extends to scenarios where a physical storage device is removed from the cluster, as the encrypted data remains unreadable without the proper keys. vSAN supports both Original Storage Architecture (OSA) and Express Storage Architecture (ESA) deployments, with encryption behavior varying by architecture. For OSA, data-at-rest encryption occurs at the Local Object Manager (LSOM) layer on the target host, and each disk has a different randomly generated Data Encryption Key. For ESA in hyperconverged infrastructure mode, data is encrypted at the VM host before network transmission, and all disks in the cluster use the same DEK to encrypt object data. In OSA, encryption occurs after other data processing operations such as deduplication and compression, preserving storage efficiency. vSAN encryption is the recommended approach for securing data on vSAN datastores because it is designed to be compatible with vSAN deduplication and compression, whereas virtual machine encryption causes these storage efficiency features to become less effective.

vSphere Virtual Machine Encryption provides an alternative or complementary data-at-rest encryption layer that works across all datastore types, including vSAN, iSCSI, NFS, and Fibre Channel. VM Encryption occurs before data reaches the storage layer, protecting virtual machine files and disks regardless of the underlying storage technology. This can be applied on a per-VM basis and operates independently of the underlying storage layer, making it applicable to environments where granular, VM-level encryption control is required. Most virtual machine files, in particular guest data not stored in the VMDK file, are encrypted. When combined with storage-level encryption, administrators should evaluate the performance impact of multiple encryption layers on latency and throughput, as well as the potential loss of storage efficiency features like deduplication and compression.

For organizations consuming VCF through the VCF Automation layer, VCF Encryption Management extends these VM and disk encryption capabilities to the namespace level. This service allows organization administrators to use encryption keys from their own third-party key providers to encrypt VMs and disks within a VCF Automation namespace, and also supports encrypting VMs with a Virtual Trusted Platform Module (vTPM). Provider administrators must register a default standard key provider in VMware vCenter before organization administrators can configure namespace-level encryption; the vSphere Native Key Provider cannot be used in this role, and key providers must be listed in the VMware Compatibility Guide for Key Management Servers. Organization administrators configure encryption by setting up a key provider and creating a namespace encryption class. Configuration of key providers requires either the Encryption Management Admin role or a custom role that grants the right to configure key providers.

Both encryption mechanisms require a key management infrastructure. VCF supports integration with KMIP 1.1-compatible external Key Management Servers (KMS) or the built-in vSphere Native Key Provider (NKP). VCF establishes a cryptographic domain of trust between key providers, VMware vCenter, and VMware ESX hosts. When using a Standard Key Provider, the KMS sends keys to vCenter upon request, which are used as the Key Encryption Key (KEK) and are AES-256 keys. Standard Key Providers support key wrapping, creating a three-tier key hierarchy: Data Encryption Keys (DEK) encrypt object data, Key Encryption Keys (KEK) protect the DEK, and a wrapping key stored in the KMS protects the KEK. This approach reduces the number of keys stored in external KMS systems while maintaining cryptographic separation. When using an external KMS, the recommendation is to deploy highly available KMS clusters to distribute the keys that encrypt the vSAN datastore, avoiding a

single point of failure in the encryption key chain. The vSphere Native Key Provider offers a simpler deployment model for environments that do not require an external KMS. Native Key Provider equips each participating host with decryption keys so hosts can operate independently of network-accessible key servers.

vSAN supports key rotation for both Key Encryption Keys (KEK) and Data Encryption Keys (DEK), with the capability to re-encrypt all data on the storage using new keys. vSAN encryption supports configurable rekey intervals that can be set to default or custom values. Key wrapping supports automatic key rotation with configurable intervals. This allows organizations to meet key lifecycle management requirements without disrupting operations. Encryption can also be enforced through vSAN storage policies, where the data-at-rest encryption option can be specified as a policy attribute, allowing administrators to define which datastores require encryption when provisioning virtual machines.

VCF supports virtual Trusted Platform Module (vTPM) 2.0 for virtual machines, enabling in-guest encryption capabilities such as Windows BitLocker and Linux disk encryption. Virtual machines can include various forms of encryption: VMs using a vTPM device, VMs with disks encrypted, and VMs with encryption enabled without disks encrypted. These guest-level encryption features work independently of or in combination with VMware's infrastructure-level encryption, supporting defense-in-depth strategies.

ESX hosts store their configuration data in encrypted form. When the host has a physical TPM 2.0 enabled, the configuration encryption key is stored in the TPM. Core dumps on an ESX host that has encryption mode enabled are always encrypted. ESX also supports key persistence as a cache for encryption keys in environments where a KMS may be unavailable. With key persistence enabled, ESX hosts can persist the encryption keys in the Trusted Platform Module (TPM) across reboots, allowing encryption operations to continue when the key server is unavailable. Each ESX host obtains the encryption keys initially and retains them in its key cache; if the ESX host has a TPM, the encryption keys are persisted in the TPM across reboots. Key persistence requires that the ESX host has a TPM, and can be enabled using the `esxcli system security keypersistence enable` command.

Memory Tiering encryption protects tiered memory without requiring external key management. VCF generates random 256-bit AES-XTS keys at the kernel level during VM power-on, unique to each VM instance. During vMotion, tiered memory pages are decrypted and transmitted over the encrypted vMotion channel, with new keys generated at the destination.

For access control over cryptographic operations, VCF provides the No Cryptography Administrator role, which supports all Administrator privileges except for the Cryptographic Operations privileges. This allows standard VM and infrastructure management while restricting unauthorized encryption changes. The No Cryptography Administrator role can be cloned to create custom roles with only specific Cryptographic Operations privileges, providing fine-grained control over encryption-related tasks.

The cryptographic modules used across VCF components are validated against industry-standard best practices. NSX is configured to use FIPS 140-3 validated cryptographic modules by default, with validation performed through the NIST Cryptographic Module Validation Program (CMVP). VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 as a validated cryptographic module. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic algorithms including AES, ECDSA, HMAC, RSA, and SHA2 variants, as well as VMware OpenSSL FIPS Object Module versions 3.0 and 2.0.20-vmw, which collectively support AES, CKG, DRBG, DSA, ECDSA, HMAC, KAS-SSC, RSA, SHS, Triple-DES, SHA-3, and additional key derivation functions. ESX hosts use FIPS 140-2 validated cryptographic modules that implement security functions as a combination of hardware, software, and firmware. vSAN encryption uses AES-NI CPU offloading for efficient processing.

For workloads deployed through VMware Kubernetes Service (VKS) on vSphere Supervisor, the Kubernetes control plane supports encryption at rest for API objects stored in etcd. The kube-apiserver implements this through the EncryptionConfiguration API, specified via the `--encryption-provider-config` argument. When configured, Secrets, ConfigMaps, and other designated resource types are encrypted on write to etcd. The kube-apiserver supports an external KMS provider as well as local encryption keys; when using local keys, the aescbc provider encrypts data using Base64-encoded secret keys specified in the EncryptionConfiguration resource. Using an external KMS is the recommended approach

for production environments, as it allows keys to be managed and rotated independently of the cluster configuration. Encryption at rest for the Kubernetes control plane is not enabled by default; the default identity provider stores data in plaintext, and administrators must explicitly configure `EncryptionConfiguration` to activate it. After enabling `EncryptionConfiguration`, existing objects remain unencrypted until they are read and re-written. The Kubernetes `etcd` encryption mechanism does not extend to data stored in filesystems mounted into containers; for container workload data on persistent volumes, encryption depends on the underlying storage layer. vSAN File Service volumes used with vSphere Supervisor are mounted without encryption by default, so workloads relying on shared file volumes must address encryption at the storage layer or within the application. Kubernetes Secrets encrypted at rest are also protected from disclosure if an attacker gains access to `etcd` backup data.

Classifying which data requires encryption, selecting between vSAN encryption, VM encryption, or both for specific workload categories, choosing the Key Provider model, and operating the key lifecycle (rotation, revocation, archive, destruction) are organizational data-policy decisions.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication

Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control PR.DS-02

The confidentiality, integrity, and availability of data-in-transit are protected [Withdrawn:
Incorporated into PR.DS-01, PR.DS-02, PR.DS-10]

SCF Controls: CRY-01, CRY-03, CRY-04, DCH-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides cryptographic protection for data in transit across management, compute, storage, and inter-site networks. The architecture applies encryption at multiple layers using validated cryptographic modules and current TLS protocol versions.

VCF management and monitoring communications use TLS as the transport protocol. VCF Operations for Networks supports modern TLS protocol versions, with the ability to restrict cryptographic module usage to FIPS-validated modules by enabling FIPS mode for external connections. Telegraf, the metrics collection agent, is configured to require a modern minimum TLS version for its communication channels. When using the databus for on-premises environments, HTTPS is the recommended transport to protect data during transmission and to verify subscriber authenticity. The TLS implementation includes customizable PKI options ranging from fully automated certificate management within VCF to integration with enterprise PKI infrastructure such as Microsoft Active Directory Certificate Services. VCF Operations provides centralized certificate lifecycle management across VCF components, supporting auto-renewal for VMCA, MSCA, and OpenSSL CA, handling automated renewal, monitoring, and replacement. Machine SSL certificates can be renewed through the API for a specified period up to 730 days. Starting in vSphere 9.0, all vSphere TLS profiles are FIPS compliant, and the COMPATIBLE profile supports modern TLS cipher suites and elliptic curves. The vCenter appliance uses VMware's Boring Crypto Module version 6.0, which provides FIPS-validated cryptographic operations including AES, ECDSA, HMAC, RSA, and SHA-2 variants.

NSX, which provides networking services within VCF, uses FIPS 140-3 validated cryptographic modules by default. These modules are validated through the NIST Cryptographic Module Validation Program. NSX Manager uses FIPS 140 approved algorithms for authentication to its cryptographic module. For site-to-site connectivity, the NSX L2 VPN FIPS compliance suite uses FIPS-approved encryption with Perfect Forward Secrecy enabled and standardized Diffie-Hellman key exchange, providing transmission confidentiality for tunneled traffic. VCF Operations for Networks supports modern ECDSA and RSA signature algorithms for data source connections.

VCF Automation uses the BouncyCastle FIPS 2.0.0 cryptographic module, which is compliant with FIPS 140-3 (Certificate #4743). VCF Operations for Networks uses the BC-FJA (Bouncy Castle FIPS Java API) version 2.0.0 with FIPS 140-2 Certificate #37009. These validated modules underpin the cryptographic operations used for securing communications across the automation and operations components.

At the storage layer, vSAN provides data-in-transit (DIT) encryption that protects data as it moves between hosts within the cluster. DIT encryption is a cluster-wide setting that, when enabled, encrypts all data and metadata traffic across hosts. Forward secrecy is enforced for vSAN data-in-transit encryption, meaning that compromise of a long-term key does not expose previously encrypted traffic. DIT encryption operates independently of data-at-rest encryption and does not require external key management servers. The behavior differs by storage architecture: in vSAN Original Storage Architecture (OSA), data-at-rest encryption occurs at the target host's Local Object Manager layer, so data traverses the network before encryption, making DIT encryption strongly recommended. In vSAN Express Storage Architecture (ESA) in HCI mode, data is encrypted at the VM host before network transmission, making DIT encryption optional based on compliance requirements.

VM Encryption provides confidentiality protection across all datastore types including vSAN, iSCSI, NFS, and Fibre Channel. VM encryption is implemented on the ESX host rather than on the storage array, so it protects data both at rest and in transit to the storage backend. Disk encryption uses AES-256 as the disk encryption key.

Encrypted vSphere vMotion protects VM data during live migrations. For encrypted VMs, vMotion always uses encryption and cannot be disabled. For unencrypted VMs, encrypted vMotion offers three settings: Disabled, Opportunistic (default, uses encryption when supported), and Required. AES-NI significantly improves encryption performance for these operations.

Cross-vCenter vMotion supports encryption when source and destination use shared key providers; vCenter Crypto Manager provides an `importProvider` method to import a vSphere Native Key Provider configuration between sites. vSphere Fault Tolerance log traffic, which synchronizes VM state between primary and secondary instances, can also be encrypted to protect this synchronization data in transit.

Storage protocol support varies by type. vSAN File Service supports NFS4 Kerberos authentication with security options `krb5`, `krb5i`, and `krb5p`, where `krb5p` provides authentication plus encryption of data in transit. iSCSI uses CHAP for session authentication but does not encrypt data natively, so VM Encryption or in-guest encryption is needed for confidentiality on iSCSI networks. Fibre Channel Gen 7 supports end-to-end encryption with secure Host Bus Adapters.

HCX Network Extension services support transport encryption for data between site pairs, and this encryption is enabled by default. VCF Operations HCX tunnel encryption similarly uses transport encryption by default to protect Network Extension data and migration traffic between sites. This default-on approach reduces the risk of data being transmitted in cleartext during workload migrations or network extensions.

High-quality entropy generation on ESX hosts supports the proper functioning of security-related operations such as generating encryption keys for secure network communication. This foundational capability helps maintain the strength of cryptographic keys used across all transmission encryption functions in the platform.

VMware Kubernetes Service (VKS), which runs on vSphere Supervisor, applies TLS encryption across all control-plane communication paths. The Kubernetes API server enforces encrypted transmission within the control plane and between the control plane and its clients by default, so all API server interactions travel over TLS. Cipher suites are configurable at each component layer: the `kube-apiserver` `--tls-cipher-suites` parameter accepts a comma-separated list of permitted cipher suites; the `kube-scheduler` exposes the same `'tls-cipher-suites'` parameter to keep its API endpoint aligned; and the `kubelet` exposes `'tlsCipherSuites'` and `'tlsMinVersion'` settings in `'KubeletConfiguration'` to scope the permitted cipher algorithms and minimum protocol version at the node level. Antrea, the CNI plugin included with Supervisor, supports configurable TLS cipher suites for its own secure communication channels through the `'tlsCipherSuites'` setting, and the vSphere Cloud Provider Interface (CPI) exposes the same capability through a configurable cipher suite list.

For environments with strict cryptographic requirements, VKS supports FIPS mode through the `ClusterClass` variable `'fips.enabled'`, which controls which encryption algorithms are permitted at the node level. TanzuKubernetesRelease references carrying the `'-fips.1'` suffix indicate that FIPS cryptographic modules are active for that node pool. The Istio service mesh package, available as a standard package on VKS clusters, ships with FIPS compliance and supports mutual TLS (mTLS) between pods within the mesh; the `'meshMTLS.minProtocolVersion'` setting controls the minimum acceptable protocol version for all inter-service traffic. Ingress-layer encryption for workloads is handled by the Contour package, which exposes `'tls.minimum-protocol-version'` and `'tls.maximum-protocol-version'` settings so operators can define a bounded range of acceptable protocol versions for inbound HTTPS traffic. The Supervisor secret injection agent automatically configures mutual TLS for its communication with the vault agent injector service using auto-generated certificates. Harbor, available as a Supervisor Service, accepts custom TLS certificates through its `'tlsCertificate.tls.crt'` and `'tlsCertificate.tls.key'` configuration fields, supporting encrypted access to the container registry for image distribution.

Defining the encryption policy for customer workload traffic, selecting cipher and FIPS configurations for environments with stricter requirements, and validating that data transmitted from customer applications and containerized workloads meets confidentiality standards are organizational data-policy decisions.

VMware Private AI Services (PAIS) provisions VKS clusters using a FIPS-enabled Kubernetes build for cryptographic compliance across both control plane and worker node communications. The VKS cluster topology version is `v1.33.1--vmware.1-fips-vkr.2` with FIPS compliance enabled, running on an Ubuntu 24.04 OS image, covering the cryptographic modules that protect data in transit within the cluster fabric.

PAIS, activated through the `PAISConfiguration` custom resource on the Supervisor, requires HTTPS for all external integrations. The `spec.clientTls.caBundleRefs` section of the `PAISConfiguration` YAML references CA trust bundles supplied as `ConfigMap` resources. Operators must configure HTTPS trust bundles for the OIDC provider, the Harbor container registry, content management systems hosting Knowledge Base data sources, MCP servers providing tools to models, and the

pgvector database. Separate trust bundles are recommended per application, with periodic updates required before certificate expiration.

The PAIS Supervisor endpoint uses HTTPS on port 6443 with certificate-based authentication. The PAIS ingress endpoint is protected by a self-signed certificate stored in the `pais-ingress-default` Kubernetes Secret. Administrators retrieve the CA certificate using `kubectl get secrets/pais-ingress-default -o yaml` and distribute it to clients that connect to the service, including Grafana when configured to scrape the PAIS Prometheus endpoint. CA trust bundles for external entity connections are managed through ConfigMaps and updated as certificate content changes.

VCF Automation Provider Management for PAIS uses a base64-encoded certificate (`TM_CERT_BASE64`) obtained by running `openssl s_client` against the VCF Automation FQDN on port 443, enabling authenticated HTTPS communication between AI catalog tooling and the PAIS environment. MCP server integrations require the MCP server's issuer certificate to be added as a CA trust bundle before connecting over HTTPS using either Streamable HTTP or Server-Sent Events transport.

Telemetry sent from PAIS to the OpenTelemetry Collector is authenticated using a Kubernetes Secret containing Authorization Bearer tokens and custom authorization headers. LLM trace transport to the collector uses HTTP/protobuf or gRPC, both protecting trace traffic in transit.

One configuration detail that auditors should verify: PAIS Prometheus TLS client authentication and certificate validation are turned off by default (the `tls-client-authentication` setting on the Prometheus endpoint). Organizations should review this setting and enable mutual TLS where their policy requires it. The underlying network transport encryption between VMs and workload domains is provided by VCF and is documented in VCF Coverage.

VMware vDefend (Contributes)

VMware vDefend contributes to transmission confidentiality through inspection, visibility, and enforcement mechanisms at the network layer, while the underlying cryptographic protection of data in transit is the responsibility of endpoint applications and infrastructure components.

TLS Inspection uses a transparent TLS proxy to intercept and analyze encrypted traffic flows traversing the environment. This allows security policy to be applied to traffic that would otherwise be opaque and supports detection of threats embedded within encrypted sessions. TLS Inspection can be deployed to provide visibility into encrypted connections while preserving end-to-end encryption for flows not subject to a decryption policy, and supports both inbound and outbound inspection profiles.

Security Intelligence, integrated within the Security Services Platform (SSP), surfaces workloads communicating over application protocols that transport data without encryption. The Security Segmentation Report identifies communication chains containing at-risk unprotected members and quantifies the number of unprotected data flows hitting default-allow rules across observed traffic. Administrators can use this reporting to identify and prioritize remediation of encryption coverage gaps, including restricting or blocking cleartext protocols.

The Security Services Platform and its component services use FIPS 140-2 and FIPS 140-3 validated cryptographic modules for their own communications. Network Detection and Response (NDR) Sensors connect to the SSP using mutual TLS authentication (mTLS), with a dedicated certificate for each sensor signed by an intermediate certificate authority on the SSP. The SSP can be configured to forward log messages to a syslog server over TLS, and Malware Prevention Service remote logging likewise uses TLS to transmit log data to a remote log server. NDR also supports SSL verification for event logs sent over HTTPS. When NDR shares data to the cloud, it anonymizes sensitive customer information before transmission.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides cryptographic protection for data transmitted during disaster recovery operations, covering management communications and replication data flows.

All communications between the PNR server and VMware vCenter (vCenter) instances take place over TLS connections. PNR requires an SSL/TLS certificate, with x509v3 Extended Key Usage indicating TLS Web Server Authentication, as the endpoint certificate for all TLS connections to the PNR server. PNR defaults to the current TLS version for all communication endpoints.

and supports administrative configuration of the minimum acceptable protocol version. Administrators configure the minimum TLS protocol version by editing the `tls_minimum_protocol_version` parameter in the `envoy-proxy-config.json` file; when changing the minimum version, the update must be applied consistently across all occurrences in the system. PNR uses TLS certificates and private keys to protect network communication and authenticate with other servers.

For replication data, vSphere Replication encrypts replication traffic in transit for both new and existing replications. Network encryption is mandatory when using vSphere Replication 9.0.3 and later and is enabled by default. PNR also supports configuring network encryption of replication traffic as an option for replication scenarios where mandatory encryption does not apply automatically. PNR supports protection and recovery of encrypted virtual machines through both array-based and vSphere Replication protection groups, allowing VM disk encryption to persist through the replication process. Recovery of encrypted virtual machines requires that the protected and recovery sites share a common Key Management Server (KMS), or that the KMS clusters at both sites use common encryption keys, to maintain key availability after failover.

Defining the encryption policy for environments with stricter requirements and validating that workload traffic running on protected virtual machines meets confidentiality standards are organizational data-policy decisions.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies TLS-based encryption across multiple communication paths, covering database client connections, management interfaces, service-to-service communication, and data migration traffic. Starting with DSM, the platform enforces FIPS 140-3 compliant cryptographic standards and validates certificates during upload, rejecting unsupported algorithms such as Ed25519.

For database client connections, DSM enforces a minimum TLS protocol version across all supported database engines. PostgreSQL instances enforce a configurable minimum TLS protocol version via the `ssl_min_protocol_version` setting and support certificate-based authentication with CA verification. PostgreSQL replication connections support SSL/TLS encryption with a configurable `sslmode` parameter to secure data in transit between source and target databases, and DSM validates SSL trust before establishing replication. MySQL locks TLS protocol enforcement at the platform level so users cannot weaken it. MySQL has `require_secure_transport` set to ON by default, which requires all client connections to use encrypted transport. MySQL supports FIPS mode via the `ssl_fips_mode` setting. DSM adds SQL Server as a supported database engine; SQL Server clusters use TLS to encrypt client connections, require a minimum TLS version for DSM operator management, and expose the `network.tlsProtocols` engine setting to configure the set of allowed TLS versions.

For management and service-to-service communication, the DSM Provider exposes an HTTPS endpoint. The Consumption Operator requires a TLS certificate for secure communication with the DSM provider. In network-isolated deployments, Consumption Operator image transfers to a private registry support optional TLS certificate authentication. Metrics forwarding from DSM to VCF Operations supports mutual TLS (mTLS) authentication, requiring a client certificate and private key. DSM SMTP settings include an Auto TLS option that establishes a secure connection to the SMTP server.

DSM provides certificate management capabilities to support the TLS infrastructure. Custom certificates are validated for FIPS 140-3 compliance at upload time; accepted key types are ECDSA P-256, ECDSA P-384, and RSA with a minimum key size of 2048 bits, and Ed25519 keys are rejected as non-compliant. Trusted root certificates added through the DSM UI must comply with FIPS requirements.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides native, configurable cryptographic mechanisms to protect the confidentiality of data in transit at both the application data plane and the Controller management plane.

Each virtual service in Avi is associated with an SSL/TLS Profile, which defines the accepted protocol versions, cipher suites, and their priority order. SSL/TLS Profiles are managed at Templates > Security > SSL/TLS Profile in the Controller UI. Predefined profile templates are available, including a System-Standard template, and administrators can create custom profiles to enforce the cipher suites and protocol versions appropriate for their environment. Elliptic Curve (EC) cryptography is available for virtual services and supports Perfect Forward Secrecy with less computational overhead than RSA-based key exchange. TLS persistence state exchanged between Service Engines when a client reconnects is carried in encrypted form.

At the L4 proxy level, the Default-TLS protocol parser can be associated with a virtual service to inspect TLS handshake data using DataScript, supporting selective offload and re-encryption scenarios.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports a PKIProfile custom resource definition that enables certificate-based authentication and encryption for backend service communication. The System-Standard SSL Profile can be applied through the RouteBackendExtension CRD to enable SSL/TLS re-encryption for traffic to backend servers, providing modern cipher suites for Kubernetes ingress and routing scenarios. In VCF environments, the Avi load balancer uses secrets to handle encrypted HTTPS traffic, configured through the VCF IaaS Service Console.

When FIPS mode is enabled on the Avi Controller cluster, all cryptographic operations across the Controller and Service Engines are restricted to FIPS 140-3 approved algorithms. Avi uses the OpenSSL FIPS Provider version 3.1.2 in this mode, which has been validated at FIPS 140-3 Security Level 1 and awarded Certificate #4985 by CMVP. Enabling FIPS mode is a cluster-level configuration that applies uniformly to all cryptographic material handled by the platform. FIPS mode does not support SSL Client Hello events in Avi DataScript, and post-quantum cryptographic capabilities are not available in FIPS mode.

The Avi Controller and Service Engines use SSH for secure management communication. The SE_SECURE_CHANNEL designation classifies traffic between the Controller and Service Engines to maintain a dedicated secure communication channel. Avi also integrates with Let's Encrypt via the ACME protocol to automate certificate issuance and renewal for virtual services, and with hardware security modules such as the Thales Luna HSM for external key management. Remote server file transfer supports Secure Copy Protocol (SCP) and Secure File Transfer Protocol (SFTP). For deployments requiring hardware acceleration, Avi Service Engine integrates with Intel QuickAssist Technology to offload bulk cryptographic operations following SSL/TLS handshake completion.

Avi DataScript exposes cryptographic functions for application-layer use cases. The `avi.crypto.encrypt()` function encrypts data using a caller-provided key, optional initialization vector, and algorithm parameter. The HTTP Cookie Encryption Gateway uses these functions to encrypt cookie values in HTTP responses, protecting session state carried between client and server. The `avi.utils.rand_bytes` function generates cryptographically secure random bytes for token and nonce generation.

Defining which application traffic requires encryption and configuring the virtual service profiles to apply protection at the appropriate boundary are organizational data-policy decisions.

Control PR.DS-10

[Withdrawn: Incorporated into PR.DS-01, PR.DS-02, PR.DS-10] The confidentiality, integrity, and availability of data-in-use are protected

SCF Controls: CFG-02, CRY-01, DCH-01, IAC-21

Aggregate Coverage: Meets

VCF (Meets)

VCF provides multiple layers of data protection controls spanning encryption, storage resilience, backup and recovery, disaster recovery, centralized monitoring, and access management.

For data at rest, vSAN encryption protects data on storage devices so that if a device is physically removed from the cluster, the data remains unreadable. At the virtual machine level, VM encryption protects NVRAM, swap (VSWP), and snapshot (VMSN) files, providing per-VM granularity independent of the underlying storage encryption. For data in transit, vSAN data-in-transit encryption protects data as it moves between hosts and file service inter-host connections within a vSAN cluster, with forward secrecy enforced. TLS protects data in transit between other VCF components. Both vSAN and VM encryption integrate with external Key Management Server (KMS) infrastructure for key lifecycle management, requiring a trust relationship established through certificate and key file exchange. VCF components use FIPS-validated cryptographic modules: NSX cryptographic modules are validated to FIPS 140-3 standards, vSphere uses FIPS-validated cryptographic modules matching the FIPS 140-2 standard, and VCF Automation runs in FIPS-compliant mode by default using FIPS 140-3 validated modules.

vSAN implements erasure coding through RAID-5 storage policies, which split data into blocks with parity information to protect against component failures. vSAN includes failure indication and data rebuild mechanisms that detect storage failures and automatically reconstruct unavailable data. Virtual machines on vSAN datastores can be assigned storage policies that define specific data protection and performance characteristics, giving administrators granular control over how data is protected at the workload level.

VCF supports backup methods for its management components at multiple levels. VMware vCenter file-based daily backups are configured through the vCenter Management Interface for each vCenter instance. vCenter file-based backup supports optional password-based encryption of backup files, and backup files are stored off-appliance on servers accessible via FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB. When vSphere Native Key Provider is configured, vCenter backups contain the Key Derivation Key and must be stored in a secure, access-controlled location. VCF Operations backups support both file-based and image-based methods. NSX Manager backup is configured automatically during the bring-up process. For vSphere Supervisor environments, control plane backup and restore can be performed from the Workload Management UI, and Supervisor control plane backup can also be included as an option in vCenter file-based backup schedules. vSAN Data Protection uses native snapshots stored locally on vSAN Express Storage Architecture (ESA) clusters to help recover virtual machines from operational failure or ransomware attacks.

For Kubernetes workloads, VMware Kubernetes Service (VKS) provides dedicated data protection capabilities built into the VCF platform. VKS cluster node VMs are backed up through Supervisor state backup using the vCenter backup feature available in the vCenter Management Interface, so Supervisor state is covered by the same vCenter backup workflow used for the management plane. When data protection is activated for a VKS cluster, VKS cluster management installs the data protection extension, selected plugins, and Velero on the cluster; activation requires an Organization Administrator or Project Administrator role. Backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. Two backup methods are available: vSphere Plugin Snapshot performs block-level backup writing directly to object storage and is faster for workloads with large numbers of small files, while File System Backup operates at the file system level and supports incremental backups. The vSphere Plugin Snapshot method performs full backups on each run since it does not support changed block tracking, so organizations that require incremental backups should use the File System Backup method. Both methods support stateless and stateful workloads. Backup scope is configurable to the entire cluster, selected namespaces, or specific resources identified by label,

and VKS cluster backups include file system backups in the restore by default. Velero 1.17 supports scheduled backups, allowing organizations to configure automated backup cadences. Backup repositories support deduplication, compression, and encryption of backup data. The Velero Plugin for vSphere backs up and restores both stateless and stateful applications running on vSphere Pods in the Supervisor. VKS Backup and Restore Hooks enable execution of pre- and post-operation scripts for granular control over the data protection lifecycle, supporting application consistency and custom automation during recovery. Cross-cluster restore is available through the Restore from another cluster option in the Data Protection tab of the VCF Automation Tenant Portal. Data protection account credentials are scoped to users with Organization Administrator or Project Administrator roles, restricting who can configure backup target locations; VCF Automation enables platform teams to create target locations pointing to self-provisioned storage environments, supporting both cloud-hosted accounts and on-premises endpoints. VCF Automation also supports snapshotting VM groups, where each member VM receives a distinct snapshot, and restoring a VM group snapshot restores each member of the group.

Kubernetes cluster state is stored in etcd, and two backup methods are available for the etcd datastore: the built-in snapshot method and volume snapshot. The `etcdctl` snapshot save command creates a backup by specifying the endpoint, CA certificate, client certificate, and client key, providing authenticated access to the backup operation. Snapshots can be restored from a snapshot file or from a remaining data directory. During `kubeadm` upgrades, backup folders for etcd state and cluster manifests are written automatically to `/etc/kubernetes/tmp` with timestamped names, providing a recovery point in case of upgrade failure. Storage policy-based data management is available through Kubernetes StorageClass objects that reference vSphere storage policies via Storage Policy Based Management (SPBM); those policies may include encryption settings, allowing organizations to apply consistent encryption-at-rest requirements to persistent volumes through standard Kubernetes StorageClass configuration. CSI-based data protection for VKS requires a validated configuration between VKS and the underlying storage infrastructure.

VKS clusters on the Supervisor also support the Kubernetes VolumeSnapshot API, which provides `VolumeSnapshotContent` and `VolumeSnapshot` resources as a native point-in-time snapshot mechanism for persistent volumes. Volume snapshots can be provisioned dynamically from a `PersistentVolumeClaim` using a `VolumeSnapshotClass` that specifies storage provider parameters and the deletion policy for snapshot content. Restoring from a snapshot is performed by creating a new `PersistentVolumeClaim` with the target `VolumeSnapshot` as its `dataSource`, referenced via the `snapshot.storage.k8s.io` API group. Kubernetes `PersistentVolumes` have a configurable reclaim policy; setting the policy to `Retain` preserves volume data in a `Released` state after the associated `PersistentVolumeClaim` is deleted, allowing administrators to recover or migrate the data before the underlying storage is reclaimed.

Kubernetes Secrets provide a mechanism for storing sensitive configuration data separately from application code, reducing the risk of accidental exposure in container workloads. Applications consuming Secrets from environment variables or mounted volumes should avoid logging secret values in the clear or transmitting them to untrusted parties. Using short-lived Secrets helps limit the impact of accidental or intentional exposure. Kubernetes and applications can take additional precautions with Secrets, such as avoiding writing sensitive data to non-volatile storage.

vSphere APIs for Data Protection provide an integration point for third-party backup software to perform nondisruptive full, differential, and incremental image backups using VMFS snapshot capabilities, without requiring virtual machines to be powered off or placing backup processing overhead on VMware ESX hosts. For virtual machines running supported Microsoft Windows operating systems, these APIs integrate with Microsoft Volume Shadow Copy Services (VSS) to maintain application consistency during backup operations.

VMware Live Site Recovery extends data protection with orchestrated disaster recovery across sites. Replication can be configured with recovery point objectives as low as 60 seconds, with options for network compression, multiple point-in-time recovery, and automatic replication of new disks. vSphere Replication provides configurable RPO settings for VM-level replication to local or remote datastores. Application-level high availability and disaster recovery mechanisms combine real-time availability with sitewide disaster recovery, with data replication to secondary sites providing recovery options in case of catastrophic failure.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, enabling administrators to track the status of data protection controls from a single view. This monitoring layer helps organizations verify that their data protection configurations remain in place and functioning as expected.

For Kubernetes workloads on VKS clusters, volume health status is reported through `volumehealth.storage.kubernetes.io/messages` annotations on `PersistentVolumeClaims`, giving administrators granular visibility into whether individual persistent volumes are accessible.

Management of data protection settings is restricted through role-based access controls. VCF Operations uses privilege-based access controls that restrict visibility based on user roles, limiting which accounts can view sensitive operational data. For VKS clusters, managing data protection requires assignment of an Organization Administrator or Project Administrator role. VCF documentation includes storage security best practices covering securing access to storage devices, implementing storage encryption, and protecting virtual machine data as part of an overall data protection posture.

Selecting which of these data protection mechanisms apply to specific datasets, defining protection policies and recovery objectives, and configuring the relevant features to match those decisions remain organizational responsibilities. VCF supplies the technical mechanisms; organizations define what to protect, to what recovery point, and with which retention and access controls.

VMware Private AI Services (PAIS) contributes to data protection by applying access controls, authenticated connectivity, and credential management to AI workloads, model repositories, knowledge bases, and associated data assets that the platform handles.

The Model Gallery uses Harbor project access capabilities to restrict access to the sensitive data used to train and tune models. PAIS integrates with Harbor registries as a model storage backend, requiring authentication and certificate-based trust for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, so organizations using an alternate backend can apply equivalent registry-level access controls.

Access to PAIS itself is gated by OIDC group-based authorization. Only user accounts that are members of the groups specified in the `authorizedGroups` configuration can access the service, and the OIDC group claim name is configurable to match the identity provider in use. PAIS uses a CA trust bundle for secure communication with external services and databases, and supports CA trust bundle management for secure connections with external registries and content management systems by uploading or referencing certificate files. VCF Automation Provider Management requires trusted certificate import for vCenter validation before integration with PAIS, restricting integration paths to validated endpoints.

For retrieval-augmented generation, PAIS Knowledge Bases link to external data sources through stored credentials, scoping indexed-data retrieval to defined service identities, and Data Indexing and Retrieval handles automatic collection and indexing of updates from those linked sources over time. Personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources. SharePoint data sources for PAIS Knowledge Bases require user name and password authentication, with support limited to SharePoint On-Premises deployments.

PAIS observability also flows through authenticated paths: the Grafana integration uses OIDC provider authentication for metrics visualization, and LLM traces can be sent to an OpenTelemetry Collector for monitoring.

PAIS DSM database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes. A default storage policy can be selected to define storage placement for the database in PAIS, and storage policy and VM class selections should be chosen to suit RAG workloads when the database supports RAG use cases.

Organizations connecting external data sources or registries to PAIS should examine the capabilities and parameters of those integrations and approve only those suitable for use, since unreviewed connectors can affect what data models access or expose.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to data protection controls by providing network-level security mechanisms that protect data in transit and restrict unauthorized network access to systems where data is stored or processed.

The vDefend distributed firewall (DFW) enforces microsegmentation policies at the vNIC level, restricting which workloads can communicate with data stores, databases, and application tiers. By segmenting the data center network into isolated security zones, vDefend limits the blast radius of a compromise and restricts lateral movement toward systems that hold sensitive data. Administrators define granular firewall rules based on workload identity, security tags, and application-level attributes, limiting access to data repositories to authorized services. Identity Firewall extends policy enforcement to user identity, allowing administrators to define access controls based on which authenticated user initiated the connection rather than solely the source workload, strengthening data access controls in environments with user-based authorization requirements. Security policies are defined, propagated, and enforced across Bare Metal servers through the Security Services Platform (SSP), extending microsegmentation protections beyond virtualized workloads to physical infrastructure connected to the environment.

The SSP includes Security Intelligence, which identifies risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP. This visibility allows administrators to detect and remediate unencrypted data flows that could expose sensitive information in transit. Security Intelligence administrators can monitor traffic leakage between environments, establish exceptions, and implement lockdown protection rules to control inter-environment flows. Security Intelligence also enables administrators to generate policy recommendations and deploy them in monitor-before-enforcement mode, allowing observation of traffic patterns before applying restrictive rules. The SSP summary panel displays the number of services that are fully protected, partially protected, or not protected, giving administrators a dashboard view of segmentation coverage gaps across the environment.

IDS/IPS profiles attach to Distributed Firewall and Gateway Firewall rules to inspect east-west and north-south network traffic for signatures and behaviors associated with data theft, command-and-control communication, and exploitation of vulnerabilities in data-handling services. In vDefend, IDS/IPS signature rules support storing TLS/SSL certificates on disk for forensic analysis and threat investigation, providing durable artifacts for post-incident review of potential data exfiltration events.

Malware Prevention profiles attach to DFW and Gateway Firewall rules and can be configured to send files to the cloud for detailed analysis or to process files locally without cloud connectivity, accommodating environments with data-residency or air-gap requirements. Malware Prevention collects file analysis data including file hash submissions and assigns an Analyst UUID to each submission to track its analysis lifecycle. The Malware Prevention dashboard displays trends of malicious, suspicious, and suppressed file events across the data center, and file verdict filtering allows operators to focus on specific verdict categories such as malicious-only views.

Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to cloud services, providing a built-in data privacy mechanism for environments that enable cloud-assisted threat detection.

These network security controls complement the data-at-rest encryption, backup, replication, and access management capabilities provided by other VCF components. vDefend does not perform data encryption, classification, backup, or recovery itself, but it protects the network paths and access patterns through which data is stored, replicated, and retrieved.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication-based data protection for virtual machine workloads across sites. Protection groups allow administrators to organize virtual machines and datastores under consistent snapshot and replication policies at scale, covering both local recovery via vSAN snapshots and cross-site recovery via vSphere Replication or array-based replication. Protection group membership can be modified after creation, and virtual machines can be automatically enrolled for protection using storage tag selection on designated datastores, reducing manual overhead in maintaining protection coverage across a growing environment.

PNR introduces an immutability mode for protection groups that, when enabled, prevents the data protection group from being modified or deleted. This mechanism allows administrators to safeguard protection configurations against inadvertent or unauthorized changes. PNR Health monitoring provides consolidated visibility into data protection service health, operation

issues for local and replication snapshots, storage utilization, and protection group membership changes, giving administrators a current view of protection posture across the environment.

Site Recovery Manager (SRM) integrates with vSphere Replication to provide orchestrated failover with configurable recovery point objectives, giving organizations control over acceptable data loss thresholds for protected workloads. PNR supports additional site topologies, including shared recovery site configurations where protected site resources are mapped to isolated datacenters, networks, folders, and datastores on the recovery site. Inventory mappings allow administrators to define resource configurations once and apply them consistently across protection groups.

vSAN Snapshots and Replication is a native, integrated snapshot-based backup capability for virtual machines running on vSAN datastores, managed through the vSphere Client. It provides VM restore and clone operations from existing snapshots, supporting both rapid recovery from operational failures and ransomware recovery scenarios. Test failover operations allow administrators to validate that recovery configurations are functional before an actual recovery event occurs.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides several mechanisms that support data protection for managed database instances, covering PostgreSQL, MySQL, and SQL Server databases.

The most direct contribution is DSM's automated backup framework, which administrators can enable on a per-database basis or through data service policies. When configured, DSM performs scheduled full and incremental backups of database content and stores them in S3-compatible object storage at a configurable backup location. Backup retention is configurable (backup-retention-period), and DSM retains backups of deleted databases until the configured retention period expires, supporting recovery from accidental deletion. For point-in-time recovery, DSM restores a backup to a newly created database VM with a user-specified name and datastore location, and can target the most recent timestamp or a specific point in time. DSM archives binary logs in backup storage as part of its backup protection mechanism. Administrators can also initiate manual on-demand backups of primary PostgreSQL databases to safeguard data before high-impact operations or as immediate protection after major changes. For PostgreSQL multi-site deployments, DSM performs a full backup automatically during a promotion event before resuming the regular schedule.

Data service policies give administrators control over backup behavior across all databases governed by a policy. Policies can require that databases have automated backups enabled, allow users to opt in, or disallow automated backups entirely. The allowed-backup-locations setting in the data service policy restricts users to selecting from approved backup locations, reducing the risk of backup misconfiguration. Policies can be enforced across multiple tenants and across different namespaces and namespace labels, supporting consistent data protection posture in multi-tenant deployments. A Compliance tab on data service policies displays compliance reports and allows administrators to expand each policy violation to view the noncompliant database, data service, and namespace, giving administrators visibility into where data protection requirements are not being met. In 9.1, data service policies extend to SQL Server databases in addition to MySQL and PostgreSQL.

DSM implements role-based access control that separates administrative and user-level database access. DSM Admins can create, monitor, and manage all data services in the environment; DSM Users can only manage and monitor the data services they own. This access model limits who can modify backup configurations and policy settings. Infrastructure policies govern which storage resources are available for database VMs, including CPU, memory, storage policies, IP pool, and VM classes, giving administrators control over the storage environment in which data resides.

Control plane recovery requires that a Provider Backup Repo has been configured at installation time. If the Provider VM fails, the restore-provider command restores it to the latest timestamp. In the VCF Automation context, tenants can perform point-in-time restores directly through the VCF Automation UI, broadening restore access to self-service scenarios.

One limitation applies: if an incremental backup in the backup chain is deleted, DSM cannot restore the full data; a successful restore from an incremental chain requires the last full backup and all following incremental backups. Organizations must protect the integrity of the backup chain through access controls on the backup storage.

DSM provides configurable backup, recovery, and policy enforcement mechanisms for managed database instances. The broader data protection program requires organizational decisions about backup schedules, retention periods, backup storage security, and off-site management that DSM does not prescribe on its own.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several application-layer mechanisms that support the implementation of data protection controls within a VCF deployment.

At the transport layer, Avi performs TLS termination with configurable SSL/TLS profiles for connections between clients and virtual services. The SSL/TLS protocol at the Avi proxy secures data in transit by reducing the risk of unauthorized parties reading or modifying information transferred between end users and application workloads. SSL/TLS profiles are configurable through the Avi Controller UI under Templates > Security > SSL/TLS Profile. Management interface access is further restricted through configuration of allowed ciphers and HMACs for management sessions.

Avi integrates with Hardware Security Modules (HSMs), including the Thales Luna (formerly SafeNet Luna) HSM, for cryptographic key storage and management. This allows organizations to store the private keys used in TLS termination and other cryptographic operations within a dedicated hardware key store rather than in software. The Avi Controller also stores sensitive configuration data encrypted in a local database, and backup files can be protected with a passphrase that encrypts the keys included in the backup. Backup and restore operations verify that the FIPS mode of the backup configuration matches the target controller environment.

Avi's Web Application Firewall (WAF) applies both positive and negative security models to inspect and filter HTTP/HTTPS application traffic. WAF policies support ModSecurity rules for application protection and a Positive Security model that learns application behavior to define allowed request patterns. The Application Rules service, available through the Avi Cloud Console, provides WAF rules specifically designed to address known application vulnerabilities including CVE-tracked issues, with automatic updates to keep rules current. WAF configuration is accessible through the Controller UI under Templates > Security > WAF Policy.

Avi DataScript provides a programmable layer for enforcing additional data protection behaviors at the proxy boundary. DataScripts are Lua-based scripted rules that allow inspection and manipulation of client HTTP requests and server HTTP responses, supporting content switching, redirection, header manipulation, and logging. DataScript can be used to enforce cipher suite policies by denying clients connecting with unsupported ciphers. DataScript also supports blocklist-based access control by checking client IP addresses against named IP groups and terminating connections from blocked sources while logging the violation. XML-based DataScript use cases can extract client identifiers from request payloads and compare them against configured string groups to restrict access to authorized clients.

Access to Avi configuration objects is restricted through granular role-based access control (RBAC). Avi supports extended granular RBAC using label-based markers to restrict user permissions to specific resources based on key-value pair matching. The RBAC model differentiates Read and Write access across objects such as SSL/TLS Profiles, PKI Profiles, Authentication Profiles, IP Address Groups, and Health Monitors, allowing organizations to scope access to data protection-relevant configuration to authorized roles only. Roles can also be scoped to tenants through label group associations.

These mechanisms address data protection at the application delivery layer. Broader organizational data protection controls, including data classification policies, data handling procedures, and data-at-rest protection beyond the Avi proxy boundary, require organizational governance and platform-level capabilities that Avi does not provide as an application delivery controller.

Control PR.DS-11

Backups of data are created, protected, maintained, and tested [Withdrawn: Moved to PR.DS-11]

SCF Controls: BCD-11, BCD-11.1, BCD-11.5, BCD-11.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in backup capabilities across its management components, workload layers, and storage subsystems, supporting organizations in meeting their Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).

Management component backups

VCF supports backup of all core management components. VMware vCenter supports both file-based and image-based backup methods, with file-based daily backups configured through the vCenter Management Interface of each vCenter instance. vCenter file-based backup and restore supports FTP, FTPS, HTTP, HTTPS, SFTP, NFS, or SMB as the backup server protocol. vCenter file-based backup optionally encrypts backup files using an encryption password that must be provided during restore; because vCenter backups contain the Key Derivation Key used for vSphere encryption, backup files should be stored on a secured backup server with appropriate access controls. VCF Operations similarly supports file-based and image-based backup methods. NSX Manager uses file-based backup, which VCF Operations configures automatically during the initial bring-up process. File-based backup jobs for VCF Operations and vCenter must be configured separately after deployment.

Scheduled backups should be implemented to prepare for critical failure scenarios, upgrade events, or certificate updates of management components. To capture a consistent state across related components, VCF requires creating a series of coordinated backup jobs that run simultaneously across component nodes. Simultaneous backups of component nodes help ensure that the backed-up state is logically consistent, reducing the need for integrity remediation during a restore. On-demand manual backups can be taken after a successful recovery operation or after a scheduled backup failure. VCF Operations backup is also configured to take a backup on state change, providing an additional layer of protection when configuration changes occur.

The backup file server stores backups from all NSX Manager or Global Manager nodes, and NSX includes a script to automatically delete old backups to manage storage consumption. NSX Global Manager backups should be periodically cleaned up to avoid excessive storage consumption on the backup file server. VCF Operations for Networks can store backups on local storage, retaining up to five backup files, or upload them to SSH or FTP servers. An initial on-demand backup should be performed after configuring VCF Operations to verify that backups complete successfully before relying on scheduled jobs. Sufficient storage capacity must be provisioned to accommodate backup data across all components.

Backup integrity and restore procedures

Backup integrity verification in VCF centers on version compatibility. When restoring a vCenter instance from a file-based backup, administrators must have a valid backup that matches the exact version of the vCenter appliance being restored to. VCF Operations must be available before restoring vCenter, and vCenter must be available before restoring VCF Operations, establishing a defined dependency order for restore operations. These dependencies require careful sequencing during recovery to restore the management plane to a consistent state.

Workload-level data protection

For workload-level data protection, VCF provides several mechanisms. Changed Block Tracking (CBT) tracks modified disk blocks on virtual machines, enabling incremental backups that reduce backup windows and storage requirements. VMware vSphere Storage APIs for Data Protection (VADP) provide a standardized interface for third-party backup solutions to integrate with VCF. vSphere Supervisor supports backup of VM Service VMs through backup partner solutions based on VADP, and if a VADP-based backup solution is deployed on the default management cluster, the solution must be properly started and operational before starting up or shutting down VCF. Quiesced snapshots are appropriate for automated or periodic backups of VM Service virtual machines, as they capture a consistent state before the backup operation proceeds.

VCF Automation supports snapshotting a VM group to create an object that references distinct snapshots for each member VM; restoring a VM group snapshot restores each member of the group.

vSphere Supervisor control plane backup and restore can be performed using vCenter file-based backup and restore from the Workload Management UI. For applications that provide their own backup capabilities, VCF documentation recommends using application-specific backup methods rather than relying on filesystem backup alone.

vSAN data protection and snapshots

vSAN Data Protection allows snapshots to be managed through protection groups with configurable snapshot retention policies and scheduling intervals. The native Snapshot Service is supported by vSAN Express Storage Architecture (ESA) but not by vSAN Original Storage Architecture (OSA). Native snapshots in vSAN ESA are much faster than traditional vSphere snapshots because a base VMDK and its snapshots are contained in one vSAN object rather than being separate objects, allowing more frequent backups and faster recovery. In vSAN OSA, snapshots are separate vSAN objects. The vSAN Distributed File System Snapshot can be used by third-party backup vendors to copy changed files incrementally to a different physical location. The vSAN Snapshot Service API provides programmatic access for operations including creating linked clones from snapshots and restoring deleted virtual machines.

VMware Kubernetes Service backup

VMware Kubernetes Service (VKS) and the Supervisor layer extend VCF's backup capabilities to containerized workloads, cluster state, and persistent volume data. VKS Supervisor backup and restore for cluster node VMs is activated through the vCenter backup feature available in the vCenter Management Interface, integrating Kubernetes cluster state backup with the same management-plane backup infrastructure used for other VCF components.

For workload-level backup of VKS clusters, the platform supports three complementary methods: vSphere Plugin Snapshot (CSI Snapshot), File System Backup (FSB), and the Velero Plugin for vSphere. The vSphere Plugin Snapshot method produces crash-consistent, block-level backups of persistent volumes through the Container Storage Interface (CSI) layer and supports snapshot direct access and network traffic offload; it is faster and less resource-intensive than filesystem backup for complex filesystems with large numbers of small files, making it well-suited for production databases and high-IOPS applications. The File System Backup method operates at the filesystem level, supports NFS volumes and incremental backups where unchanged files are not re-transferred between runs, and offers backup repository features including deduplication, compression, and encryption; it is appropriate for legacy volumes with non-CSI storage. The Velero Plugin for vSphere can back up and restore both stateless and stateful applications running on vSphere Pods in the Supervisor. Platform teams can use both FSB and CSI Volume Snapshots within a single protection strategy to maximize data durability across workload types. VKS cluster backup supports opt-in and opt-out approaches for FSB volume backup, giving operators control over which volumes are included in filesystem-level operations. Third-party backup software can also integrate with VKS clusters using the standard Kubernetes CSI snapshot API: tools create a VolumeSnapshot object from the target PVC, materialize a temporary PVC from the snapshot, and use a Data Mover pod to transfer data to the backup destination. Kubernetes implements Persistent Volume Claim as Snapshot Source Protection, which blocks deletion of in-use API objects while a snapshot is in progress, reducing the risk of partial or inconsistent backup data. Kubernetes also supports provisioning a new PersistentVolumeClaim directly from a VolumeSnapshot by specifying the snapshot as the dataSource, enabling volume-level point-in-time recovery without requiring a full application restore workflow.

VKS cluster management provides a Create backup wizard that allows users to create backups immediately or schedule backups of specified data resources in a cluster. Backup scheduling supports immediate execution, recurring schedule formats with targeted start times, or custom cron expressions; automated backup scheduling can also be configured using the Velero CLI with the `velero schedule create` command, specifying the interval or cron expression for recurring backup operations. For on-demand backups outside a scheduled window, the `velero backup create` command backs up Kubernetes resources and persistent volume data for stateful workloads, with support for per-namespace targeting and volume snapshot inclusion. VKS cluster backups can retain a maximum of 720 backups per backup schedule; when high-frequency schedules are required, the retention period should be reduced to remain within this limit. Backup schedules can be edited, paused, or deleted through the management interface. File system backups are included in the restore by default, and snapshot data can be moved to a

separate backup storage location. Before defining a backup, a target location and credential must be created; if a data protection credential is deleted, scheduled backups relying on that credential will fail on their next execution, creating a detectable gap in backup execution history that administrators should monitor. Creating a backup schedule requires the Organization Administrator or Project Administrator role.

VKS cluster backup and restore operations are managed through the VCF Automation Tenant Portal under Manage & Govern > VCF Services > Kubernetes Management > Clusters > Data Protection. The portal provides restore operations on specific backups, and a dedicated cross-cluster restore capability in the Data Protection tab enables restoring backups from a source cluster to a different target cluster. VKS cluster management supports backup and restore of an entire cluster, selected namespaces from the backup, or specific resources identified by a label. The CloneFromSnapshot CRD includes a status.phase field that tracks restore progress through multiple phases, providing operational visibility during restore operations.

For Kubernetes cluster state, etcd is the backing store for all Kubernetes objects, and clusters using etcd should have a backup plan. etcd backup can be performed using the built-in etcdctl snapshot save command by specifying the endpoint, CA certificate, and client credentials, or by taking a volume snapshot of the etcd storage volume when the underlying storage supports it. etcd snapshots can be restored from a previous snapshot file or from the remaining data directory, and cross-patch-version restores are supported. During kubeadm upgrades, automatic backup folders are written to /etc/kubernetes/tmp containing etcd data and manifests as a recovery point.

Backup automation through APIs

VCF exposes backup automation through its APIs, including the RecoveryBackupJobBackupRequest data structure for specifying backup location, protocol, authorization, and database scope, as well as the RecoveryBackupSchedulesUpdateSpec for programmatically managing backup schedules.

Disaster recovery planning

For disaster recovery planning, VCF supports application disaster recovery with data replication to a secondary site. Organizations should plan and test disaster recovery strategies regularly to meet their RTO and RPO targets. VCF Operations provides integration with VCF Protection and Recovery for periodic test runs to validate that existing recovery plans work with the underlying infrastructure and configured RPO limits. Application disaster recovery may result in some data loss during failover depending on the configured RPO.

VCF directly provides the mechanisms for creating recurring backups, managing retention, and supporting RTO/RPO requirements through multiple backup and snapshot methods. However, organizations must establish backup policies, define RTO/RPO targets, schedule regular restore testing, and maintain backup infrastructure such as external storage and third-party backup solutions to fully satisfy this control.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) provides backup and restore capabilities for the vDefend control plane, covering firewall rules, microsegmentation policies, IDS/IPS configurations, Bare Metal server information, tokens, and all associated security data managed by the platform. These backups protect against data loss from hardware or software malfunctions, data corruption, malware incidents, or unintentional deletion.

SSP supports recurring backup schedules configurable through the Backup Schedule interface, with frequency options ranging from 6 hours to 720 hours (30 days), as well as weekly scheduling by selecting the day and time. Recurring backups can be activated or deactivated by toggling the Recurring setting. Best practice guidance recommends scheduling backups during periods of low platform usage to minimize operational impact. A backup should also be performed before executing scale-out operations on the SSP cluster, to preserve the current configuration state before significant topology changes. Backup data is encrypted with a passphrase and transmitted to an SFTP server. Adequate storage must be verified on the backup server before activating recurring backups, and the platform must be in a healthy state for backup operations to proceed. Backup is also blocked if NSX is not onboarded to SSP.

SSP maintains a Backup History section that displays the status of each backup operation, showing "Completed" when the operation succeeds. When backup or restore operations enter a failed state, pod logs provide detailed error messages,

including database query failures and volume attachment errors, to support troubleshooting. Restoration supports deploying the backed-up configuration onto the same SSP instance or a new instance, enabling recovery when the current instance is in a non-recoverable state. Restoration requires that the same NSX instance that was onboarded at the time of backup be used, and that the platform be deployed on the same vSAN datastore and build version as the initial installation. Certificate consistency between backup and restored environments must be maintained to avoid disruptions to NDR Sensor connectivity.

These capabilities address the backup component of this control for vDefend's own configuration and policy data. vDefend does not back up general workload data or application-level information; those responsibilities fall to the broader VCF platform's replication, snapshot, and backup mechanisms, including vSAN Data Protection, Protection and Recovery (PNR), and integration with third-party backup providers. vDefend's contribution is limited to protecting the security policy and configuration data that defines the network security posture of the environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides replication, snapshot, and recovery testing capabilities that support recovery point and recovery time objectives for protected workloads.

vSphere Replication delivers host-based continuous replication with RPO configurable from 1 minute to 24 hours, set via a slider during replication configuration. PNR uses the configured RPO to determine the most recent available state to which virtual machines are recovered during disaster recovery. vSAN snapshots and replication is a native, integrated snapshot-based backup solution for VMs running on vSAN datastores, managed through the vSphere Client, and supports RPO as low as 1 minute. Snapshot retention schedules support hourly, daily, weekly, and monthly snapshots with a maximum retention duration of three years. Predefined retention templates are available for quick configuration of RPO and snapshot retention parameters. Array-based replication supports configuring replication schedule, frequency, and RPO through VM storage policies, depending on the storage array's implementation.

PNR replication classes are preconfigured with an RPO that defines the acceptable amount of data loss after a disaster. In deployments using VCF Automation integration, replication classes can be assigned at the organization level.

Cyber Recovery, the cloud-based recovery component within PNR, uses incremental snapshots that transfer only modified or new data to cloud backup. This design enables detection of ransomware encryption by comparing entropy rates between normal snapshots and snapshots containing suspect data. Ransomware recovery plans in Cyber Recovery support predefined retention templates for configuring snapshot RPO and retention parameters.

PNR's own configuration is protected through backup settings that specify a datastore path, enable or disable the backup scheduler, set a retention period, and schedule backup frequency and time. PNR REST APIs can be configured to export and upload configuration data to a datastore on a daily basis. PNR also maintains internal database backups for audit and recovery purposes, covering the replication manager database (srmdb), recovery manager database (vrmsdb), and snapshot service database (snapservice).

Recovery plan testing is the integrity verification mechanism for protected data. During disaster recovery execution, PNR first attempts storage synchronization; if that succeeds, it uses the synchronized storage state to recover virtual machines to their most recent available state per the configured RPO. RPO violation dashboards in VCF Operations report violation counts for incoming and outgoing replications, enabling monitoring of whether replication is meeting defined targets.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides a built-in backup framework for managed PostgreSQL, MySQL, and SQL Server databases, giving administrators and database owners the tools to establish recurring backup schedules aligned with organizational recovery objectives.

Backup configuration is available at database creation and can be modified at any time through the database settings interface. Administrators activate automated backups using the Enable Automated Backups toggle (also exposed as Enable Backups in MySQL flows), specify a backup location pointing to S3-compatible object storage, and define a retention period. PostgreSQL databases support both full and incremental backups, and SQL Server databases support full and differential backup schedules. SQL Server adds a Log Backup Frequency setting in Advanced Settings with a maximum value of 30

minutes that is directly related to the Recovery Point Objective for that database. Backup schedules are expressed as cron expressions and can be customized per database or applied at the policy level.

Data Service Policies provide centralized backup governance for databases deployed within a namespace. A policy can include named backup jobs specifying backup type and schedule, and the policy backup requirement setting offers three options: Require Automated Backups (databases must have automated backups), Allow Automated Backups (users can choose to activate or deactivate automated backups), and Disallow. Allowed backup locations are defined in the policy via the `allowedBackupLocations` parameter, restricting where backups can be stored. When multiple policies apply, DSM aggregates the backup schedules into a single effective backup policy per database. High Availability clusters require automated backups to be enabled in order to provision databases, helping ensure that recoverable copies exist for replicated topologies.

DSM also supports on-demand backups for primary PostgreSQL databases, independent of the configured automated schedule, which is useful for capturing a point-in-time snapshot before a significant change. Backup storage is managed centrally through the Settings pane Storage Settings tab, which displays Database Backup Storage buckets and allows administrators to add or edit object storage targets. Provider-level control plane backups are stored in a designated Provider Backup Repo bucket configured during Provider VM setup, and recovery of the Provider VM from backup uses the `restore-provider` command with a `pgbackrest.conf` path to restore the appliance to the latest timestamp.

DSM retains automated backups of deleted databases until the configured retention period expires. When a database with configured backups is deleted, the system automatically creates an archive containing all collected backups that remains available in the Archives tab for the remainder of the retention period, allowing recovery of inadvertently deleted databases. Administrators can also manually delete retained backups of deleted databases when they are no longer needed.

Point-in-time recovery is supported from configured backup storage, restoring a backup at a specified date and time to a newly created database VM with a user-specified name and datastore location. The restore function is also accessible through the VCF Automation UI for tenant users. If any incremental backup in a chain is deleted, DSM cannot restore data to points in time that depended on that backup, and a restore from an incremental chain requires the last full backup plus all following incremental backups. Maintaining a balanced schedule of full and incremental backups reduces the risk of a gap in the recovery chain.

DSM provides operational validation of the backup target through the backup storage repository alert, which checks connection and operational status, bucket name, certificate expiration date, credentials, and sufficient available space in the repository. This helps surface configuration drift or storage failures that would otherwise compromise recoverability.

Satisfying this control fully requires that the organization define RTOs and RPOs for each database workload, configure backup policies accordingly, and periodically test restoration to verify that backup data is valid and recovery objectives are achievable. DSM provides the technical backup infrastructure and operational checks on the backup target; RTO and RPO definition and end-to-end backup integrity testing are organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) includes a built-in backup and restore capability for the Avi Controller configuration database. The configuration database defines all clouds, virtual services, users, tenants, and related entities. Protecting it is the primary mechanism for recovering the Avi control plane after a Controller failure.

Backup operations can be created on-demand or on a recurring schedule via the Controller web UI, CLI (using the `export` command), or REST API (using the `/api/scheduler/` endpoint). The scheduler supports configurable frequency units, including hourly, daily, and weekly intervals, with the run mode set to periodic. For single-node Controller deployments, enabling periodic external configuration backups is mandatory; the product documentation states that external backups are required to handle recovery from a complete VM or disk failure.

Avi supports multiple backup storage targets. Local backups are stored directly on the Controller with a configurable retention count, configured via the "Enable Local Backups (On Controller)" setting. Remote backups are transferred over Secure Copy Protocol (SCP) or Secure File Transfer Protocol (SFTP) to an off-Controller server, configured via the "Enable Remote Server Backup" setting. In 9.1, configuration backups can also be stored in Amazon S3 buckets as an additional remote storage

target. When deployed as part of VCF, Avi backups are stored by default on the same server used for VCF Operations appliance backups; the recommended best practice is to configure an external SFTP server as the backup destination. VCF Operations can be used to configure the external backup server and storage path for Avi backups. Product guidance also recommends storing backups with clear labeling that includes version and date information.

Before a restore proceeds, Avi performs a set of pre-restore checks to validate the backup image. In 9.1, these checks include verification of backup configuration version compatibility, presence of all file objects from the configuration on the Controller, FIPS mode consistency between the backup and the current Controller environment, Service Engine attachment verification, system configuration validation, and patch verification. All checks must pass before the restore operation is allowed to proceed.

Restore operations can be performed via the CLI (import command with the `keep_uuid` option to restore configuration to an empty Controller), the web UI, or the REST API restore endpoint. The API method accepts a configuration file and a passphrase parameter to decrypt an encrypted backup; the passphrase must match the one used when creating the backup. Restore operations generate system reports tracking operation state, start time, end time, duration, and total checks completed. The Controller metrics database can also be exported and imported separately to prevent loss of metrics data during version rollbacks. If all three nodes of a Controller cluster are permanently unavailable, recovery must be performed using a backup and restore procedure.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling traffic redirection to a healthy site when a primary site fails. Avi GSLB adaptive replication mode also protects against configuration errors propagating across data centers by preventing faulty configuration objects from being replicated to follower sites.

The Avi backup and restore capability covers the Controller configuration plane. Application data, workload VM images, and the broader RTO/RPO framework depend on organizational process decisions and on the underlying VCF platform for VM-level data protection (see VCF Coverage).

Control PR.IR

[Withdrawn: Moved to PR.IR-04] [Withdrawn: Incorporated into PR.IR-01] Networks and environments are protected from unauthorized logical access and usage. The organization's technology assets are protected from environmental threats. Mechanisms are implemented to achieve resilience requirements in normal and adverse situations. Adequate resource capacity to ensure availability is maintained. [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Moved to PR.IR-02] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01] [Withdrawn: Moved to PR.IR-03]

SCF Controls: GOV-01, GOV-01.1, RSK-01, SEA-01, SEA-01.1, SEA-01.2, SEA-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several centralized management capabilities that support organization-wide implementation of cybersecurity and data protection controls, though it does not constitute a complete governance, risk, and compliance (GRC) platform on its own.

VCF Automation Organizations offer a centralized structure for access control and resource sharing across the platform. Organization administrators can distribute infrastructure and configure access management to groups within their organizations using the organization management functionality in VCF Automation. IT teams and cloud service providers can monitor resource usage, control permissions, and provide managed services through VCF Automation Organizations while maintaining security through network isolation. The Organization Administrator role can create and manage policies centrally, providing a single point of control for security policy definition and enforcement within the VCF environment. VCF Automation also supports role-based access control through group membership and role assignment management in its Access Control interface.

VCF SSO and the VCF Identity Broker provide centralized authentication and identity management across VCF components. The Identity Broker acts as a centralized authentication source, and VCF SSO integrates with it to manage authentication for VCF instance components. VCF Operations integrates with VCF SSO for centralized user and group authentication and management, and provides VCF SSO and centralized management of federated access through unified identity configuration. Role-based access control (RBAC) enforces consistent authorization policies across the stack: vCenter allows fine-grained control over authorization with permissions and roles by associating a role to a user or group on objects in the vCenter object hierarchy, and vSAN similarly supports RBAC and permissions management.

For network security management, NSX Manager provides centralized policy and grouping constructs. Security groups are defined and managed through NSX Manager, and in multi-site deployments, global security groups can be created on an NSX global manager and consumed by associated local managers, enabling consistent group definitions across geographically distributed environments. vDefend policies on Tier-0 and Tier-1 gateways are managed centrally from NSX Manager. For distributed firewall enforcement, microsegmentation, and advanced security policy at the vNIC level between workloads, VMware vDefend is a separate product that extends NSX networking; when deployed, its policies are managed from the same NSX Manager interface. PowerShell cmdlets such as `InvokePatchSecurityPolicyForDomain` are available for programmatic creation of security policies, supporting automation of security policy deployment at scale. The VCF distributed switch includes built-in security controls that help protect network traffic, providing baseline security capabilities that are centrally configured through vCenter.

VCF Operations provides continuous monitoring and operational visibility across the environment. Its configuration management capabilities include scheduled drift detection for vCenter and cluster objects, enabling proactive detection of configuration deviations from the desired state. Administrators can view and compare configuration drifts and identify settings that have changed. VCF Log Management provides centralized log aggregation that collects logs from all VCF components, including vCenter, ESX, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. The VCF Log Management cluster is the central point for log collection, aggregation, and analysis for all VCF instances within a given fleet.

VCF Operations is the lifecycle management layer, coordinating configuration and updates across VCF components from a single management plane. It simplifies provisioning new infrastructure, managing passwords, installing certificates, and patching or upgrading infrastructure components.

An auditor evaluating this control should verify that the organization has designated VCF Automation Organizations as the centralized structure for access control and policy management, that VCF SSO and Identity Broker are configured for centralized authentication across all components, that NSX Manager security policies are defined and applied consistently across all workload domains, that VCF Operations drift detection is scheduled and monitored, and that VCF Operations is used as the authoritative source for component lifecycle operations. The auditor should also confirm that these VCF-native capabilities are integrated into the organization's broader cybersecurity governance framework, as VCF addresses the technical control implementation layer but does not replace the need for organizational policies, risk management processes, and compliance monitoring tools.

VMware vDefend (Contributes)

VMware vDefend contributes to centralized management of cybersecurity controls by providing a unified management plane for network security policy across the virtualized data center. vDefend's centralized capabilities span firewall policy, intrusion detection and prevention, malware prevention, and traffic analytics, all managed through a single interface or, for multi-site deployments, through Global Manager.

The vDefend distributed firewall (DFW) allows administrators to define, organize, and enforce microsegmentation policies from a central management plane. Policies are organized into pre-defined categories (Infrastructure, Environment, Application) that provide a logical structure for managing large rule sets. Administrators can create security groups based on VM attributes, IP sets, or dynamic criteria, and apply east-west firewall rules to those groups consistently. When rules are published, they are pushed from the management plane to every host in the targeted clusters, so enforcement is uniform across the environment without requiring per-host configuration. For multi-site or federated deployments, NSX Federation Security provides centralized management of security policies across all sites through Global Manager. Distributed and Gateway Firewall policies created from Global Manager are synchronized to Local Managers at each registered site. Administrators can define custom regions within a federated deployment and assign specific Security and Network policies to those regions, enabling policy scoping at geographic or administrative boundaries.

In 9.1, vDefend extends centralized policy management to VPC-scoped workloads in VCF Automation. Five system-defined security strategies are available for VPC security posture: VPC Isolation, VPC Isolation with essential services, VPC External Connectivity, VPC Secure Connection, and NONE. Project Administrators can select a pre-defined security posture that enforces Secure by Default principles, rather than manually configuring firewall rules for individual VPCs. The Distributed Firewall supports Organizations in VCF Automation for multi-tenant policy isolation, and the Organization Admin (Tenant Admin) role holds full access to manage Transit Gateway firewalls, distributed firewalls, and all VPC gateway firewalls within that tenant context.

Distributed IDS/IPS and Malware Prevention are centrally managed. IDS/IPS profiles and signature sets are configured centrally and distributed to hosts, and Distributed Malware Prevention rules follow the same publish model as firewall policies. In multi-site environments, IDS/IPS signature management is centralized through Global Manager, which distributes updates to multiple Local Managers and supports both automatic update and manual version control.

Security Services Platform provides centralized network security analytics and visibility through Security Intelligence, which analyzes traffic flows across the data center and generates policy recommendations, including recommended security policies and security groups, that administrators can review and publish as Distributed Firewall rules. The platform includes segmentation planning tools that help administrators design and implement microsegmentation strategies from a central vantage point. Security Services Platform also extends centralized policy management to bare metal servers, where security policies are defined, propagated, and enforced through the same centralized model as virtualized workloads.

Role-based access control within vDefend and Security Services Platform governs who can perform security operations. Security Services Platform defines five roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector, each with differentiated permissions for policy publishing, traffic visualization, and configuration changes.

Configuration of Distributed Firewall policies requires explicit DFW Manage/View rights and rights for Groups and Services, so access to centralized policy management is controlled at the permission level.

vDefend's centralized management is scoped to network security controls. Organization-wide centralized management of all cybersecurity and data protection processes, including identity management, compute hardening, compliance tracking, and governance, requires the broader VCF platform and external GRC systems.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) helps organizations achieve disaster recovery requirements for virtualized workloads by orchestrating virtual machine recovery at a secondary site. Recovery plans can be created with configurable properties to support disaster recovery operations, and replication classes are preconfigured with a Recovery Point Objective (RPO) that defines the acceptable amount of data loss after a disaster. PNR orchestrates both array-based replication and host-based replication.

Recovery plans run under both planned circumstances for migration and unplanned circumstances for disaster recovery. Operators can test recovery plans before using them in production to validate recovery procedures. Multi-region deployments with separate management domains can be designed to contain the impact of a disaster event to one region.

PNR exposes role-based access through specific roles such as SRM Recovery Plans Administrator and SRM Recovery Administrator, and role assignments must be configured on both the primary and secondary sites for consistent access control across the recovery environment. In Protection and Recovery for VCF Automation, Organization Administrators can perform multi-tenant disaster recovery operations on behalf of project administrators and project advanced users.

Operational visibility is provided through VCF Operations dashboards for Protection and Recovery. The Protection Groups dashboard surfaces a critical health status when a serious issue occurs with a protection group or its replication, and PNR classifies health findings into Error, Warning, and Info categories so operators can diagnose, troubleshoot, and remediate issues that affect resilience.

Cyber Recovery, part of the PNR suite, extends resilience to cyber incident scenarios. Integrated CrowdStrike vulnerability analysis applies the Exploitability and Predictive Risk Technology (ExPRT) rating to recommend immediate remediation of Critical vulnerabilities, timely remediation of Medium-severity vulnerabilities, and scheduled remediation of Low-severity findings. vSphere Replication supports point-in-time recovery for cyber resilience.

Recovery sites should be located in a facility that is unlikely to be affected by environmental, infrastructure, or other disturbances that affect the protected site. Decisions about acceptable RPO thresholds, recovery site selection, and operational processes for declaring and executing recovery remain organizational responsibilities outside the product.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to resilience through technical mechanisms at both the management plane and database levels, addressing both normal operations and adverse conditions such as node failures and site outages.

The DSM Provider Appliance, which hosts the management plane, relies on vSphere High Availability for its own resilience. DSM requires that HA be activated on VMware vCenter clusters hosting database workloads as a prerequisite for infrastructure policy compliance, making HA an enforced platform dependency rather than an optional configuration.

At the database level, DSM PostgreSQL deployments include a monitor node that orchestrates automatic failover. When the primary database node fails, the monitor node promotes the replica to primary without manual intervention. For environments requiring high availability across multiple failure domains, DSM provides a Cross vSphere Cluster HA topology that distributes PostgreSQL instances across multiple vSphere clusters, offering the highest availability and resilience for those configurations.

For cross-site resilience, DSM supports multi-site deployments for PostgreSQL databases. Before establishing a multi-site deployment, administrators must configure remote replication on the primary instance and retrieve the Certificate Authority from the primary instance to add it to the DSM Provider VM that will host the secondary. Users with the DSM User role must manually establish trust between primary and secondary instances. Secondary PostgreSQL instances support read-only connections while replication is active. DSM requires that the values of `max_connections`, `max_worker_processes`,

max_wal_senders, max_prepared_transactions, and max_locks_per_transaction on the secondary database be equal to or greater than those on the primary. When a site fails, DSM provides a switchover workflow that promotes the secondary instance to primary. DSM also provides a failback workflow that reverses the roles and restores the system to a fully operational state. During a switchover, DSM validates trust of the new primary database certificate before redirecting secondary instances. DSM requires that organizations define disaster recovery requirements, including whether to enable multi-site replication, before creating a PostgreSQL database.

DSM extends high availability to MySQL deployments. DSM supports MySQL HA clusters and read replicas as distinct deployment topologies. A Cross vSphere Cluster HA configuration distributing a primary and two replicas across three vSphere clusters provides the highest availability for MySQL in multi-cluster environments. DSM requires that disaster recovery requirements be defined before creating a MySQL database.

For recovery operations, restoring a PostgreSQL cluster to a different DSM control plane should use resources equal to or greater than those of the source cluster to maintain stability.

DSM's technical mechanisms support but do not substitute for organizational resilience programs. Organizations must define recovery time and recovery point objectives, document and test disaster recovery procedures, and maintain runbooks for failover and failback operations.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms spanning the control plane, data plane, and geographic distribution layers. Organizations can use these mechanisms to satisfy resilience requirements for their application delivery infrastructure.

Control-plane resilience is achieved through the Avi Controller cluster. Production deployments use a Controller cluster that maintains quorum and fault tolerance, allowing the control plane to remain available when one node is unavailable. Controller clusters can be deployed across two availability zones, with documented failure scenarios and recovery actions for each topology. When running a single-node Controller, the Backup and Restore feature must be used for disaster recovery. After a storage failure event, the Controller is restored from a configuration archive, and at least one Service Engine controller IP must match a previous controller IP to enable Service Engines to reconnect to the Controller after restoration. The Controller's backup and restore capability also supports configuration migration across Controller instances.

For cross-site application failover, Avi Load Balancer includes Global Server Load Balancing (GSLB). Avi GSLB provides resilience when loss of a data center or network connection occurs, and supports an active disaster recovery deployment mode in which a geographically remote site receives application traffic when the primary site is unavailable. Where a deployment has only one active site, at least one geographically remote cloud should be designated as the GSLB disaster recovery target.

At the data plane, Service Engine distribution and scaling provide resilience at the workload level. A scaled-out virtual service experiences no more than performance degradation if a single Service Engine in the group fails, making the scaled-out model preferable to legacy high availability modes for resilience. Availability Zones can be configured within each Service Engine Group, with two or three zones recommended per group. Each Availability Zone should be defined around a distinct fault domain associated with shared power supplies, shared networking devices, or other common infrastructure, and maps specific VMware vCenter (vCenter) instances, hosts, and datastores that share that fault domain. In multi-vCenter deployments, this spreads data-plane capacity across multiple infrastructure failure boundaries.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) federation architecture supports designation of a leader cluster and multiple member clusters for disaster recovery and multi-cluster coordination. This extends Avi's resilience model to multi-cluster Kubernetes deployments, allowing application traffic management to continue across cluster failures.

In VCF deployments, the Cloud Console's Central Licensing feature maintains a global capacity pool that removes the need for duplicate licenses in disaster recovery scenarios, reducing licensing barriers to activating DR sites.

Achieving the resilience requirements in this control is an organizational process. The organization must define recovery objectives, validate failover procedures through testing, maintain configuration archives, and coordinate resilience activities across the underlying VCF platform. Avi's control-plane HA, GSLB, Availability Zone configuration, and AMKO multi-cluster federation capabilities directly support that process without substituting for it.

Control PR.IR-01

[Withdrawn: Incorporated into PR.IR-01] Networks and environments are protected from unauthorized logical access and usage [Withdrawn: Incorporated into PR.AA-03, PR.AA-05, PR.IR-01] [Withdrawn: Incorporated into PR.AA-06, PR.IR-01]

SCF Controls: NET-01, NET-02, SEA-01, SEA-02

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in mechanisms for implementing and governing network security controls across the infrastructure stack, spanning virtual switching, network segmentation, policy management, role-based access control, audit logging, and documented hardening procedures.

NSX, the networking component of VCF, delivers a hierarchical security policy framework organized around domains, security policies, and individual rules. Each rule can be configured with action, direction, IP protocol, source groups, destination groups, services, and scope, providing administrators a structured and repeatable model for defining network security posture. Security policies are organized into categories (Emergency, Infrastructure, Environment, Application) so that multiple administrators can create and manage policies without conflicts or overrides. Firewall rules within each category are organized into sections, supporting logical grouping and ordered evaluation. This hierarchical structure supports both centralized governance and delegated administration, allowing organizations to maintain consistent security standards while enabling application teams to manage policies within their assigned boundaries.

VCF's network security governance model is built on role-based access control (RBAC) that spans networking and security functions. NSX Projects and VPCs support scoped role assignments including VPC Admin, Security Admin, Network Admin, Security Operator, and Network Operator roles. These roles can be assigned at the project or VPC level, enabling least-privilege access to network security configuration. A VPC Admin has full access to networking and security objects within their assigned VPC, while Enterprise Admins retain overarching control. NSX Advanced Network Management extends RBAC to specific networking components including static routes, locale services, segments, segment profiles, IP address pools, forwarding policies, DNS, DHCP, load balancing, and NAT. This separation of duties allows organizations to delegate day-to-day network security operations while retaining centralized oversight.

The NSX VPC workflow provides a structured mechanism for implementing network security controls at the application level. Application owners can add subnets inside their assigned VPC and configure security policies to meet workload requirements without dependency on the Enterprise Admin. VPC Admins and Security Admins add security policies within the VPC to address the security requirements of connected workloads. Default East-West firewall rules are activated automatically when an appropriate security license is applied and can be adjusted as needed. This self-service model, bounded by RBAC, allows security policy implementation to scale across the organization while maintaining governance guardrails.

VCF includes multiple layers of network security controls. VMware vDefend, a separately licensed product that extends NSX, provides Distributed Firewall enforcement across deployment and operational scenarios, while its Gateway Firewall provides perimeter security. Context profiles and Layer 7 access profiles enable firewall rules with application-level and domain-based attributes for both distributed and gateway firewall enforcement. For containerized workloads, the Antrea Container Network Interface (CNI) plugin in VMware Kubernetes Service (VKS) enforces Kubernetes NetworkPolicy at the namespace and pod level. The AntreaPolicy feature gate enables AntreaNetworkPolicy and ClusterNetworkPolicy objects that extend standard NetworkPolicy with richer Layer 4 rule sets; traffic not explicitly permitted is blocked by default when a policy applies to a pod. The Antrea NetworkPolicyStats feature gate collects enforcement statistics, giving operators visibility into which policies are matching traffic and at what volume to support operational monitoring and periodic policy review. A Kubernetes cluster must provide and enforce NetworkPolicy for network security controls to be effective.

The VKS networking layer within VCF integrates directly with the broader NSX security framework. Supervisors using NSX VPC networking operate in the system VPC while VKS clusters reside in vSphere Namespace VPCs, providing topology-level isolation between the management plane and workload clusters. NSX VPC pod IP pools are configured as Private, restricting

direct external accessibility of pod addresses. Antrea EgressSeparateSubnet allows egress traffic from specific workloads to originate from a subnet distinct from the default node subnet, supporting more granular traffic segmentation. The Network Control Plane (NCP) component bridges Kubernetes networking objects with NSX, realizing VirtualNetwork, VirtualNetworkInterface, and LoadBalancer resources for the VKS control plane; communication between Supervisor and NSX is secured using TLS. Kubernetes control plane services communicate using certificates by default, and connections from nodes and pods to the control plane are secured by default and can run over untrusted networks. Supervisor networking architecture requires a deliberate deployment-time choice: NSX with embedded load balancer, or vSphere Distributed Switch with external load balancer. This choice determines which network security mechanisms are available downstream, and organizational procedures should reflect which path is in use. VKS Cluster Management Custom Policies provide a governance mechanism that should be reviewed and updated to ensure policy logic reflects current security and operational requirements. The Argo CD Supervisor Service deployment implements network segmentation and firewall rules to secure communication between its components. Organizations operating service meshes alongside VKS gain OSI Layer 7 network policies based on workload identity and mutual TLS encryption for pod-to-pod traffic, providing an additional isolation layer beyond namespace boundaries.

At the virtual infrastructure layer, vSphere Distributed Switches provide centralized management of virtual networking, handling traffic for all associated hosts in a data center. Distributed switches support network segmentation using Private VLAN (PVLAN) and VLAN-based SPAN for distributed port mirroring. Network segmentation is built into the VCF architecture: management traffic, vMotion, and storage traffic are isolated on separate networks. Network I/O Control allocates bandwidth to traffic types based on share values, and the Storage Traffic Separation network profile creates dedicated vSphere Distributed Switches with separate physical NICs for storage traffic isolation. NSX distributed port groups and uplink port groups support Traffic Filtering and Marking policies configurable at the port level, providing additional granularity for layer 2 security controls. ESX hosts also support IPsec for VMkernel network communication, with security associations and policies configurable via `esxcli network ip ipsec` commands, supporting both transport and tunnel mode with upper layer protocol filtering for tcp, udp, icmp6, or any traffic.

vSphere Lifecycle Manager enforces desired-state configuration for hosts and clusters, applying and remediating configuration to match the defined software specification. This helps detect and address configuration drift that could weaken network security posture, and the remediation process can be managed programmatically through the vSphere Automation API.

VCF publishes security baselines through the Security Configuration Guide and DISA STIGs. The NSX Security Configuration Guide provides documented procedures for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes. Recommendations cover configuring strong authentication, implementing RBAC, and securing administrative access. NSX security best practices address creating and managing security groups, implementing distributed firewalling, configuring security policies, and enforcing microsegmentation to control network traffic. Security Technical Implementation Guides for Supervisor and VMware Kubernetes Release (VKr) components are available to provide hardening guidance for VKS deployments, extending the documented security baseline to the containerized workload layer. These documented hardening procedures, aligned with industry-standard best practices, give organizations a baseline for developing and updating their network security control procedures.

Audit logging supports ongoing governance by recording security policy changes with full traceability. NSX firewall audit logs capture the user performing the operation, the module name, operation type, operation status, and modified resource details including the security policy display name, identifier, path, and rule configurations. This audit trail enables organizations to track who changed network security policies, what was changed, and when, supporting both compliance review and change management processes.

Programmatic management capabilities, including PowerCLI cmdlets such as `InvokePatchSecurityPolicyForDomain` for creating distributed firewall policies, support infrastructure-as-code approaches to network security governance, enabling version-controlled and repeatable policy deployment.

VMware vDefend (Meets)

VMware vDefend provides the technical enforcement layer that underlies Network Security Control (NSC) implementation, though the procedural and governance aspects of developing and updating NSC procedures remain organizational responsibilities.

Security Services Platform enables monitoring of traffic after publishing assets and security policies to NSX Manager, allowing administrators to refine policies and adjust security posture based on observed traffic behavior. Security Intelligence Policy Recommendations correlate observed traffic patterns within the NSX environment to assist with enforcing more dynamic security policies; these recommendations can be reviewed and published directly to the Distributed Firewall (DFW) rule set. The Security Intelligence infrastructure classification feature identifies compute entities providing network infrastructure services in the NSX environment, supporting structured policy development around infrastructure traffic categories.

Dynamic NSGroups enable DFW and Gateway Firewall (GFW) rules to update automatically as workloads are deployed or modified in the environment. Security Services Platform provides a workflow to import data center hierarchy from CSV, which translates IP addresses to virtual machines, tags those VMs, and creates NSX groups necessary for segmentation planning. This supports the initial development of network security control structures from existing IP-based inventories.

vDefend DFW security posture is applied to VPCs through system-defined Security Profiles accessible in NSX Manager. When a Security Profile is applied to a VPC in VCF Automation, the system automatically generates and realizes system-managed DFW rules within the NSX Project space. DFW policies extend to Bare Metal servers, with Bare Metal server groups, vDefend DFW policies, and rules defined in NSX Manager and managed through Security Services Platform. Malware Prevention Service is configured through the IDS/IPS & Malware Prevention Setup wizard, which provides a guided sequence of steps to prepare the data center.

NSX Federation Security provides centralized management of security policies across multiple sites through a Global Manager, supporting consistent policy enforcement in distributed and multi-site environments. The Security Overview dashboard in NSX Manager displays threat detection and response features, a visual summary of the overall security configuration, and the capacity of NSX objects, giving administrators visibility into the state of deployed network security controls.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to Network Security Controls implementation through its infrastructure policy framework, which governs how databases are placed on the network and which network resources they may access.

DSM's architecture requires that network connectivity be provided through vSphere Distributed Switches (VDS) or NSX Virtual Distributed Switches (N-VDS). During initial setup, administrators configure IP pools that define the address space available for database deployment. IP pools may be created either during infrastructure policy definition or in advance, with each pool specified using a Subnet Prefix in CIDR notation that controls network vs. host address allocation. The vSphere administrator is responsible for regulating database IP assignment through this mechanism, tying database network placement to explicitly defined, administrator-controlled address ranges rather than allowing ad-hoc assignment.

Infrastructure policies aggregate network configuration choices alongside compute and storage settings into named policies that govern how databases are provisioned. The DSM administrator UI provides an Infrastructure Policies view that displays all configured policies and their associated resources, including IP pools, VM classes, CPU, memory, and storage policies, giving administrators continuous visibility into how network resources are allocated across the environment. Defining infrastructure policies is advised to provide full visibility into infrastructure usage by DSM users.

DSM actively detects conflicting network configurations. When it detects overlap between Supervisor infrastructure policy IP ranges and system configuration networks, it generates a NetworkOverlapFound alert and requires resolution before provisioning operations can proceed. Infrastructure policies should be updated to remove overlapping networks that may cause provisioning failures.

DSM supports custom certificate management for the Provider VM, including an IP-inclusive certificate style where the Subject Alternative Name can list one or more IP addresses and optionally FQDNs, aligning certificate identity with the addresses assigned through IP pool management. For SQL Server databases, administrators can specify the allowed TLS versions for client connections using the network.tlsProtocols custom engine setting in the data service policy.

DSM is a database-as-a-service platform rather than a dedicated network security tool. It does not provide firewalls, intrusion detection, or network traffic inspection; those capabilities are provided by VMware vDefend, which is a separate product. Developing and updating organizational procedures for network security controls is an organizational responsibility that DSM does not fulfill. The network isolation and address management controls DSM exposes are implemented through the underlying VCF platform infrastructure, and the broader NSC governance framework must be established by the organization.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer network security policy mechanisms that help organizations implement network access controls at the application delivery boundary. These Avi-native capabilities operate at the Virtual Service level and give administrators structured objects for defining, governing, and updating access rules as requirements change.

Avi's Network Security Policy evaluates incoming client traffic based on network-level parameters and determines whether a connection should be accepted, discarded, or rate-limited. IP Group-based access control lists applied per Virtual Service are the most scalable method for implementing network-layer ACLs, allowing administrators to specify which source addresses may reach individual application services. Policies can be created and modified through the Avi Controller CLI using the `configure networksecuritypolicy` command, and updated programmatically through the REST API using the Modify Network Security ACL endpoint and IP Group UUID references.

Starting with Avi Load Balancer version 32.1, NSX security groups can be used directly in both HTTP Policies and Network policies. Security groups defined once in NSX are reused across Avi Virtual Service security policies, removing the need to manually maintain IP address lists in Avi. When an IP address changes in NSX, the update propagates automatically to Avi Load Balancer, keeping Virtual Service security policies current without manual intervention. This integration provides a unified governance model where network security group membership is managed centrally in NSX and reflected automatically in Avi policy enforcement.

Avi's DDoS Policy detects and mitigates Layer 4 through Layer 7 network attacks through the Network Security policy framework, providing additional network security control at the application delivery layer.

Within the broader VCF platform, NSX provides underlay routing and network infrastructure for Avi Service Engines. East-west firewall enforcement between application tiers is provided by VMware vDefend, a separate product that extends the platform's network security posture beyond what Avi provides at the application proxy boundary.

Satisfying this control fully requires the organization to document procedures for governing and updating network security controls across the Avi tier and the broader platform, assign ownership of Avi policy objects, and establish change management processes covering both Avi Network Security Policies and VCF-layer controls.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control PR.IR-02

The organization's technology assets are protected from environmental threats [Withdrawn: Moved to PR.IR-02]

SCF Controls: BCD-01, PES-01, PES-07, PES-07.5, PES-08, PES-09, SEA-01.2, THR-09

Aggregate Coverage: Contributes

VCF (Contributes)

The VCF platform's VMware Kubernetes Service (VKS) and vSphere Supervisor layer provide Kubernetes-native mechanisms that contribute to resilience requirements for containerized workloads in both normal operation and adverse conditions. Resilience for workloads running on VKS is not automatic; it depends on how administrators configure the cluster and how application teams structure their deployments.

At the workload level, VKS supports ReplicaSets and Deployments that distribute pod replicas across available nodes. Applications running in production should be replicated to mitigate involuntary disruptions such as node failures or hardware faults, and Kubernetes cloud-native design accounts for arbitrary container restarts without service loss. StatefulSets provide ordered, stable pod identity and persistent storage supports for stateful workloads that require them, while DaemonSets maintain per-node infrastructure services across the cluster. Kubernetes liveness probes detect broken application states and trigger automatic container restarts when health checks fail, and readiness probes restrict traffic routing to pods until they report as ready.

For planned disruptive operations such as node drains, OS upgrades, and cluster maintenance, VKS supports Pod Disruption Budgets (PDBs). A PDB defines the minimum number of replicas that must remain available during a voluntary disruption. When cluster administrators or automated processes perform disruptions on nodes, PDBs coordinate changes so that no more than an acceptable number of pods are unavailable at once, enabling disruption-tolerant maintenance with minimal replica impact.

For batch workloads implemented as Kubernetes Jobs, VKS supports `podFailurePolicy`, which defines rules for handling retrievable and non-retrievable pod failures based on container exit codes and pod conditions. Specifying a failure policy helps avoid unnecessary pod retries when a failure is definitively non-retrievable, using custom pod conditions to distinguish failure categories. Jobs using `podFailurePolicy` require the pod template's `restartPolicy` to be set to `Never`.

VKS supports topology-aware scheduling through vSphere Zones and Fault Domains. Supervisor can be assigned to vSphere Zones to provide high availability and fault tolerance, and VKS clusters can be provisioned across specific availability zones. For production environments where availability is a priority, at least three failure zones should be selected, with control plane components including the API server, scheduler, etcd, and cluster controller manager replicated across them. Failure domains, also known as vSphere Fault Domains, are defined and managed by the vSphere administrator when creating vSphere Zones in Supervisor. Stateful workloads using vSAN Data Persistence can also run on a multi-zone Supervisor to achieve cluster-level high availability.

At the node level, VKS supports MachineHealthCheck, which monitors node health and triggers automated remediation when nodes become unhealthy. The `unhealthyLessThanOrEqualTo` parameter controls when remediation fires: remediations are only triggered if the number of unhealthy machines is at or below a configured threshold, which helps prevent runaway remediation during partial cluster failures. The `unhealthyConditions` array defines the specific node conditions, statuses, and timeout durations that trigger remediation. The `remediation.maxInFlight` parameter on MachineDeployments controls how many concurrent node remediations occur simultaneously, expressed as an integer or percentage. VKS Cluster Management Policy Insights provide health alerts for infrastructure-level failures that prevent policy enforcement, such as an unhealthy policy operator or a failed Gatekeeper installation, giving administrators visibility into cluster health degradation.

VCF Operations monitors Kubernetes cluster health metrics including node status and kubelet status, providing visibility into cluster health from the platform management layer. The Network Inventory feature supports viewing per-node health conditions including MemoryPressure, PIDPressure, DiskPressure, and the Ready state, giving operators visibility into

resource constraints that could affect workload availability. Supervisor cluster infrastructure component pods such as etcd and kube-apiserver record restart events and uptime duration, supporting health monitoring and troubleshooting of the cluster infrastructure layer.

Achieving resilience requirements involves organizational decisions that go beyond what VKS configures by default. Teams must determine appropriate replica counts, define PDB policies, select and validate failure zones, test disruption scenarios, and document expected disruption tolerance levels for their workloads.

VMware vDefend (Contributes)

VMware vDefend contributes to achieving resilience requirements by maintaining continuous network security enforcement during both normal operations and failure scenarios. While the broader resilience story for VCF spans compute, storage, and disaster recovery infrastructure, vDefend addresses the network security dimension: firewall policies, microsegmentation, IDS/IPS inspection, and threat prevention must remain operational through failures and recovery events for the overall resilience posture to hold.

The vDefend distributed firewall (DFW) enforces security policies at the vNIC level of each virtual machine. Because policies are applied at the hypervisor rather than at a centralized appliance, they follow workloads automatically during live migration and are re-established when virtual machines restart on surviving hosts after a failure. This architecture means that microsegmentation boundaries and firewall rules remain intact through host maintenance windows, load-balancing migrations, and unplanned host failures without requiring manual reconfiguration or policy re-application.

For site-level resilience, NSX Federation Security maintains a consistent security posture across multiple locations. During disaster recovery events and workload migrations between sites, NSX Federation Security synchronizes firewall rules, security groups, and policy definitions so that the security framework established at the primary site is preserved at the recovery site. This reduces security gaps during the period when workloads are transitioning between sites or running at a secondary location.

The Security Services Platform (SSP), which hosts vDefend's centralized management and analytics functions, offers several resilience mechanisms. For host-level failures, VMware recommends deploying SSP with vSphere HA enabled so that failed management components are automatically restarted on surviving hosts. For storage-level resilience, SSP can be deployed on a vSAN stretched configuration, which protects SSP data from multiple host failures within a single site and facilitates quick recovery from site failures. SSP supports backup and restore operations to recover its own configuration and state; backup operations require the platform to be in a healthy state, and administrators should verify certificate consistency between backup and restore environments to avoid NDR Sensor disruptions. SSP cluster health monitoring tracks NetworkUnavailable, DiskPressure, and Ready conditions with a 5-minute timeout threshold for remediation, enabling automated detection of degraded cluster conditions. After restoring a backup in a disaster recovery or in-place scenario, Agent health status must be verified as Up on Bare Metal servers before the platform is considered operational. Administrators should also back up the SSP system before performing scale-out operations to allow recovery if expansion encounters issues.

vDefend also provides operational resilience through its threat response capabilities. Intelligent Assist offers two remediation strategies to help security teams respond to threats while maintaining the broader security posture: the Targeted Strategy applies surgical, lower-risk remediation with potentially lower effectiveness, while the Comprehensive Strategy selects the broadest available response for more effective remediation with potentially lower safety implications for connected workloads. Intelligent Assist remediation policy rules are not enabled by default and must be manually enabled by an analyst or administrator after due diligence and verification, providing deliberate control over automated response actions. Objects generated during remediation that encounter errors require manual cleanup in Intelligent Assist.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) helps organizations achieve disaster recovery requirements for virtualized workloads by orchestrating virtual machine recovery at a secondary site. Recovery plans can be created with configurable properties to support disaster recovery operations, and replication classes are preconfigured with a Recovery Point Objective (RPO) that defines the acceptable amount of data loss after a disaster. PNR orchestrates both array-based replication and host-based replication.

Recovery plans run under both planned circumstances for migration and unplanned circumstances for disaster recovery. Operators can test recovery plans before using them in production to validate recovery procedures. Multi-region deployments with separate management domains can be designed to contain the impact of a disaster event to one region.

PNR exposes role-based access through specific roles such as SRM Recovery Plans Administrator and SRM Recovery Administrator, and role assignments must be configured on both the primary and secondary sites for consistent access control across the recovery environment. In Protection and Recovery for VCF Automation, Organization Administrators can perform multi-tenant disaster recovery operations on behalf of project administrators and project advanced users.

Operational visibility is provided through VCF Operations dashboards for Protection and Recovery. The Protection Groups dashboard surfaces a critical health status when a serious issue occurs with a protection group or its replication, and PNR classifies health findings into Error, Warning, and Info categories so operators can diagnose, troubleshoot, and remediate issues that affect resilience.

Cyber Recovery, part of the PNR suite, extends resilience to cyber incident scenarios. Integrated CrowdStrike vulnerability analysis applies the Exploitability and Predictive Risk Technology (ExPRT) rating to recommend immediate remediation of Critical vulnerabilities, timely remediation of Medium-severity vulnerabilities, and scheduled remediation of Low-severity findings. vSphere Replication supports point-in-time recovery for cyber resilience.

Recovery sites should be located in a facility that is unlikely to be affected by environmental, infrastructure, or other disturbances that affect the protected site. Decisions about acceptable RPO thresholds, recovery site selection, and operational processes for declaring and executing recovery remain organizational responsibilities outside the product.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to resilience through technical mechanisms at both the management plane and database levels, addressing both normal operations and adverse conditions such as node failures and site outages.

The DSM Provider Appliance, which hosts the management plane, relies on vSphere High Availability for its own resilience. DSM requires that HA be activated on VMware vCenter clusters hosting database workloads as a prerequisite for infrastructure policy compliance, making HA an enforced platform dependency rather than an optional configuration.

At the database level, DSM PostgreSQL deployments include a monitor node that orchestrates automatic failover. When the primary database node fails, the monitor node promotes the replica to primary without manual intervention. For environments requiring high availability across multiple failure domains, DSM provides a Cross vSphere Cluster HA topology that distributes PostgreSQL instances across multiple vSphere clusters, offering the highest availability and resilience for those configurations.

For cross-site resilience, DSM supports multi-site deployments for PostgreSQL databases. Before establishing a multi-site deployment, administrators must configure remote replication on the primary instance and retrieve the Certificate Authority from the primary instance to add it to the DSM Provider VM that will host the secondary. Users with the DSM User role must manually establish trust between primary and secondary instances. Secondary PostgreSQL instances support read-only connections while replication is active. DSM requires that the values of `max_connections`, `max_worker_processes`, `max_wal_senders`, `max_prepared_transactions`, and `max_locks_per_transaction` on the secondary database be equal to or greater than those on the primary. When a site fails, DSM provides a switchover workflow that promotes the secondary instance to primary. DSM also provides a fallback workflow that reverses the roles and restores the system to a fully operational state. During a switchover, DSM validates trust of the new primary database certificate before redirecting secondary instances. DSM requires that organizations define disaster recovery requirements, including whether to enable multi-site replication, before creating a PostgreSQL database.

DSM extends high availability to MySQL deployments. DSM supports MySQL HA clusters and read replicas as distinct deployment topologies. A Cross vSphere Cluster HA configuration distributing a primary and two replicas across three vSphere clusters provides the highest availability for MySQL in multi-cluster environments. DSM requires that disaster recovery requirements be defined before creating a MySQL database.

For recovery operations, restoring a PostgreSQL cluster to a different DSM control plane should use resources equal to or greater than those of the source cluster to maintain stability.

DSM's technical mechanisms support but do not substitute for organizational resilience programs. Organizations must define recovery time and recovery point objectives, document and test disaster recovery procedures, and maintain runbooks for failover and failback operations.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms spanning the control plane, data plane, and geographic distribution layers. Organizations can use these mechanisms to satisfy resilience requirements for their application delivery infrastructure.

Control-plane resilience is achieved through the Avi Controller cluster. Production deployments use a Controller cluster that maintains quorum and fault tolerance, allowing the control plane to remain available when one node is unavailable. Controller clusters can be deployed across two availability zones, with documented failure scenarios and recovery actions for each topology. When running a single-node Controller, the Backup and Restore feature must be used for disaster recovery. After a storage failure event, the Controller is restored from a configuration archive, and at least one Service Engine controller IP must match a previous controller IP to enable Service Engines to reconnect to the Controller after restoration. The Controller's backup and restore capability also supports configuration migration across Controller instances.

For cross-site application failover, Avi Load Balancer includes Global Server Load Balancing (GSLB). Avi GSLB provides resilience when loss of a data center or network connection occurs, and supports an active disaster recovery deployment mode in which a geographically remote site receives application traffic when the primary site is unavailable. Where a deployment has only one active site, at least one geographically remote cloud should be designated as the GSLB disaster recovery target.

At the data plane, Service Engine distribution and scaling provide resilience at the workload level. A scaled-out virtual service experiences no more than performance degradation if a single Service Engine in the group fails, making the scaled-out model preferable to legacy high availability modes for resilience. Availability Zones can be configured within each Service Engine Group, with two or three zones recommended per group. Each Availability Zone should be defined around a distinct fault domain associated with shared power supplies, shared networking devices, or other common infrastructure, and maps specific VMware vCenter (vCenter) instances, hosts, and datastores that share that fault domain. In multi-vCenter deployments, this spreads data-plane capacity across multiple infrastructure failure boundaries.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) federation architecture supports designation of a leader cluster and multiple member clusters for disaster recovery and multi-cluster coordination. This extends Avi's resilience model to multi-cluster Kubernetes deployments, allowing application traffic management to continue across cluster failures.

In VCF deployments, the Cloud Console's Central Licensing feature maintains a global capacity pool that removes the need for duplicate licenses in disaster recovery scenarios, reducing licensing barriers to activating DR sites.

Achieving the resilience requirements in this control is an organizational process. The organization must define recovery objectives, validate failover procedures through testing, maintain configuration archives, and coordinate resilience activities across the underlying VCF platform. Avi's control-plane HA, GSLB, Availability Zone configuration, and AMKO multi-cluster federation capabilities directly support that process without substituting for it.

Control PR.IR-03

Mechanisms are implemented to achieve resilience requirements in normal and adverse situations

[Withdrawn: Moved to PR.IR-03]

SCF Controls: BCD-01, SEA-01, SEA-01.2, SEA-02

Aggregate Coverage: Contributes

VCF (Contributes)

The VCF platform's VMware Kubernetes Service (VKS) and vSphere Supervisor layer provide Kubernetes-native mechanisms that contribute to resilience requirements for containerized workloads in both normal operation and adverse conditions. Resilience for workloads running on VKS is not automatic; it depends on how administrators configure the cluster and how application teams structure their deployments.

At the workload level, VKS supports ReplicaSets and Deployments that distribute pod replicas across available nodes. Applications running in production should be replicated to mitigate involuntary disruptions such as node failures or hardware faults, and Kubernetes cloud-native design accounts for arbitrary container restarts without service loss. StatefulSets provide ordered, stable pod identity and persistent storage supports for stateful workloads that require them, while DaemonSets maintain per-node infrastructure services across the cluster. Kubernetes liveness probes detect broken application states and trigger automatic container restarts when health checks fail, and readiness probes restrict traffic routing to pods until they report as ready.

For planned disruptive operations such as node drains, OS upgrades, and cluster maintenance, VKS supports Pod Disruption Budgets (PDBs). A PDB defines the minimum number of replicas that must remain available during a voluntary disruption. When cluster administrators or automated processes perform disruptions on nodes, PDBs coordinate changes so that no more than an acceptable number of pods are unavailable at once, enabling disruption-tolerant maintenance with minimal replica impact.

For batch workloads implemented as Kubernetes Jobs, VKS supports `podFailurePolicy`, which defines rules for handling retrievable and non-retrievable pod failures based on container exit codes and pod conditions. Specifying a failure policy helps avoid unnecessary pod retries when a failure is definitively non-retrievable, using custom pod conditions to distinguish failure categories. Jobs using `podFailurePolicy` require the pod template's `restartPolicy` to be set to `Never`.

VKS supports topology-aware scheduling through vSphere Zones and Fault Domains. Supervisor can be assigned to vSphere Zones to provide high availability and fault tolerance, and VKS clusters can be provisioned across specific availability zones. For production environments where availability is a priority, at least three failure zones should be selected, with control plane components including the API server, scheduler, etcd, and cluster controller manager replicated across them. Failure domains, also known as vSphere Fault Domains, are defined and managed by the vSphere administrator when creating vSphere Zones in Supervisor. Stateful workloads using vSAN Data Persistence can also run on a multi-zone Supervisor to achieve cluster-level high availability.

At the node level, VKS supports MachineHealthCheck, which monitors node health and triggers automated remediation when nodes become unhealthy. The `unhealthyLessThanOrEqualTo` parameter controls when remediation fires: remediations are only triggered if the number of unhealthy machines is at or below a configured threshold, which helps prevent runaway remediation during partial cluster failures. The `unhealthyConditions` array defines the specific node conditions, statuses, and timeout durations that trigger remediation. The `remediation.maxInFlight` parameter on MachineDeployments controls how many concurrent node remediations occur simultaneously, expressed as an integer or percentage. VKS Cluster Management Policy Insights provide health alerts for infrastructure-level failures that prevent policy enforcement, such as an unhealthy policy operator or a failed Gatekeeper installation, giving administrators visibility into cluster health degradation.

VCF Operations monitors Kubernetes cluster health metrics including node status and kubelet status, providing visibility into cluster health from the platform management layer. The Network Inventory feature supports viewing per-node health conditions including MemoryPressure, PIDPressure, DiskPressure, and the Ready state, giving operators visibility into

resource constraints that could affect workload availability. Supervisor cluster infrastructure component pods such as etcd and kube-apiserver record restart events and uptime duration, supporting health monitoring and troubleshooting of the cluster infrastructure layer.

Achieving resilience requirements involves organizational decisions that go beyond what VKS configures by default. Teams must determine appropriate replica counts, define PDB policies, select and validate failure zones, test disruption scenarios, and document expected disruption tolerance levels for their workloads.

VMware vDefend (Contributes)

VMware vDefend contributes to achieving resilience requirements by maintaining continuous network security enforcement during both normal operations and failure scenarios. While the broader resilience story for VCF spans compute, storage, and disaster recovery infrastructure, vDefend addresses the network security dimension: firewall policies, microsegmentation, IDS/IPS inspection, and threat prevention must remain operational through failures and recovery events for the overall resilience posture to hold.

The vDefend distributed firewall (DFW) enforces security policies at the vNIC level of each virtual machine. Because policies are applied at the hypervisor rather than at a centralized appliance, they follow workloads automatically during live migration and are re-established when virtual machines restart on surviving hosts after a failure. This architecture means that microsegmentation boundaries and firewall rules remain intact through host maintenance windows, load-balancing migrations, and unplanned host failures without requiring manual reconfiguration or policy re-application.

For site-level resilience, NSX Federation Security maintains a consistent security posture across multiple locations. During disaster recovery events and workload migrations between sites, NSX Federation Security synchronizes firewall rules, security groups, and policy definitions so that the security framework established at the primary site is preserved at the recovery site. This reduces security gaps during the period when workloads are transitioning between sites or running at a secondary location.

The Security Services Platform (SSP), which hosts vDefend's centralized management and analytics functions, offers several resilience mechanisms. For host-level failures, VMware recommends deploying SSP with vSphere HA enabled so that failed management components are automatically restarted on surviving hosts. For storage-level resilience, SSP can be deployed on a vSAN stretched configuration, which protects SSP data from multiple host failures within a single site and facilitates quick recovery from site failures. SSP supports backup and restore operations to recover its own configuration and state; backup operations require the platform to be in a healthy state, and administrators should verify certificate consistency between backup and restore environments to avoid NDR Sensor disruptions. SSP cluster health monitoring tracks NetworkUnavailable, DiskPressure, and Ready conditions with a 5-minute timeout threshold for remediation, enabling automated detection of degraded cluster conditions. After restoring a backup in a disaster recovery or in-place scenario, Agent health status must be verified as Up on Bare Metal servers before the platform is considered operational. Administrators should also back up the SSP system before performing scale-out operations to allow recovery if expansion encounters issues.

vDefend also provides operational resilience through its threat response capabilities. Intelligent Assist offers two remediation strategies to help security teams respond to threats while maintaining the broader security posture: the Targeted Strategy applies surgical, lower-risk remediation with potentially lower effectiveness, while the Comprehensive Strategy selects the broadest available response for more effective remediation with potentially lower safety implications for connected workloads. Intelligent Assist remediation policy rules are not enabled by default and must be manually enabled by an analyst or administrator after due diligence and verification, providing deliberate control over automated response actions. Objects generated during remediation that encounter errors require manual cleanup in Intelligent Assist.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) helps organizations achieve disaster recovery requirements for virtualized workloads by orchestrating virtual machine recovery at a secondary site. Recovery plans can be created with configurable properties to support disaster recovery operations, and replication classes are preconfigured with a Recovery Point Objective (RPO) that defines the acceptable amount of data loss after a disaster. PNR orchestrates both array-based replication and host-based replication.

Recovery plans run under both planned circumstances for migration and unplanned circumstances for disaster recovery. Operators can test recovery plans before using them in production to validate recovery procedures. Multi-region deployments with separate management domains can be designed to contain the impact of a disaster event to one region.

PNR exposes role-based access through specific roles such as SRM Recovery Plans Administrator and SRM Recovery Administrator, and role assignments must be configured on both the primary and secondary sites for consistent access control across the recovery environment. In Protection and Recovery for VCF Automation, Organization Administrators can perform multi-tenant disaster recovery operations on behalf of project administrators and project advanced users.

Operational visibility is provided through VCF Operations dashboards for Protection and Recovery. The Protection Groups dashboard surfaces a critical health status when a serious issue occurs with a protection group or its replication, and PNR classifies health findings into Error, Warning, and Info categories so operators can diagnose, troubleshoot, and remediate issues that affect resilience.

Cyber Recovery, part of the PNR suite, extends resilience to cyber incident scenarios. Integrated CrowdStrike vulnerability analysis applies the Exploitability and Predictive Risk Technology (ExPRT) rating to recommend immediate remediation of Critical vulnerabilities, timely remediation of Medium-severity vulnerabilities, and scheduled remediation of Low-severity findings. vSphere Replication supports point-in-time recovery for cyber resilience.

Recovery sites should be located in a facility that is unlikely to be affected by environmental, infrastructure, or other disturbances that affect the protected site. Decisions about acceptable RPO thresholds, recovery site selection, and operational processes for declaring and executing recovery remain organizational responsibilities outside the product.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to resilience through technical mechanisms at both the management plane and database levels, addressing both normal operations and adverse conditions such as node failures and site outages.

The DSM Provider Appliance, which hosts the management plane, relies on vSphere High Availability for its own resilience. DSM requires that HA be activated on VMware vCenter clusters hosting database workloads as a prerequisite for infrastructure policy compliance, making HA an enforced platform dependency rather than an optional configuration.

At the database level, DSM PostgreSQL deployments include a monitor node that orchestrates automatic failover. When the primary database node fails, the monitor node promotes the replica to primary without manual intervention. For environments requiring high availability across multiple failure domains, DSM provides a Cross vSphere Cluster HA topology that distributes PostgreSQL instances across multiple vSphere clusters, offering the highest availability and resilience for those configurations.

For cross-site resilience, DSM supports multi-site deployments for PostgreSQL databases. Before establishing a multi-site deployment, administrators must configure remote replication on the primary instance and retrieve the Certificate Authority from the primary instance to add it to the DSM Provider VM that will host the secondary. Users with the DSM User role must manually establish trust between primary and secondary instances. Secondary PostgreSQL instances support read-only connections while replication is active. DSM requires that the values of `max_connections`, `max_worker_processes`, `max_wal_senders`, `max_prepared_transactions`, and `max_locks_per_transaction` on the secondary database be equal to or greater than those on the primary. When a site fails, DSM provides a switchover workflow that promotes the secondary instance to primary. DSM also provides a fallback workflow that reverses the roles and restores the system to a fully operational state. During a switchover, DSM validates trust of the new primary database certificate before redirecting secondary instances. DSM requires that organizations define disaster recovery requirements, including whether to enable multi-site replication, before creating a PostgreSQL database.

DSM extends high availability to MySQL deployments. DSM supports MySQL HA clusters and read replicas as distinct deployment topologies. A Cross vSphere Cluster HA configuration distributing a primary and two replicas across three vSphere clusters provides the highest availability for MySQL in multi-cluster environments. DSM requires that disaster recovery requirements be defined before creating a MySQL database.

For recovery operations, restoring a PostgreSQL cluster to a different DSM control plane should use resources equal to or greater than those of the source cluster to maintain stability.

DSM's technical mechanisms support but do not substitute for organizational resilience programs. Organizations must define recovery time and recovery point objectives, document and test disaster recovery procedures, and maintain runbooks for failover and failback operations.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms spanning the control plane, data plane, and geographic distribution layers. Organizations can use these mechanisms to satisfy resilience requirements for their application delivery infrastructure.

Control-plane resilience is achieved through the Avi Controller cluster. Production deployments use a Controller cluster that maintains quorum and fault tolerance, allowing the control plane to remain available when one node is unavailable. Controller clusters can be deployed across two availability zones, with documented failure scenarios and recovery actions for each topology. When running a single-node Controller, the Backup and Restore feature must be used for disaster recovery. After a storage failure event, the Controller is restored from a configuration archive, and at least one Service Engine controller IP must match a previous controller IP to enable Service Engines to reconnect to the Controller after restoration. The Controller's backup and restore capability also supports configuration migration across Controller instances.

For cross-site application failover, Avi Load Balancer includes Global Server Load Balancing (GSLB). Avi GSLB provides resilience when loss of a data center or network connection occurs, and supports an active disaster recovery deployment mode in which a geographically remote site receives application traffic when the primary site is unavailable. Where a deployment has only one active site, at least one geographically remote cloud should be designated as the GSLB disaster recovery target.

At the data plane, Service Engine distribution and scaling provide resilience at the workload level. A scaled-out virtual service experiences no more than performance degradation if a single Service Engine in the group fails, making the scaled-out model preferable to legacy high availability modes for resilience. Availability Zones can be configured within each Service Engine Group, with two or three zones recommended per group. Each Availability Zone should be defined around a distinct fault domain associated with shared power supplies, shared networking devices, or other common infrastructure, and maps specific VMware vCenter (vCenter) instances, hosts, and datastores that share that fault domain. In multi-vCenter deployments, this spreads data-plane capacity across multiple infrastructure failure boundaries.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) federation architecture supports designation of a leader cluster and multiple member clusters for disaster recovery and multi-cluster coordination. This extends Avi's resilience model to multi-cluster Kubernetes deployments, allowing application traffic management to continue across cluster failures.

In VCF deployments, the Cloud Console's Central Licensing feature maintains a global capacity pool that removes the need for duplicate licenses in disaster recovery scenarios, reducing licensing barriers to activating DR sites.

Achieving the resilience requirements in this control is an organizational process. The organization must define recovery objectives, validate failover procedures through testing, maintain configuration archives, and coordinate resilience activities across the underlying VCF platform. Avi's control-plane HA, GSLB, Availability Zone configuration, and AMKO multi-cluster federation capabilities directly support that process without substituting for it.

Control PR.IR-04

[Withdrawn: Moved to PR.IR-04] Adequate resource capacity to ensure availability is maintained

SCF Controls: CAP-01, CAP-02, CAP-03, CAP-04, CAP-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides built-in capacity and performance management through VCF Operations, which delivers capabilities organized around three functional areas: assess, optimize, and plan. These capabilities allow administrators to evaluate whether physical capacity is sufficient to meet current or forecasted demand, balance supply against consumption, and manage production capacity as organizational requirements change.

The assess capability evaluates current and projected resource utilization across compute, storage, and networking. VCF Operations includes a capacity analytics engine that analyzes historical resource utilization data and generates projected utilization metrics. The engine computes and publishes metrics in the Capacity Analytics Generated group, including a capacityRemainingPercentage that tracks the most constrained resource relative to usable capacity. Capacity dashboards display key indicators including time remaining before capacity is projected to run out, the amount of remaining capacity, the number of virtual machines that can fit in remaining capacity, and reclaimable resources that can increase available capacity. The Capacity Summary dashboard provides details on available resources and what is currently running on those resources. The recommended approach for usable capacity is to maintain a green state by calculating total capacity minus high availability reservation for the time remaining.

The optimize capability helps administrators manage resources within the virtualized infrastructure to maintain performance and maximize resource utilization while keeping capacity within acceptable limits. The Workload Optimization screen lets administrators optimize workload placement based on policy settings, accessible via the Workload Placement tab under Capacity. Capacity Optimization allows forecasting the impact of adding workloads by modeling various scenarios to determine whether desired workloads can fit in targeted data centers. Administrators configure capacity policy settings by defining requirements and tolerances for their environment, such as CPU utilization thresholds, and then configure object groups and policies accordingly. At the vSphere layer, Distributed Resource Scheduler (DRS) continuously compares cluster and host-level metrics against an ideal resource usage given resource pool attributes, current demand, and a configurable imbalance target, automatically migrating virtual machines to maintain load balance. vSphere also applies admission control when creating or modifying resource pools, rejecting reservation requests that would exceed available capacity to prevent over-commitment of guaranteed resource allocations.

The plan capability uses historical resource utilization data and real-time predictive projections to forecast future capacity needs. The capacity engine uses an industry-standard statistical analysis model of demand behavior for its projections. Infrastructure Planning shows time remaining and the impact on CPU and memory when capacity changes, including graphical representations of whether removing capacity decreases the time remaining before resources run out. Committed scenarios allow capacity to be reserved so that operations teams do not perform ad hoc resource increases on workloads while a capacity manager is engaged in resource planning for new projects.

At the storage layer, vSAN provides storage-specific capacity and performance metrics. VCF Operations collects disk I/O and disk space metrics to monitor vSAN disk group performance, including read-cached hit rate, write-buffer free percentage, cache disk destage rate, congestion metrics, and outstanding I/O statistics. vSAN displays deduplication and compression savings information when these space efficiency features are enabled. vSAN also supports auto-policy management to optimize capacity utilization based on cluster size and type. The vSAN Performance Dashboard in VCF Operations provides a consolidated view of storage performance alongside compute and network resources.

The Consumption layer within VCF extends these capacity management capabilities to Kubernetes workloads running on VMware Kubernetes Service (VKS) and the vSphere Supervisor. At the namespace level, vSphere Namespace resource capacity can be configured with explicit limits on CPU, memory, storage, and storage policy consumption. When a vSphere Namespace is configured, a resource pool is created on VMware vCenter, and administrators can apply capacity and usage

quotas to bound what workloads in that namespace may consume; by default, this resource pool is created without capacity or usage quotas, requiring administrators to configure limits explicitly. The StoragePolicyQuota resource allows per-namespace limits on storage capacity allocated under a given storage policy, specified via the `spec.limit` parameter. VKS Cluster Management quota policies provide an additional boundary at the cluster management layer, with preconfigured templates (small, medium, and large) that define common limits on CPU and memory requests, or a custom template that allows specification of CPU and memory limits and request quantities for various resource types.

Within Kubernetes namespaces, ResourceQuota objects control resource allocation across pods and containers, allowing administrators to set per-namespace quotas on CPU, memory, and storage. ResourceQuota configuration can be enabled to protect system-critical priority classes, including system-node-critical and system-cluster-critical, from resource contention. LimitRange resources work alongside ResourceQuota to set default and maximum resource requests and limits at the pod level, reducing resource exhaustion from workloads that do not specify their own constraints; cluster administrators can use LimitRange to set per-claim storage request ceilings and ResourceQuota to cap total namespace storage consumption. Kubernetes pods can be configured with resource requests and limits at both pod-level and container-level, providing fine-grained control over CPU and memory allocation.

At the node level, Kubernetes nodes report capacity and allocatable resources including CPU, memory, ephemeral storage, hugepages, and pod count limits. The kubelet `systemReserved` configuration reserves CPU cores and memory for system processes, protecting node stability from workload interference. For workloads requiring stronger latency and performance guarantees, kubelet resource management policies can be configured. Node overprovisioning capacity reservation is configured by defining resource requests and limits for placeholder pods in a Deployment manifest, with total reserved resources calculated as the product of replica count and per-pod resource quantities, keeping headroom available for newly scheduled workloads.

The Kubernetes kube-scheduler manages availability, performance, and capacity through scheduler policies and profiles. Kube-scheduler metrics can be used to build capacity planning dashboards, assess current or historical scheduling limits, and identify workloads that cannot be scheduled due to resource shortfalls. Kubernetes Dynamic Resource Allocation allows consumable device capacity to be requested via ResourceClaimTemplate objects, with requestPolicy constraints controlling how those capacities are consumed across allocations; device capacity can define a default request policy value and valid range with step increments. The Supervisor Monitor tab under vSAN provides a Capacity view for tracking how much capacity stateful service objects are consuming.

VM classes in VKS support two reservation types: guaranteed, which fully reserves configured resources so that requests equal limits, and best effort, which does not hold resources in reserve. The choice of VM class reservation type affects how compute capacity is consumed under varying load conditions and is relevant to capacity planning for VM-based workloads on the platform. Kubernetes production cluster guidance recommends maintaining a capacity expansion plan based on expected pod and container counts, with additional capacity provisioned to allow critical workloads to reschedule in the event of node failures.

VMware Private AI Services (PAIS) provides several mechanisms that support capacity management for AI workloads. These mechanisms operate at multiple layers: organization quotas, region quotas, zone configurations, VM class and storage class reservations, infrastructure policies, and observability for capacity trending.

The foundation of capacity management in PAIS is the organization quota system. Organization region quotas in VCF Automation accept only finite CPU and memory limits and reservations; unlimited resources cannot be assigned. CPU and memory reservations cannot be over-provisioned, though CPU and memory limits and storage can be. VCF Automation creates a resource pool for the namespace in the clusters that correspond to the specified zones, applying the reservation and limit values to that resource pool so the platform enforces the quota at runtime.

Within organizations, capacity is allocated through region and zone quotas. Provider administrators use the VCF Automation Provider Management portal to configure a region and assign region quotas, with quotas based on the zones selected for one or multiple supervisors. For each zone, CPU and memory limits and reservations are specified along with reserved or non-reserved VM classes and storage classes; storage limits per storage class are configurable. Region quotas can include explicit

GPU resource counts by profile (for example, H100 and L40 vGPU profiles assigned per zone). The PAIS SupervisorNamespaceClassConfig captures these per-zone CPU limits, CPU reservations, memory limits, and memory reservations as a managed configuration object. When an organization quota spans multiple supervisors in the same region, a separate region quota is required for each supervisor, so administrators account for each physical boundary in their capacity plan.

VM class reservations provide another layer of capacity control designed specifically for AI workloads. Zone capacity is configured through reserved VM class instances, where each reservation specifies a VM class name and a count of reserved instances in the zone. VM class capacity is reserved in Supervisor zones to support resource availability for the workloads that run there. For workloads requiring GPU resources, VM classes with GPU reservations require capacity configuration using the `dcli` command, which sets reserved VM class instances with a count parameter per zone. Guaranteed VM classes are not permitted in a region quota with zero reservation, and guaranteed VM classes are not allowed in a quota unless CPU and memory reservations are provided to all zones, so resource availability commitments are tied to explicit capacity configuration. GPU-enabled workload domains receive license capacity allocation, while the management domain does not.

When AI catalog items are created in VCF Automation through the Private AI Services quickstart, an infrastructure policy is selected to define the quality and quantity of resources that the PAIS DSM database can consume from vSphere clusters; the policy also determines which storage policies and VM classes are available. A default storage policy can be selected to define storage placement and resources for the database. AI Kubernetes cluster deployments require selection of a storage class that defines storage placement and resources for the virtual machines, and the PAIS VKS control plane configuration requires specification of a VM class and storage class to represent the resources allocated to control plane nodes. PAIS model endpoints similarly use storage class policies that describe storage requirements and classes of service for the VMs created for the Kubernetes cluster nodes running the model. The containerd storage volume used by PAIS workloads is sized at 100 GiB and mounted at `/var/lib/containerd`, giving administrators a fixed local-image footprint to plan against.

PAIS also supports observability for capacity planning. A Prometheus server is deployed in the Private AI Services namespace with its own metrics database backed by a Persistent Volume; storage size for that database is inferred from the metrics retention property in the PAISConfiguration custom resource, allowing administrators to plan monitoring infrastructure capacity alongside AI workload capacity. The VCF Consumption CLI connects to the Supervisor endpoint and streams metrics from the PAIS controller pod, and PAIS metrics can be visualized in Grafana for monitoring and troubleshooting, including LLM completion API response times, inference engine tokens-per-second generation rate, and GPU compute and memory utilization. These signals feed the organizational capacity planning process that the control evaluates.

VMware vDefend (Contributes)

VMware vDefend includes capacity and performance management capabilities specific to its security processing infrastructure through the Security Services Platform (SSP).

The SSP provides a Platform Host Capacity view that gives administrators visibility into resource utilization across the security processing cluster. This view tracks cluster data, unexported flow data, total flows, prioritized applications and groups, the average number of flows every five minutes, and the data collection status per cluster. The SSP also displays a time-series graph showing flow distribution over an hour and generates a warning notification when unexported flows affect the prioritized collection of applications and groups. SSP monitors which hosts are operating within capacity and which are capped when flows on the host exceed capacity. The system dashboard provides flow processing capacity analysis to display cluster sizing requirements.

When approaching capacity limits, vDefend provides actionable guidance: administrators can monitor specific metrics, add worker nodes, disable flow collection on certain hosts or clusters, or rebalance virtual machines across transport nodes to manage system performance. Resource reservation is enabled by default for SSP deployments, reserving the required CPU and memory at the resource pool level. The documentation advises against oversubscribing host CPU and memory, and recommends adjusting virtual machine allocations or migrating virtual machines when resources are insufficient.

SSP includes tools to manage license pool consumption for capacity reservations in mission-critical production sites and to set hard limits for development environments, supporting capacity planning across different environment tiers.

Host Transport Node Metrics monitoring helps detect capacity constraints within the Distributed Firewall processing layer, allowing administrators to optimize resource allocation and verify that security enforcement does not affect workload performance. DFW Resource Utilization Metrics provide a dedicated view for capacity planning and performance troubleshooting within the Distributed Firewall. For IDS/IPS deployments, administrators can assess current CPU and memory load on ESX hosts to identify hosts with unused capacity that can accommodate the IDPS engine without performance degradation.

Broader infrastructure capacity planning across compute, storage, and networking is handled by VCF Operations, which provides the full assess, optimize, and plan lifecycle for the overall VCF environment.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several resource prioritization and protection controls that contribute to limiting and managing resource consumption across its services.

The DR REST API Gateway includes a multi-tier rate limiter designed to manage the risks of API resource exhaustion. At the IP address tier, the system enforces a default quota of 100 requests per IP address within a 60-second window. At the service tier, the system enforces a default quota of 1,000 requests per service name within a 60-second window, where service names include srm, vr, and configure. These thresholds are configurable, and administrators should evaluate the settings based on their deployment requirements.

Recovery plan execution uses a five-level priority system (priority 1 through priority 5) that controls the order in which virtual machines are powered on during failover or test recovery. Administrators assign virtual machines to priority groups so that business-critical workloads receive resources first. The Protection and Recovery server powers on groups of virtual machines according to priority, requiring all virtual machines in the next-higher priority group to recover or fail before the next priority group starts. Virtual machine dependencies must be placed in the same priority group, and the system tracks when a dependent virtual machine has a different priority than its dependency, flagging the status as Lower Priority or Higher Priority for administrator review. For large environments, PNR supports a configurable limit on the number of concurrent power-on and power-off operations, which helps prevent infrastructure overload and operation timeouts during recovery plan execution.

For recovered virtual machines at the target site, PNR supports resource pool mapping with reservations, limits, and affinity rules. Administrators configure resource pools on the recovery site and map them to source-site pools so that recovered workloads inherit appropriate resource allocations. The replication.createPlaceholderVmWithMinResources advanced setting, which defaults to false, can be set to true to have PNR use minimum CPU and memory resources when creating placeholder virtual machines, preventing recovered workloads from starting with insufficient resources.

PNR monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached, providing visibility into resource contention affecting the DR management infrastructure. The Protection and Recovery unified dashboard in VCF Operations displays a historical chart of bandwidth consumed by replication tasks relative to available capacity and tracks virtual machine utilization trends over time to identify machines with high utilization that may experience performance degradation. For replication traffic, administrators can manage bandwidth consumption by adjusting RPO targets, deactivating replication on high-change-rate virtual machines when bandwidth is constrained, or enabling data compression, which requires additional CPU resources on both the source site and the server managing the target datastore.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) addresses resource prioritization through its infrastructure policy framework, which gives vSphere administrators direct control over the compute, storage, and network resources that database workloads can consume. Infrastructure policies define guardrails on the quality and quantity of resources available to DSM users, restricting access to vSphere cluster capacity. The policies include configurable limits for CPU, memory, storage policies, IP pools, and VM classes, all visible and manageable from the Infrastructure Policies view in the DSM UI.

Administrators create infrastructure policies in the vSphere Client during DSM configuration and assign them to data service deployments. The DataServicePolicy custom resource includes an allowedInfrastructurePolicies field that constrains which infrastructure policies can be applied to database instances in a given namespace, scoping resource consumption to the boundaries defined for each deployment context. The DSM Consumption Operator also introduces the InfraPolicyBinding custom resource to enforce namespace-specific policy bindings, providing an additional layer of namespace-scoped resource control. When self-service consumption is enabled, infrastructure policies are published as cluster-scoped resources in the consumption cluster, so that tenant users can only provision databases within the resource envelope their assigned infrastructure policy defines.

Resource pool configurations support capacity partitioning. When resource pools are used as compute resources for database provisioning, DSM requires that three resource pools be selected with each from a different cluster within the same data center, and that all selected compute resources share common storage policies. This distributes workloads across infrastructure and limits the scope of any single resource-contention event.

DSM monitors IP pool utilization and generates global alerts when IP pool capacity approaches its limit, prompting administrators to expand the IP pool range or add pools before provisioning failures occur. DSM also detects and prevents network overlap between infrastructure policy IP ranges and system configuration networks, reducing the risk of misconfiguration that could exhaust network resources. Resource utilization metrics for CPU, memory, and data disk use are tracked at the DSM level, providing visibility into potential bottlenecks before they affect database availability.

DSM's resource controls address the resource governance aspect of this control within the database-as-a-service layer. Broader protection against network-layer denial of service, including traffic shaping, rate limiting, and connection throttling, is handled by the underlying VCF networking and security infrastructure rather than by DSM directly. Organizations should complement DSM's infrastructure policies with network-level controls appropriate to their threat model.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer provides application-layer capacity management mechanisms across three areas: real-time capacity visibility through Pool and Service Engine metrics, proactive capacity management through elastic scaling and configurable resource controls, and multi-tenant capacity governance through the VCF organization-managed mode introduced in 9.1.

On the visibility side, the Pool Metrics system tracks both Estimated Capacity (the pool's maximum possible connections) and Available Capacity (currently open connections) at the pool level. Pool Metrics deliver specialized analytics and performance data representing the health and capacity of backend pool servers. At the individual server level, the `l4_server.avg_available_capacity` metric estimates connections-per-second capacity available for each server, calculated as the difference between maximum capacity and average load. The License Hub Platform Dashboard Resources tab visualizes hardware consumption overall and per controller and worker node, including System Load tracking of overall CPU demand against allocated vCPU capacity on a 15-minute average.

On the scaling and configuration side, each Service Engine has a maximum capacity for processing traffic measured in terms of traffic throughput or SSL transactions per second, which is a function of the SE VM size (number of vCPUs or memory), type of traffic, and deployment environment. CPU and memory reservations with limits set to unlimited are recommended for Service Engine virtual machines to achieve consistent and deterministic performance. Elastic HA N+M mode allows administrators to define a buffer expressed as M, an integer count of buffer Service Engines. When an N+M group is scaled out to the maximum number of Service Engines, Avi Load Balancer permits additional virtual service placements into the spare capacity represented by M. Pool configuration allows setting the maximum number of connections per server on the Advanced tab to help prevent servers from being overloaded and to maintain optimal connection handling.

In the 9.1 Avi for VCF integration, organization-managed mode adds Service Unit quota enforcement per organization. Provider administrators can assign either a quota measured in Service Units or specific Service Engine Groups to organizations through the VCF Automation Provider Management portal, establishing resource governance to help prevent organizations from over-consuming shared Avi Load Balancer resources. In organization-managed mode, the provider or Load Balancer administrator manages resource assignments to enforce quotas and resource boundaries, and organization administrators can

edit a Service Engine Group to scale the underlying performance (CPU and memory) or modify high-availability behaviors. Service Engine capacity provisioned on the Avi Controller is periodically reported, and the license quota reservation mechanism can be configured to keep a specific amount of capacity always available for a tier when a consumption ceiling is set.

These mechanisms give operations teams the metrics and controls needed to assess current application delivery capacity, monitor utilization trends, and adjust Service Engine group configuration or scale out in response to demand. The organizational processes for defining capacity plans, setting review cadences, acting on threshold alerts, and making scale decisions remain the responsibility of the organization.

Control PR.PS

[Withdrawn: Incorporated into ID.AM-08, PR.PS-03] Configuration management practices are established and applied Software is maintained, replaced, and removed commensurate with risk Hardware is maintained, replaced, and removed commensurate with risk Log records are generated and made available for continuous monitoring Installation and execution of unauthorized software are prevented Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle [Withdrawn: Incorporated into PR.PS-01] [Withdrawn: Incorporated into ID.AM-08, PR.PS-06] [Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02] [Withdrawn: Incorporated into PR.PS-04] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01]

SCF Controls: CFG-01, CFG-02, CFG-02.1, CFG-02.5, MNT-01, MNT-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered configuration management capability spanning infrastructure state definition, drift detection, policy enforcement, and workload-level configuration automation.

VCF Operations includes a Configuration Templates feature that allows administrators to define a desired state as a set of configurations and then monitor the environment against those definitions. Configuration templates are created and managed through the Fleet Management > Configuration Drifts interface in VCF Operations, or through the Infrastructure Operations > Configurations > Policy Definition interface. VCF Operations supports managing global configuration templates across multiple vCenter instances, with the ability to assign templates to policies, activate them, and enforce them across the fleet.

The Configuration Drifts feature provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters, comparing the current vCenter value against the configuration template value for each instance. When a deviation from assigned template values occurs, a configuration drift notification alerts administrators. The Configuration Drift dashboard allows viewing and comparing drifts, and the Detect Drift function can be run across all configuration templates to display results in a consolidated drifts table. Drift detection can also be scheduled, enabling continuous detection of configuration deviations from the desired state without manual intervention.

Source control integration extends the configuration management program with version control, change tracking, and auditability. VCF Operations can synchronize configuration templates to and from a supported source control repository, enabling versioning, auditing, and controlled management of templates. This integration facilitates accurate configuration updates, supports change control with reviews, and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes.

VCF Operations provides policy management capabilities through the Infrastructure Operations Configurations module, including the ability to add, edit, and remove policies. The Configure Host Security Config Data workflow allows selective enforcement of host security hardening rules by configuring enforcement options for individual configuration elements. VCF Operations also supports export of configuration content, including configuration files, policies, compliance scorecards, and global settings, enabling backup and portability of configuration baselines. The config polling interval can be adjusted to control how frequently configuration data is collected from data sources, allowing administrators to tune the monitoring cadence to their operational requirements.

vSphere Lifecycle Manager (vLCM) provides image-based lifecycle management for ESX hosts, maintaining consistency by defining and enforcing approved host images across the fleet. vLCM manages all hosts in a cluster collectively with a single image, and clusters are assigned a base image and optional vendor add-on to define the desired state. When hosts deviate from the defined image, the cluster reports a non-compliant status, and remediation installs the approved image across all hosts in the cluster. vSphere Lifecycle Manager images are created in the vSphere Client and then imported into VCF using VCF Operations.

vSphere Host Profiles provide a complementary mechanism that captures the configuration of a validated reference host, including memory, storage, networking, and advanced settings, stores it as a managed object, and enforces it against other hosts to detect and remediate configuration deviations. vSphere Configuration Profiles extend this to the cluster level through JSON configuration documents that can be downloaded, edited offline, and imported, with built-in alarm support to notify administrators of configuration drift via email or SNMP traps.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) extends configuration management with a Kubernetes-native declarative model in which every cluster component, workload, and security policy is expressed as a YAML manifest. Kubernetes recommends that object configuration be stored in a source control system such as Git to enable change review processes and audit trails. VKS cluster security configurations are immutable and persistent by design, moving away from manual node-level configuration. ClusterClass configuration variables expose granular control over cluster infrastructure across releases, and the VKS Add-on Management feature provides a declarative API for add-on installation and configuration across a fleet of workload clusters through AddonConfig resources. The Cluster API, which underlies VKS cluster creation and management, provides declarative, Kubernetes-style APIs for the full cluster lifecycle including creation, configuration, and ongoing management. StatefulSet controllers use ControllerRevision objects to track historical configuration changes, supporting rollback and version tracing. Kubernetes Operators extend the declarative model to custom resources by interacting with the API server to reconcile the actual state of complex stateful applications and services against a declared desired state, enabling management of domain-specific workloads beyond native Kubernetes primitives. Kubernetes ConfigMaps separate application configuration from container images by storing configuration data as key-value pairs; they can be updated at runtime to propagate changes to running pods without requiring a pod restart. The KubeletConfiguration API type, managed through kubeadm, centralizes kubelet configuration across cluster nodes.

The Argo CD Supervisor Service implements a GitOps model for the consumption layer: all infrastructure and application configurations are expressed declaratively in a Git repository, and Argo CD can automatically apply changes from the repository to the target environment. Argo CD also manages VKS cluster lifecycle, with applications defined in Git referencing cluster lifecycle management manifests that target a specific namespace and Kubernetes API server endpoint, extending configuration-as-code governance from workloads to the clusters themselves. Argo CD continuously monitors the live application state against the desired state in Git, tracks per-resource sync status and health state, and reports deviations as OutOfSync. It provides both a CLI and a web-based UI for defining applications and visualizing cluster configuration drift, paralleling the drift-detection capability at the VCF Operations layer. Kustomize, available as a Kubernetes-native configuration management tool, transforms base resource manifests through declarative patching, field customization, and resource composition, enabling environment-specific variation without modifying source manifests. VKS Cluster Management Policies use the open-source OPA Gatekeeper as the policy engine for Security, Registry, Mutation, and Custom policy types; custom Security Policy templates allow organizations to fine-tune security context parameters and governance controls to their specific requirements. Security Technical Implementation Guides (STIGs) for Supervisor and VMware Kubernetes Release (VKr) deployments are available through Tanzu STIG Hardening, providing a structured configuration baseline for organizations building a configuration management program across the full VCF stack.

VCF Automation extends configuration management to workloads through integration with Ansible Open Source, Ansible Automation Platform, and Puppet Enterprise. Ansible integration is configured through Infrastructure > Connections > Integrations > Add Integration > Ansible Tower, and allows automated configuration management of VM-based applications deployed on the platform. Puppet Enterprise integration requires establishing a connection between the external Puppet system and the VCF Automation instance and is available on all projects by default. VCF Automation policies apply to both current and new deployments, and the Provisioning Service API allows programmatic integration and centralization of configuration properties.

VMware Private AI Services (PAIS), formerly Private AI Services, provides structured, configurable mechanisms that organizations can apply as part of a configuration management program for AI infrastructure on VCF.

The PAISConfiguration Custom Resource Definition (CRD) is the central PAIS configuration artifact. Administrators define PAIS settings in a YAML file compliant with the PAISConfiguration CRD, with sections for storage policy, CA trust bundles, PostgreSQL database connection, OIDC provider integration, and ingress service type. Configuration is managed using

kubectl to update or patch the PAISConfiguration custom resource. Client TLS configuration references CA bundles for OIDC provider and Harbor authentication, with trust bundles supplied through ConfigMap resources referenced in the spec.clientTls.caBundleRefs section. The documentation recommends organizing CA trust bundles per application and monitoring them for certificate expiration so renewals are applied before associated certificates expire. When a CA certificate is selected and added from the namespace, PAIS is updated with a new ConfigMap resource.

Harbor Registry integration provides configuration control points for AI model distribution and lifecycle management. PAIS deployment uses Harbor replication rules with configurable filters, target namespaces, and trigger mode controls, including manual trigger mode for explicit replication runs. Disconnected (air-gapped) environments use a Bastion and Admin host pattern for PAIS setup, with replication configured to a destination registry aligned to organizational requirements.

The VCF Automation Provider Management surface manages region configuration and quotas for PAIS deployments. Provider administrators configure regions by selecting an NSX Manager instance integrated with the vCenter instances for the region, then assign region quota based on the zones selected for one or more supervisors. Regions are associated with supervisor clusters for PAIS deployment. VCF Automation aggregates zones with the same name across multiple supervisors in a region, combining their CPU, memory, and reserved VM class resources and presenting them as a single unit at the region level.

VCF Automation provides catalog items for provisioning AI workloads, including Deep Learning VMs and GPU-accelerated VMware Kubernetes Service (VKS) clusters, through a self-service catalog organizations configure to their deployment standards. The PAIS Quickstart generates blueprints that can be customized for deployment on VCF Automation. Passwords entered in the PAIS Quickstart, including the private container registry password and proxy password, are saved as secrets in VCF Automation rather than embedded in catalog item definitions. PAIS Data Services Manager (DSM) database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes.

PAIS observability is configured through the same PAISConfiguration custom resource. Prometheus runtime metrics collection is activated by uncommenting the spec.observability.prometheusRuntime section and supplying a storage class and configurable metrics retention period; LLM traces can be exported to an OpenTelemetry Collector through the same configuration path. VI administrators can visualize PAIS controller pod operation metrics in VCF Operations, with Telegraf user configuration stored in a telegraf-user-config ConfigMap in the vmware-system-monitoring namespace. The VCF Consumption CLI provides a command-line interface for cluster management capabilities through a plugin installation command, giving administrators a scriptable surface for repeatable PAIS workload operations.

VMware vDefend (Contributes)

VMware vDefend provides configuration management mechanisms for its network security policy infrastructure, contributing to an organization's broader configuration management program.

The vDefend distributed firewall (DFW) supports a draft configuration management workflow that separates policy authoring from activation. Administrators prepare and review firewall policy changes in draft form before publishing them to the enforcement plane. Draft configurations can be saved as a new configuration or as an update to an existing one, and can be locked with an optional comment requirement to enforce change control discipline. Auto drafts and manual drafts can be cloned and saved, with the option to edit the name and lock the configuration with a required comment. Export options include the published configuration, an auto-saved draft, or a manually saved draft. The Publish function commits a draft and makes it active; the Revert function returns the environment to the previous published configuration. Auto-drafts and saved manual drafts can be loaded and published at any time, giving administrators the ability to restore a prior policy state after a change.

In federated deployments, a Global Manager provides centralized configuration management across distributed Local Manager sites. IDS/IPS signatures, profiles, Distributed Firewall and Gateway Firewall policies, oversubscription settings, and syslog settings can all be managed centrally from the Global Manager and applied across all Local Managers. This enables consistent security policy baselines across geographically distributed environments.

The vDefend also supports full rollback capability, which deletes newly added policies and reverts the security configuration to its prior state in reverse order. This applies to broader policy migration and transition scenarios, beyond the draft-level Revert function.

Security Services Platform (SSP) extends configuration management to vDefend's detection and prevention services. The SSP deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. The SSP Configuration Database is the storage layer for system settings and configurations. SSP also extracts all IDS policies, rules, and security profiles to support multiple remediations, clean up stale policies, and suggest policies that do not conflict with each other. IDS/IPS remediation policies can be verified by navigating to Security > IDS/IPS & Malware Prevention > Emergency Threat Rules. Security policies defined within SSP are propagated and enforced across Bare Metal servers as well, extending policy management scope beyond virtual workloads.

Administrators can use flow inactivity data and Security Intelligence recommendations to identify and remove unused or outdated DFW policies and rules, supporting configuration lifecycle hygiene. Security Intelligence's segmentation posture assessment stores data in a Configuration Management Database (CMDB) within the Security Services Platform, maintaining application context and workload attributes. Segmentation planning supports importing workload context from flat files containing IP addresses, subnets, virtual machines, logical segments, and organizational roles, allowing administrators to establish a baseline for policy configuration decisions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several configuration management mechanisms specific to disaster recovery operations.

The Configuration Import/Export Tool allows administrators to export and import PNR configuration data, including inventory mappings, recovery plans, protection groups, and related objects, into XML files. This capability supports configuration versioning and backup by capturing the complete disaster recovery configuration state: server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool provides schema support for programmatic configuration management and offers multiple export and import modes. Administrators can use a properties file (`srm_configuration.properties`) to simplify or automate the import process, invoke the `import-export.jar` utility interactively using the `--importInteractive` flag with parameters for the XML file path, delay, and retry count, or use a script-based method that exports configuration data without requiring credential entry. Exports can be integrated directly into recovery plans as callout steps, so configuration data is captured automatically during recovery operations.

The Protection and Recovery Appliance Management Interface allows administrators to configure network settings on the appliance after initial deployment. PNR upgrade procedures preserve advanced settings and configurations from the prior release, maintaining configuration continuity across version changes. Advanced settings can also be modified through the Site Pair > Configure > Advanced Settings interface in the product UI.

The DR IP Customizer tool provides structured management of network configuration for protected virtual machines. It generates CSV files describing the IP properties of protected VMs grouped by site and recovery plan, which administrators can modify with recovery-site-specific values and reapply. This structured approach supports repeatable and auditable network configuration changes during recovery operations.

Storage Replication Adapter (SRA) configuration management is supported through the Appliance Management Interface, which provides a Download Configuration Archive function for retrieving and importing SRA configurations. PNR also rescans storage arrays every 24 hours by default to detect configuration changes.

In deployments that integrate with VCF Automation, Provider Administrators install PNR in desired regions, pair regions together, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. The VCF Operations Orchestrator Plugin for Protection and Recovery requires administrator login to access and execute workflows for managing site mappings and network configurations.

Access to PNR configuration changes is governed by role-based access control. Granular permissions restrict who can modify advanced settings, manage array managers, and create, modify, or execute protection groups and recovery plans, supporting separation of duties for configuration change management.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a dsmsystemconfig Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes, configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides several mechanisms that support the implementation of configuration management controls across the application delivery layer.

The Controller maintains a centralized Configuration Database that stores all configuration information including tenants, virtual services, pools, policies, and accounts. This is the single source of truth for all system settings. When an administrator makes a change through the web interface, CLI, or REST API, that change is automatically propagated to all Controller cluster members, so any node can assume leadership with a complete and current configuration.

The Controller CLI provides direct access to the full configuration surface. The `configure systemconfiguration` command allows administrators to modify system-wide parameters including DNS, NTP, portal settings, and cryptographic algorithm configuration, with changes synchronized to Service Engines. The `configure` command covers a broad range of objects including virtual services, pools, health monitors, authentication profiles, application profiles, and policy sets, and supports creation, modification, and deletion of those objects. The REST API exposes comparable capabilities programmatically, including the `PUT api/systemconfiguration` endpoint for system-wide settings and the `/api/cloud` endpoint for cloud configuration resources.

Configuration management in Avi can be automated through the Ansible `aviconfig` role, which allows configurations to be expressed as structured dictionaries and applied in a repeatable manner, reducing the need for multiple individual task definitions. The Controller supports on-demand configuration backup and restore, enabling disaster recovery and configuration migration across Controller instances.

In the 9.1 VCF integration, Avi distinguishes between two operational modes: Provider-Managed Mode, where the provider administrator manages Service Engine Group settings including scale-out, CPU, and memory configurations; and Organization-Managed Mode, where the organization administrator manages their own Service Engine Group configurations and infrastructure settings. This separation clarifies ownership and scope of configuration responsibilities within a shared VCF deployment. After upgrading Avi components, a drift check should be performed against VCF Operations, vCenter, and NSX Manager to verify configuration consistency across the stack.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) configuration is customized through the AddonConfig resource, a Supervisor namespace-scoped resource that supports modification of parameters such as logging level and shard virtual service size.

The Config Events overlay in the Service Engine Analytics view allows operators to correlate configuration changes with observed traffic behavior, supporting investigation of the impact of individual changes. Avi Load Balancer events provide the building blocks for configuration automation workflows.

Organizations should define change control procedures, assign ownership of configuration baselines, and determine which changes require approval before these mechanisms can function within a formal configuration management program. Avi provides the technical instruments; the program structure requires organizational governance.

Control PR.PS-01

Configuration management practices are established and applied [Withdrawn: Incorporated into PR.PS-01]
[Withdrawn: Incorporated into PR.PS-01, ID.RA-07] [Withdrawn: Incorporated into PR.DS-01, PR.PS-01]

SCF Controls: CFG-01

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides a layered configuration management capability spanning infrastructure state definition, drift detection, policy enforcement, and workload-level configuration automation.

VCF Operations includes a Configuration Templates feature that allows administrators to define a desired state as a set of configurations and then monitor the environment against those definitions. Configuration templates are created and managed through the Fleet Management > Configuration Drifts interface in VCF Operations, or through the Infrastructure Operations > Configurations > Policy Definition interface. VCF Operations supports managing global configuration templates across multiple vCenter instances, with the ability to assign templates to policies, activate them, and enforce them across the fleet.

The Configuration Drifts feature provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters, comparing the current vCenter value against the configuration template value for each instance. When a deviation from assigned template values occurs, a configuration drift notification alerts administrators. The Configuration Drift dashboard allows viewing and comparing drifts, and the Detect Drift function can be run across all configuration templates to display results in a consolidated drifts table. Drift detection can also be scheduled, enabling continuous detection of configuration deviations from the desired state without manual intervention.

Source control integration extends the configuration management program with version control, change tracking, and auditability. VCF Operations can synchronize configuration templates to and from a supported source control repository, enabling versioning, auditing, and controlled management of templates. This integration facilitates accurate configuration updates, supports change control with reviews, and enables continuous integration and continuous development workflows for automated testing and validation of configuration changes.

VCF Operations provides policy management capabilities through the Infrastructure Operations Configurations module, including the ability to add, edit, and remove policies. The Configure Host Security Config Data workflow allows selective enforcement of host security hardening rules by configuring enforcement options for individual configuration elements. VCF Operations also supports export of configuration content, including configuration files, policies, compliance scorecards, and global settings, enabling backup and portability of configuration baselines. The config polling interval can be adjusted to control how frequently configuration data is collected from data sources, allowing administrators to tune the monitoring cadence to their operational requirements.

vSphere Lifecycle Manager (vLCM) provides image-based lifecycle management for ESX hosts, maintaining consistency by defining and enforcing approved host images across the fleet. vLCM manages all hosts in a cluster collectively with a single image, and clusters are assigned a base image and optional vendor add-on to define the desired state. When hosts deviate from the defined image, the cluster reports a non-compliant status, and remediation installs the approved image across all hosts in the cluster. vSphere Lifecycle Manager images are created in the vSphere Client and then imported into VCF using VCF Operations.

vSphere Host Profiles provide a complementary mechanism that captures the configuration of a validated reference host, including memory, storage, networking, and advanced settings, stores it as a managed object, and enforces it against other hosts to detect and remediate configuration deviations. vSphere Configuration Profiles extend this to the cluster level through JSON configuration documents that can be downloaded, edited offline, and imported, with built-in alarm support to notify administrators of configuration drift via email or SNMP traps.

At the Kubernetes consumption layer, VMware Kubernetes Service (VKS) extends configuration management with a Kubernetes-native declarative model in which every cluster component, workload, and security policy is expressed as a YAML

manifest. Kubernetes recommends that object configuration be stored in a source control system such as Git to enable change review processes and audit trails. VKS cluster security configurations are immutable and persistent by design, moving away from manual node-level configuration. ClusterClass configuration variables expose granular control over cluster infrastructure across releases, and the VKS Add-on Management feature provides a declarative API for add-on installation and configuration across a fleet of workload clusters through AddonConfig resources. The Cluster API, which underlies VKS cluster creation and management, provides declarative, Kubernetes-style APIs for the full cluster lifecycle including creation, configuration, and ongoing management. StatefulSet controllers use ControllerRevision objects to track historical configuration changes, supporting rollback and version tracing. Kubernetes Operators extend the declarative model to custom resources by interacting with the API server to reconcile the actual state of complex stateful applications and services against a declared desired state, enabling management of domain-specific workloads beyond native Kubernetes primitives. Kubernetes ConfigMaps separate application configuration from container images by storing configuration data as key-value pairs; they can be updated at runtime to propagate changes to running pods without requiring a pod restart. The KubeletConfiguration API type, managed through kubeadm, centralizes kubelet configuration across cluster nodes.

The Argo CD Supervisor Service implements a GitOps model for the consumption layer: all infrastructure and application configurations are expressed declaratively in a Git repository, and Argo CD can automatically apply changes from the repository to the target environment. Argo CD also manages VKS cluster lifecycle, with applications defined in Git referencing cluster lifecycle management manifests that target a specific namespace and Kubernetes API server endpoint, extending configuration-as-code governance from workloads to the clusters themselves. Argo CD continuously monitors the live application state against the desired state in Git, tracks per-resource sync status and health state, and reports deviations as OutOfSync. It provides both a CLI and a web-based UI for defining applications and visualizing cluster configuration drift, paralleling the drift-detection capability at the VCF Operations layer. Kustomize, available as a Kubernetes-native configuration management tool, transforms base resource manifests through declarative patching, field customization, and resource composition, enabling environment-specific variation without modifying source manifests. VKS Cluster Management Policies use the open-source OPA Gatekeeper as the policy engine for Security, Registry, Mutation, and Custom policy types; custom Security Policy templates allow organizations to fine-tune security context parameters and governance controls to their specific requirements. Security Technical Implementation Guides (STIGs) for Supervisor and VMware Kubernetes Release (VKr) deployments are available through Tanzu STIG Hardening, providing a structured configuration baseline for organizations building a configuration management program across the full VCF stack.

VCF Automation extends configuration management to workloads through integration with Ansible Open Source, Ansible Automation Platform, and Puppet Enterprise. Ansible integration is configured through Infrastructure > Connections > Integrations > Add Integration > Ansible Tower, and allows automated configuration management of VM-based applications deployed on the platform. Puppet Enterprise integration requires establishing a connection between the external Puppet system and the VCF Automation instance and is available on all projects by default. VCF Automation policies apply to both current and new deployments, and the Provisioning Service API allows programmatic integration and centralization of configuration properties.

VMware Private AI Services (PAIS), formerly Private AI Services, provides structured, configurable mechanisms that organizations can apply as part of a configuration management program for AI infrastructure on VCF.

The PAISConfiguration Custom Resource Definition (CRD) is the central PAIS configuration artifact. Administrators define PAIS settings in a YAML file compliant with the PAISConfiguration CRD, with sections for storage policy, CA trust bundles, PostgreSQL database connection, OIDC provider integration, and ingress service type. Configuration is managed using kubectl to update or patch the PAISConfiguration custom resource. Client TLS configuration references CA bundles for OIDC provider and Harbor authentication, with trust bundles supplied through ConfigMap resources referenced in the spec.clientTls.caBundleRefs section. The documentation recommends organizing CA trust bundles per application and monitoring them for certificate expiration so renewals are applied before associated certificates expire. When a CA certificate is selected and added from the namespace, PAIS is updated with a new ConfigMap resource.

Harbor Registry integration provides configuration control points for AI model distribution and lifecycle management. PAIS deployment uses Harbor replication rules with configurable filters, target namespaces, and trigger mode controls, including

manual trigger mode for explicit replication runs. Disconnected (air-gapped) environments use a Bastion and Admin host pattern for PAIS setup, with replication configured to a destination registry aligned to organizational requirements.

The VCF Automation Provider Management surface manages region configuration and quotas for PAIS deployments. Provider administrators configure regions by selecting an NSX Manager instance integrated with the vCenter instances for the region, then assign region quota based on the zones selected for one or more supervisors. Regions are associated with supervisor clusters for PAIS deployment. VCF Automation aggregates zones with the same name across multiple supervisors in a region, combining their CPU, memory, and reserved VM class resources and presenting them as a single unit at the region level.

VCF Automation provides catalog items for provisioning AI workloads, including Deep Learning VMs and GPU-accelerated VMware Kubernetes Service (VKS) clusters, through a self-service catalog organizations configure to their deployment standards. The PAIS Quickstart generates blueprints that can be customized for deployment on VCF Automation. Passwords entered in the PAIS Quickstart, including the private container registry password and proxy password, are saved as secrets in VCF Automation rather than embedded in catalog item definitions. PAIS Data Services Manager (DSM) database resource allocation is controlled through an infrastructure policy that defines the quality and quantity of resources the database can consume from vSphere clusters, with associated storage policies and VM classes.

PAIS observability is configured through the same PAISConfiguration custom resource. Prometheus runtime metrics collection is activated by uncommenting the `spec.observability.prometheusRuntime` section and supplying a storage class and configurable metrics retention period; LLM traces can be exported to an OpenTelemetry Collector through the same configuration path. VI administrators can visualize PAIS controller pod operation metrics in VCF Operations, with Telegraf user configuration stored in a `telegraf-user-config` ConfigMap in the `vmware-system-monitoring` namespace. The VCF Consumption CLI provides a command-line interface for cluster management capabilities through a plugin installation command, giving administrators a scriptable surface for repeatable PAIS workload operations.

VMware vDefend (Contributes)

VMware vDefend provides configuration management mechanisms for its network security policy infrastructure, contributing to an organization's broader configuration management program.

The vDefend distributed firewall (DFW) supports a draft configuration management workflow that separates policy authoring from activation. Administrators prepare and review firewall policy changes in draft form before publishing them to the enforcement plane. Draft configurations can be saved as a new configuration or as an update to an existing one, and can be locked with an optional comment requirement to enforce change control discipline. Auto drafts and manual drafts can be cloned and saved, with the option to edit the name and lock the configuration with a required comment. Export options include the published configuration, an auto-saved draft, or a manually saved draft. The Publish function commits a draft and makes it active; the Revert function returns the environment to the previous published configuration. Auto-drafts and saved manual drafts can be loaded and published at any time, giving administrators the ability to restore a prior policy state after a change.

In federated deployments, a Global Manager provides centralized configuration management across distributed Local Manager sites. IDS/IPS signatures, profiles, Distributed Firewall and Gateway Firewall policies, oversubscription settings, and syslog settings can all be managed centrally from the Global Manager and applied across all Local Managers. This enables consistent security policy baselines across geographically distributed environments.

The vDefend also supports full rollback capability, which deletes newly added policies and reverts the security configuration to its prior state in reverse order. This applies to broader policy migration and transition scenarios, beyond the draft-level Revert function.

Security Services Platform (SSP) extends configuration management to vDefend's detection and prevention services. The SSP deployment wizard conducts validations before implementing configuration changes to confirm that configurations are correct and compatible. The SSP Configuration Database is the storage layer for system settings and configurations. SSP also extracts all IDS policies, rules, and security profiles to support multiple remediations, clean up stale policies, and suggest policies that do not conflict with each other. IDS/IPS remediation policies can be verified by navigating to Security > IDS/IPS & Malware

Prevention > Emergency Threat Rules. Security policies defined within SSP are propagated and enforced across Bare Metal servers as well, extending policy management scope beyond virtual workloads.

Administrators can use flow inactivity data and Security Intelligence recommendations to identify and remove unused or outdated DFW policies and rules, supporting configuration lifecycle hygiene. Security Intelligence's segmentation posture assessment stores data in a Configuration Management Database (CMDB) within the Security Services Platform, maintaining application context and workload attributes. Segmentation planning supports importing workload context from flat files containing IP addresses, subnets, virtual machines, logical segments, and organizational roles, allowing administrators to establish a baseline for policy configuration decisions.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides several configuration management mechanisms specific to disaster recovery operations.

The Configuration Import/Export Tool allows administrators to export and import PNR configuration data, including inventory mappings, recovery plans, protection groups, and related objects, into XML files. This capability supports configuration versioning and backup by capturing the complete disaster recovery configuration state: server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array manager information with Storage Replication Adapter details. The tool provides schema support for programmatic configuration management and offers multiple export and import modes. Administrators can use a properties file (`srm_configuration.properties`) to simplify or automate the import process, invoke the `import-export.jar` utility interactively using the `--importInteractive` flag with parameters for the XML file path, delay, and retry count, or use a script-based method that exports configuration data without requiring credential entry. Exports can be integrated directly into recovery plans as callout steps, so configuration data is captured automatically during recovery operations.

The Protection and Recovery Appliance Management Interface allows administrators to configure network settings on the appliance after initial deployment. PNR upgrade procedures preserve advanced settings and configurations from the prior release, maintaining configuration continuity across version changes. Advanced settings can also be modified through the Site Pair > Configure > Advanced Settings interface in the product UI.

The DR IP Customizer tool provides structured management of network configuration for protected virtual machines. It generates CSV files describing the IP properties of protected VMs grouped by site and recovery plan, which administrators can modify with recovery-site-specific values and reapply. This structured approach supports repeatable and auditable network configuration changes during recovery operations.

Storage Replication Adapter (SRA) configuration management is supported through the Appliance Management Interface, which provides a Download Configuration Archive function for retrieving and importing SRA configurations. PNR also rescans storage arrays every 24 hours by default to detect configuration changes.

In deployments that integrate with VCF Automation, Provider Administrators install PNR in desired regions, pair regions together, and manage organizational access to PNR capabilities through the VCF Automation Provider Management UI. The VCF Operations Orchestrator Plugin for Protection and Recovery requires administrator login to access and execute workflows for managing site mappings and network configurations.

Access to PNR configuration changes is governed by role-based access control. Granular permissions restrict who can modify advanced settings, manage array managers, and create, modify, or execute protection groups and recovery plans, supporting separation of duties for configuration change management.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) supports configuration management by providing structured mechanisms for defining, applying, and monitoring the configuration of database infrastructure components. Administrators interact with DSM through two primary interfaces: the Provider UI for system-wide settings and the vSphere Client for infrastructure configuration. The Settings view in the Provider interface is the central location for managing system-wide settings, including LDAPS integration, SMTP configuration, and directory service settings. The Administrator Dashboard displays at-a-glance metrics covering the

number of configured users, their assigned roles, and the types and counts of provisioned database services, giving administrators a current view of deployment state.

Infrastructure configuration in DSM is governed by infrastructure policies. These policies define which VM classes are available for database VMs, which storage policies apply, and which vSphere clusters and namespaces are used during provisioning. Infrastructure policy configuration requires that placements, storage policies, VM classes, and IP ranges be correctly configured for valid policy status. Policies that are actively in use by a database cannot have their existing settings modified, though new compute resources with corresponding parameters can be added; unused policies can be changed at any time. VM classes are configurable resource profiles that specify vCPU cores and memory allocation, and can be defined to match organizational capacity standards. Infrastructure policies also establish guardrails that restrict the quantity and quality of resources DSM users can consume from vSphere clusters. Configuration tasks performed during initial deployment include configuring IP pools, defining VM classes, assigning user permissions, creating infrastructure policies, and selecting storage policies.

Database-level configuration is managed through the database instance settings. DSM allows configuration of database instances using either custom or default configuration profiles, with configuration properties varying by database type (PostgreSQL, MySQL, MinIO, or SQL Server). DSM automates provisioning, backups, and security patch application for managed database instances. After initial provisioning, database VM resource configuration can be adjusted at runtime. Optional database configuration parameters for PostgreSQL and MySQL databases can be added or removed after database creation. Maintenance windows can be configured to control when software updates and database option changes are applied, providing a mechanism for scheduled, controlled configuration changes.

DSM provides a Maintenance Policy editor, accessible from the Version & Upgrade section under the DSM System tab, for configuring automatic software updates of the DSM plug-in within defined maintenance windows. The DSM controller manages component and feature dependencies through status monitoring and automated remediation.

When integrated with VCF Automation, DSM supports data service policies that define and enforce configurations for each tenant or organization. These policies can be enforced across different namespaces and namespace labels to maintain a uniform configuration posture. The Consumption Operator automates database deployments based on predefined infrastructure and backup policies, reducing the scope for manual configuration drift.

DSM provides visibility into configuration activity through the Operations tab, which displays the progress of database configuration changes, resource changes, and disk extension tasks. A support bundle can be created and downloaded to collect diagnostic information for troubleshooting system configuration failures. DSM system configuration is also managed through a `dsmsystemconfig` Custom Resource within the gateway, which can be inspected via SSH access to the appliance VM to review directory service status and configuration details.

DSM's contribution to a configuration management program is at the platform level: it provides technical mechanisms for defining baseline configurations through policies and VM classes, enforcing them during provisioning, and tracking changes through operational visibility. The broader configuration management program, including change control processes, configuration baseline documentation and approval, configuration audits against external standards, and periodic review cycles, must be established and maintained by the organization.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer provides several mechanisms that support the implementation of configuration management controls across the application delivery layer.

The Controller maintains a centralized Configuration Database that stores all configuration information including tenants, virtual services, pools, policies, and accounts. This is the single source of truth for all system settings. When an administrator makes a change through the web interface, CLI, or REST API, that change is automatically propagated to all Controller cluster members, so any node can assume leadership with a complete and current configuration.

The Controller CLI provides direct access to the full configuration surface. The `configure systemconfiguration` command allows administrators to modify system-wide parameters including DNS, NTP, portal settings, and cryptographic algorithm

configuration, with changes synchronized to Service Engines. The ``configure`` command covers a broad range of objects including virtual services, pools, health monitors, authentication profiles, application profiles, and policy sets, and supports creation, modification, and deletion of those objects. The REST API exposes comparable capabilities programmatically, including the ``PUT api/systemconfiguration`` endpoint for system-wide settings and the ``/api/cloud`` endpoint for cloud configuration resources.

Configuration management in Avi can be automated through the Ansible ``aviconfig`` role, which allows configurations to be expressed as structured dictionaries and applied in a repeatable manner, reducing the need for multiple individual task definitions. The Controller supports on-demand configuration backup and restore, enabling disaster recovery and configuration migration across Controller instances.

In the 9.1 VCF integration, Avi distinguishes between two operational modes: Provider-Managed Mode, where the provider administrator manages Service Engine Group settings including scale-out, CPU, and memory configurations; and Organization-Managed Mode, where the organization administrator manages their own Service Engine Group configurations and infrastructure settings. This separation clarifies ownership and scope of configuration responsibilities within a shared VCF deployment. After upgrading Avi components, a drift check should be performed against VCF Operations, vCenter, and NSX Manager to verify configuration consistency across the stack.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) configuration is customized through the AddonConfig resource, a Supervisor namespace-scoped resource that supports modification of parameters such as logging level and shard virtual service size.

The Config Events overlay in the Service Engine Analytics view allows operators to correlate configuration changes with observed traffic behavior, supporting investigation of the impact of individual changes. Avi Load Balancer events provide the building blocks for configuration automation workflows.

Organizations should define change control procedures, assign ownership of configuration baselines, and determine which changes require approval before these mechanisms can function within a formal configuration management program. Avi provides the technical instruments; the program structure requires organizational governance.

Control PR.PS-02

Software is maintained, replaced, and removed commensurate with risk [Withdrawn: Incorporated into ID.RA-01, PR.PS-02] [Withdrawn: Incorporated into ID.AM-08, PR.PS-02]

SCF Controls: MNT-01, MNT-02, MNT-03, MNT-03.1, PRM-07, SEA-07.1, TDA-17, VPM-01, VPM-01.1, VPM-02, VPM-05

Aggregate Coverage: Meets

VCF (Meets)

VCF provides integrated mechanisms for identifying, tracking, and remediating vulnerabilities across the infrastructure stack. These capabilities span automated detection, compliance monitoring, alert-driven tracking, structured remediation workflows, and lifecycle management tooling.

VCF Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This capability builds on several legacy diagnostics tools and operational data to deliver integrated issue detection and remediation from a single pane. Diagnostic Findings uses a library of log and property-based diagnostic rules (also called signatures) to identify known issues across the platform, giving operations teams a structured way to discover and resolve problems.

VCF Operations extends vulnerability tracking through compliance management, which detects violations, highlights risk areas, and provides actionable remediation recommendations. When VCF Operations detects non-compliance with a defined policy, it generates alerts or notifications. Depending on the severity, administrators can configure automated remediation actions to bring objects back into compliance without manual intervention. VCF Operations also maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation tied directly to detected conditions. To retrieve remediation recommendations for a specific virtual machine, the system must be connected to a VCF Operations instance with at least one triggered alert for that virtual machine.

Configuration Drifts in VCF Operations provides a proactive method to monitor configuration changes across vCenter instances and vSphere clusters. Administrators can view and compare configuration drifts and identify settings that have changed over time. VCF Operations audit logging tracks each configuration change to an authenticated user who initiated the change or scheduled the job that performed the change, allowing administrators to determine who changed what and when.

VCF lifecycle management simplifies and automates the process of applying updates and patches to software components within the VCF stack. VCF Operations includes patch planner functionality for updating or patching individual VCF core components in a VCF domain, and provides a Plan Patching capability to create patching plans for desired components. Pre-update validation runs upgrade prechecks to verify readiness before proceeding, identifying issues before the update starts. Update bundle management supports both online and offline depots; the VCF Download Tool and the lcm-bundle-transfer-util command handle bundle download, staging, and repository configuration for environments with limited or no internet connectivity.

On the patching side, Broadcom releases security advisories for critical known vulnerabilities with step-by-step remediation instructions. Patch releases for VCF components provide time-sensitive fixes to security and catastrophic issues that affect business operations. These patches are released between major, minor, and maintenance releases and can be selectively applied based on environmental impact and operational costs.

vSphere Lifecycle Manager (vLCM) manages desired-state configurations for ESX hosts. It can create a desired state that includes a specific version of the ESX host, compatible partner software and firmware components, and add-ons. When hosts deviate from the target specification, cluster remediation applies the desired state to each non-compliant host, with the Coordinator Manager running pre-checks to evaluate how each host is affected and whether additional steps are needed. Patches can be staged to ESX hosts before remediation begins, reducing the time hosts spend in maintenance mode during the remediation window. Remediation can also be initiated manually or scheduled as a regular task to run at a time convenient for operations teams, supporting consistent patch compliance over time. Firmware add-ons can be added, replaced, removed, upgraded, or downgraded as part of the image. The vSphere Automation REST API allows administrators to query

effective global and cluster-specific remediation policies before initiating remediation, supporting a review-before-apply workflow that reduces risk during patching operations.

VCF also provides tooling for managing remediation at scale. VCF PowerCLI supports parallel remediation with a configurable maximum number of concurrent remediations, allowing administrators to remediate multiple hosts simultaneously. Live Patching allows security updates to be applied to ESX hosts without requiring a host reboot. vCenter RDU upgrades perform automatic rollback if the upgrade fails, providing a safety net during update operations. Maintenance releases are scheduled, cumulative updates focused on platform stability and support, providing bug and security fixes, hardware enablement changes, driver updates, guest OS support, and backward-compatible new features with limited scope to minimize operational impact.

For containerized workloads running on vSphere namespaces, VMware Kubernetes Service (VKS) extends vulnerability identification and remediation to the application layer. Harbor Registry, deployable as a standard package on VKS clusters, performs automated vulnerability scanning against container images using the Trivy vulnerability database, which can be configured to point to a custom or mirrored registry. Harbor also supports image signing to establish content trust, giving administrators a mechanism to identify images that have passed security review. Admission controls can be configured to restrict workload deployments to images sourced from a designated Harbor instance where scanning is enforced, helping constrain the image surface to scanned and trusted artifacts.

VKS MachineHealthCheck provides automated remediation of unhealthy cluster nodes. The `remediation.maxInFlight` parameter controls how many concurrent node remediations may proceed simultaneously, and the `triggerIf.unhealthyLessThanOrEqualTo` threshold determines the condition under which remediation activates. The Kubernetes API surfaces a Remediating condition on VKS clusters, giving administrators direct visibility into the status of ongoing node remediation. DISA Security Technical Implementation Guides (STIGs) are available for both Supervisor and VKS cluster releases (VKrs), documenting known configuration weaknesses and providing step-by-step remediation guidance for hardening these deployments. The Kubernetes Security Response Committee tracks upstream Kubernetes vulnerabilities, assigns CVE identifiers, and publishes advisories through the kube-security-announce mailing list and the official Kubernetes CVE list; the committee's policy is to fully disclose vulnerabilities as soon as a user mitigation is available, with timeframes ranging from immediate to a few weeks depending on the complexity of the issue and vendor coordination requirements. Organizations running VKS can subscribe to receive these notifications and coordinate patch deployments accordingly.

CI/CD pipelines deployed on the VCF consumption layer can incorporate Harness CI/CD with Security Testing Orchestration (STO). Harness STO integrates Wiz to perform pre-deployment vulnerability scanning across container image layers and automatically deduplicates findings, presenting each unique vulnerability, CVE, misconfiguration, or exposed secret as a single actionable item on the pipeline execution's vulnerabilities tab.

VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to vulnerability remediation by providing network-level threat detection and structured response mechanisms that identify, track, and contain exploitation attempts across protected workloads.

vDefend Distributed IDS/IPS continuously monitors east-west traffic for known vulnerability exploits using signature-based detection. In 9.1, IDS/IPS event monitoring displays CVE reference information and Common Vulnerability Scoring System (CVSS) scores for vulnerabilities targeted by detected exploits, enabling security teams to correlate detected traffic with the specific vulnerability being exploited and prioritize response based on severity. Administrators can search the signature database by CVE ID, making it possible to verify detection coverage for a newly disclosed vulnerability and identify which IDS signatures apply before system signature updates are deployed.

Custom signatures extend detection to application-specific and zero-day threats. vDefend IDS/IPS supports custom signatures that can be exported, edited, and re-uploaded to the system. Before publication, the system validates custom signatures and identifies those tagged as Invalid or Warning, preventing deployment of malformed detection rules. Custom IDS/IPS profiles can include custom signatures with assigned severity levels. Administrators can exempt known false positives from inspection when internal applications use protocols that resemble attacks but are not malicious, reducing alert noise without degrading detection coverage.

The Security Services Platform (SSP) provides a structured remediation workflow for detected security events. When vDefend IDS/IPS, Malware Prevention, or Network Detection and Response (NDR) identifies a threat, administrators can apply remediation actions that automatically create Distributed Firewall rules or IDS/IPS policies to block the attack vector. Two remediation strategies are available: Targeted remediation creates surgically scoped rules that address the specific threat with potentially lower effectiveness, while Comprehensive remediation creates broader policies that protect against similar attack patterns with potentially lower safety margins. The Response and Remediation feature in SSP performs automated creation of policy based on user role and permissions. Intelligent Assist automates selection between these strategies and handles creation of the necessary groups, security profiles, rules, and policies. For Malware events, Targeted remediation enables all IDS signatures for the affected workload, and Comprehensive remediation creates Distributed Firewall policies. Remediations detected on the Gateway Firewall are applied on the Distributed Firewall, extending protection to east-west traffic. Applied remediation policies can be verified in NSX Manager at Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

SSP manages IDS policy lifecycle by extracting all active policies, rules, and security profiles to support multiple concurrent remediations, identify stale policies for cleanup, and suggest additions that avoid conflicts with existing rules. The Security Services Platform also identifies vulnerable workloads that could be exploited for lateral movement, helping administrators understand exposure before a threat can propagate across segments.

Remediations are not automatically applied. Administrators must review and manually apply suggested remediations through the NSX Manager UI, and objects generated during remediation that encounter errors require manual cleanup. This manual review step gives security teams control over which containment actions are deployed.

The Malware Prevention Service can deny access to suspicious files or delete files confirmed as malicious directly on the protected endpoint, providing a remediation path that extends beyond network policy to the file level.

These capabilities complement VCF's infrastructure-level vulnerability and patch management by providing a network security layer that can detect active exploitation and apply containment actions while patches are being evaluated and deployed.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to the vulnerability remediation process primarily through its software update mechanisms and compliance tracking features. DSM does not provide vulnerability scanning or external CVE tracking; those functions require organizational processes and tools outside the platform.

DSM supports software remediation through update bundles that apply patches to DSM appliances and managed database versions. The DSM controller manages component dependencies through status monitoring and automated remediation, helping maintain a consistent update baseline across the environment. Database engines, including PostgreSQL and MySQL, can be upgraded to new minor and major versions through the DSM interface; upgrade operations during the maintenance window may include CVE fixes, bug fixes, and performance improvements, allowing operators to remediate known vulnerabilities by updating to patched releases.

To support issue identification, DSM surfaces database alerts with mitigation suggestions so that operators can resolve operational issues without disrupting database services. Operators should verify VM status and infrastructure health when resolving alerts to identify underlying causes. The platform can generate and download log bundles that aggregate relevant logs from database VMs to support faster diagnosis when a service faces a problem. Operators can also review active VMware vCenter infrastructure alarms through DSM troubleshooting guidance and resolve the underlying problems causing those alarms.

Data service policies in DSM include a compliance tab that tracks whether deployed databases conform to the policy. When a data service policy is deleted, the associated services are marked as non-compliant, providing visibility into configuration drift. These policies can be enforced across different tenants, supporting consistent configuration standards across the environment.

DSM handles the patching and software update aspects of vulnerability remediation within its own scope and provides monitoring and compliance visibility. The broader requirements of the control, including external vulnerability scanning to identify CVEs in database software, a centralized vulnerability tracking system for prioritization and assignment, and defined

organizational remediation timelines and escalation procedures, must be addressed through organizational processes and tools that operate alongside DSM.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several mechanisms that support an organization's vulnerability identification and remediation processes for application delivery infrastructure.

For application-layer vulnerability identification, Avi's Web Application Firewall (WAF) supports virtual patching through integration with Dynamic Application Security Testing (DAST) tools. Organizations can import scanner results into Avi to identify vulnerable application endpoints. The WAF creates Positive Security rules for each identified vulnerability, restricting requests to known-good parameters without requiring changes to the protected application. This allows organizations to limit exposure to identified vulnerabilities while application-level remediation is underway.

In 9.1, the Avi Cloud Console adds a Live Security Threat Intelligence service, which includes an Application Rules Service providing rules targeting known application vulnerabilities identified by CVE. The service covers over 5,000 applications and automatically synchronizes rule database updates, keeping CVE-based protections current without manual rule management. When the service is temporarily unavailable, Avi Controllers continue to operate using the cached rule database.

For tracking and documentation, the Avi Application Security Report generates a downloadable PDF documenting WAF security findings and pre-check results, supporting both technical review and organizational documentation requirements.

The WAF Recommendation system supports the tuning portion of the vulnerability management process by proposing configuration changes to address false positives, with reasoning and risk assessment accompanying each suggested change. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation. Alert Actions can trigger ControlScripts in response to system events, enabling automated remediation responses to detected conditions in place of manual administrator intervention.

For platform-level vulnerabilities in the Avi Controller and Service Engines, Avi supports patch application and rollback. After upgrading to a new version, old root partitions that may contain packages with known CVEs can be removed to reduce residual exposure. If a patch introduces instability, rollback features allow operators to return the Controller and all Service Engine groups to the prior version via CLI commands (rollback system, rollbackpatch system) or the REST API (POST api/rollback). The REST API also supports non-disruptive SE-group-specific rollback, allowing selective rollback of individual Service Engine groups. Organizations can lock the Avi Controller Linux system to a specific OS version to avoid CVE scanner false positives from inactive, unused package versions.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control PR.PS-03

[Withdrawn: Incorporated into ID.AM-08, PR.PS-03] Hardware is maintained, replaced, and removed commensurate with risk

SCF Controls: MNT-01, MNT-02, MNT-03, MNT-03.1, PRM-07, SEA-07.1, TDA-17

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides lifecycle management, compliance monitoring, and component tracking capabilities that help organizations identify and address unsupported technology assets, applications, and services within the virtualized infrastructure.

vSphere Lifecycle Manager is the primary mechanism for tracking component supportability across the VCF stack. Administrators define a desired-state software specification for each cluster, and Lifecycle Manager validates hosts against that specification to detect discrepancies. When a cluster or standalone host runs component versions that fall outside supported target versions, vSphere Lifecycle Manager reports an INCOMPATIBLE compliance status, giving administrators visibility into which infrastructure components have fallen out of alignment with current supported configurations. When a software component is removed from the desired specification and the cluster is remediated, the component is uninstalled from all hosts in that cluster via the Software.apply API. This provides a direct mechanism for removing unsupported or deprecated software from the environment. Hardware Support Manager plugins extend lifecycle management to vendor-specific firmware and drivers, helping identify when components are out of date or no longer supported by their vendor. For PCI devices, vSphere Lifecycle Manager checks that the driver-firmware version combination is compatible with the target image specification, not just the individual driver and firmware versions in isolation, and a non-compliant status takes precedence over an incompatible status in the compliance evaluation order. Prior to remediating a cluster or host, vSphere Lifecycle Manager performs pre-checks against a compatibility data bundle to verify that the currently installed ESX version can be upgraded to the target version; objects showing INCOMPATIBLE status may require further investigation before remediation can proceed, as remediation is not guaranteed to succeed.

VCF Operations tracks the software and firmware versions running across the VCF environment and can connect to online or offline depots to access software bundles and compatibility data. Components can be flagged as INCOMPATIBLE when they do not match target versions, giving administrators centralized visibility into what needs to be updated or replaced.

VCF Operations extends this visibility through compliance violation detection. It discovers non-compliant objects across the environment and surfaces associated compliance violations, enabling administrators to take remedial action. The CSA Compliance Pack for VCF assesses compliance across a broad set of object types, including Virtual Machine, Host System, NSX Manager Service, vSAN, Data Center, and ESX Cluster objects. Together, these tools provide a continuous view of the compliance posture of the infrastructure, which includes flagging components that may no longer meet current supportability requirements. VCF Operations also supports email notifications for alerts, and sends notifications to the Organization owner when security or system degradation issues are discovered or when emergency updates are applied.

Broadcom publishes security advisories (such as VMSAs) that document vulnerabilities and their impact on products. VCF operational guidance recommends keeping the infrastructure up to date by running current component versions. Running outdated components that are too far behind the latest version can cause support problems or upgrade difficulties, and fixes for known issues are often available only in later releases.

These capabilities address the detection, notification, and remediation aspects of the control. However, VCF does not provide a built-in workflow for documenting justification and obtaining formal approval for the continued use of unsupported components. Organizations must establish their own governance processes, such as exception request workflows and risk acceptance documentation, to satisfy the requirement for justified and approved use of unsupported technology. VCF's compliance reporting and lifecycle management data can inform those processes by identifying which components require attention and providing evidence for risk assessments.

VMware vDefend (Contributes)

VMware vDefend provides lifecycle management and operational visibility capabilities through its Security Services Platform (SSP) that support controlled maintenance activities for the vDefend security infrastructure.

SSP's Platform Inventory Monitor gives administrators status visibility across environments, regions, zones, and virtual machines, identifying assets in success, timeout, or out-of-sync states. Filtering by name and status allows administrators to assess operational health before and after maintenance activities. The View details of external rollouts option in SSP displays progress details for Refresh operations covering Bare Metal servers, NDR Sensors, and Service VMs at both the individual and overall feature status levels, providing granular visibility into rollout state.

SSP enforces sequencing constraints on maintenance operations: Bare Metal Service operations such as onboarding, offboarding, and upgrading Bare Metal servers should not be performed while a backup or restore is in progress. After restoring a backup in either a disaster recovery or in-place scenario, agent health status must be confirmed as Up on Bare Metal servers before proceeding. The vDefend CLI provides a command to display the health of all services and agents running on a Bare Metal server, giving administrators a mechanism to verify service state before and after servicing. SSP also includes Depot and Registry services that run as systemd-managed services and can be restarted and monitored via systemctl commands.

SSP proactively manages its Platform CA certificate lifecycle. The certificate manager and security intelligence services within SSP can be queried for operational status to diagnose service availability issues during and after maintenance events.

NDR Sensor management operations, including activating or deactivating features and offboarding sensors, are restricted to the Enterprise Admin or Security Engineer role, limiting who can execute maintenance actions on detection infrastructure. Tokens, Bare Metal servers, and Bare Metal server interfaces are included in the full inventory backup, supporting recovery after maintenance activities.

When using vDefend Intelligent Assist or Network Detection and Response remediation workflows, objects that encounter errors during remediation require manual cleanup, which is a constraint administrators should account for in maintenance planning.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to technology lifecycle management by providing built-in tooling for managing the versions, update schedules, and operational states of the database services it provisions. Lifecycle management capabilities are accessible through the DSM UI, which gives administrators and users the ability to create, update, and deprovision data services. In DSM, supported engines include PostgreSQL, MySQL, MinIO, and Microsoft SQL Server.

For the DSM platform components themselves, the DSM UI provides version and upgrade management capabilities that give administrators visibility into current data service versions and options for upgrading or deactivating them. Database management capabilities accessible through DSM include operating system and database engine upgrades. The DSM controller manages component dependencies through status monitoring and automated remediation, helping keep platform components in a consistent operational state.

DSM provides a maintenance policy mechanism to control when automated software updates are applied to the DSM plug-in. Administrators can configure the maintenance policy through either the DSM UI or the vSphere Client. The policy settings include a start date, a start time, and a duration that limits how long the update window may run, allowing organizations to schedule updates during low-impact periods. The maintenance_policy setting is accessible under the plug-in software update section.

For individual database instances, DSM supports a separate maintenance window configuration and a maintenance policy that administrators can set at database creation and adjust throughout the database's operational lifetime. The default maintenance window is six hours, beginning each Saturday at 23:59, and it is configurable via the maintenance-window setting. DSM adds a Monthly Occurrences setting that refines the maintenance schedule from a standard weekly cadence to specific weeks within a month, allowing selection of a particular day and one or more occurrences of that day. This granular scheduling is available for MySQL, SQL Server, and other supported engines, and is also accessible to tenants through the VCF Automation interface.

Infrastructure governance is supported through the Data Services Manager Consumption Operator, which automates database deployments based on predefined infrastructure and backup policies. The Consumption Operator applies infrastructure policy and backup location bindings to namespaces matching a configured selector, helping align deployed services with approved infrastructure configurations across their operational lifetime.

A vSphere administrator plans, administers, and secures resources for databases by creating and managing infrastructure policies in DSM. DSM deploys Telegraf agents on the provider appliance and on each database workload cluster to collect VM-level and engine-specific metrics, supporting operational awareness across the service lifecycle.

Technology lifecycle management at the organizational level requires processes beyond what DSM directly provides. DSM does not maintain a centralized inventory of all technology assets across the broader environment, nor does it manage end-of-support or end-of-life calendars for the infrastructure it depends on. Organizations must establish their own processes for tracking asset lifecycles, consulting vendor roadmaps, and making upgrade or retirement decisions within a formal change management framework. DSM's maintenance and version management capabilities are most effective when integrated into those broader organizational lifecycle processes.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer has built-in mechanisms for managing the lifecycle of its own technology components. The Avi Controller is the central management plane responsible for deploying, configuring, and decommissioning Service Engine VMs. In vCenter and NSX environments, the Controller automatically manages the Service Engine lifecycle, provisioning new Service Engine VMs when a Service Engine VM or its ESX host fails.

The Avi Controller REST API supports application lifecycle automation, providing programmatic visibility into all configured virtual services and enabling create, update, and delete operations across the application delivery estate. Infrastructure-as-code integrations build on this API: Avi Ansible modules allow operators to define, create, and manage Virtual Services, Pools, and Health Monitors consistently across deployments. Avi automation integrates with DevOps workflows and infrastructure-as-code practices to streamline operations and reduce manual errors.

VCF introduces a dedicated Avi Load Balancer integration for VCF. The VCF Automation Provider Management portal supports resource governance and capacity planning to help prevent organizations from over-consuming shared Avi Load Balancer resources. Organization and project administrators can define blueprints that act as reusable designs for deploying Layer 4 and Layer 7 virtual services; blueprints can be scoped to a single project or shared across projects within an organization. Service Engine Groups can be assigned to projects, enabling a self-service model for application teams while retaining administrative control over capacity allocation.

Avi also manages the lifecycle of associated security artifacts. The Avi License Hub manages the Platform CA certificate lifecycle and automatically initiates certificate refresh processes. The Controller license ledger tracks consumed and available licensing values and displays consumption metrics for Service Engines.

The control asks whether the organization manages the lifecycles of technology assets, applications, and services broadly. Avi contributes the mechanisms for lifecycle management of the application delivery layer, but the organizational governance process of tracking all technology assets across the environment, defining end-of-life criteria, and executing planned decommissioning activities extends beyond what any single tool provides.

Not applicable for this control: VCF Protection and Recovery. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control PR.PS-04

Log records are generated and made available for continuous monitoring [Withdrawn: Incorporated into PR.PS-04]

SCF Controls: MON-01, MON-01.4, MON-03

Aggregate Coverage: Meets

VCF (Meets)

VCF produces structured event logs across its component stack that contain all six content elements specified by this control: event type, timestamp, location, source, outcome, and user identity. The platform's Consumption layer, which includes VMware Kubernetes Service (VKS), vSphere Supervisor, and vSphere namespaces, extends this coverage to Kubernetes workloads using the kube-apiserver audit mechanism and component logging infrastructure.

Event type identification

VCF components classify events by category and severity. VCF Operations generates audit events organized into categories including Access, Access_control, Account_management, Configuration, Data_access, Network, Notification, Permissions, Session, System, Policy, and Firewall. VCF Operations log entries include a logging level (info, warning, error) and a component class name identifying the subsystem that generated the event, along with a descriptive message. VCF Automation records events for catalog deployments, cloud template operations, Day 2 operations, and resource actions, and its audit logs display a status value or message for each reportable action type. VCF Automation issues specific events such as "Deployment requested" and "Deployment completed" around catalog and cloud template operations. NSX Manager audit logs record administrative changes with structured metadata including request ID, component name, subcomponent, and update status, and include a description of the event for actions such as logon, logoff, and resource access. The VMware vCenter EventEx interface constructs extended events with an explicit eventTypeId and severity parameter, providing machine-readable event classification at the API level. For workloads running on VKS clusters, the kube-apiserver records every API request using the audit.k8s.io/v1 Event schema, where the verb field captures the operation performed (create, get, update, delete, list, watch, patch) and the objectRef field identifies the resource type and API group involved. The audit Event record also includes an auditID that uniquely identifies each event for correlation across log entries, and a stage field indicating which stage of request processing produced the entry (RequestReceived, ResponseStarted, ResponseComplete, or Panic).

Timestamps

All logging subsystems across the VCF stack include date and time information. VCF Operations log events contain a timestamp as the first of eight common fields. VCF Operations Infrastructure Operations records the date and time when events and alerts are generated in the Created On field. NSX Manager audit logs record timestamps in ISO 8601 format for create and modify operations, and each NSX audit log entry includes a timestamp. VCF Automation audit logs record a timestamp for every reportable action. Kubernetes audit events include requestReceivedTimestamp and stageTimestamp fields, recording when the request was received by the API server and when each processing stage completed. Kubernetes system component logs in klog format carry a timestamp in every log entry alongside severity level, source file, and line number.

Event location and source

VCF Operations log entries include the source IP address and host IP of the system that generated the event, along with a source field indicating where the event originated, such as a VMware ESX host or syslog aggregation forwarder. Each event forwarded to VCF Operations contains source information and name-value pair fields extracted from the raw event data. NSX audit logs record the source of each event. VCF Log Management allows operators to search and filter collected log events by source. In VKS clusters, the Kubernetes audit event objectRef field records the namespace, resource type, resource name, API group, and API version; the requestURI field records the full API path; and the sourceIPs field records the originating IP address of the request, with the userAgent field providing additional context for service-to-service calls. Syslog log messages

from vSphere Pods include namespace name, pod UID, pod name, container name, and ESX host name as metadata fields when the LogAgentConfiguration Custom Resource is applied, providing workload-level source attribution alongside infrastructure-level source data. The Supervisor can also be configured to preserve the source IP addresses of authentication requests and Kubernetes API Server requests, making those addresses available for inspection in audit logs.

Outcome

VCF Operations log events can be filtered by logging level, and the Analyze page allows searching and filtering based on timestamp, text, source, and extracted fields. NSX audit logs include a result field that records the success or failure of the logged action. NSX Manager audit logging records operation status with detailed change tracking for administrative operations, including old and new values. VCF Automation audit logs contain a status value for each action indicating the outcome. Audit events across the platform capture success and failure states for operations. Kubernetes audit events record outcome in the responseStatus field, which contains the HTTP response status code indicating success or failure; at the RequestResponse audit level, response bodies are also captured, including error messages for failed operations. VM Operator logs record VM creation failures and reconciliation events for VirtualMachineService resources in VKS clusters, capturing failure details such as OVF deployment errors caused by insufficient ESX host resources.

User identity

VCF Operations audit logs can be filtered by User ID, User Name, Auth Source, Session, Client IP, Category, and Message. User permission events are sourced from VMware vCenter logs and can be filtered by event, status, updated by, object name, and object type. VCF Automation events record the user who triggered each event in the Owner field, and event logs record API access token usage by including the UUID of the token that performed the action. VCF Automation audit logs also include the user name and project name associated with each action, along with a trace ID for correlation. NSX Manager generates audit logs that record UserName, ModuleName, Operation, and Operation status with timestamps and request identifiers. The vCenter EventEx interface accepts a userName parameter when constructing event records, associating user identity with the logged action at the API level. VCF SSO audit event records include the timestamp, the user who performed the action, an event description, severity, and the IP address of the client connection to vCenter. Kubernetes audit events capture identity in the user field, which records the authenticated username, UID, group memberships, and extra attributes of the requester; for requests made through service accounts, the service account name and namespace are recorded as part of the user context.

Log detail and centralized management

ESX hosts support configurable syslog log levels that can be adjusted using esxcli system syslog commands, and the host agent log level can be set to verbose or other levels to control the detail captured. ESX syslog messages conform with RFC 3164, which defines structured message formatting. ESX audit records conform to RFC 5424 and contain event time, status, description, and user information for security-relevant activity tracked on the host. The Syslog.global.auditRecord.remote parameter enables forwarding ESX audit records to the remote syslog collector specified by Syslog.global.logHost. VCF Operations log events contain eight common parts: timestamp, thread name, host IP, logging level, class name, message text, token number, and duration. For centralized log management, VCF Log Management can be configured to pull tasks, events, and alerts from vCenter instances and receive syslog feeds from ESX hosts. vCenter can also stream events directly to a remote syslog server by enabling the vpxd.event.syslog.enabled option in the vCenter Management Interface; forwarded events carry the fields eventId, createTime, eventType, severity, user, target, chainId, and desc. The VCF Operations audit log is integrated with syslog, allowing collection of all audit log data through the syslog collector. The VCF Log Management Analyze page provides a centralized interface for searching and correlating log events across all sources. NSX audit log messages are stored in /var/log/audit/audit.log. For deployments evaluated against global compliance frameworks, all auditable events defined by the applicable security requirements are logged by the platform.

For the Consumption layer, Kubernetes audit policy supports four logging levels (None, Metadata, Request, and RequestResponse), giving administrators fine-grained control over the verbosity and scope of audit records for VKS clusters. Audit events are written in JSONlines format to a log file via the kube-apiserver Log backend, configured through the --audit-log-path, --audit-log-maxage, --audit-log-maxbackup, and --audit-log-maxsize flags; audit events can also be forwarded in real time to an external system using the Webhook backend, which delivers batched events as HTTP POST requests to a

configured endpoint. Kubernetes audit records are collected by node log agents and forwarded to a central log store as part of the cluster observability pipeline. Fluent Bit logging agents deployed in the vmware-system-logging namespace collect and forward logs from nodes across the cluster; on VKS clusters, Fluent Bit collects Kubernetes container logs, Kubernetes API audit logs, Linux daemon logs, Linux authentication logs, and container runtime interface logs through configurable parsers and filters, and supports forwarding to Syslog, HTTP, Elasticsearch, Kafka, and Splunk. Workload logs from vSphere Pods and vSphere Namespaces are streamed to a remote Syslog server by applying a LogAgentConfiguration Custom Resource; each syslog message carries namespace name, pod UID, pod name, container name, and ESX host name as metadata fields. Kubernetes seccomp supports the SCMP_ACT_LOG action, which logs syscall execution to syslog or auditd without restricting the syscall, and the audit.json seccomp profile logs all syscalls of a process for detailed syscall-level auditing. For Windows workloads on VKS, the support bundle collects Windows Event Logs covering System, Security, Application, Windows Firewall, and networking event sources. Pod-level events accessible through kubectl describe pod record each event with a From field indicating the component source, a Reason field indicating why the event occurred, and a Message field providing details, all with associated timestamps.

VMware Private AI Services (PAIS) includes several event logging and observability mechanisms across its AI-specific components that contribute to the requirements of this control.

PAIS observability is configured through the PAISConfiguration custom resource. When activated, PAIS collects metrics in an integrated Prometheus server and supports forwarding LLM traces to an OpenTelemetry Collector over http/protobuf or gRPC. The spec.observability.prometheusRuntime section enables Prometheus with configurable storage class and metrics retention period, and the spec.observability.llmTraces section activates trace forwarding. These traces capture timing, event type, and source component information for model inference, agent execution flow, and knowledge base indexing. MLOps engineers and application developers use observability platforms such as Grafana to monitor model health, quality, and behavior of AI applications. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service and can also stream to VCF Operations through Telegraf with namepass filters that capture controller runtime worker counts, work queue depth, and reconcile concurrency.

Model endpoints built on the vLLM inference server support the VLLM_LOGGING_LEVEL environment variable to control inference logging verbosity, with DEBUG available as a supported value. Operators can retrieve logs for a specific model endpoint pod in the pais namespace by running kubectl logs against the pais-kubeconfig. Knowledge base operations record timing metrics for file downloads, embedding generation, and index operations, along with size metrics including total megabytes downloaded, number of new chunks indexed, and final index size. These records identify the type and duration of each operation.

Deep Learning VMs write cloud-init deployment logs to /var/log/dl.log and vGPU or NVIDIA data center GPU driver installation logs to /var/log/gpu-install.log. Deep Learning VMs also expose vGPU performance metrics through Prometheus for collection and visualization. These logs and metrics capture deployment progress, driver installation outcomes, and runtime performance.

Configuring all Technology Assets, Applications, and Services with sufficient event log content, including complete user identity trails and system-level API audit records across the full stack, requires configuration at the underlying VCF platform layer, including Kubernetes API server audit logging through VMware Kubernetes Service (VKS), VMware vCenter event logs, and VMware ESX host logs.

VMware vDefend (Contributes)

VMware vDefend (vDefend) produces event logs across its components that contain the information elements specified by this control, covering the network security layer of the VCF infrastructure.

Event type identification: vDefend components categorize events by type across multiple security functions. The Distributed Firewall (DFW) logs firewall rule hits with the action taken (allow, drop, or reject) and the rule ID that matched. IDS/IPS generates detection events categorized by signature severity level and threat category. Security Intelligence provides a View Full Event History capability that displays all events associated with a signature ID and the intrusion severity. Malware Prevention Service logs file analysis events categorized by detection status, verdict (BENIGN, malicious, or suspicious), and

malware family. Network Detection and Response (NDR) generates detection events forwarded to SIEM endpoints with structured metadata identifying the type of network threat detected.

Timestamps: All vDefend event logs include timestamps. Malware Prevention Service event logs record an inspection timestamp and event timestamps for each file analysis operation. Security Services Platform (SSP) logs certificate loading events with timestamp and component name information. Guest Introspection Platform Host Agent (MUX) messages written to `/var/log/syslog.log` include a timestamp in each log entry.

Event source: vDefend event logs identify the source of each event. DFW logs identify the specific vNIC, virtual machine, and security policy involved in each rule evaluation. IDS/IPS logs identify the affected workload and the network segment where the detection occurred. Malware Prevention Service logs include the client VM ID, submission source, server information, and gateway identification for each file analysis event, enabling analysts to trace events back to the originating workload. NDR events identify the network flows and endpoints involved in detected anomalies.

Outcome: vDefend logs capture the outcome of security operations. DFW logs record whether traffic was allowed, dropped, or rejected based on rule evaluation. IDS/IPS events record whether a signature match triggered an alert or a block action. Malware Prevention Service logs record the verdict (BENIGN, malicious, or other classification) and a numeric risk assessment score alongside the analysis completion status for each inspected file. Malware Prevention Service event logs also capture file hashes (SHA-256, SHA-1, MD5), file metadata including file name, file type, and file size, as well as HTTP domain, HTTP method, user agent, and file upload status for web-based file transfers. NDR detection events capture the severity and confidence level of detected threats.

User identity: vDefend captures user identity through multiple mechanisms. The Identity Firewall component collects Windows event logs from configured Event Log Servers to associate network traffic with Active Directory users and groups, enabling user-attributed firewall rule enforcement. Event Log Scraping is configurable on a per-domain basis from Servers & Site Mapping; in federated environments, Event Log Scraping and processing occur only at the Local Manager site. Event Log Sources are configured in Security > General Settings > Identity Firewall Event Log Sources, with the option to forward user identity events to VCF Log Management. NSX Manager audit logs capture the identity of administrators making configuration changes to firewall rules, security policies, and other objects through administrator identity fields, providing accountability for policy creation and modification.

Centralized log collection: VCF Log Management provides a centralized log management framework for vDefend. Unified Security Logs in VCF Log Management contain log messages for DFW, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering, enabling correlation across vDefend security functions from a single interface. Logs can be forwarded to VCF Log Management by configuring it as a syslog server.

SIEM integration: NDR forwards event logs to SIEM endpoints supporting Splunk (on-premises or cloud-hosted) and custom endpoints with configurable HTTP headers for authentication. NDR supports SSL verification for event logs sent over HTTPS and integrates with VCF Log Management as a SIEM server. Security Services Platform sends campaign and event logs to the connected SIEM as they occur. IDS/IPS events can be exported to external syslog consumers by enabling the `ids_events_to_syslog` setting (disabled by default); this requires remote syslog to be configured on the ESX host. vDefend syslog messages conform to RFC 5424 on vDefend appliances and RFC 3164 on ESX hosts. Guest Introspection Platform Host Agent (MUX) logs are written to `/var/log/syslog.log` on ESX hosts in a structured format that includes a timestamp, ContextMUX identifier, and thread ID.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN

Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

VMware Data Services Manager (Meets)

VMware Data Services Manager (DSM) provides a structured audit logging framework that captures event data across multiple dimensions required by this control. The gateway audit logs and System Audit Events view expose six core fields for each recorded event: Component (identifying which DSM component performed the operation), Event Type (classifying the action taken), Event Details (providing operation-specific context), Event Time in UTC (recording when the event occurred), Status (recording the outcome as success or failure), and Source (recording the identity of the user or system that initiated the action, using the user's email address for authenticated user actions or "System" for internally initiated operations). These fields collectively address all six event content requirements: event type, timestamp, location, source, outcome, and user identity.

The System Audit Events view in the DSM Provider interface is the designated location for reviewing non-database-related operations and tasks. DSM generates system audit events that track user actions performed through the DSM UI and API, which can be examined using the System Audit Events menu. Administrators can access this view through the System Audit section of the UI, where events are presented with all six columns visible. Audit event data can be exported in CSV or XLSX format using the ACTIONS dropdown menu, and the export covers all events visible to the authenticated user regardless of pagination.

Gateway audit log files are stored locally on the Provider VM at `/var/log/tadm/provider/audit/` with filenames in the format `gateway-audit-timestamp.log`. These files are retained for the last five days on the Provider VM, including the file containing the most recent events. The gateway logs track user read and write operations to DSM data services or infrastructure objects performed through the DSM UI and through the DSM Gateway Kubernetes interface. When a default S3 provider log repository is configured, DSM archives gateway audit log files periodically to an S3 subpath named "gateway audit."

Recovery and operational events, such as Provider Restore Success, are recorded in the System Audit Events table with Event Type and Event Time fields, allowing administrators to correlate recovery operations with specific time windows.

DSM's audit logging covers DSM control-plane events directly. However, database engines provisioned by DSM, including PostgreSQL, MySQL, and MinIO instances, may require separate database-level audit logging configuration to capture events at the application layer with the same level of field detail. Organizations should review the audit logging capabilities of each provisioned database engine and configure them to meet the full scope of this requirement across all managed assets.

VMware Avi Load Balancer (Meets)

VMware Avi Load Balancer (Avi) includes a native event logging system across both the Avi Controller and Service Engines that records structured event data covering all six fields this control specifies.

Avi system events capture a defined set of fields per entry: Timestamp (the date and time the event occurred), Resource Name and Resource Type (identifying the specific object and category of resource involved, establishing where the event occurred), Event Code (a named classification such as CONFIG_CREATE or CONFIG_UPDATE that identifies the type of event), and Description (a brief account of the event). Event logs track who made configuration changes and when, and can be filtered by event type using search parameters such as event_id=CONFIG_CREATE or event_id=CONFIG_UPDATE. For operational events such as configuration restores, the event record includes task name, status, node IP address, and success or failure messages, capturing the outcome of the operation.

Service Engine application logs apply the same structured fields at the data-plane layer, with each entry recording Timestamp, Resource Name, Resource Type, Event Code, and Description for virtual service and pool events. This extends structured logging beyond administrative actions on the Controller to application-layer events processed by the Service Engines.

The Controller's global event log, accessible via Operations > All Events, displays events across all objects including deleted objects and sub-objects such as profiles and certificates. Object-specific event logs are also available from the Events tab on detail pages for Virtual Services, Pools, Service Engines, and Controllers, automatically filtered to that object. The analytics API endpoint `/api/analytics/logs` retrieves event logs with configurable type, duration (up to one year), page_size, and end parameters to support queries across specific time periods.

Avi Controller and Service Engines log audit records for trusted channel initiation, termination, and function failures to Events, Syslog, and Splunk. The Avi Web Application Firewall (WAF) logs matched application-layer events including matched variable name and matched variable content, with audit log parts configurable to include full event data. Avi Controller also logs denial of service attack events with event_id, attack_count, threshold values, and alert level.

The Controller's Syslog-Audit-Persistence alert action template supports forwarding events to external syslog servers for audit compliance. Note that syslog notifications push alerts but do not automatically export virtual service logs; virtual service logs must be pulled from an external logging system through the API or scripted to push from the Controller to a remote destination.

Control PR.PS-05

Installation and execution of unauthorized software are prevented

SCF Controls: CFG-01, CFG-02, CFG-03, CFG-03.2, CFG-05, END-03

Aggregate Coverage: Meets

VCF (Meets)

VCF provides layered mechanisms to restrict execution of unauthorized software across the hypervisor, virtual machine, container, and automation layers.

At the host level, VMware ESX enforces UEFI Secure Boot, which verifies the digital signature of every component in the boot chain before execution. The vSphere Security Configuration Guide recommends enabling Secure Boot and Trusted Platform Module (TPM) as part of ESX host hardening. Hosts equipped with TPMs provide hardware-rooted attestation, and VMware vCenter monitors host attestation state to confirm that each host has booted into a known-good configuration. The vCenter trusted infrastructure API provides interfaces for retrieving TPM event logs, endorsement keys, and attestation data from host hardware. ESX also supports Intel Trusted Execution Technology (TXT) for hardware-based verification of the hypervisor launch environment. The hypervisor enforces acceptance levels for VIBs (vSphere Installation Bundles), restricting installation and execution of unsigned or untrusted software packages on hosts. ESX also supports the `execInstalledOnly` enforcement setting, which requires that all executables running on the host originate from installed VIBs, directly blocking execution of unsigned or ad hoc binaries outside the VIB-managed software baseline.

vSphere Lifecycle Manager (vLCM) manages all hosts in a cluster collectively with a single image, and upon remediation, the image is installed on all hosts in the cluster. This desired-state model, combined with configuration profiles and drift detection, restricts unauthorized changes to the host software baseline. VCF Operations detects configuration drifts by comparing current vCenter values against configuration template values, notifying administrators of deviations from assigned baselines. Configuration drift detection can be scheduled for vCenter instances and vSphere clusters, and configuration templates can be integrated with source control for versioning and audit. VCF Operations compliance management detects violations, flags risk areas, and provides actionable remediation recommendations.

Host security configuration hardening rules can be enforced through workflows such as Apply Host Security Configuration Rules, which apply security baselines that restrict host-level software execution and configuration changes. VCF's hardening guidance for vCenter covers securing the installation, configuring roles and permissions, securing access and authentication, and enabling auditing and logging. These hardening practices, aligned with industry-standard best practices and the Security Configuration Guide, provide a layered approach to restricting unauthorized software execution across the platform.

For virtual machines, VCF supports UEFI Secure Boot at the guest level, allowing guest operating systems to verify the integrity of their own boot process. Virtual Trusted Platform Modules (vTPMs) extend hardware-rooted trust into virtual machines without requiring physical TPM hardware. The vTPM capability is integrated with VCF Automation for VM Apps, which requires the cryptographic operations direct access privilege in vCenter to support vTPM when deploying Windows 11 VMs. PowerCLI provides the `VMware.VimAutomation.Security` module for managing vTPMs programmatically. VCF Operations management pack PAK files are signed with a digital signature that indicates the original developer or publisher and provides authenticity verification. At the virtual machine level, the `isolation.device.edit.disable` setting, available through both vCenter and VCF Operations, restricts unauthorized modification of virtual machine devices, limiting the ability to attach or alter devices that could be used to introduce unauthorized software into a guest operating system. VCF Operations also provides a setting to disable automatic installation of VMware Tools (`disable tools auto install`), which restricts software from being installed on virtual machines without explicit administrator action. Virtual machines can also be configured with the `restrict-user-commands` setting to restrict users from running commands within the guest, providing a guest-level enforcement layer that complements the RBAC-based guest operations privilege restriction.

For Kubernetes workloads running on VMware Kubernetes Service (VKS), the platform provides a layered set of enforcement mechanisms at the container, pod, and admission control layers. VKS cluster management image registry policies restrict the specific images that can be pulled from a registry for deployment in managed cluster namespaces, with a policy enforcement

setting that defaults to Deny, fully enforcing the policy and blocking admission requests with violations; a Dry run mode is available for testing without enforcement. VKS ships with a vmware-system-restricted Pod Security Policy by default that does not permit privileged access to pod containers, blocks privilege escalation to root, and requires security controls across running workloads. The vmware-system-privileged policy, which permits unrestricted workload execution, requires explicit binding through a RoleBinding or ClusterRoleBinding and is accessible only to cluster administrators by default. Namespaces can be configured to operate under the Baseline or Restricted Pod Security Standard, which restricts unprivileged processes from loading kernel modules, providing an additional boundary against unauthorized code execution. VKS clusters apply the RuntimeDefault seccomp profile to pods by default, restricting the set of system calls available to containerized processes; custom seccomp profiles with SCMP_ACT_ERRNO deny-by-default semantics can be assigned to workloads requiring tighter restrictions. For Linux-based workloads, AppArmor profiles restrict program access to specific system resources by specifying a loaded profile in the container specification; AppArmor can operate in enforcing mode, which blocks access to disallowed resources, or complain mode for audit-only monitoring of violations. AppArmor is available on both Ubuntu and Photon OS VKS node images, restricting container capabilities, file system access, and network access in VMware-native node configurations. Linux Security Modules such as SELinux can be configured to deny the module_request permission to containers entirely, blocking the kernel from loading modules on behalf of containerized processes. Admission control through ValidatingAdmissionPolicy blocks or constrains deployment of workloads that do not satisfy defined criteria, including protecting platform namespaces from non-conforming resources. Content libraries in VKS support assigning a Security Policy at creation time, scoping which artifacts can be sourced from that library and, in internet-restricted environments, limiting deployable artifacts to administrator-approved sources. Running containers can be restricted to an immutable state through the readOnlyRootFilesystem security context field, limiting the ability of a running process to introduce new executable code at runtime. Security Technical Implementation Guides (STIGs) covering Supervisor and VKr system components are available through Tanzu STIG Hardening, providing validated hardening baselines for VKS cluster node software execution environments.

PowerShell, which is the primary scripting and automation interface for VCF through PowerCLI, supports an execution policy feature that determines whether scripts are allowed to run and whether they must be digitally signed. The execution policy defaults to Restricted, the most secure setting, restricting unauthorized script execution in management contexts. Administrators can configure this policy to allow only signed scripts from trusted publishers.

VCF Automation for VM Apps allows administrators to create a list of permitted day-2 actions that users can run on deployments. By defining an explicit allow list of operations, administrators restrict users from initiating actions outside the approved set, limiting the ability to deploy or execute unauthorized software through the automation platform.

ESX Agent Manager provides privilege-based restrictions on operations performed against ESX agent virtual machines. By integrating solutions with ESX Agent Manager, administrators can limit operations such as powering off agent VMs to users who hold the EAM.Modify privilege, restricting unauthorized users from interfering with or substituting managed agent software.

The vCenter authorization model enforces consistent role-based access control across the environment. Software components require authorization to perform operations on behalf of a user, and vSphere implements mechanisms to restrict access to virtual infrastructure components to valid, authenticated users.

Across the full VCF platform, mechanisms exist at every layer to restrict execution of unauthorized software: Secure Boot and VIB acceptance levels at the host, VM-level attestation and device restriction at the guest, and Pod Security policies, seccomp syscall filtering, AppArmor and SELinux enforcement, admission control, and image registry policies at the Kubernetes workload layer. The combination of these natively available mechanisms, including defaults such as the vmware-system-restricted Pod Security Policy and the RuntimeDefault seccomp profile applied to VKS workloads, satisfies the control's requirement that mechanisms exist to configure systems against unauthorized software execution. Determining which software is authorized and selecting appropriate enforcement strictness levels for the organization's specific environment remains an organizational responsibility.

VMware vDefend (Meets)

VMware vDefend contributes to preventing the execution of unauthorized software through its Malware Prevention Service, which operates at the hypervisor layer to detect and block malicious executables and scripts within guest workloads.

The Distributed Malware Prevention feature intercepts and analyzes executable files across a range of formats, including portable executables (.exe), ELF executables (.elf), Microsoft installers (.msi), Windows shortcuts (.lnk), and related binary categories. The analysis runs through the Security Services Platform (SSP), and the Malware Prevention Service intercepts process start and stop events on endpoints to gather critical details including Process ID (PID), command lines, binary paths, and hashes. On Windows workloads, Guest Introspection drivers are required to receive the full distributed protection. When a file is identified as malicious, Distributed Malware Prevention with Guest Introspection provides interfaces for remediation actions, including denying access to suspicious files or deleting files identified as malicious.

vDefend's Malware Prevention Service also addresses fileless attacks that bypass traditional file-based controls. The Fileless Malware Detection capability monitors Indicators of Compromise (IoC) including process command lines, process hash, process execution trees, and in-memory executions. In 9.1, the service intercepts in-memory scripts through Microsoft's Antimalware Scan Interface (AMSI), capturing execution traces of scripts running directly within process memory, including PowerShell, VBScript, and JScript. This detection path addresses script-based attacks that operate within system memory using existing binaries and in-memory operations without leaving executable artifacts on disk.

Administrators can manage software execution policy through the Malware Prevention Allowlist, which lets them override or suppress the verdict that vDefend has computed for specific files, providing a mechanism to approve known-good software. Malware Prevention profiles can be configured to send files to the cloud for analysis or to process files locally, providing flexibility for environments with cloud connectivity constraints.

The Malware Prevention Dashboard supports monitoring by tracking Process Name, PID, Command Line, and Binary Path for processes associated with in-memory script buffer execution. A Process Analysis Report provides detailed results for inspected processes and in-memory script buffers, including verdict information for each, supporting investigation and incident response workflows.

These capabilities complement VCF platform controls (Secure Boot, code signing, container image trust) by adding a runtime detection and prevention layer within guest workloads, including coverage of fileless and in-memory techniques that static boot-time and installation-time controls cannot address.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the va-configurator.xml file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) applies role-based access controls that restrict software installation and activation activities to users with explicitly assigned privileged status. Several layers of privilege enforcement exist across the platform's operational surface.

Deploying the DSM Provider Appliance requires a user with the vSphere Administrator role, which has exclusive responsibility for deploying the appliance and managing DSM VM updates. This prerequisite is enforced at the deployment step and cannot be bypassed by standard user accounts.

Within DSM, activating or deactivating supported data service versions (such as PostgreSQL, MySQL, or SQL Server) is restricted to DSM administrators. Standard DSM Users cannot activate new data service versions. SQL Server instance provisioning and server-level configuration management, including Active Directory integration and high availability configuration, are also restricted to DSM administrators only.

At the database level, activating or deactivating PostgreSQL extensions requires the PostgreSQL SUPERUSER role. Extensions cannot be added by ordinary database users, which restricts the installation of additional database-level software components to specifically privileged accounts. For MySQL databases, DSM revokes the create and update privileges on objects in the mysql system schema for database users, preventing unauthorized modification of system-level components. For SQL Server databases, DSM grants the cluster administrator login restricted read-only privileges and specific ALTER privileges for server management and auditing, rather than full privileges. The `dsm_db_user` custom database role denies TAKE OWNERSHIP on the database to prevent privilege escalation.

The DSM administrator UI includes a Permissions view where administrators create, monitor, and manage user accounts and role assignments. DSM User role assignments can be scoped to one or more specific Supervisor namespaces, further limiting what operations a given user can perform within the platform.

Configuring infrastructure policies, which govern where and how database resources are provisioned, requires a vSphere administrator with appropriate DSM permissions. These policies are enforced automatically during provisioning operations.

The broader requirement to prohibit unauthorized software installations across all systems and workloads in an environment requires organizational processes and controls at the infrastructure layer that extend beyond DSM's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

Control PR.PS-06

Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle [Withdrawn: Incorporated into ID.AM-08, PR.PS-06]

SCF Controls: TDA-01, TDA-01.1, TDA-06, TDA-06.1, TDA-06.2, TDA-06.3, TDA-09

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RC

The recovery portion of the incident response plan is executed once initiated from the incident response process. Recovery actions are selected, scoped, prioritized, and performed. The integrity of backups and other restoration assets is verified before using them for restoration. Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms. The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed. The end of incident recovery is declared based on criteria, and incident-related documentation is completed. [Withdrawn: Incorporated into RC.CO-04] Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders. Public updates on incident recovery are shared using approved methods and messaging. [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

SCF Controls: BCD-01, BCD-12

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides built-in capabilities for secure recovery and reconstitution of infrastructure and workloads to a known state after a disruption, compromise, or failure. These capabilities span compute-level high availability, storage-level data protection, structured backup and restore workflows for management components, and disaster recovery across sites.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts following a physical machine failure, restoring workloads to their prior operational state. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure with no data loss or downtime. Proactive HA supports maintenance mode as a remediation method, allowing the platform to respond to hardware degradation indicators. On TPM-equipped hosts, VMware ESX supports a Secure ESX Configuration recovery key that is required to restore the host configuration following TPM failure, TPM reset, motherboard replacement, or TPM device replacement; administrators can retrieve and store this key using `esxcli system settings encryption recovery list` and should keep it in a secure, off-host location.

At the storage layer, vSAN fault domains distribute data according to storage policy so that it remains available even when hardware failures occur. vSAN stretched clusters extend a cluster across two availability zones, providing site-level resiliency against the loss of an entire availability zone. When one site becomes unavailable, the surviving site continues operations, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSAN Data Protection uses native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster to support point-in-time recovery from operational failures or ransomware attacks. Changed Block Tracking (CBT) tracks changes on disk sectors, enabling incremental backups through VADP-integrated partner backup solutions.

For large-scale disruptions, Application Disaster Recovery enables failover to a secondary site, with data replication so recovery options exist in the event of catastrophic failure. Disaster recovery can also be implemented for fleet-level components, covering the management plane itself. VCF documentation recommends planning and testing disaster recovery strategies regularly to validate that recovery time objectives (RTO) and recovery point objectives (RPO) can be met.

VCF includes structured backup and restore workflows for its management components. Administrators create a series of backup jobs that capture the state of related components, including VCF Operations, NSX Manager, and VMware vCenter, at a common point in time. VCF Operations backup is configured to take a backup on state change. VMware vCenter supports both file-based and image-based backup methods. The file-based restore procedure is a two-stage operation: stage 1 deploys a new vCenter appliance, and stage 2 transfers data from the backup location to that appliance; the restored appliance operates in non-HA mode, so vCenter High Availability must be reconfigured after recovery completes. Simultaneous backups of VCF Operations fleet management component nodes support restoring the nodes to a logically consistent state, so further integrity remediation is not required after a restore. The platform also recommends backing up the management domain

vCenter and VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as a VCF SSO reset, to preserve a known-good recovery point.

For VMware vCenter specifically, the vCenter Management API provides a unified restore process that handles multiple vCenter components in a single operation. After a file-based or image-based restore, the reconciliation API checks whether vCenter partners in embedded linked mode are available, synchronizes vCenter data and services with the partners, and runs vCenter services. The appliance recovery API exposes a restore client interface for programmatic restore operations, supporting automation of recovery workflows.

VCF Operations supports image-based backup and restore as a recovery process for single node, primary node, replica node, data node, and collector failures. VCF Operations for Networks supports backup and restore of its deployment data to enable recovery when the existing setup is unrecoverable. VCF Operations HCX provides backup and restore operations through its appliance management interface, and its Mobility Groups support workload migration with state tracking, retry capabilities, and reverse migration from destination back to the original source.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere namespaces, and VCF Services consumption, extends recovery and reconstitution capabilities to containerized workloads and self-service deployments. At the Kubernetes control-plane level, ReplicaSets and Deployment controllers continuously monitor pod health and reschedule workloads to healthy nodes when pods or nodes fail. Liveness probes detect application-level failures and trigger container restarts; readiness probes gate traffic until a workload recovers from transient faults or overloads. These self-healing mechanisms operate without manual intervention for transient failures. Pod Disruption Budgets allow administrators to define minimum availability constraints that the platform respects during voluntary disruptive actions such as node upgrades or certificate rotations, so those operations proceed without taking down an entire service.

VKS clusters support structured backup and restore through VKS Cluster Management and Velero-based mechanisms. VKS Cluster Management backup operations can capture an entire cluster or a subset of data resources, and restore operations allow the operator to specify the scope of resources to recover. Restore operations include file system backups by default; CSI volume snapshots can be optionally selected for restoration. CSI Volume Snapshots deliver crash-consistent backups with support for block mode and file system mode, incremental backups, deduplication, compression, and encryption, and provide a resilient safety net for VKS clusters when primary storage infrastructure fails. CloneFromSnapshot custom resources expose a status.phase field that tracks restore progress through multiple phases, giving operators visibility into the state of ongoing recovery operations. The Velero plugin for vSphere supports backup and restore of vSphere pods, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Deploying workloads across multiple failure zones using the Cluster API defines worker nodes across multiple failure domains with automatic healing rules that reschedule workloads when a zone becomes unavailable. Replicating control plane components across at least three failure zones limits the impact of a single-zone failure on the Kubernetes control plane itself. For VM Service workloads, the IaaS Services Console and Local Consumption Interface provide a Resources tab where users can create snapshots with optional memory capture and guest file system quiescence, and can revert a VM to a prior snapshot to restore it to a known state.

Deployment rollback is available natively in Kubernetes through Deployments with revision history, allowing administrators to return to a previous known-good revision when a newly deployed version fails. The Harness CI/CD Supervisor Service extends this with automated rollback capabilities that can revert to a previous stable state when deployment failures are detected.

Immutable infrastructure patterns supported by Kubernetes, combined with infrastructure-as-code stored in version control, provide a reproducible mechanism for reconstituting a cluster to a known, authorized state. Every change to the declared state is recorded in version control, and the cluster can be rebuilt from that record after a compromise or failure. VKS Cluster Management Policy Insights expose Sync signals that indicate when policy definitions fail to propagate from the management plane to the targeted VKS cluster estate, helping operators detect and remediate policy drift before it affects recovery posture.

Restore operations require that the target infrastructure be in place before a restore can proceed. VCF documentation recommends implementing a consistent backup strategy to safeguard the infrastructure against unforeseen disruptions and to support effective disaster recovery.

VMware vDefend (Contributes)

VMware vDefend contributes to secure recovery and reconstitution through backup and restore capabilities for its own security infrastructure, and through disaster recovery features that maintain security policy continuity across site failover events.

The Security Services Platform provides backup and restore functionality, accessible through the System > Backup and Restore interface, that allows recovery of a platform instance to its previous configuration when the current instance is in a non-recoverable state. The backup scope includes the full system inventory: tokens, Bare Metal servers, and Bare Metal server interfaces are captured as part of inventory backup, and required certificates from the backup server are restored automatically during the restore process. The platform must be in a healthy state to perform backup operations; backup and restore cannot proceed when the platform is unhealthy. Certificate consistency between backup and restored Security Services Platform environments must be maintained to avoid NDR Sensor disruptions. Backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Administrators should back up the Security Services Platform before performing scale-out operations, and Bare Metal Service operations (onboarding, offboarding, or upgrading Bare Metal servers) should not be performed while backup or restore is in progress.

The Security Services Platform can be deployed on vSAN stretched configurations, which supports recovery from site failures and reduces recovery time at the infrastructure level.

For disaster recovery scenarios, NSX Federation maintains security posture during workload migration and site failover by propagating Distributed Firewall rules, security groups, and microsegmentation policies across multiple sites. When workloads fail over from a protected site to a recovery site, the vDefend security policies governing east-west traffic at the destination site are already in place. vSphere HA can be configured to handle host-level failures affecting Security Services Platform appliances.

The broader recovery of compute infrastructure, storage, virtual machines, and application workloads to a known state is handled by other VCF components such as Protection and Recovery, vSAN Data Protection, vSphere Replication, and vCenter backup and restore.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides mechanisms for secure recovery and reconstitution of virtual machine workloads to a known state after a disruption, compromise, or failure.

Recovery is organized through protection groups and recovery plans. Protection groups define which virtual machines are protected, while recovery plans orchestrate the sequence of steps required to recover those workloads at the recovery site. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state governs which operations are permitted at each stage of the DR lifecycle. Recovery plans support two primary modes: planned migration for orderly, scheduled failover, and disaster recovery for unplanned site failures. A single recovery plan can also be configured to serve both disaster recovery and cyber recovery operations, allowing organizations to maintain consistent recovery procedures across different incident types.

Recovery plan testing is a built-in capability. Recovery plans should be tested before use for planned migration or disaster recovery to validate their functionality. This confirms that the recovery process will bring protected virtual machines online at the recovery site and that inventory mappings correctly place workloads on the appropriate networks, storage, and compute resources.

Cyber Recovery extends reconstitution capabilities with an Isolated Recovery Environment (IRE) designed for compromise scenarios such as ransomware incidents. The IRE provides a dedicated, isolated segment of the recovery environment that blocks direct private network connections from production, allowing compromised workloads to be analyzed and validated before being returned to production. Cyber Recovery transitions virtual machines through a controlled sequence of states,

including Entering validated, Validated, Staging, and Staged, to prepare them for recovery. This state-based workflow supports data integrity validation prior to production restoration.

Recovery plan compliance checks verify that protection groups are actively replicating, that sufficient point-in-time snapshots are available for each virtual machine in the plan, and that all workflow steps can execute without conflict. Continuous compliance monitoring provides warnings when VM configuration status deviates from expected state.

The Configuration Import/Export Tool enables administrators to export PNR server configuration data, including inventory mappings, placeholder datastores, advanced settings, array manager configurations, and protection group definitions. This capability supports configuration backup and reconstitution of the PNR environment itself after a failure or migration.

PNR integrates with VCF Operations for recovery plan lifecycle visibility. The Recovery Plans Details dashboard shows the current phase of the DR lifecycle, including whether a plan is ready, whether a test is in progress, and whether incomplete recovery or cleanup operations require attention. PNR also supports recovery of VCF Automation and VCF Operations services: when a disaster event affects the management domain containing these services, PNR enables service recovery in another management domain.

All communications between PNR and VMware vCenter instances use TLS certificates and private keys. The PNR Appliance supports importing server certificates signed by a certificate authority to establish secure communications across both protected and recovery sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to

re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

Control RC.CO

[Withdrawn: Incorporated into RC.CO-04] Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders. Public updates on incident recovery are shared using approved methods and messaging.

SCF Controls: BCD-01.1, BCD-01.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RC.CO-03

Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders

SCF Controls: BCD-01.6

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical mechanisms for tracking recovery operations, generating status telemetry, and forwarding notifications to stakeholders, though the organizational processes for defining communication plans, escalation paths, and stakeholder contact lists must be established outside the platform.

VCF includes built-in disaster recovery capabilities at multiple levels of the stack. Application Disaster Recovery enables failover to a secondary site to maintain operations during major disruptions, with data replication providing recovery options in case of catastrophic failure. Disaster recovery may also be implemented for fleet-level components. NSX Federation supports both planned and unplanned disaster recovery scenarios for Global Manager, and the Global Manager detects loss of connection to a Local Manager and prompts administrators to perform Network Recovery, providing real-time awareness of component status during a disruption. NSX Federation Global Manager and Local Manager VMs can be recovered using VMware Live Site Recovery for high availability of the management plane.

These recovery operations follow structured recovery plans that define execution priority groups, giving recovery teams a sequenced view of which steps have completed and which remain pending. For example, recovery plans for VCF Operations for Networks require the primary platform node to be placed in a higher priority group than other platform nodes, providing a defined sequence whose completion status can be tracked and reported. VMware Live Site Recovery orchestrates recovery plan execution across sites, with role-based access controlling who can create and execute recovery plans on the recovery site. Recovery plan creation for host-based replication involves initialization of a protection group specification, creation of the protection group task, and monitoring of task progress. The `Invoke-SrmGetTaskInfo` cmdlet monitors task progress in Live Site Recovery, and `Invoke-SrmGetRecoveryPlan` retrieves recovery plans by pairing and plan identifiers.

During recovery operations, VCF components report detailed status information at multiple levels. VMware vCenter restore jobs report state with progress percentage tracking until completion. The `com.vmware.appliance.recovery.restore.job.get` appliance shell API command retrieves the current status of a vCenter restore job. After restoration completes, the `service-control --status --all` command confirms that vCenter services have restarted successfully. VCF Operations restore tasks return a task ID that can be monitored through a REST API endpoint to track status. Recovery reconciliation jobs in vCenter include a `RecoveryReconciliationJobInfo` data structure containing description, status, progress, error details, start time, and end time, accessible through the management API with possible states of `NONE`, `RUNNING`, `FAILED`, and `SUCCEEDED`. Administrators should verify that there is no running or failed reconciliation job before initiating a new restore operation.

VCF Operations tracks recent task status with states including `Completed`, `In Progress`, `Failed`, `Maximum Time Reached`, `Not Dispatched`, `Started`, and `Unknown`, and provides a Recent Tasks tile in the Administration Control Panel for monitoring. VCF Operations also monitors recovery-related metrics, such as recovery status indicators for database components, which show whether recovery is enabled or disabled. Once a planned migration or disaster recovery operation finishes successfully, the recovered system becomes operational, and VCF Operations reflects that restored state in its health monitoring. VCF Operations dashboards provide real-time, interactive views of infrastructure health, alerts, and operational status, and are recommended over static reports for timely situational awareness during recovery activities.

VCF Operations supports multiple outbound notification methods for forwarding recovery-related alerts and status to external systems. Alert notifications can be sent via email, webhook, SNMP trap, and Slack integrations. The Slack plug-in forwards pre-formatted alert details to Slack channels and supports configuration of multiple notification rules with different channels. The webhook notification plugin supports integration with any REST API endpoint, allowing recovery status data to be forwarded to incident management platforms, communication tools, or custom dashboards. Alert notifications include details such as alert definition name, description, object name, alert impact, alert state, symptoms with metric details, and

recommended actions. Notification rules can be configured to trigger on specific alert status changes, so stakeholders receive updates as conditions evolve. Alerts can be assigned to specific users through ownership management (Take/Release Ownership), so team members know who is working on a given recovery issue.

Simultaneous backups of VCF Operations fleet management component nodes help ensure that restored components are logically consistent with each other, reducing the need for additional remediation steps that could delay recovery communications. Organizations should plan and test disaster recovery strategies regularly to meet recovery time objectives (RTO) and recovery point objectives (RPO), establishing clear benchmarks against which recovery progress can be measured and communicated.

While VCF provides the technical telemetry, dashboards, alerting integrations, and structured recovery plans needed to track and report on recovery status, the organizational processes for communicating that information to designated internal and external stakeholders, including establishing communication plans, defining escalation paths, identifying stakeholder contact lists, and selecting communication channels, must be established outside the platform.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides recovery status visibility mechanisms that support communication of recovery progress to stakeholders, though the organizational communication process for reaching external stakeholders is outside its scope.

Recovery plan state management gives operators visibility into recovery progress throughout the recovery lifecycle. The state of a recovery plan is determined by the states of the protection groups within that plan, and the plan state determines which operations are allowed at each stage. PNR recovery plans can be configured with message prompt steps that pause execution until an operator closes the prompt, creating explicit checkpoints where status can be assessed and communicated before the plan continues. The reprotect process passes through observable states visible within the recovery plan interface, extending status visibility into post-recovery operations.

PNR signals key recovery milestones through structured events and alarms. When a recovery is initiated, PNR generates a PlanExecBeginEvent on the recovery site. When a recovery plan finishes executing a command callout, PNR sends a RecoveryPlanServerCommandEndTrap that includes the protection and recovery site name, recovery plan name, and recovery type. PNR also generates alarms when connectivity issues are encountered or when protection groups and recovery plans enter an error state, providing signals that operators can use as the basis for stakeholder communication.

The Recovery Plans Details Dashboard in VCF Operations tracks recovery plan status including protection group associations, execution history, failover and reprotection status, and cleanup completion. This dashboard gives administrators a consolidated view of recovery activity that can inform status reporting to stakeholders.

Role-based access controls separate recovery plan management from recovery execution. PNR defines specific roles including the SRM Recovery Plans Administrator role, which permits managing and testing recovery plans, and the SRM Recovery Administrator role, which permits running recoveries. This separation allows organizations to designate specific individuals as responsible for communicating recovery status based on their operational role.

Not applicable for this control: VMware vDefend, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RC.CO-04

[Withdrawn: Incorporated into RC.CO-04] Public updates on incident recovery are shared using approved methods and messaging

SCF Controls: IRO-16

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RC.RP

The recovery portion of the incident response plan is executed once initiated from the incident response process. Recovery actions are selected, scoped, prioritized, and performed. The integrity of backups and other restoration assets is verified before using them for restoration. Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms. The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed. The end of incident recovery is declared based on criteria, and incident-related documentation is completed.

SCF Controls: BCD-01, BCD-01.4, BCD-02, BCD-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple recovery technologies with configurable Recovery Time Objective (RTO) and Recovery Point Objective (RPO) settings, enabling organizations to align disaster recovery operations with their specific continuity requirements.

VCF natively provides vSphere Replication, which allows administrators to configure RPO targets, enable network compression, enable multiple point-in-time (MPIT) instances with configurable retention periods, and control automatic replication of new disks. For lower recovery point objectives and orchestrated site failover, Live Site Recovery, part of VCF Protection and Recovery and licensed separately within the Protection and Recovery portfolio, supports replication with an RPO as low as 60 seconds. These granular settings allow recovery configurations to be tuned to match organizational RTO and RPO requirements for protected workloads. VCF Protection and Recovery also supports periodic test runs to verify that existing recovery plans function correctly with the underlying infrastructure, allowing organizations to validate that their RTO and RPO targets are realistic and achievable before an actual disruption occurs.

vSAN stretched clusters extend a single logical cluster across two availability zones with synchronous data mirroring between sites. When the site disaster tolerance parameter is set to site mirroring, the cluster can tolerate one site failure and data remains accessible from the surviving site. This architecture provides near-zero RPO for site-level events, since data is written to both sites before acknowledging the write. When a site fails, vSphere HA restarts any virtual machines that require restart on the remaining active site, providing both minimal RPO and RTO for site-level failures.

vSAN Data Protection provides snapshot-based recovery with configurable retention duration and scheduling intervals. Protection groups define snapshot policies with retention periods and snapshot intervals, giving administrators fine-grained control over recovery point granularity. For example, protection groups can be configured for hourly snapshots with hour-based retention. Snapshots can be replicated to external targets for offsite protection.

vSphere Replication provides an additional replication mechanism with configurable RPO parameters set through the replication specification. For VCF Operations for Networks deployments, replication can be configured for each node that requires protection, with recommended RPO values varying by deployment size. A medium-size deployment with single platform and collector nodes uses a recommended RPO of 45 minutes.

For workloads stored on Virtual Volumes (vVols), Storage Policy Based Management (SPBM) rules can define the maximum RPO as part of the VM storage policy for replication, along with replication schedule and replication frequency. This allows RPO targets to be expressed as storage policy requirements and automatically applied to any workload assigned that policy.

vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts when a host failure is detected, providing fast recovery times for host-level failures. Admission control policies can be specified in vCenter to reserve capacity and set failover share thresholds, coordinated with corresponding vSAN failure tolerance policy settings. For storage failure scenarios, VM Component Protection (VMCP) provides a configurable response when a datastore encounters an All Paths Down (APD) condition; the VMCP Response recovery setting specifies the number of minutes vSphere HA waits before taking action, giving administrators control over how quickly the environment responds to storage inaccessibility events. vSphere

Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure by maintaining a live shadow instance of a virtual machine on a separate host.

At the fleet level, VCF supports disaster recovery for fleet-level components, and Application Disaster Recovery enables failover to a secondary site to maintain operations during major disruptions. Organizations should be aware that Application Disaster Recovery may result in some data loss during failover depending on the configured RPO. For VCF Operations HCX, a delta synchronization with a two-hour RPO runs while waiting for a scheduled switchover after the initial synchronization completes.

Changed Block Tracking (CBT) tracks modified disk sectors to enable incremental backups through VADP-integrated backup solutions. This reduces backup windows and supports tighter RPO targets by allowing backup tools to capture only the blocks that have changed since the last backup rather than performing full copies each time.

The Consumption layer of the VCF platform extends these capabilities to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. Kubernetes self-healing mechanisms continuously maintain the declared replica count for Deployments and ReplicaSets: when a pod terminates or a node becomes unavailable, the scheduler places replacement pods on healthy nodes, helping reduce RTO for pod-level failures. The NodeOutOfServiceVolumeDetach feature gate allows volumes to be detached from out-of-service nodes and reattached to healthy nodes, which can reduce the time needed to recover stateful pods. Readiness and liveness probes detect container-level faults and trigger pod restarts or traffic removal so that services recover from transient conditions without manual intervention. For batch Job workloads, Kubernetes podFailurePolicy allows administrators to define rules based on container exit codes and pod conditions that distinguish retrievable failures from non-retrievable ones, preventing redundant restart attempts and allowing Jobs to fail fast when the failure type is permanent rather than transient. At the node level, node re-registration drains and reschedules all pods when a node is modified or re-added to a cluster.

VKS cluster health status is surfaced through structured conditions reported by the VKS Controller, including Ready and ControlPlaneReady indicators, and through machine-level health conditions that classify severity as Info, Warning, or Error. These signals give operations teams the visibility needed to detect degraded states and initiate recovery workflows. VKS clusters also support MachineHealthCheck, a Cluster API resource that specifies unhealthy node conditions as an array of condition types, status values, and timeout durations; when a node's conditions match the configured thresholds, MachineHealthCheck triggers automated machine remediation, reducing the manual intervention required to restore node capacity and helping lower RTO for node-level failures. MachineHealthCheck can be applied to control plane and worker node pools and patched at runtime using kubectl. When VKS clusters span multiple availability zones, Kubernetes distributes workloads across zones so that a zone-level failure affects only a subset of running pods; administrators configure topology spread constraints and pod anti-affinity rules to align workload distribution with their RTO targets for individual services.

For backup and restore of containerized workloads, VKS Cluster Management provides data protection capabilities through Velero and native management tooling. Velero backup schedules can be configured to run at defined intervals, allowing organizations to align backup frequency with RPO targets. Restore operations support file system-based backup by default, with optional CSI volume snapshot restoration; restore scope can be specified to select which Kubernetes resources to recover from a backup. Cross-cluster restore allows a backup from one VKS cluster to be applied to a different cluster, accessible through the Data Protection tab in VKS Cluster Management or through the VCF Automation Tenant Portal. VKS Backup and Restore Hooks allow execution of pre- and post-operation scripts to achieve application-consistent backups and automate steps during recovery. Restore progress is tracked through the Data Protection tab, and the CloneFromSnapshot custom resource exposes a status.phase field that reports progress through each phase of a volume restore operation. The Velero backupRepository.config.fullMaintenanceInterval parameter controls repository maintenance behavior. ControllerRevision provides immutable snapshots of state data for DaemonSet and StatefulSet controllers, supporting rollback to a prior configuration. Third-party backup tools can capture point-in-time volume snapshots through the Kubernetes CSI snapshot API, and periodic snapshots of API server backing storage provide a recovery path for storage loss scenarios.

VCF Operations monitors infrastructure health and reports capacity and availability metrics through dashboards, including capacity remaining widgets and capacity summary views across all monitored environments. These give operations teams

visibility into whether the environment is meeting its availability targets. Organizations should plan and test their recovery strategies regularly to confirm that actual recovery performance aligns with their stated objectives.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) includes backup and restore capabilities that contribute to recovery operations for the network security enforcement layer. SSP backup and restore functionality allows restoration of a platform instance with the same configuration when the current instance is in a non-recoverable state; a backup must be available before restoration can proceed. During recovery, the SSP instance may remain unhealthy until all VMs are restored, a process that can take up to 30 to 45 minutes. Restore operations may also fail if persistent volume claims cannot be attached to cluster nodes, producing ContainerCreating status and pod initialization delays that extend the recovery window.

SSP backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Organizations should account for this timeout in RTO calculations and validate recovery procedures through regular testing.

SSP cluster health monitoring defines NetworkUnavailable, DiskPressure, and Ready conditions with a 5-minute timeout threshold for remediation. The MachineHealthCheck mechanism provides a 7-minute recovery window when an SSP VM experiences a network issue; if the issue is not resolved within that window, the VM is deleted and replaced with a new one. These automated health management mechanisms provide concrete timing inputs for RTO planning for the security services layer.

For host-level resilience, vSphere High Availability (HA) should be configured with sufficient Admission Control resources for SSP deployments. When a host running SSP components fails, vSphere HA restarts those components on surviving hosts. Deploying SSP on a vSAN stretched configuration can reduce downtime during site failures by facilitating quick recovery from host or site-level events.

For NDR sensor resilience, a rollback mechanism allows switching the NDR Sensor appliance to a previously saved OS or snapshot and rebooting the sensor to restore the prior state.

While the primary RTO/RPO recovery capabilities for protected workloads reside in VCF components such as Protection and Recovery and vSAN Data Protection, vDefend contributes by providing its own recovery mechanisms with documented timing characteristics. Network security policy enforcement is a dependency for many workloads, so the time required to recover vDefend firewall rules, IDS/IPS configurations, and SSP-hosted analytics directly affects the overall recovery timeline for protected workloads.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) is designed to support RTO-based resumption of business functions through automated recovery orchestration.

Recovery plans automate the failover sequence, executing a defined series of steps in the correct order for workflows such as planned migration and reprotect. Steps can include commands and message prompts that signify the completion of particular operations, though commands and prompts cannot be added before the Configure Test Networks step. Understanding the order and context of these steps is important when customizing a plan to meet specific RTO targets.

Recovery plan execution includes built-in mechanisms that support timely completion. Steps can be configured with timeouts that cause the plan to pause for a specified interval, giving operations time to finish rather than failing immediately. Message prompt steps cannot fail; instead, the plan pauses until the operator closes the prompt, and PNR signals a PlanPromptResponse event on the recovery site when the prompt is closed. If a recovery plan fails to progress during a recovery operation due to protection site unreachability, cancelling and restarting the plan is the recommended resolution.

The VCF Operations orchestrator Plug-In for Protection and Recovery provides workflow-driven control over recovery operations. The Initiate Reprotect Recovery Plan workflow accepts a Recovery Plan input parameter specifying the plan to fail over from the protected site to the recovery site; the recovery plan must be in ready state before the Initiate Failover Recovery

Plan workflow can be executed. vSphere Replication provides a Resume Replication to vCenter workflow that resumes paused forward replication to the target site after recovery operations complete.

The Protection and Recovery Configuration Import/Export Tool exports server version, build number, site names, inventory mappings, placeholder datastores, advanced settings, and array manager data, providing a mechanism to preserve recovery configuration for continued operations after failover. Recovery plan steps can also be exported in various formats to maintain hard-copy records of the configured recovery sequence.

Recovery plan testing validates that configured plans can resume business functions within target RTOs before an actual event requires activation. Recovery plans should be tested before use for planned migration or disaster recovery operations. The Protection and Recovery dashboard in VCF Operations recommends executing recovery plans at least once every three months to maintain operational readiness and validate recovery procedures.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support an organization's ability to meet defined Recovery Time Objectives and Recovery Point Objectives for database workloads.

Point-in-time recovery. DSM supports point-in-time recovery (PITR) for PostgreSQL, MySQL, and SQL Server databases, allowing administrators to restore data to a specific moment within the configured backup retention period. When initiating a restore, administrators identify a restore point and choose either the most recent timestamp or a user-specified date and time, and the restored database is created as a new database instance. The granularity of recovery is bounded by the configured backup schedule and retention settings, and PITR can only restore data from within the configured retention period. PITR requires the source database to be operational, the required backup to be available, and connectivity to the S3 storage repository. SQL Server PITR can restore onto the same or a different SQL Server cluster. PostgreSQL restore can also target a different DSM control plane by specifying a time value; if the time field is omitted, DSM restores the latest available state. For SQL Server, DSM automatically manages the recovery model based on backup status, using Full Recovery Model when automated backups are enabled and Simple Recovery Model otherwise. PITR may fail or be incomplete if binary log files are missing from the source database, which administrators should account for in operational procedures.

Log backup frequency and RPO. DSM exposes a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes. The log backup frequency is directly related to the achievable RPO for both PostgreSQL and SQL Server databases, and administrators should configure this value based on their RPO requirements.

Database cloning. DSM can clone a MySQL or PostgreSQL database to create an identical database. Cloning is functionally equivalent to PITR to the latest available time and can act as a recovery mechanism when the most recent consistent state is the desired recovery target.

Provider VM recovery and restore duration. DSM documents a recovery procedure for a single Provider VM failure, and the Provider VM restoration must complete fully before proceeding to subsequent recovery steps. This is a relevant consideration for control plane RTO planning. Database restoration duration depends on data volume and underlying infrastructure performance, and administrators should account for this when planning restore operations against an RTO target.

Defining and formally documenting RTO and RPO targets is an organizational process outside DSM's scope. DSM provides the backup, restore, and cloning mechanisms that technical teams configure and test against those targets. Organizations must establish their RTO and RPO requirements, configure DSM backup policies accordingly, test recovery procedures, and verify operational results align with those targets.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several application-layer mechanisms that support an organization's RTO and RPO objectives for the application delivery tier.

At the control-plane level, Avi Controller cluster deployments can span two availability zones, with defined failure scenarios and documented recovery actions for each. When a Controller cluster becomes non-operational, the `recover_cluster.py` script provides a structured recovery path: one node must be recovered with its configuration and become the Controller leader,

while other nodes are added as followers. The script requires double confirmation before proceeding unless the `--proceed` flag is used for non-interactive automation. If all three nodes are permanently unavailable, recovery requires a backup and restore procedure.

Configuration data is the primary RPO-relevant element of the Avi control plane. Enabling periodic external configuration backups is mandatory for single-node Controller deployments, including when deploying Avi Load Balancer within VCF environments using a single-node Controller. The Avi Controller backup and restore capability supports disaster recovery and configuration migration across Controller instances. After a storage failure, the Controller must be restored from the configuration archive. The restore process follows a defined sequence of tasks: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Factory reset recovery is irreversible and deletes all configuration, making backup-based recovery the preferred path. After a disaster recovery operation, at least one Service Engine controller IP must match a previous controller IP from before the event to enable Service Engines to reconnect to Controllers.

At the data-plane level, in vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, reducing the time to restore application traffic delivery.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling DNS-based traffic steering across sites during a site failure. The GSLB adaptive replication mode prevents faulty configuration objects from replicating to follower sites, protecting against configuration errors that could cause application failure across multiple data centers. GSLB pools configured with the priority algorithm support a manual resume option for controlled failover and recovery management.

Organizations must define RTO and RPO targets for their application delivery tier, configure backup schedules aligned with those targets, and periodically test restore procedures to verify that recovery objectives are achievable in practice.

Control RC.RP-01

The recovery portion of the incident response plan is executed once initiated from the incident response process

SCF Controls: BCD-01.5, BCD-12

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides several technical capabilities that support an organization's ability to define and meet Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) as part of business continuity and disaster recovery planning, though the organizational criteria for when to initiate BC/DR plans remain a governance responsibility.

VCF includes configurable RPO settings at multiple levels of the stack. vSphere Replication allows administrators to specify an RPO value directly through the replication specification's Rpo parameter, giving precise control over the maximum acceptable data loss window for replicated workloads. For VCF Operations for Networks deployments, replication can be configured for each node that requires protection, with recommended RPO values varying by deployment size. For migration scenarios involving VCF Operations HCX, delta synchronization with a configurable recovery point objective runs continuously after initial synchronization completes, maintaining data currency while waiting for a scheduled switchover. The VCF documentation explicitly notes that application disaster recovery may result in some data loss during failover depending on the configured RPO, which helps organizations understand the tradeoffs when setting their recovery criteria. Storage Policy Based Management (SPBM) provides an additional mechanism for encoding RPO requirements at the policy level: SPBM rules can define the maximum recovery point objective for Virtual Volumes objects and can include RPO settings within replication policy components, allowing administrators to associate data protection requirements directly with VM storage policies.

For RTO support, vSphere HA and vSAN stretched clusters provide automated failover capabilities that directly influence achievable recovery times. vSAN stretched clusters extend a single logical cluster across two availability zones with synchronous data mirroring between sites, providing near-zero RPO for site-level events since data is written to both sites before acknowledging the write. When the site disaster tolerance parameter is set to site mirroring, the cluster can tolerate one site failure and data remains accessible from the surviving site. vSphere HA restarts virtual machines on the remaining active site during a site failure. When vSphere HA admission control is configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, the platform can restart all VMs from one site on the other site. vSAN stretched clusters can also tolerate a witness host failure when one site is unavailable, provided the storage policy Site disaster tolerance rule is configured for Site mirroring. These automated recovery mechanisms give organizations measurable recovery time baselines against which to set their initiation criteria.

vSphere HA automatically restarts virtual machines on surviving hosts when a host failure is detected, providing fast recovery times for host-level failures. Admission control policies can be specified in VMware vCenter to reserve capacity and set failover share thresholds, coordinated with corresponding vSAN failure tolerance policy settings. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure by maintaining a live shadow instance of a virtual machine on a separate host, with no data loss or downtime during failover. When vSphere HA is used alongside DRS, the cluster can bring hosts out of standby mode or migrate virtual machines to defragment resources, helping to maintain the capacity required for HA failovers even when aggregate cluster resources are constrained.

VCF supports multiple disaster recovery deployment models at the application level. Disaster recovery with failover to a secondary site maintains operations during major disruptions. The platform documentation recommends combining real-time high availability with sitewide disaster recovery for maximum resilience. Disaster recovery can also be implemented for fleet-level components, and NSX Federation supports both planned and unplanned disaster recovery scenarios for Global Manager, extending recovery capabilities across the networking layer.

vSAN Data Protection provides snapshot-based recovery with configurable retention and scheduling through protection groups. Each protection group contains snapshot policies that define retention duration and snapshot scheduling intervals, allowing organizations to align snapshot frequency with their RPO requirements. Protection groups can be configured for

hourly snapshots with hour-based retention, and snapshots can be replicated to external targets for offsite protection. vSAN Distributed File System Snapshot provides the ability to retrieve data from files in the event of accidental deletion.

Changed Block Tracking (CBT) tracks modified disk sectors to enable incremental backups through VADP-integrated backup solutions. vCenter tracks changes on disk sectors, and VADP-based backup partner solutions can automatically perform backup, full restore, and registration of VMs. This reduces backup windows and supports tighter RPO targets by allowing backup tools to capture only the blocks that have changed since the last backup rather than performing full copies each time.

VCF's backup infrastructure supports recovery operations through scheduled backup jobs that capture the state of related management components at a common point in time. The documentation recommends implementing scheduled backups to prepare for critical failures, upgrades, or certificate updates of management components. VCF Operations backup can be configured to take a backup on state change, providing additional data protection for management plane components.

VCF Operations monitors the infrastructure and generates alerts when conditions change, which can inform decisions about when to activate contingency plans. VCF Operations supports creation and configuration of alert definitions to monitor infrastructure events and conditions, including log-based alerts. Alert definitions can be configured with criticality and impact metadata that reflects business priorities. VCF Operations also reports capacity and availability metrics through dashboards, including capacity remaining widgets and capacity summary views across all monitored environments, giving operations teams visibility into whether the environment is meeting its availability targets.

The VCF documentation explicitly states that organizations must plan and test disaster recovery strategies regularly to meet their recovery time objectives and recovery point objectives. While VCF provides the technical mechanisms for configurable RPO, automated RTO through HA and stretched clusters, snapshot-based data protection, incremental backup support, and infrastructure monitoring, the definition of specific initiation criteria for BC/DR plans remains an organizational responsibility. The thresholds that trigger activation, the governance processes around those decisions, and the alignment of technical capabilities with business requirements all require organizational planning beyond what the platform provides.

VMware vDefend (Contributes)

VMware vDefend contributes to secure recovery and reconstitution through backup and restore capabilities for its own security infrastructure, and through disaster recovery features that maintain security policy continuity across site failover events.

The Security Services Platform provides backup and restore functionality, accessible through the System > Backup and Restore interface, that allows recovery of a platform instance to its previous configuration when the current instance is in a non-recoverable state. The backup scope includes the full system inventory: tokens, Bare Metal servers, and Bare Metal server interfaces are captured as part of inventory backup, and required certificates from the backup server are restored automatically during the restore process. The platform must be in a healthy state to perform backup operations; backup and restore cannot proceed when the platform is unhealthy. Certificate consistency between backup and restored Security Services Platform environments must be maintained to avoid NDR Sensor disruptions. Backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Administrators should back up the Security Services Platform before performing scale-out operations, and Bare Metal Service operations (onboarding, offboarding, or upgrading Bare Metal servers) should not be performed while backup or restore is in progress.

The Security Services Platform can be deployed on vSAN stretched configurations, which supports recovery from site failures and reduces recovery time at the infrastructure level.

For disaster recovery scenarios, NSX Federation maintains security posture during workload migration and site failover by propagating Distributed Firewall rules, security groups, and microsegmentation policies across multiple sites. When workloads fail over from a protected site to a recovery site, the vDefend security policies governing east-west traffic at the destination site are already in place. vSphere HA can be configured to handle host-level failures affecting Security Services Platform appliances.

The broader recovery of compute infrastructure, storage, virtual machines, and application workloads to a known state is handled by other VCF components such as Protection and Recovery, vSAN Data Protection, vSphere Replication, and vCenter backup and restore.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) enforces technical preconditions that must be satisfied before recovery operations can execute, providing the operational criteria layer for BC/DR plan initiation.

Recovery plan state management gates which operations are permitted at each stage. The state of a recovery plan is determined by the states of the protection groups within that plan, and the plan state determines which operations are allowed. Plans transition through defined states including Ready, Test in progress, Test complete, and recovery states. The recovery plan must be in a "failedOver" state before a reprotect process can be initiated, and the originally protected site must be operational before reprotection can proceed. This state-based gating is enforced both through the PNR interface and through the VCF Operations orchestrator plugin for PNR, which provides workflow-based verification of preconditions before initiating reprotect operations.

Two distinct recovery types define the criteria path for initiation: Planned Migration for orderly workload evacuation when both sites are operational, and Disaster Recovery for unplanned site failures. In PNR, the same recovery plan can be used for both disaster recovery and cyber recovery operations, consolidating the criteria framework across recovery scenarios. Most recovery plans require different configurations for emergency scenarios at the protected site versus planned migration of services from one site to another.

vSphere Replication provides the RPO configuration layer that determines what recovery state is available when initiation occurs. RPO can be configured using a slider with a range from 1 minute to 24 hours to set the acceptable period for which data can be lost if a site failure occurs. Per-VM retention policies using the Latest instances option support up to 200 recovery points. Recovery point configuration should balance storage consumption and snapshot consolidation time; the guidance recommends using the fewest recovery points that meets business requirements. When a recovery is initiated, administrators can select whether to synchronize recent changes from the source site before the recovery operation, reducing exposure to data loss, or to recover immediately using the latest data already available at the target site.

PNR integrates with VCF Automation through replication classes, which are preconfigured with RPO values that define the acceptable amount of data loss after a disaster. This allows organizations using VCF Automation to define recovery criteria at the replication class level for consistent policy application across workloads. Protection and Recovery Dashboards in VCF Operations provide monitoring of RPO status and vSAN snapshots and replication metrics, giving administrators visibility into whether recovery thresholds are being maintained across protection groups.

Recovery plan testing validates that the technical criteria for successful recovery are met before relying on the plan in an actual event. PNR records the result of test recovery operations, including cancellation status, in the recovery plan state. A recovery plan must also reflect the current state of its protection groups; if any members show a status other than OK, the problems must be corrected before any changes can be made to the plan.

The organizational criteria for when to declare a disaster and authorize plan initiation are governance responsibilities outside PNR's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom

point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

Control RC.RP-02

Recovery actions are selected, scoped, prioritized, and performed

SCF Controls: BCD-01, BCD-01.4, BCD-02, BCD-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides multiple recovery technologies with configurable Recovery Time Objective (RTO) and Recovery Point Objective (RPO) settings, enabling organizations to align disaster recovery operations with their specific continuity requirements.

VCF natively provides vSphere Replication, which allows administrators to configure RPO targets, enable network compression, enable multiple point-in-time (MPIT) instances with configurable retention periods, and control automatic replication of new disks. For lower recovery point objectives and orchestrated site failover, Live Site Recovery, part of VCF Protection and Recovery and licensed separately within the Protection and Recovery portfolio, supports replication with an RPO as low as 60 seconds. These granular settings allow recovery configurations to be tuned to match organizational RTO and RPO requirements for protected workloads. VCF Protection and Recovery also supports periodic test runs to verify that existing recovery plans function correctly with the underlying infrastructure, allowing organizations to validate that their RTO and RPO targets are realistic and achievable before an actual disruption occurs.

vSAN stretched clusters extend a single logical cluster across two availability zones with synchronous data mirroring between sites. When the site disaster tolerance parameter is set to site mirroring, the cluster can tolerate one site failure and data remains accessible from the surviving site. This architecture provides near-zero RPO for site-level events, since data is written to both sites before acknowledging the write. When a site fails, vSphere HA restarts any virtual machines that require restart on the remaining active site, providing both minimal RPO and RTO for site-level failures.

vSAN Data Protection provides snapshot-based recovery with configurable retention duration and scheduling intervals. Protection groups define snapshot policies with retention periods and snapshot intervals, giving administrators fine-grained control over recovery point granularity. For example, protection groups can be configured for hourly snapshots with hour-based retention. Snapshots can be replicated to external targets for offsite protection.

vSphere Replication provides an additional replication mechanism with configurable RPO parameters set through the replication specification. For VCF Operations for Networks deployments, replication can be configured for each node that requires protection, with recommended RPO values varying by deployment size. A medium-size deployment with single platform and collector nodes uses a recommended RPO of 45 minutes.

For workloads stored on Virtual Volumes (vVols), Storage Policy Based Management (SPBM) rules can define the maximum RPO as part of the VM storage policy for replication, along with replication schedule and replication frequency. This allows RPO targets to be expressed as storage policy requirements and automatically applied to any workload assigned that policy.

vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts when a host failure is detected, providing fast recovery times for host-level failures. Admission control policies can be specified in vCenter to reserve capacity and set failover share thresholds, coordinated with corresponding vSAN failure tolerance policy settings. For storage failure scenarios, VM Component Protection (VMCP) provides a configurable response when a datastore encounters an All Paths Down (APD) condition; the VMCP Response recovery setting specifies the number of minutes vSphere HA waits before taking action, giving administrators control over how quickly the environment responds to storage inaccessibility events. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure by maintaining a live shadow instance of a virtual machine on a separate host.

At the fleet level, VCF supports disaster recovery for fleet-level components, and Application Disaster Recovery enables failover to a secondary site to maintain operations during major disruptions. Organizations should be aware that Application Disaster Recovery may result in some data loss during failover depending on the configured RPO. For VCF Operations HCX, a delta synchronization with a two-hour RPO runs while waiting for a scheduled switchover after the initial synchronization completes.

Changed Block Tracking (CBT) tracks modified disk sectors to enable incremental backups through VADP-integrated backup solutions. This reduces backup windows and supports tighter RPO targets by allowing backup tools to capture only the blocks that have changed since the last backup rather than performing full copies each time.

The Consumption layer of the VCF platform extends these capabilities to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. Kubernetes self-healing mechanisms continuously maintain the declared replica count for Deployments and ReplicaSets: when a pod terminates or a node becomes unavailable, the scheduler places replacement pods on healthy nodes, helping reduce RTO for pod-level failures. The NodeOutOfServiceVolumeDetach feature gate allows volumes to be detached from out-of-service nodes and reattached to healthy nodes, which can reduce the time needed to recover stateful pods. Readiness and liveness probes detect container-level faults and trigger pod restarts or traffic removal so that services recover from transient conditions without manual intervention. For batch Job workloads, Kubernetes podFailurePolicy allows administrators to define rules based on container exit codes and pod conditions that distinguish retrievable failures from non-retrievable ones, preventing redundant restart attempts and allowing Jobs to fail fast when the failure type is permanent rather than transient. At the node level, node re-registration drains and reschedules all pods when a node is modified or re-added to a cluster.

VKS cluster health status is surfaced through structured conditions reported by the VKS Controller, including Ready and ControlPlaneReady indicators, and through machine-level health conditions that classify severity as Info, Warning, or Error. These signals give operations teams the visibility needed to detect degraded states and initiate recovery workflows. VKS clusters also support MachineHealthCheck, a Cluster API resource that specifies unhealthy node conditions as an array of condition types, status values, and timeout durations; when a node's conditions match the configured thresholds, MachineHealthCheck triggers automated machine remediation, reducing the manual intervention required to restore node capacity and helping lower RTO for node-level failures. MachineHealthCheck can be applied to control plane and worker node pools and patched at runtime using kubectl. When VKS clusters span multiple availability zones, Kubernetes distributes workloads across zones so that a zone-level failure affects only a subset of running pods; administrators configure topology spread constraints and pod anti-affinity rules to align workload distribution with their RTO targets for individual services.

For backup and restore of containerized workloads, VKS Cluster Management provides data protection capabilities through Velero and native management tooling. Velero backup schedules can be configured to run at defined intervals, allowing organizations to align backup frequency with RPO targets. Restore operations support file system-based backup by default, with optional CSI volume snapshot restoration; restore scope can be specified to select which Kubernetes resources to recover from a backup. Cross-cluster restore allows a backup from one VKS cluster to be applied to a different cluster, accessible through the Data Protection tab in VKS Cluster Management or through the VCF Automation Tenant Portal. VKS Backup and Restore Hooks allow execution of pre- and post-operation scripts to achieve application-consistent backups and automate steps during recovery. Restore progress is tracked through the Data Protection tab, and the CloneFromSnapshot custom resource exposes a status.phase field that reports progress through each phase of a volume restore operation. The Velero backupRepository.config.fullMaintenanceInterval parameter controls repository maintenance behavior.

ControllerRevision provides immutable snapshots of state data for DaemonSet and StatefulSet controllers, supporting rollback to a prior configuration. Third-party backup tools can capture point-in-time volume snapshots through the Kubernetes CSI snapshot API, and periodic snapshots of API server backing storage provide a recovery path for storage loss scenarios.

VCF Operations monitors infrastructure health and reports capacity and availability metrics through dashboards, including capacity remaining widgets and capacity summary views across all monitored environments. These give operations teams visibility into whether the environment is meeting its availability targets. Organizations should plan and test their recovery strategies regularly to confirm that actual recovery performance aligns with their stated objectives.

VMware vDefend (Contributes)

VMware vDefend's Security Services Platform (SSP) includes backup and restore capabilities that contribute to recovery operations for the network security enforcement layer. SSP backup and restore functionality allows restoration of a platform instance with the same configuration when the current instance is in a non-recoverable state; a backup must be available before restoration can proceed. During recovery, the SSP instance may remain unhealthy until all VMs are restored, a process

that can take up to 30 to 45 minutes. Restore operations may also fail if persistent volume claims cannot be attached to cluster nodes, producing ContainerCreating status and pod initialization delays that extend the recovery window.

SSP backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Organizations should account for this timeout in RTO calculations and validate recovery procedures through regular testing.

SSP cluster health monitoring defines NetworkUnavailable, DiskPressure, and Ready conditions with a 5-minute timeout threshold for remediation. The MachineHealthCheck mechanism provides a 7-minute recovery window when an SSP VM experiences a network issue; if the issue is not resolved within that window, the VM is deleted and replaced with a new one. These automated health management mechanisms provide concrete timing inputs for RTO planning for the security services layer.

For host-level resilience, vSphere High Availability (HA) should be configured with sufficient Admission Control resources for SSP deployments. When a host running SSP components fails, vSphere HA restarts those components on surviving hosts. Deploying SSP on a vSAN stretched configuration can reduce downtime during site failures by facilitating quick recovery from host or site-level events.

For NDR sensor resilience, a rollback mechanism allows switching the NDR Sensor appliance to a previously saved OS or snapshot and rebooting the sensor to restore the prior state.

While the primary RTO/RPO recovery capabilities for protected workloads reside in VCF components such as Protection and Recovery and vSAN Data Protection, vDefend contributes by providing its own recovery mechanisms with documented timing characteristics. Network security policy enforcement is a dependency for many workloads, so the time required to recover vDefend firewall rules, IDS/IPS configurations, and SSP-hosted analytics directly affects the overall recovery timeline for protected workloads.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) is designed to support RTO-based resumption of business functions through automated recovery orchestration.

Recovery plans automate the failover sequence, executing a defined series of steps in the correct order for workflows such as planned migration and reprotect. Steps can include commands and message prompts that signify the completion of particular operations, though commands and prompts cannot be added before the Configure Test Networks step. Understanding the order and context of these steps is important when customizing a plan to meet specific RTO targets.

Recovery plan execution includes built-in mechanisms that support timely completion. Steps can be configured with timeouts that cause the plan to pause for a specified interval, giving operations time to finish rather than failing immediately. Message prompt steps cannot fail; instead, the plan pauses until the operator closes the prompt, and PNR signals a PlanPromptResponse event on the recovery site when the prompt is closed. If a recovery plan fails to progress during a recovery operation due to protection site unreachability, cancelling and restarting the plan is the recommended resolution.

The VCF Operations orchestrator Plug-In for Protection and Recovery provides workflow-driven control over recovery operations. The Initiate Reprotect Recovery Plan workflow accepts a Recovery Plan input parameter specifying the plan to fail over from the protected site to the recovery site; the recovery plan must be in ready state before the Initiate Failover Recovery Plan workflow can be executed. vSphere Replication provides a Resume Replication to vCenter workflow that resumes paused forward replication to the target site after recovery operations complete.

The Protection and Recovery Configuration Import/Export Tool exports server version, build number, site names, inventory mappings, placeholder datastores, advanced settings, and array manager data, providing a mechanism to preserve recovery configuration for continued operations after failover. Recovery plan steps can also be exported in various formats to maintain hard-copy records of the configured recovery sequence.

Recovery plan testing validates that configured plans can resume business functions within target RTOs before an actual event requires activation. Recovery plans should be tested before use for planned migration or disaster recovery operations. The

Protection and Recovery dashboard in VCF Operations recommends executing recovery plans at least once every three months to maintain operational readiness and validate recovery procedures.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support an organization's ability to meet defined Recovery Time Objectives and Recovery Point Objectives for database workloads.

Point-in-time recovery. DSM supports point-in-time recovery (PITR) for PostgreSQL, MySQL, and SQL Server databases, allowing administrators to restore data to a specific moment within the configured backup retention period. When initiating a restore, administrators identify a restore point and choose either the most recent timestamp or a user-specified date and time, and the restored database is created as a new database instance. The granularity of recovery is bounded by the configured backup schedule and retention settings, and PITR can only restore data from within the configured retention period. PITR requires the source database to be operational, the required backup to be available, and connectivity to the S3 storage repository. SQL Server PITR can restore onto the same or a different SQL Server cluster. PostgreSQL restore can also target a different DSM control plane by specifying a time value; if the time field is omitted, DSM restores the latest available state. For SQL Server, DSM automatically manages the recovery model based on backup status, using Full Recovery Model when automated backups are enabled and Simple Recovery Model otherwise. PITR may fail or be incomplete if binary log files are missing from the source database, which administrators should account for in operational procedures.

Log backup frequency and RPO. DSM exposes a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes. The log backup frequency is directly related to the achievable RPO for both PostgreSQL and SQL Server databases, and administrators should configure this value based on their RPO requirements.

Database cloning. DSM can clone a MySQL or PostgreSQL database to create an identical database. Cloning is functionally equivalent to PITR to the latest available time and can act as a recovery mechanism when the most recent consistent state is the desired recovery target.

Provider VM recovery and restore duration. DSM documents a recovery procedure for a single Provider VM failure, and the Provider VM restoration must complete fully before proceeding to subsequent recovery steps. This is a relevant consideration for control plane RTO planning. Database restoration duration depends on data volume and underlying infrastructure performance, and administrators should account for this when planning restore operations against an RTO target.

Defining and formally documenting RTO and RPO targets is an organizational process outside DSM's scope. DSM provides the backup, restore, and cloning mechanisms that technical teams configure and test against those targets. Organizations must establish their RTO and RPO requirements, configure DSM backup policies accordingly, test recovery procedures, and verify operational results align with those targets.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several application-layer mechanisms that support an organization's RTO and RPO objectives for the application delivery tier.

At the control-plane level, Avi Controller cluster deployments can span two availability zones, with defined failure scenarios and documented recovery actions for each. When a Controller cluster becomes non-operational, the `recover_cluster.py` script provides a structured recovery path: one node must be recovered with its configuration and become the Controller leader, while other nodes are added as followers. The script requires double confirmation before proceeding unless the `--proceed` flag is used for non-interactive automation. If all three nodes are permanently unavailable, recovery requires a backup and restore procedure.

Configuration data is the primary RPO-relevant element of the Avi control plane. Enabling periodic external configuration backups is mandatory for single-node Controller deployments, including when deploying Avi Load Balancer within VCF environments using a single-node Controller. The Avi Controller backup and restore capability supports disaster recovery and configuration migration across Controller instances. After a storage failure, the Controller must be restored from the configuration archive. The restore process follows a defined sequence of tasks: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Factory reset recovery is irreversible and deletes all configuration,

making backup-based recovery the preferred path. After a disaster recovery operation, at least one Service Engine controller IP must match a previous controller IP from before the event to enable Service Engines to reconnect to Controllers.

At the data-plane level, in vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, reducing the time to restore application traffic delivery.

For multi-site deployments, Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling DNS-based traffic steering across sites during a site failure. The GSLB adaptive replication mode prevents faulty configuration objects from replicating to follower sites, protecting against configuration errors that could cause application failure across multiple data centers. GSLB pools configured with the priority algorithm support a manual resume option for controlled failover and recovery management.

Organizations must define RTO and RPO targets for their application delivery tier, configure backup schedules aligned with those targets, and periodically test restore procedures to verify that recovery objectives are achievable in practice.

Control RC.RP-03

The integrity of backups and other restoration assets is verified before using them for restoration

SCF Controls: BCD-13, BCD-13.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several built-in mechanisms that support the verification of backup and restoration asset integrity, though a complete integrity verification program requires additional organizational processes.

VCF enforces version compatibility validation as a prerequisite to all restore operations. Before restoring a VMware vCenter instance from a file-based backup, the administrator must verify that the vCenter version retrieved from VCF Operations matches the version associated with the backup file. The backup must be of the same version as the vCenter appliance on which the restore will be performed. The same version-matching requirement applies to VCF Operations backups, where the backup must match the version of the target VCF Operations appliance. VCF Operations backup and restore setups must also have identical versions. These version compatibility checks help detect mismatched or corrupted backup assets before a restore attempt proceeds.

VCF enforces component dependency verification before restoration can begin. Restoring VCF Operations requires that vCenter is available, and restoring vCenter requires that VCF Operations is available. The platform requires proper sequencing and verification of component restoration to maintain dependencies and system integrity. Before initiating a new restore operation for vCenter, administrators must verify that there is no running or failed reconciliation job from a prior attempt. These prerequisite checks help confirm that the environment is in a known-good state before restoration proceeds.

When backing up VCF management components (VCF Operations, vCenter, NSX Manager), the platform requires simultaneous backups of component nodes so that restored state is logically consistent across nodes. VCF recommends creating backup jobs that capture the state of related management components at a common point in time, which helps maintain consistency across the backup set. Administrators must have access to the most recent backup files for restore operations. vCenter file-based backup files support optional encryption using a password that must be supplied at restore time; if encryption is enabled, a failed decryption attempt indicates that the file has been corrupted or tampered with. Because these backup files also contain the Key Derivation Key used for cryptographic operations in the environment, they must be stored in a secure location with restricted access.

After a file-based or image-based restore of vCenter, VCF provides a reconciliation API that allows administrators to monitor the post-restore reconciliation process. The API endpoint at `/api/appliance/recovery/reconciliation/job` enables tracking of whether the restored data has been successfully reconciled with the running environment. Failures or inconsistencies during reconciliation indicate integrity problems with the restored data.

For NSX Manager, the `get_backup_timestamps.sh` script retrieves the list of available backups from NSX Manager or Global Manager nodes, allowing administrators to identify and select specific backups for restoration. This supports verification that the intended backup file exists and is accessible before restoration begins.

VCF provides multiple operational monitoring paths for verifying backup and restore operations. VCF Operations for Networks exposes a backup-restore CLI with a status action that lets administrators check the state of backup and restore configurations. VCF Operations also allows administrators to track any failure in the backup or restore process through the Infrastructure page under Settings, Infrastructure and Support, Overall Health section. VCF Operations provides backup task monitoring accessible from the task page.

Certain components impose additional freshness and validity constraints on backup assets. HCX does not support restoring from backup files that are more than two days old due to potential inventory changes between the backup time and the present. Restore operations for vSphere Supervisor should be avoided in cases where they might cause orphaned resources, version mismatches, an unstable cluster state, or other unpredictable behavior. When recovery errors are detected in VCF Operations, administrators should either correct the errors or restore from a known good backup.

The platform's lifecycle management includes a compliance check capability that can verify software specifications against a committed draft, providing a mechanism to confirm that restored components match expected software baselines. This check runs against the committed draft software specification, or if no commit exists, against the working draft. While this is primarily a lifecycle management feature, it can be applied post-restore to verify that the restored environment's software state matches the expected specification.

These capabilities collectively provide version validation, prerequisite verification, post-restore reconciliation monitoring, backup freshness constraints, and software specification compliance checks. However, a complete restoration integrity verification program also requires organizational processes such as regular test restores to validate recoverability, documented restore procedures with acceptance criteria, and storage-level integrity checks (such as checksums) on backup files at rest. VCF provides the technical controls that support and partially automate integrity verification, but the overarching verification program is an organizational responsibility.

VMware vDefend (Contributes)

The Security Services Platform (SSP) component of VMware vDefend enforces a set of pre-restoration compatibility requirements that must be satisfied before a backup can be used for restoration. The SSP version and build number of the target environment must exactly match those used when the backup was taken; a version or build mismatch blocks restoration. Service and messaging FQDNs must also match between the backup environment and the restoration target. Certificate consistency between the backup and restored SSP environments is required to avoid disruption to SSP services and to the NDR Sensors that depend on those certificates. In 9.1, the same NSX instance that was onboarded at the time of the backup must be present at restoration, and the platform must be deployed on the same vSAN datastore as the initial installation using the same build version. Adequate storage capacity on the SFTP server must be verified before activating recurring backups.

SSP Backup History displays backup status and shows "Completed" when a backup operation succeeds, providing visibility into whether a valid backup is available before a restore is attempted. When restore operations fail, SSP surfaces the failure state for troubleshooting. Specific failure modes include inability to locate disk objects referenced by the backup (which prevents restore pods from attaching required volumes), database schema dependency violations such as foreign key constraints referencing tables that do not exist, and permission or data integrity issues surfaced by `pg_restore` during database restoration.

VMware vDefend does not perform cryptographic hash verification or digital signature validation of backup file contents. Organizations requiring cryptographic assurance of backup data integrity must implement those controls at the SFTP server or storage layer.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) contributes to restoration integrity verification through non-disruptive test failover, snapshot status assessment, post-operation validation, and operational history tracking.

Recovery plans should be tested before being used for planned migration or disaster recovery operations. Test failover validates that protected virtual machines can be recovered successfully without disrupting production replication. PNR's cleanup capability removes test artifacts and isolates recovery environments after validation testing, replacing recovered virtual machines with placeholders while preserving their identity and configuration. This test-and-cleanup cycle allows organizations to verify that their restoration assets will produce a functional recovery before relying on them during an actual event.

PNR's Cyber Recovery capability enables administrators to badge snapshots with security status indicators: Verified for snapshots confirmed as clean, Compromised for snapshots with confirmed malware presence, and Encrypted for snapshots with detected data encryption. This badging mechanism creates an audit trail of snapshot validation and security assessment, allowing administrators to identify and select a known-clean restoration point before initiating recovery. PNR also supports disaster recovery of vSAN-replicated virtual machines using a clean room environment at one recovery site for isolated validation before production restoration, enabling integrity verification independent of a full plan execution.

vSAN Snapshots and Replication, integrated into PNR, provides VM restore and clone operations from existing snapshots. Administrators can return individual machines to a known point in time to confirm data and configuration integrity before bringing them back into production.

After a reprotect operation completes, testing can be conducted to confirm that the new configuration of the protected and recovery sites is valid. PNR maintains a history log for each recovery plan that records reprotect operations and can be exported as a report to verify whether errors occurred. A recovery plan can return to the ready state even if errors occurred during reprotect, so administrators should review the history log to confirm that the operation completed without integrity issues.

Before and after upgrade operations, protection groups and recovery plans must be verified to confirm they remain valid. PNR deployments consist of protected and recovery sites that are checked for connection validity and protection group and recovery plan integrity following upgrades.

Recovery plan steps can be exported in various formats for future reference and to maintain records of recovery procedures, supporting documentation of integrity verification activities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides built-in pre-restore and post-restore validation mechanisms for its Controller configuration backups.

Before any restore can proceed, the Avi Controller runs a multi-stage pre-check sequence. The checks cover Controller cluster readiness; the absence of active upgrade, patch, rollback, or rollback-patch operations on Service Engine Groups; configuration version compatibility between the backup file and the running controller software; FIPS mode alignment between the backup and the target environment; presence of all required file objects referenced by the configuration; system configuration validity; and available disk space across cluster nodes. The Controller also checks and obtains user consent prior to executing the restore. Each pre-check result is logged with a check code, description, validation details, state, start time, end time, and duration, giving administrators a traceable record of what was verified before the restore began. A restore that fails any pre-check does not proceed.

After a restore completes, the Avi Controller runs post-restore validation tasks that verify the count of restored objects, including clouds and Service Engine Groups, and invokes cloud discovery to confirm that the restored configuration reflects the actual infrastructure state. The Controller generates system reports recording the operation type, image version, total checks performed, and checks completed. The status of the restore operation is queryable at any time via the CLI `show upgrade status` command or via the `GET /api/upgradestatusinfo` API endpoint.

Configuration backups are passphrase-encrypted. The CLI restore command and the REST API restore method each require a passphrase that must match the passphrase used when creating the backup. A backup that has been tampered with, or whose passphrase is unknown, cannot be successfully restored.

In VCF deployments, Avi Load Balancer backups are stored by default on the same server used for VCF Operations appliance backups. Administrators configure the external backup server and storage path for Avi backups through VCF Operations. When restoring a Controller cluster from backup in a VCF environment, the restored instance must remain synchronized with the VCF Operations lifecycle. The Avi for VCF documentation recommends storing backups securely with clear labeling, including version and date identifiers. Before upgrade operations, the Avi Controller requires verification of image checksums or digital signatures to confirm file integrity before applying updates.

To make verified backups available when needed, organizations should configure the Avi backup scheduler to automate periodic backups and specify a remote backup destination for resilience against a Controller cluster failure. On single-node Controller deployments, enabling periodic external configuration backups is mandatory to support recovery from a complete VM or disk failure.

These integrity checks apply to the Avi Controller configuration backup. Integrity verification for the Controller and Service Engine virtual machine images relies on vSphere and vSAN mechanisms provided by VCF, covered under VCF Coverage.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RC.RP-04

Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms

SCF Controls: BCD-01, BCD-01.4, BCD-02, BCD-02.1

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides infrastructure-level backup, restore, high availability, and disaster recovery capabilities that support an organization's ability to resume missions and business functions within defined Recovery Time Objectives (RTOs). While VCF does not itself define or manage an organization's contingency plan, it supplies the mechanisms that underpin timely recovery of the virtualized infrastructure layer. VCF documentation explicitly calls out the need to plan and test disaster recovery strategies to meet both RTO and RPO targets.

Host and workload availability

vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts after a host failure. Admission control policies reserve sufficient capacity for restart operations, and dedicated failover hosts can be reserved exclusively for this purpose. Proactive HA integrates with hardware health providers to detect degrading components and places hosts into maintenance mode before a failure occurs, allowing VMs to be evacuated proactively. vSphere Fault Tolerance provides continuous availability by maintaining a live shadow instance of a VM on a separate host, enabling zero-downtime failover for individual workloads with no data loss.

Site-level resilience

vSAN stretched clusters extend a single logical cluster across two availability zones. When one site fails, the surviving site continues storage and compute operations. The site disaster tolerance rule can be configured for site mirroring, and the cluster can tolerate a witness host failure when one site is unavailable. After cluster expansion, the host failure cluster tolerates setting must be updated to reflect the number of hosts in the remaining availability zone.

Data protection and backup

vSAN Data Protection provides snapshot-based recovery through protection groups with configurable snapshot scheduling intervals and retention policies. vSAN Express Storage Architecture (ESA) delivers metadata-based snapshots with improved performance. Changed Block Tracking (CBT) enables incremental backups through VADP-integrated backup partner solutions, reducing backup windows and storage requirements. VADP-based solutions can automatically perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Management component backup and restore

VCF provides structured backup and restore procedures for its management components, including VCF Operations, NSX Manager, and vCenter. VCF Operations backup is configured to take a backup on state change. Backup jobs for these components should be created to capture the state of related components at a common point in time. VCF Operations backup jobs should be scheduled to run on a daily basis. This coordinated approach to management plane backups helps reduce the time required to restore the infrastructure to a known-good state after a disruption.

Restore sequencing is documented for dependent management components. vCenter, VCF Operations, and VCF Operations fleet management must be available before proceeding with the restore of VCF Automation. Following these dependency chains is important for meeting recovery time targets, as restoring components out of order can introduce delays. VCF Operations supports export of dashboards, views, reports, alert definitions, and other configuration content, so operational tooling can be restored alongside the infrastructure.

If both the active and standby NSX Global Manager instances fail, documented recovery procedures must be initiated to restore network management functions. The platform recommends performing test recoveries to validate that recovery plans work as expected, which is a standard practice for verifying that RTOs can be met in an actual disruption.

Disaster recovery and workload mobility

VCF integrates with VMware Live Site Recovery, which provides the ability to create recovery plans on a designated recovery site. Recovery plans define the sequencing and automation of failover and failback operations for protected virtual machines, directly supporting the ability to resume workloads within target RTOs. Recovery plan creation requires initialization of protection group specifications and association of protection groups with the plan. The platform also supports delta synchronization with configurable recovery point objectives during planned migrations and failover scenarios.

VCF Operations HCX provides workload mobility for migrating VMs between sites. HCX uses the Mobility Agent service to perform vMotion, Cold, and Replication Assisted vMotion (RAV) migrations, supporting bulk migration and mobility group scheduling for different recovery scenarios.

Containerized workload recovery

The VCF platform's Consumption layer extends these recovery capabilities to containerized workloads running on VMware Kubernetes Service (VKS). VKS Cluster Management provides native backup and restore for VKS clusters and their namespaces. Backup operations include file system backups by default, with optional selection of CSI volume snapshots for stateful workload data. Restore operations can target the original cluster or a different cluster; the VCF Automation Tenant Portal exposes a Restore from another cluster option in the Data Protection tab of VKS Cluster Management, allowing organizations to recover workloads to an alternate site or cluster. Completed restore operations are tracked and displayed in the Restores section of that tab, giving operators a record of recovery status.

For workload-level backup and restore on VKS clusters, Velero is available as a Supervisor service and supports scheduled automated backups as well as on-demand restore operations. Administrators can create restores from a specified backup and optionally wait for completion to confirm recovery status. The `backupRepository.config.fullMaintenanceInterval` parameter controls repository maintenance cadence and accepts `fastGC`, `eagerGC`, or `normalGC` as valid values, allowing organizations to tune maintenance operations to their recovery schedule requirements.

For vSphere Pods, the Velero plugin for vSphere handles backup and restore using the `CloneFromSnapshot` custom resource. A `CloneFromSnapshot` CR is created in the same namespace as the originally snapshotted PVC, and the resource carries a `status.phase` field that tracks restore progress through multiple phases. CSI volume snapshots must reach `ReadyToUse` state before they can be restored as a `PersistentVolumeClaim`; VKS clusters also support restoring raw block device snapshots when `PersistentVolumeClaim` resources specify `volumeMode` as `Block`.

At the control plane layer, Kubernetes components underlying VKS clusters use leader election to maintain continuity during component failures. Both `kube-scheduler` and `kube-controller-manager` expose a `retryPeriod` parameter in their `LeaderElectionConfiguration` that controls how quickly these components attempt to reacquire leadership, reducing the window during which scheduling and workload management are interrupted without manual intervention. Kubernetes `ReplicaSets` and `Deployments` automatically reschedule pods when nodes become unavailable, and the VKS Controller reports cluster phase and component readiness conditions via `kubectl`, allowing operators to monitor recovery progress. Supporting services such as the Contour ingress controller are configured with multiple replicas by default to maintain availability through individual component failures.

VCF provides the technical mechanisms for meeting RTOs, but the organization remains responsible for defining the contingency plan itself, setting the RTO targets, testing recovery procedures regularly, and maintaining the operational processes that tie these platform capabilities together into a working recovery strategy.

VMware vDefend (Contributes)

The Security Services Platform (SSP) supports DR activation by providing an Update & Redeploy option that resumes an interrupted deployment from the point where it stopped, rather than requiring a restart from the beginning. SSP backup and restore operations are executed as Kubernetes jobs within the `nsxi-platform` namespace, allowing them to be tracked, retried, and managed through standard Kubernetes tooling as part of a structured recovery process. These operations also generate job pod logs that record command execution details, giving operators a verifiable record of restore activity following a DR event.

Within the vDefend platform, the License Hub deployment provides the same Update & Redeploy option to resume from the point of failure after resolving an error, as well as a Cleanup option to remove previous deployment tasks when a fresh deployment is needed.

Defining RTOs, coordinating the broader recovery of missions and business functions, and confirming that all systems meet those objectives are organizational contingency planning responsibilities that extend beyond vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) is designed to support RTO-based resumption of business functions through automated recovery orchestration.

Recovery plans automate the failover sequence, executing a defined series of steps in the correct order for workflows such as planned migration and reprotect. Steps can include commands and message prompts that signify the completion of particular operations, though commands and prompts cannot be added before the Configure Test Networks step. Understanding the order and context of these steps is important when customizing a plan to meet specific RTO targets.

Recovery plan execution includes built-in mechanisms that support timely completion. Steps can be configured with timeouts that cause the plan to pause for a specified interval, giving operations time to finish rather than failing immediately. Message prompt steps cannot fail; instead, the plan pauses until the operator closes the prompt, and PNR signals a PlanPromptResponse event on the recovery site when the prompt is closed. If a recovery plan fails to progress during a recovery operation due to protection site unreachability, cancelling and restarting the plan is the recommended resolution.

The VCF Operations orchestrator Plug-In for Protection and Recovery provides workflow-driven control over recovery operations. The Initiate Reprotect Recovery Plan workflow accepts a Recovery Plan input parameter specifying the plan to fail over from the protected site to the recovery site; the recovery plan must be in ready state before the Initiate Failover Recovery Plan workflow can be executed. vSphere Replication provides a Resume Replication to vCenter workflow that resumes paused forward replication to the target site after recovery operations complete.

The Protection and Recovery Configuration Import/Export Tool exports server version, build number, site names, inventory mappings, placeholder datastores, advanced settings, and array manager data, providing a mechanism to preserve recovery configuration for continued operations after failover. Recovery plan steps can also be exported in various formats to maintain hard-copy records of the configured recovery sequence.

Recovery plan testing validates that configured plans can resume business functions within target RTOs before an actual event requires activation. Recovery plans should be tested before use for planned migration or disaster recovery operations. The Protection and Recovery dashboard in VCF Operations recommends executing recovery plans at least once every three months to maintain operational readiness and validate recovery procedures.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides technical mechanisms that support an organization's ability to meet defined Recovery Time Objectives and Recovery Point Objectives for database workloads.

Point-in-time recovery. DSM supports point-in-time recovery (PITR) for PostgreSQL, MySQL, and SQL Server databases, allowing administrators to restore data to a specific moment within the configured backup retention period. When initiating a restore, administrators identify a restore point and choose either the most recent timestamp or a user-specified date and time, and the restored database is created as a new database instance. The granularity of recovery is bounded by the configured backup schedule and retention settings, and PITR can only restore data from within the configured retention period. PITR requires the source database to be operational, the required backup to be available, and connectivity to the S3 storage repository. SQL Server PITR can restore onto the same or a different SQL Server cluster. PostgreSQL restore can also target a different DSM control plane by specifying a time value; if the time field is omitted, DSM restores the latest available state. For SQL Server, DSM automatically manages the recovery model based on backup status, using Full Recovery Model when automated backups are enabled and Simple Recovery Model otherwise. PITR may fail or be incomplete if binary log files are missing from the source database, which administrators should account for in operational procedures.

Log backup frequency and RPO. DSM exposes a Log Backup Frequency setting in Advanced Settings with a maximum value of 30 minutes. The log backup frequency is directly related to the achievable RPO for both PostgreSQL and SQL Server databases, and administrators should configure this value based on their RPO requirements.

Database cloning. DSM can clone a MySQL or PostgreSQL database to create an identical database. Cloning is functionally equivalent to PITR to the latest available time and can act as a recovery mechanism when the most recent consistent state is the desired recovery target.

Provider VM recovery and restore duration. DSM documents a recovery procedure for a single Provider VM failure, and the Provider VM restoration must complete fully before proceeding to subsequent recovery steps. This is a relevant consideration for control plane RTO planning. Database restoration duration depends on data volume and underlying infrastructure performance, and administrators should account for this when planning restore operations against an RTO target.

Defining and formally documenting RTO and RPO targets is an organizational process outside DSM's scope. DSM provides the backup, restore, and cloning mechanisms that technical teams configure and test against those targets. Organizations must establish their RTO and RPO requirements, configure DSM backup policies accordingly, test recovery procedures, and verify operational results align with those targets.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides several application-layer mechanisms that support resuming application traffic delivery in alignment with recovery time objectives during and after disruption events.

Global Server Load Balancing (GSLB) in Avi includes health-based failover that automatically detects when a site or pool member is unavailable and redirects DNS-based application traffic to healthy members across geographic locations. Avi GSLB supports an active disaster recovery deployment mode, giving organizations a dedicated DR configuration that routes application traffic to a standby site upon primary site failure. The GSLB Service's `manual_resume` setting, configurable per service group through the Avi Controller UI or CLI, gives operations teams explicit control over traffic resumption after failover. When `manual_resume` is enabled, backup pool members continue serving traffic even after the primary member recovers, and traffic does not return to the primary until an administrator explicitly deactivates the manual resume state using the `no manual_resume` CLI command. Avi GSLB also supports a manual failback capability alongside manual resume, so teams can control both the direction and timing of traffic transitions. This allows recovery teams to validate application health before shifting load back to the primary site, supporting disciplined adherence to defined recovery timelines.

Avi GSLB adaptive replication mode provides a safeguard during multi-site recovery. It prevents faulty configuration objects from being replicated to follower sites, protecting against configuration errors that could propagate an outage across multiple data centers. GSLB federation supports automatic leader site failover: global application service continues across all remaining federated sites when a leader site fails.

At the data plane level, Service Engine high availability and BGP graceful restart support rapid resumption of application traffic after infrastructure events. BGP graceful restart is configurable on Service Engines participating in BGP peering, with the graceful restart timer set to be less than the hold timer to keep routing recovery within defined time windows. When a Service Engine fails and is not recovered by vSphere HA within a configured timeout period, the Avi Controller resumes normal recovery processes to restore capacity.

Avi Controller configuration backup and restore supports disaster recovery for the control plane. In single-node Controller deployments, including those following Avi Load Balancer for VCF deployment guidance, the Backup and Restore feature is required for disaster recovery. After a storage failure, the Controller must be restored from a configuration archive; at least one Service Engine controller IP must match a previous controller IP for Service Engines to reconnect after restoration. The restore process follows sequential steps: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Three-node Controller cluster deployments can recover a non-operational cluster by restoring one node with its configuration to become the cluster leader, then adding the remaining nodes as followers.

Meeting the control's broader requirement, that all missions and business functions resume within documented RTOs, depends on an organizational contingency plan that defines RTOs, assigns responsibilities, and coordinates recovery across the full infrastructure stack.

Control RC.RP-05

The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed

SCF Controls: BCD-12

Aggregate Coverage: Meets

VCF (Contributes)

VCF provides built-in capabilities for secure recovery and reconstitution of infrastructure and workloads to a known state after a disruption, compromise, or failure. These capabilities span compute-level high availability, storage-level data protection, structured backup and restore workflows for management components, and disaster recovery across sites.

At the compute layer, vSphere High Availability (HA) automatically restarts virtual machines on surviving hosts following a physical machine failure, restoring workloads to their prior operational state. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure with no data loss or downtime. Proactive HA supports maintenance mode as a remediation method, allowing the platform to respond to hardware degradation indicators. On TPM-equipped hosts, VMware ESX supports a Secure ESX Configuration recovery key that is required to restore the host configuration following TPM failure, TPM reset, motherboard replacement, or TPM device replacement; administrators can retrieve and store this key using ``esxcli system settings encryption recovery list`` and should keep it in a secure, off-host location.

At the storage layer, vSAN fault domains distribute data according to storage policy so that it remains available even when hardware failures occur. vSAN stretched clusters extend a cluster across two availability zones, providing site-level resiliency against the loss of an entire availability zone. When one site becomes unavailable, the surviving site continues operations, and with local fault protection enabled, the cluster can perform repairs on missing or broken components in the available site. vSAN Data Protection uses native snapshots stored locally on a vSAN Express Storage Architecture (ESA) cluster to support point-in-time recovery from operational failures or ransomware attacks. Changed Block Tracking (CBT) tracks changes on disk sectors, enabling incremental backups through VADP-integrated partner backup solutions.

For large-scale disruptions, Application Disaster Recovery enables failover to a secondary site, with data replication so recovery options exist in the event of catastrophic failure. Disaster recovery can also be implemented for fleet-level components, covering the management plane itself. VCF documentation recommends planning and testing disaster recovery strategies regularly to validate that recovery time objectives (RTO) and recovery point objectives (RPO) can be met.

VCF includes structured backup and restore workflows for its management components. Administrators create a series of backup jobs that capture the state of related components, including VCF Operations, NSX Manager, and VMware vCenter, at a common point in time. VCF Operations backup is configured to take a backup on state change. VMware vCenter supports both file-based and image-based backup methods. The file-based restore procedure is a two-stage operation: stage 1 deploys a new vCenter appliance, and stage 2 transfers data from the backup location to that appliance; the restored appliance operates in non-HA mode, so vCenter High Availability must be reconfigured after recovery completes. Simultaneous backups of VCF Operations fleet management component nodes support restoring the nodes to a logically consistent state, so further integrity remediation is not required after a restore. The platform also recommends backing up the management domain vCenter and VCF Identity Broker appliance following any substantial modifications to the identity source configuration, such as a VCF SSO reset, to preserve a known-good recovery point.

For VMware vCenter specifically, the vCenter Management API provides a unified restore process that handles multiple vCenter components in a single operation. After a file-based or image-based restore, the reconciliation API checks whether vCenter partners in embedded linked mode are available, synchronizes vCenter data and services with the partners, and runs vCenter services. The appliance recovery API exposes a restore client interface for programmatic restore operations, supporting automation of recovery workflows.

VCF Operations supports image-based backup and restore as a recovery process for single node, primary node, replica node, data node, and collector failures. VCF Operations for Networks supports backup and restore of its deployment data to enable recovery when the existing setup is unrecoverable. VCF Operations HCX provides backup and restore operations through its appliance management interface, and its Mobility Groups support workload migration with state tracking, retry capabilities, and reverse migration from destination back to the original source.

The Consumption layer of VCF, which encompasses VMware Kubernetes Service (VKS), vSphere namespaces, and VCF Services consumption, extends recovery and reconstitution capabilities to containerized workloads and self-service deployments. At the Kubernetes control-plane level, ReplicaSets and Deployment controllers continuously monitor pod health and reschedule workloads to healthy nodes when pods or nodes fail. Liveness probes detect application-level failures and trigger container restarts; readiness probes gate traffic until a workload recovers from transient faults or overloads. These self-healing mechanisms operate without manual intervention for transient failures. Pod Disruption Budgets allow administrators to define minimum availability constraints that the platform respects during voluntary disruptive actions such as node upgrades or certificate rotations, so those operations proceed without taking down an entire service.

VKS clusters support structured backup and restore through VKS Cluster Management and Velero-based mechanisms. VKS Cluster Management backup operations can capture an entire cluster or a subset of data resources, and restore operations allow the operator to specify the scope of resources to recover. Restore operations include file system backups by default; CSI volume snapshots can be optionally selected for restoration. CSI Volume Snapshots deliver crash-consistent backups with support for block mode and file system mode, incremental backups, deduplication, compression, and encryption, and provide a resilient safety net for VKS clusters when primary storage infrastructure fails. CloneFromSnapshot custom resources expose a status.phase field that tracks restore progress through multiple phases, giving operators visibility into the state of ongoing recovery operations. The Velero plugin for vSphere supports backup and restore of vSphere pods, and VADP-based backup partner solutions can perform backup, full restore, and registration of VM Service VMs on a Supervisor.

Deploying workloads across multiple failure zones using the Cluster API defines worker nodes across multiple failure domains with automatic healing rules that reschedule workloads when a zone becomes unavailable. Replicating control plane components across at least three failure zones limits the impact of a single-zone failure on the Kubernetes control plane itself. For VM Service workloads, the IaaS Services Console and Local Consumption Interface provide a Resources tab where users can create snapshots with optional memory capture and guest file system quiescence, and can revert a VM to a prior snapshot to restore it to a known state.

Deployment rollback is available natively in Kubernetes through Deployments with revision history, allowing administrators to return to a previous known-good revision when a newly deployed version fails. The Harness CI/CD Supervisor Service extends this with automated rollback capabilities that can revert to a previous stable state when deployment failures are detected.

Immutable infrastructure patterns supported by Kubernetes, combined with infrastructure-as-code stored in version control, provide a reproducible mechanism for reconstituting a cluster to a known, authorized state. Every change to the declared state is recorded in version control, and the cluster can be rebuilt from that record after a compromise or failure. VKS Cluster Management Policy Insights expose Sync signals that indicate when policy definitions fail to propagate from the management plane to the targeted VKS cluster estate, helping operators detect and remediate policy drift before it affects recovery posture.

Restore operations require that the target infrastructure be in place before a restore can proceed. VCF documentation recommends implementing a consistent backup strategy to safeguard the infrastructure against unforeseen disruptions and to support effective disaster recovery.

VMware vDefend (Contributes)

VMware vDefend contributes to secure recovery and reconstitution through backup and restore capabilities for its own security infrastructure, and through disaster recovery features that maintain security policy continuity across site failover events.

The Security Services Platform provides backup and restore functionality, accessible through the System > Backup and Restore interface, that allows recovery of a platform instance to its previous configuration when the current instance is in a

non-recoverable state. The backup scope includes the full system inventory: tokens, Bare Metal servers, and Bare Metal server interfaces are captured as part of inventory backup, and required certificates from the backup server are restored automatically during the restore process. The platform must be in a healthy state to perform backup operations; backup and restore cannot proceed when the platform is unhealthy. Certificate consistency between backup and restored Security Services Platform environments must be maintained to avoid NDR Sensor disruptions. Backup and restore operations enter a failed state after 30 minutes if internal services are restarted manually or due to failure. Administrators should back up the Security Services Platform before performing scale-out operations, and Bare Metal Service operations (onboarding, offboarding, or upgrading Bare Metal servers) should not be performed while backup or restore is in progress.

The Security Services Platform can be deployed on vSAN stretched configurations, which supports recovery from site failures and reduces recovery time at the infrastructure level.

For disaster recovery scenarios, NSX Federation maintains security posture during workload migration and site failover by propagating Distributed Firewall rules, security groups, and microsegmentation policies across multiple sites. When workloads fail over from a protected site to a recovery site, the vDefend security policies governing east-west traffic at the destination site are already in place. vSphere HA can be configured to handle host-level failures affecting Security Services Platform appliances.

The broader recovery of compute infrastructure, storage, virtual machines, and application workloads to a known state is handled by other VCF components such as Protection and Recovery, vSAN Data Protection, vSphere Replication, and vCenter backup and restore.

VCF Protection and Recovery (Meets)

VCF Protection and Recovery (PNR) provides mechanisms for secure recovery and reconstitution of virtual machine workloads to a known state after a disruption, compromise, or failure.

Recovery is organized through protection groups and recovery plans. Protection groups define which virtual machines are protected, while recovery plans orchestrate the sequence of steps required to recover those workloads at the recovery site. The state of a recovery plan is determined by the states of the protection groups within it, and the plan state governs which operations are permitted at each stage of the DR lifecycle. Recovery plans support two primary modes: planned migration for orderly, scheduled failover, and disaster recovery for unplanned site failures. A single recovery plan can also be configured to serve both disaster recovery and cyber recovery operations, allowing organizations to maintain consistent recovery procedures across different incident types.

Recovery plan testing is a built-in capability. Recovery plans should be tested before use for planned migration or disaster recovery to validate their functionality. This confirms that the recovery process will bring protected virtual machines online at the recovery site and that inventory mappings correctly place workloads on the appropriate networks, storage, and compute resources.

Cyber Recovery extends reconstitution capabilities with an Isolated Recovery Environment (IRE) designed for compromise scenarios such as ransomware incidents. The IRE provides a dedicated, isolated segment of the recovery environment that blocks direct private network connections from production, allowing compromised workloads to be analyzed and validated before being returned to production. Cyber Recovery transitions virtual machines through a controlled sequence of states, including Entering validated, Validated, Staging, and Staged, to prepare them for recovery. This state-based workflow supports data integrity validation prior to production restoration.

Recovery plan compliance checks verify that protection groups are actively replicating, that sufficient point-in-time snapshots are available for each virtual machine in the plan, and that all workflow steps can execute without conflict. Continuous compliance monitoring provides warnings when VM configuration status deviates from expected state.

The Configuration Import/Export Tool enables administrators to export PNR server configuration data, including inventory mappings, placeholder datastores, advanced settings, array manager configurations, and protection group definitions. This capability supports configuration backup and reconstitution of the PNR environment itself after a failure or migration.

PNR integrates with VCF Operations for recovery plan lifecycle visibility. The Recovery Plans Details dashboard shows the current phase of the DR lifecycle, including whether a plan is ready, whether a test is in progress, and whether incomplete recovery or cleanup operations require attention. PNR also supports recovery of VCF Automation and VCF Operations services: when a disaster event affects the management domain containing these services, PNR enables service recovery in another management domain.

All communications between PNR and VMware vCenter instances use TLS certificates and private keys. The PNR Appliance supports importing server certificates signed by a certificate authority to establish secure communications across both protected and recovery sites.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides several mechanisms that support the secure recovery and reconstitution of database services to a known state following a disruption, compromise, or failure.

For backup-based recovery, DSM supports point-in-time recovery (PITR), which restores a backup to a newly created database VM. During the restore operation, the administrator can specify the database name, choose the target datastore location, and configure management settings. DSM supports restoring backups from either local or cloud-compatible (S3-compatible) storage, with restoration permitted to any point in time within the configured backup retention period. When restoring a deleted database, DSM's Archives tab allows users to access databases with retained backups and create a new database VM from a selected restore point, including options to restore to the most recent available timestamp or a custom point in time. PITR coverage extends across PostgreSQL, MySQL, and SQL Server database engines. For SQL Server, DSM automatically manages the database recovery model based on backup status, using Full Recovery for databases with automated backups enabled and Simple Recovery otherwise. Cloning a MySQL or PostgreSQL database is functionally equivalent to PITR to the latest available time, giving operators an additional path for rebuilding a known-good database instance. For failed clusters, DSM supports restoration to a different cluster with the option to target either the latest available time or a specific custom restore point.

For active recovery and failover of PostgreSQL databases, DSM provides a multi-site disaster recovery deployment model in which a secondary instance replicates from the primary across sites. When a failover is needed, DSM provides a switchover workflow that reverses the roles of instances, redirecting the secondary to become the new primary and restoring the database service to a fully operational state. DSM also provides a switchover workflow for failback, allowing operators to reverse instance roles again after the primary site is restored. DSM requires trust validation of the new primary database certificate when redirecting secondary instances during disaster recovery switchover, and operators with the DSM user role must manually establish trust between primary and secondary instances by retrieving the Certificate Authority from the primary and adding it to the Provider VM that will host the secondary. For backup-location certificates, DSM supports a Trust On First Use (TOFU) configuration that extracts and trusts certificates for specific backup locations, and at least one backup location must be configured with a trusted root certificate when a data service policy requires or allows automated backups. DSM also preserves the backing virtual machines of removed database nodes in an idle state until an instance is promoted again, maintaining infrastructure capacity for disaster recovery operations.

The resiliency of the DSM Provider Appliance itself is supplied by the underlying VCF platform (see VCF Coverage); DSM relies on vSphere High Availability to restart the appliance on another host in the event of a host failure, and does not add a separate management-plane HA mechanism. If a DSM provider restore fails for any reason, the documented procedure is to re-deploy the appliance and then follow the recovery procedure again rather than re-attempting the restore workflow on the same appliance.

DSM tracks recovery operations through its audit and operations interfaces. Event logs record Provider Restore Success events with timestamps, allowing operators to verify that recovery operations completed. Restore operation progress is visible in the Operations tab and Operations view, and a new entry appears in the Databases view table when a restore completes. To support integrity of recovery artifacts, the DSM Consumption Operator deployment includes Signature Verification of packages.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides application-layer recovery and reconstitution mechanisms at the load balancing and application delivery tier.

The Avi Controller cluster can be deployed across two availability zones, with defined failure scenarios and documented recovery actions for each zone-loss case. Availability zones should be configured based on fault domains associated with shared power supplies, shared networking devices, or other common infrastructure to reduce the risk of virtual service unavailability. When the cluster enters manual recovery state following a failure or compromise, Avi automatically revokes all Service Engine secure channel credentials and causes Service Engines to reboot themselves, halting all application traffic delivery. This returns the data plane to a controlled, known state. Service Engines that subsequently re-establish connectivity to a recovered Controller node reconfigure themselves automatically to connect only to that node.

If all three Controller cluster nodes are permanently unavailable, recovery must be performed using a backup and restore procedure. When a Controller node fails but is not permanently lost, it can be recovered by bringing the existing node back online, which is transparent to existing data traffic, or by rebuilding a new Controller node, which is disruptive to existing connections. Factory reset recovery is irreversible and deletes all Controller configuration, requiring the database to be recreated from the configuration archive. When a Service Engine is compromised or rebooted independently, all configurations including private keys and public certificates are wiped from the Service Engine, providing a clean starting state for reconstitution.

Elastic High Availability (Elastic HA) provides fast recovery for individual virtual services following the failure of a Service Engine, redistributing workloads to surviving Service Engines without requiring a full cluster-level recovery event. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, so application services are restored in a defined sequence.

Avi GSLB (Global Server Load Balancing) supports an Active disaster recovery deployment mode, enabling global-level recovery and reconstitution for applications served across multiple sites.

Avi provides configuration backup and restore capabilities for the Controller. A remote backup destination should be specified to protect against non-recoverable Controller cluster failures. The Controller checks and obtains user consent prior to performing a restore operation. After a storage failure requiring a full restore, the Controller is restored from the configuration archive. The restore process follows a defined sequence: cloud discovery, post-restore validation, configuration unblocking, and placement resumption. Post-restore validation verifies the count of restored configuration objects, including clouds and Service Engine groups, confirming that the reconstituted state matches the backup. Restore operations report state information including the operation type, image version, and cluster node name. The Controller logs restore completion events with timestamps, node IP addresses, task status, and success or failure messages for audit trail purposes.

Avi's recovery mechanisms address the application delivery tier. VM-level backup and restore for the Controller and Service Engine VMs, storage-level recovery, and infrastructure reconstitution depend on the underlying VCF platform. See VCF Coverage for those mechanisms.

Control RC.RP-06

The end of incident recovery is declared based on criteria, and incident-related documentation is completed

SCF Controls: IRO-02, IRO-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control RS

The incident response plan is executed in coordination with relevant third parties once an incident is declared. Incident reports are triaged and validated. Incidents are categorized and prioritized. Incidents are escalated or elevated as needed. The criteria for initiating incident recovery are applied. [Withdrawn: Incorporated into RS.MA-02] [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04] Analysis is performed to establish what has taken place during an incident and the root cause of the incident. [Withdrawn: Moved to RS.MA-03] [Withdrawn: Moved to ID.RA-08] Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved. Incident data and metadata are collected, and their integrity and provenance are preserved. An incident's magnitude is estimated and validated. [Withdrawn: Incorporated into PR.AT-01] Internal and external stakeholders are notified of incidents. Information is shared with designated internal and external stakeholders. [Withdrawn: Incorporated into RS.MA-01, RS.MA-04] [Withdrawn: Incorporated into RS.CO-03] Incidents are contained. Incidents are eradicated. [Withdrawn: Incorporated into ID.RA-06] [Withdrawn: Incorporated into RS.MA-01] [Withdrawn: Incorporated into ID.IM-03, ID.IM-04] [Withdrawn: Incorporated into ID.IM-03]

SCF Controls: IRO-01, IRO-02, IRO-04, IRO-07, IRO-09, IRO-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI

provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions.

vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to

be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control RS.AN

[Withdrawn: Incorporated into RS.MA-02] [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04] Analysis is performed to establish what has taken place during an incident and the root cause of the incident [Withdrawn: Moved to RS.MA-03] [Withdrawn: Moved to ID.RA-08] Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved Incident data and metadata are collected, and their integrity and provenance are preserved An incident's magnitude is estimated and validated

SCF Controls: IRO-02, IRO-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low

and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports forensic investigation and evidence preservation through event logging, security-related audit trails, and protection group state tracking. PNR records operational information in log files that exclude sensitive information such as private keys and passwords, making these logs suitable for sharing with forensic investigators or external auditors without exposing credentials. PNR also logs certificate verification error messages in security-related log files, providing an audit trail of authentication events relevant to incident investigation.

PNR captures Info-level events when users include or remove datastores in protection groups, recording protection group membership changes that contribute to a chronological record of administrative activity. PNR tracks collection state for each protection group to indicate which operational phase the group is in, including modifying, testing, replicating, or recovering, which gives investigators context for reconstructing administrative actions during an incident. The VCF Operations Recovery Plans Dashboard exposes PNR operational state for monitoring and after-action review.

Organizations performing forensic investigation should forward PNR log files to a centralized log aggregation system such as VCF Log Management to preserve evidence integrity beyond the appliance's local log retention. Chain of custody documentation, evidence handling procedures, and integration with broader incident response workflows remain organizational responsibilities outside PNR's scope.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.AN-03

Analysis is performed to establish what has taken place during an incident and the root cause of the incident

SCF Controls: IRO-13

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RS.AN-06

Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved

SCF Controls: IRO-02, IRO-08, IRO-09

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support digital forensic investigations and evidence preservation, though the organization retains responsibility for chain-of-custody procedures, legal compliance, and formal forensic processes.

VCF Operations includes a Forensics Widget that can be added to custom dashboards for operational analysis during investigations. The widget displays data based on configurable filter sections, where each section progressively filters objects and passes the results to the next section. Administrators can search for and select specific objects in the environment on which to base the widget data, using text filters and tag-based filtering to narrow scope. The widget supports comparing data across two time periods, which is useful when investigating changes in environment behavior around a suspected incident. After adding the Forensics Widget to a dashboard, administrators should configure its options to tailor the output to the specific investigative needs of the dashboard users.

For evidence capture, VMware vCenter supports VM snapshots that record the memory, disk, and settings state of a virtual machine at a specific point in time. Reverting to a snapshot returns all of these to the exact state they were in when the snapshot was taken, making snapshots useful for preserving system state during an investigation. VM files (VMDKs, memory snapshots, log files) can also be collected and copied without powering down the workload, allowing incident responders to capture volatile and non-volatile evidence without altering the running state of the original workload. vSAN extends snapshot capabilities with immutable snapshots through its data protection service. An immutable vSAN snapshot is a read-only copy of data that cannot be modified or deleted, even by an attacker with administrative privileges. Once immutability mode is enabled on a protection group, it cannot be disabled by an administrator. This property helps protect forensic evidence from tampering. The `vmkfstools` command on VMware ESX hosts supports a `--chainConsistent` option that checks the entire virtual disk snapshot chain for corrupted links or invalid parent-child relationships, allowing investigators to verify the structural integrity of snapshot evidence before relying on it. VCF Automation exposes day-2 resource actions (Suspend, Create Snapshot, Delete Snapshot, Power On) through its API, allowing forensic preservation steps to be invoked programmatically as part of an incident response workflow. Day-2 action policies can be configured to entitle specific roles to perform snapshot actions and can be scoped at the organization level.

Audit logging across VCF components provides the evidentiary foundation that forensic investigators rely on. VCF Operations audit events capture operational details that facilitate security and compliance audits and provide information for conducting security forensics. The audit log feature in VCF Operations for Networks is always on and captures CRUD operations, login/logout events, and actions from the API, UI, and CLI. VCF Automation creates audit logs for reportable actions including catalog deployments, template operations, and day-2 actions. NSX audit logs use structured syslog fields with an `audit="true"` marker to identify security-related events, and a separate `nsx-audit-write.log` captures modification events. These audit records, combined with event logs from vCenter, ESX hosts, and VCF Operations, create a detailed trail of administrative actions, configuration changes, authentication events, and system state transitions. ESX hosts maintain audit records as a separately configurable logging feature from general event logs; these audit records must be explicitly activated and are not enabled by default, a step auditors should verify when assessing the forensic readiness of the platform.

For centralized evidence preservation, VCF components support log forwarding to external SIEM platforms via syslog. NSX remote logging supports TLS-encrypted transport with certificate verification. vSphere Supervisor similarly supports TLS-encrypted syslog forwarding with CA-based certificate verification. Forwarding logs to external systems with their own retention and integrity controls helps organizations maintain an independent, tamper-resistant record of events for forensic analysis.

Organizations deploying VCF should establish documented forensic procedures that define how to collect, handle, and preserve digital evidence from the virtualized environment. This includes defining who has authority to initiate evidence collection, how VM snapshots and log exports are stored to maintain integrity, and how the chain of custody is recorded from initial collection through analysis and potential legal proceedings. VCF provides the raw technical capabilities for evidence capture, audit logging, and secure log forwarding, but the procedural controls, trained personnel, legal chain-of-custody documentation, evidentiary handling procedures, and specialized forensic tooling required to maintain a legally defensible chain of custody are organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend provides several technical capabilities that support digital forensic investigations by capturing, preserving, and exporting network-level evidence. While vDefend does not manage chain-of-custody documentation or legal evidentiary procedures, it generates and retains the forensic artifacts that investigators rely on during incident analysis.

vDefend IDS/IPS captures and stores packet capture (PCAP) files associated with detected intrusion events, which can be exported in TAR format for detailed analysis and forensic investigation. IDS/IPS also provides a filestore capability that stores matched files to disk when a signature rule is triggered, and stores TLS/SSL certificates on disk for forensic analysis and threat investigation. These artifacts preserve the raw network traffic, file evidence, and certificate data surrounding a security event. The NDR Sensor extends this by recording raw network packets associated with detected intrusion events through its IDS Packet Capture capability.

Malware Prevention generates detailed analysis reports for both file-based and process-based (fileless) malware detections. The File Analysis Report and Process Analysis Report each support downloading screenshots and PCAP files from the inspection analysis. These artifacts document the behavior observed during sandboxing and can serve as evidence of malicious activity during a forensic investigation.

Network Detection and Response (NDR) correlates individual detections into campaigns using correlation rules that link related events across workloads. Campaign data includes detection types, identified threats, affected workloads, and mapped MITRE ATT&CK tactics. This correlated view helps investigators reconstruct the sequence and scope of an attack, connecting individual events into a coherent narrative. NDR campaign correlation rules link file transfer detections with command-and-control events, IDS drive-by events with subsequent malicious file transfers, and custom IDS signature events sharing the same signature ID on the same workload. Security Intelligence also detects and categorizes suspicious events using MITRE tactics and techniques, recording the number of occurrences during the selected time period.

The Distributed Firewall (DFW) and Gateway Firewall both support per-rule logging. Administrators can attach log labels to firewall rules, which tag matched traffic in log output for easier parsing in a log aggregator. These timestamped, attributable records of firewall rule hits provide evidence of network access patterns during and around a security incident. Security Explorer tracks compute entities that were in the inventory during the selected time period and separately identifies entities deleted from inventory, helping investigators establish a forensic timeline of asset activity.

The Security Services Platform supports role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role allows forensic investigators to review security data without the ability to modify it, supporting the integrity of the evidence under review. The Security Operator role monitors security systems and responds to security incidents.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports forensic investigation and evidence preservation through event logging, security-related audit trails, and protection group state tracking. PNR records operational information in log files that exclude sensitive information such as private keys and passwords, making these logs suitable for sharing with forensic investigators or external auditors without exposing credentials. PNR also logs certificate verification error messages in security-related log files, providing an audit trail of authentication events relevant to incident investigation.

PNR captures Info-level events when users include or remove datastores in protection groups, recording protection group membership changes that contribute to a chronological record of administrative activity. PNR tracks collection state for each

protection group to indicate which operational phase the group is in, including modifying, testing, replicating, or recovering, which gives investigators context for reconstructing administrative actions during an incident. The VCF Operations Recovery Plans Dashboard exposes PNR operational state for monitoring and after-action review.

Organizations performing forensic investigation should forward PNR log files to a centralized log aggregation system such as VCF Log Management to preserve evidence integrity beyond the appliance's local log retention. Chain of custody documentation, evidence handling procedures, and integration with broader incident response workflows remain organizational responsibilities outside PNR's scope.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service

Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control RS.AN-07

Incident data and metadata are collected, and their integrity and provenance are preserved

SCF Controls: IRO-08

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support digital forensic investigations and evidence preservation, though the organization retains responsibility for chain-of-custody procedures, legal compliance, and formal forensic processes.

VCF Operations includes a Forensics Widget that can be added to custom dashboards for operational analysis during investigations. The widget displays data based on configurable filter sections, where each section progressively filters objects and passes the results to the next section. Administrators can search for and select specific objects in the environment on which to base the widget data, using text filters and tag-based filtering to narrow scope. The widget supports comparing data across two time periods, which is useful when investigating changes in environment behavior around a suspected incident. After adding the Forensics Widget to a dashboard, administrators should configure its options to tailor the output to the specific investigative needs of the dashboard users.

For evidence capture, VMware vCenter supports VM snapshots that record the memory, disk, and settings state of a virtual machine at a specific point in time. Reverting to a snapshot returns all of these to the exact state they were in when the snapshot was taken, making snapshots useful for preserving system state during an investigation. VM files (VMDKs, memory snapshots, log files) can also be collected and copied without powering down the workload, allowing incident responders to capture volatile and non-volatile evidence without altering the running state of the original workload. vSAN extends snapshot capabilities with immutable snapshots through its data protection service. An immutable vSAN snapshot is a read-only copy of data that cannot be modified or deleted, even by an attacker with administrative privileges. Once immutability mode is enabled on a protection group, it cannot be disabled by an administrator. This property helps protect forensic evidence from tampering. The `vmkfstools` command on VMware ESX hosts supports a `--chainConsistent` option that checks the entire virtual disk snapshot chain for corrupted links or invalid parent-child relationships, allowing investigators to verify the structural integrity of snapshot evidence before relying on it. VCF Automation exposes day-2 resource actions (Suspend, Create Snapshot, Delete Snapshot, Power On) through its API, allowing forensic preservation steps to be invoked programmatically as part of an incident response workflow. Day-2 action policies can be configured to entitle specific roles to perform snapshot actions and can be scoped at the organization level.

Audit logging across VCF components provides the evidentiary foundation that forensic investigators rely on. VCF Operations audit events capture operational details that facilitate security and compliance audits and provide information for conducting security forensics. The audit log feature in VCF Operations for Networks is always on and captures CRUD operations, login/logout events, and actions from the API, UI, and CLI. VCF Automation creates audit logs for reportable actions including catalog deployments, template operations, and day-2 actions. NSX audit logs use structured syslog fields with an `audit="true"` marker to identify security-related events, and a separate `nsx-audit-write.log` captures modification events. These audit records, combined with event logs from vCenter, ESX hosts, and VCF Operations, create a detailed trail of administrative actions, configuration changes, authentication events, and system state transitions. ESX hosts maintain audit records as a separately configurable logging feature from general event logs; these audit records must be explicitly activated and are not enabled by default, a step auditors should verify when assessing the forensic readiness of the platform.

For centralized evidence preservation, VCF components support log forwarding to external SIEM platforms via syslog. NSX remote logging supports TLS-encrypted transport with certificate verification. vSphere Supervisor similarly supports TLS-encrypted syslog forwarding with CA-based certificate verification. Forwarding logs to external systems with their own retention and integrity controls helps organizations maintain an independent, tamper-resistant record of events for forensic analysis.

Organizations deploying VCF should establish documented forensic procedures that define how to collect, handle, and preserve digital evidence from the virtualized environment. This includes defining who has authority to initiate evidence

collection, how VM snapshots and log exports are stored to maintain integrity, and how the chain of custody is recorded from initial collection through analysis and potential legal proceedings. VCF provides the raw technical capabilities for evidence capture, audit logging, and secure log forwarding, but the procedural controls, trained personnel, legal chain-of-custody documentation, evidentiary handling procedures, and specialized forensic tooling required to maintain a legally defensible chain of custody are organizational responsibilities.

VMware vDefend (Contributes)

VMware vDefend provides several technical capabilities that support digital forensic investigations by capturing, preserving, and exporting network-level evidence. While vDefend does not manage chain-of-custody documentation or legal evidentiary procedures, it generates and retains the forensic artifacts that investigators rely on during incident analysis.

vDefend IDS/IPS captures and stores packet capture (PCAP) files associated with detected intrusion events, which can be exported in TAR format for detailed analysis and forensic investigation. IDS/IPS also provides a filestore capability that stores matched files to disk when a signature rule is triggered, and stores TLS/SSL certificates on disk for forensic analysis and threat investigation. These artifacts preserve the raw network traffic, file evidence, and certificate data surrounding a security event. The NDR Sensor extends this by recording raw network packets associated with detected intrusion events through its IDS Packet Capture capability.

Malware Prevention generates detailed analysis reports for both file-based and process-based (fileless) malware detections. The File Analysis Report and Process Analysis Report each support downloading screenshots and PCAP files from the inspection analysis. These artifacts document the behavior observed during sandboxing and can serve as evidence of malicious activity during a forensic investigation.

Network Detection and Response (NDR) correlates individual detections into campaigns using correlation rules that link related events across workloads. Campaign data includes detection types, identified threats, affected workloads, and mapped MITRE ATT&CK tactics. This correlated view helps investigators reconstruct the sequence and scope of an attack, connecting individual events into a coherent narrative. NDR campaign correlation rules link file transfer detections with command-and-control events, IDS drive-by events with subsequent malicious file transfers, and custom IDS signature events sharing the same signature ID on the same workload. Security Intelligence also detects and categorizes suspicious events using MITRE tactics and techniques, recording the number of occurrences during the selected time period.

The Distributed Firewall (DFW) and Gateway Firewall both support per-rule logging. Administrators can attach log labels to firewall rules, which tag matched traffic in log output for easier parsing in a log aggregator. These timestamped, attributable records of firewall rule hits provide evidence of network access patterns during and around a security incident. Security Explorer tracks compute entities that were in the inventory during the selected time period and separately identifies entities deleted from inventory, helping investigators establish a forensic timeline of asset activity.

The Security Services Platform supports role-based access control with five defined roles: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. The Auditor role allows forensic investigators to review security data without the ability to modify it, supporting the integrity of the evidence under review. The Security Operator role monitors security systems and responds to security incidents.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) supports forensic investigation and evidence preservation through event logging, security-related audit trails, and protection group state tracking. PNR records operational information in log files that exclude sensitive information such as private keys and passwords, making these logs suitable for sharing with forensic investigators or external auditors without exposing credentials. PNR also logs certificate verification error messages in security-related log files, providing an audit trail of authentication events relevant to incident investigation.

PNR captures Info-level events when users include or remove datastores in protection groups, recording protection group membership changes that contribute to a chronological record of administrative activity. PNR tracks collection state for each protection group to indicate which operational phase the group is in, including modifying, testing, replicating, or recovering,

which gives investigators context for reconstructing administrative actions during an incident. The VCF Operations Recovery Plans Dashboard exposes PNR operational state for monitoring and after-action review.

Organizations performing forensic investigation should forward PNR log files to a centralized log aggregation system such as VCF Log Management to preserve evidence integrity beyond the appliance's local log retention. Chain of custody documentation, evidence handling procedures, and integration with broader incident response workflows remain organizational responsibilities outside PNR's scope.

Not applicable for this control: VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RS.AN-08

An incident's magnitude is estimated and validated

SCF Controls: IRO-02.4

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend provides structured classification and prioritization mechanisms for security detection events within the network security domain.

Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help security teams prioritize response actions. Security Intelligence also categorizes detected events by MITRE adversarial tactics and techniques, recording occurrence counts during the selected time period, which provides additional context for classification decisions.

Network Detection and Response (NDR) assigns impact scores to campaigns, with higher scores indicating higher priority for triage and response. Detection events are classified into impact levels; events with an impact score from 1 to 24 are classified as Informational, indicating the detected activity is not essentially malicious. NDR calculates impact scores from Confidence and Severity values, and contextual scoring logic may promote some Informational detections to a higher impact level. NDR also provides filtering of the unified event list by detection impact score using checkboxes, which allows security teams to focus investigation on higher-priority detections.

The Security Services Platform (SSP) Campaign view includes a Blueprint tab that visualizes correlated security events and key actors, supporting investigation of multi-stage incidents. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

VMware vDefend includes an Intelligent Assist triage capability: when responding to security incidents, security teams can select a Targeted Strategy for surgical, safer remediation with potentially lower effectiveness, or a Comprehensive Strategy for broader remediation with potentially lower safety. This capability helps match remediation scope to assessed incident severity.

IDS/IPS events are classified by severity level (Informational, Low, Medium, High, and Critical), and vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping non-critical severity data (Low and Informational) first, followed by Medium, then High and Critical severity events, with packet captures dropped only as a last resort. This built-in severity hierarchy reflects the product's internal classification model.

The broader incident classification process, including establishing organizational incident categories, defining triage protocols, and coordinating business continuity actions, remains an organizational function that extends beyond network-layer detection capabilities.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RS.CO

[Withdrawn: Incorporated into PR.AT-01] Internal and external stakeholders are notified of incidents
Information is shared with designated internal and external stakeholders [Withdrawn: Incorporated into
RS.MA-01, RS.MA-04] [Withdrawn: Incorporated into RS.CO-03]

SCF Controls: IRO-02, IRO-02.5, IRO-06.1, IRO-09, IRO-10, IRO-10.2, IRO-10.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities for documenting, monitoring, and reporting cybersecurity incident status through VCF Operations and its integration with external IT service management platforms. These capabilities give internal stakeholders visibility into incident lifecycle from detection through resolution, though the organizational processes governing stakeholder communication and escalation must be established separately.

VCF Operations includes a dedicated Troubleshooting Incidents page that displays a summary of all incidents, including their current status, the count of affected entities for in-progress incidents, and the top root causes identified. Individual incident records capture detailed metadata: state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Each incident can be tracked with a status of resolved (root cause found) or unresolved (no root cause identified), providing a basic incident lifecycle within the platform. Investigators can flag specific metrics and mark them as root cause during analysis. The incident page also shows historical context, including past incidents created for the same entity, traffic and flow data, and anomaly highlights that allow filtering by metric name, entity name, and other parameters. Each incident records who created it and when, providing an audit trail of incident activity. A consolidated list view of all incidents with their status is available, with options to edit, share, or delete individual records.

For alert-driven incident detection, VCF Operations allows administrators to define metric event symptoms based on threshold violations reported by monitored systems. These symptoms feed into alert definitions, where the impact setting can be configured to indicate risk levels requiring near-term attention. Symptom definitions can describe incremental levels of concern, giving operations teams graduated visibility into developing issues. Critical and immediate alerts are surfaced for prompt action. VCF Operations maps events from target systems into its own severity model, defining event triggers and mapping severity levels so that high-priority conditions are appropriately flagged.

To facilitate stakeholder reporting and integration with organizational incident management workflows, VCF Operations provides a ServiceNow Notification Plug-in that sends alert notifications to ServiceNow to create incident tickets automatically. These incidents carry structured data including the caller, category, subcategory, business service, and contact type. Notification rules can be configured to populate incident fields such as state, resolution code, resolution notes, on-hold reason, impact, urgency, priority, assignment group, assigned person, severity, approval actions, related problems, and change cause. The ServiceNow Management Pack extends this integration by watching a predefined set of incident, alert, and event columns in ServiceNow and displaying current values back in VCF Operations as alert notes, keeping both systems synchronized. The impact parameter for incidents opened in ServiceNow defaults to the value set in the VCF Operations alert, maintaining consistency across platforms.

VCF also integrates with SIEM and log management systems via syslog forwarding. VMware vCenter syslog forwarding supports the TCP, UDP, TLS, and RELP protocols and can be configured through the vCenter Management API. VCF Operations supports configuration of a remote syslog host for centralized log collection. These syslog capabilities enable continuous monitoring and data correlation across the infrastructure stack, feeding incident-relevant data to external analysis platforms.

These capabilities address the technical side of incident situational awareness, but the control also requires organizational processes for defining stakeholder notification procedures, escalation paths, reporting cadences, and data protection incident handling workflows. VCF Operations provides the tooling to document and track incidents with rich metadata, monitor their status in real time, and push incident information to external systems where broader stakeholder communication can occur.

The organization must define the policies and procedures that govern how and when this information reaches the appropriate internal stakeholders throughout the incident lifecycle.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) provides audit logging and alerting capabilities that support situational awareness during cybersecurity and data protection incidents. The System Audit Events view, accessible through the DSM administrative interface, records administrative actions with structured fields: Source (the user identifier or "System" when DSM initiates the operation), Event Type (the category of audited operation), Status (the outcome), Component (the DSM subsystem involved), Event Time (UTC), and Event Details (operation-specific context). These records give administrators a traceable account of actions within DSM that can be reviewed during an incident investigation to establish what occurred, when it occurred, and who or what initiated it. Audit event data can be exported from DSM in CSV or XLSX format using the ACTIONS drop-down menu in the System Audit Events view, supporting the documentation and reporting requirements of an incident response process.

DSM generates alerts for specific categories of security-relevant events, including authentication failures, backup and restore corruptions, and certificate errors. Administrators can enable or disable alerts for database operation failures through the "Enable Alerts for DB Operation Failure" setting. DSM also raises metrics-based alerts when resource thresholds are exceeded, and surfaces resolution suggestions alongside active database alerts in the UI to support investigation and remediation. Alerts are classified at multiple severity levels, including CRITICAL and WARNING. When alerts fire, DSM transmits notifications to configured webhooks with structured data including the alert name, alert level, trigger timestamp, current service status, and database cluster identifier and name.

Webhook configuration in DSM includes direct integration with ServiceNow. DSM populates the ServiceNow short_description, description, close_code, and close_notes fields with alert and cluster context, allowing DSM alert data to be routed into an existing incident management workflow without additional middleware. This reduces the manual steps required to open and populate incident tickets when DSM detects a security-relevant event.

DSM can also be monitored using VCF Operations for troubleshooting and status visibility, extending operational awareness beyond the DSM interface.

DSM's contribution to this control is through audit trail visibility, configurable alerting with severity classification, external notification forwarding, and ServiceNow integration. The broader requirement to document incident status end-to-end, assign incidents to responsible parties, track them through resolution, and formally report outcomes to stakeholders requires an organizational incident response process and dedicated case management tooling. DSM provides the data feeds, event notifications, and ServiceNow integration that support that process but does not replace it.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Control RS.CO-02

Internal and external stakeholders are notified of incidents

SCF Controls: IRO-02, IRO-10, IRO-10.2, IRO-10.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.CO-03

Information is shared with designated internal and external stakeholders [Withdrawn: Incorporated into RS.CO-03]

SCF Controls: IRO-02, IRO-10, IRO-10.2, IRO-10.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides detection, monitoring, alerting, notification delivery, and investigation capabilities through VCF Operations that support timely identification and reporting of incidents involving sensitive or regulated data. While the organizational process of formally reporting such incidents to regulators, affected individuals, or other stakeholders falls outside the platform's scope, VCF supplies the technical foundation that enables an organization to detect incidents quickly, gather evidence, and route information to the people and systems responsible for response.

VCF Operations event auditing provides visibility into platform interaction changes across the VCF infrastructure and surfaces suspicious access events and policy violations. This capability allows security teams to identify unauthorized or anomalous activity that may indicate a data incident. VCF Operations also provides audit tracking that identifies who made changes to the data center during a specific time range, which is important for establishing the scope and timeline of an incident involving sensitive data.

VCF Operations compliance management continuously monitors infrastructure by evaluating collected data against defined policies. When a compliance alert is triggered on VMware vCenter instances, VMware ESX hosts, virtual machines, distributed port groups, or distributed switches, compliance violations are recorded for investigation. This automated detection of deviations from compliance baselines helps organizations identify potential data-related incidents as they occur rather than discovering them after the fact. Compliance management also highlights risk areas and provides actionable remediation recommendations, supporting the triage process that precedes formal incident reporting.

VCF Operations generates alerts based on configurable thresholds and event definitions. When an alert fires, VCF Operations can deliver notifications through multiple outbound channels: SNMP traps to network management platforms, webhook calls to REST-enabled systems (in JSON or XML format), a ServiceNow plug-in that automatically creates incidents in the ServiceNow ticketing system, a Slack plug-in that forwards alerts to Slack channels with links to alert details, and email. Notification rules let administrators filter which alerts are forwarded and to which endpoints, so that events potentially involving data exposure reach the right teams without delay.

All VCF components support syslog forwarding to external log aggregation and SIEM platforms. vCenter syslog forwarding can be configured through the vCenter Management API, and ESX hosts send syslog feeds through Log Collections configuration. VCF Log Management ingests and indexes these events from across the stack, providing real-time analytics to search and filter logs instantly for troubleshooting or auditing. Users can collect and analyze log feeds, view log-related metrics, and dynamically extract fields from log messages based on customized queries. This centralized log management gives security operations teams the ability to correlate events across the environment.

Accurate log correlation depends on synchronized clocks across all components. The vSphere documentation notes that incorrect time settings in vCenter and ESX hosts make it difficult to inspect and correlate log files to detect attacks and render auditing inaccurate; NTP should be configured on all vCenter instances and ESX hosts so that log timestamps are reliable for incident investigation and reporting.

The Diagnostic Findings feature provides a consolidated view of known product issues, VMSA-based security exposures, and industry best-practice recommendations across the VCF environment. Diagnostic Findings are alerts without notifications that result from a scan of the platform against known issues, logs, and properties. This provides an additional signal that may be relevant during incident triage, helping teams determine whether an observed event is related to a known vulnerability.

For incident tracking and investigation, VCF Operations provides capabilities at multiple levels. The Troubleshooting Incident Page in VCF Network Operations displays information related to incidents, including status, root cause metrics, closing

remarks, and timestamps for when incidents were created. During investigation, analysts can flag metrics and mark root causes, creating a documented trail that supports the incident reporting process. Incident status can be tracked as resolved or unresolved within the platform. VCF Operations also supports scheduled automated reports at regular intervals to track current resources and identify potential risks to the environment, which can feed an organization's incident reporting workflow.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, giving organizations awareness of the state of their data protection posture. VCF Automation includes data compliance controls that require explicit consent before exposing user names. This supports organizations that must track access to personally identifiable information.

To satisfy this control fully, organizations must establish incident response procedures that define reporting timelines, designate responsible personnel, identify the authorities and regulators to notify, and specify the content and format of incident reports. VCF provides the detection, correlation, notification delivery, and evidence-gathering layer, but the reporting process itself requires organizational policies, communication channels, and human decision-making.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.MA

The incident response plan is executed in coordination with relevant third parties once an incident is declared. Incident reports are triaged and validated. Incidents are categorized and prioritized. Incidents are escalated or elevated as needed. The criteria for initiating incident recovery are applied. [Withdrawn: Incorporated into RS.MA-02] [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04] [Withdrawn: Moved to RS.MA-03] [Withdrawn: Incorporated into RS.MA-01, RS.MA-04] [Withdrawn: Incorporated into RS.MA-01]

SCF Controls: IRO-02, IRO-04, IRO-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low

and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during

an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.MA-01

The incident response plan is executed in coordination with relevant third parties once an incident is declared [Withdrawn: Incorporated into RS.MA-01, RS.MA-04] [Withdrawn: Incorporated into RS.MA-01]

SCF Controls: IRO-02, IRO-02.5, IRO-04, IRO-07, IRO-10

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.MA-02

Incident reports are triaged and validated [Withdrawn: Incorporated into RS.MA-02] [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04]

SCF Controls: IRO-02, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.MA-03

Incidents are categorized and prioritized [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04]
[Withdrawn: Moved to RS.MA-03]

SCF Controls: IRO-02.4

Aggregate Coverage: Contributes

VMware vDefend (Contributes)

VMware vDefend provides structured classification and prioritization mechanisms for security detection events within the network security domain.

Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help security teams prioritize response actions. Security Intelligence also categorizes detected events by MITRE adversarial tactics and techniques, recording occurrence counts during the selected time period, which provides additional context for classification decisions.

Network Detection and Response (NDR) assigns impact scores to campaigns, with higher scores indicating higher priority for triage and response. Detection events are classified into impact levels; events with an impact score from 1 to 24 are classified as Informational, indicating the detected activity is not essentially malicious. NDR calculates impact scores from Confidence and Severity values, and contextual scoring logic may promote some Informational detections to a higher impact level. NDR also provides filtering of the unified event list by detection impact score using checkboxes, which allows security teams to focus investigation on higher-priority detections.

The Security Services Platform (SSP) Campaign view includes a Blueprint tab that visualizes correlated security events and key actors, supporting investigation of multi-stage incidents. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions.

VMware vDefend includes an Intelligent Assist triage capability: when responding to security incidents, security teams can select a Targeted Strategy for surgical, safer remediation with potentially lower effectiveness, or a Comprehensive Strategy for broader remediation with potentially lower safety. This capability helps match remediation scope to assessed incident severity.

IDS/IPS events are classified by severity level (Informational, Low, Medium, High, and Critical), and vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping non-critical severity data (Low and Informational) first, followed by Medium, then High and Critical severity events, with packet captures dropped only as a last resort. This built-in severity hierarchy reflects the product's internal classification model.

The broader incident classification process, including establishing organizational incident categories, defining triage protocols, and coordinating business continuity actions, remains an organizational function that extends beyond network-layer detection capabilities.

Not applicable for this control: VCF, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control RS.MA-04

Incidents are escalated or elevated as needed [Withdrawn: Incorporated into RS.MA-02, RS.MA-03, RS.MA-04] [Withdrawn: Incorporated into RS.MA-01, RS.MA-04]

SCF Controls: IRO-02, IRO-04, IRO-07

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require

zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.MA-05

The criteria for initiating incident recovery are applied

SCF Controls: BCD-01, BCD-01.5

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides several technical capabilities that support an organization's ability to define and meet Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) as part of business continuity and disaster recovery planning, though the organizational criteria for when to initiate BC/DR plans remain a governance responsibility.

VCF includes configurable RPO settings at multiple levels of the stack. vSphere Replication allows administrators to specify an RPO value directly through the replication specification's Rpo parameter, giving precise control over the maximum acceptable data loss window for replicated workloads. For VCF Operations for Networks deployments, replication can be configured for each node that requires protection, with recommended RPO values varying by deployment size. For migration scenarios involving VCF Operations HCX, delta synchronization with a configurable recovery point objective runs continuously after initial synchronization completes, maintaining data currency while waiting for a scheduled switchover. The VCF documentation explicitly notes that application disaster recovery may result in some data loss during failover depending on the configured RPO, which helps organizations understand the tradeoffs when setting their recovery criteria. Storage Policy Based Management (SPBM) provides an additional mechanism for encoding RPO requirements at the policy level: SPBM rules can define the maximum recovery point objective for Virtual Volumes objects and can include RPO settings within replication policy components, allowing administrators to associate data protection requirements directly with VM storage policies.

For RTO support, vSphere HA and vSAN stretched clusters provide automated failover capabilities that directly influence achievable recovery times. vSAN stretched clusters extend a single logical cluster across two availability zones with synchronous data mirroring between sites, providing near-zero RPO for site-level events since data is written to both sites before acknowledging the write. When the site disaster tolerance parameter is set to site mirroring, the cluster can tolerate one site failure and data remains accessible from the surviving site. vSphere HA restarts virtual machines on the remaining active site during a site failure. When vSphere HA admission control is configured to reserve 50% of the cluster's aggregate CPU and memory resources for failover, the platform can restart all VMs from one site on the other site. vSAN stretched clusters can also tolerate a witness host failure when one site is unavailable, provided the storage policy Site disaster tolerance rule is configured for Site mirroring. These automated recovery mechanisms give organizations measurable recovery time baselines against which to set their initiation criteria.

vSphere HA automatically restarts virtual machines on surviving hosts when a host failure is detected, providing fast recovery times for host-level failures. Admission control policies can be specified in VMware vCenter to reserve capacity and set failover share thresholds, coordinated with corresponding vSAN failure tolerance policy settings. vSphere Fault Tolerance provides continuous availability for individual workloads in the event of a hardware failure by maintaining a live shadow instance of a virtual machine on a separate host, with no data loss or downtime during failover. When vSphere HA is used alongside DRS, the cluster can bring hosts out of standby mode or migrate virtual machines to defragment resources, helping to maintain the capacity required for HA failovers even when aggregate cluster resources are constrained.

VCF supports multiple disaster recovery deployment models at the application level. Disaster recovery with failover to a secondary site maintains operations during major disruptions. The platform documentation recommends combining real-time high availability with sitewide disaster recovery for maximum resilience. Disaster recovery can also be implemented for fleet-level components, and NSX Federation supports both planned and unplanned disaster recovery scenarios for Global Manager, extending recovery capabilities across the networking layer.

vSAN Data Protection provides snapshot-based recovery with configurable retention and scheduling through protection groups. Each protection group contains snapshot policies that define retention duration and snapshot scheduling intervals, allowing organizations to align snapshot frequency with their RPO requirements. Protection groups can be configured for

hourly snapshots with hour-based retention, and snapshots can be replicated to external targets for offsite protection. vSAN Distributed File System Snapshot provides the ability to retrieve data from files in the event of accidental deletion.

Changed Block Tracking (CBT) tracks modified disk sectors to enable incremental backups through VADP-integrated backup solutions. vCenter tracks changes on disk sectors, and VADP-based backup partner solutions can automatically perform backup, full restore, and registration of VMs. This reduces backup windows and supports tighter RPO targets by allowing backup tools to capture only the blocks that have changed since the last backup rather than performing full copies each time.

VCF's backup infrastructure supports recovery operations through scheduled backup jobs that capture the state of related management components at a common point in time. The documentation recommends implementing scheduled backups to prepare for critical failures, upgrades, or certificate updates of management components. VCF Operations backup can be configured to take a backup on state change, providing additional data protection for management plane components.

VCF Operations monitors the infrastructure and generates alerts when conditions change, which can inform decisions about when to activate contingency plans. VCF Operations supports creation and configuration of alert definitions to monitor infrastructure events and conditions, including log-based alerts. Alert definitions can be configured with criticality and impact metadata that reflects business priorities. VCF Operations also reports capacity and availability metrics through dashboards, including capacity remaining widgets and capacity summary views across all monitored environments, giving operations teams visibility into whether the environment is meeting its availability targets.

The VCF documentation explicitly states that organizations must plan and test disaster recovery strategies regularly to meet their recovery time objectives and recovery point objectives. While VCF provides the technical mechanisms for configurable RPO, automated RTO through HA and stretched clusters, snapshot-based data protection, incremental backup support, and infrastructure monitoring, the definition of specific initiation criteria for BC/DR plans remains an organizational responsibility. The thresholds that trigger activation, the governance processes around those decisions, and the alignment of technical capabilities with business requirements all require organizational planning beyond what the platform provides.

VMware vDefend (Contributes)

VMware vDefend contributes to business continuity by providing security-layer continuity mechanisms that remain active during disaster recovery events and workload migrations. NSX Federation Security maintains security posture across data centers during disaster recovery and workload migration, preserving distributed firewall and gateway firewall policies so that enforcement continues through failover.

The Security Services Platform, which provides the underlying infrastructure for vDefend's threat detection and inspection services, supports vSphere High Availability configurations. When a VMware ESX host becomes unhealthy, vSphere HA migrates the affected Security Services Platform virtual machines to healthy hosts in the cluster, restoring threat detection capacity without manual intervention. VMware recommends enabling vSphere HA for host-level failure recovery and configuring a storage policy with RAID for datastore-level failure tolerance in Security Services Platform deployments.

Security Services Platform can also be deployed on a vSAN stretched cluster configuration, which replicates storage across two physically distinct sites connected by a high-bandwidth or low-latency inter-site link. This configuration requires a minimum of two sites with their own hosts and a witness host to handle potential conflicts arising from network partitions, supporting site-level failure scenarios.

When vSphere HA restarts workload VMs on a new recovery host after a failover, the vDefend distributed firewall automatically reinspects all traffic from those VMs on the receiving host, because the Flow Table contents cannot be moved between hosts during host recovery. Security policy enforcement resumes on the new host without manual reconfiguration.

The broader BCMS framework, including Continuity of Operations Plan and BC/DR playbooks, impact analyses, and organizational governance processes, is outside vDefend's scope and must be established through dedicated business continuity management programs.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) enforces technical preconditions that must be satisfied before recovery operations can execute, providing the operational criteria layer for BC/DR plan initiation.

Recovery plan state management gates which operations are permitted at each stage. The state of a recovery plan is determined by the states of the protection groups within that plan, and the plan state determines which operations are allowed. Plans transition through defined states including Ready, Test in progress, Test complete, and recovery states. The recovery plan must be in a "failedOver" state before a reprotect process can be initiated, and the originally protected site must be operational before reprotection can proceed. This state-based gating is enforced both through the PNR interface and through the VCF Operations orchestrator plugin for PNR, which provides workflow-based verification of preconditions before initiating reprotect operations.

Two distinct recovery types define the criteria path for initiation: Planned Migration for orderly workload evacuation when both sites are operational, and Disaster Recovery for unplanned site failures. In PNR, the same recovery plan can be used for both disaster recovery and cyber recovery operations, consolidating the criteria framework across recovery scenarios. Most recovery plans require different configurations for emergency scenarios at the protected site versus planned migration of services from one site to another.

vSphere Replication provides the RPO configuration layer that determines what recovery state is available when initiation occurs. RPO can be configured using a slider with a range from 1 minute to 24 hours to set the acceptable period for which data can be lost if a site failure occurs. Per-VM retention policies using the Latest instances option support up to 200 recovery points. Recovery point configuration should balance storage consumption and snapshot consolidation time; the guidance recommends using the fewest recovery points that meets business requirements. When a recovery is initiated, administrators can select whether to synchronize recent changes from the source site before the recovery operation, reducing exposure to data loss, or to recover immediately using the latest data already available at the target site.

PNR integrates with VCF Automation through replication classes, which are preconfigured with RPO values that define the acceptable amount of data loss after a disaster. This allows organizations using VCF Automation to define recovery criteria at the replication class level for consistent policy application across workloads. Protection and Recovery Dashboards in VCF Operations provide monitoring of RPO status and vSAN snapshots and replication metrics, giving administrators visibility into whether recovery thresholds are being maintained across protection groups.

Recovery plan testing validates that the technical criteria for successful recovery are met before relying on the plan in an actual event. PNR records the result of test recovery operations, including cancellation status, in the recovery plan state. A recovery plan must also reflect the current state of its protection groups; if any members show a status other than OK, the problems must be corrected before any changes can be made to the plan.

The organizational criteria for when to declare a disaster and authorize plan initiation are governance responsibilities outside PNR's scope.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer provides application-layer resilience mechanisms at both the control plane and the data plane that organizations can incorporate into business continuity plans for application delivery services.

At the control plane, the Avi Controller is deployed as a cluster with continuous configuration replication across all nodes, providing management-plane redundancy so that a single Controller node failure does not interrupt application delivery operations. Avi supports deployment of the Controller cluster across two availability zones, with vSphere HA recommended to support recovery of any node that fails in the secondary zone. For single-node deployments, enabling vSphere HA on the Controller VM is recommended for node recovery following a host failure. The Avi Controller provides configuration backup and restore capability that supports disaster recovery and configuration migration across Controller instances; organizations should capture and retain Controller backups as part of their continuity documentation.

Availability Zone awareness in Avi allows multiple availability zones to be configured, each defining a subset of vCenter instances, hosts, and datastores that share a fault domain. Configuring availability zones during Service Engine Group setup

distributes data-plane capacity across isolated failure domains, supporting continuity designs where application delivery capacity remains available if one fault domain becomes unavailable.

At the data plane, Avi's Elastic High Availability mode provides fast recovery for individual virtual services following Service Engine failure. In vSphere DRS-enabled clusters, virtual service recovery occurs before vSphere HA brings up a replacement Service Engine when virtual service slots are available in other Service Engines, giving the application delivery layer its own recovery path distinct from the infrastructure restart cycle. If vSphere HA does not recover the failed Service Engine within a configured timeout period, the Avi Controller resumes recovery independently. Service Engine VMs should be deployed on vSphere clusters configured with both HA and DRS in fully automated mode; when Avi is deployed with VMware Kubernetes Service (VKS) on VCF, DRS and HA are required on every vSphere cluster used with Avi.

For Kubernetes environments, the Avi Multi-Cluster Kubernetes Operator (AMKO) provides federation architecture that supports disaster recovery across Kubernetes clusters. AMKO designates a leader cluster and multiple member clusters, coordinating application delivery failover as part of a multi-cluster DR strategy.

Avi ControlScripts, used in conjunction with the alert framework, can perform automated failover actions such as adding or removing routes based on VIP attachment and detachment events, allowing organizations to define automated remediation workflows that respond to system events without manual administrator intervention.

In 9.1 deployments using VCF Automation, Avi's Central Licensing maintains a global capacity pool that removes the requirement for duplicate licenses in DR scenarios, supporting license continuity across failover sites.

Organizations should document these mechanisms, including the Elastic HA configuration, Controller cluster topology and backup schedule, availability zone placement, and AMKO federation design, in their Business Continuity and Disaster Recovery playbooks. The technical recovery capabilities are built into the product; the planning artifacts, testing procedures, and escalation workflows are organizational responsibilities that extend beyond what Avi provides.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.MI

Incidents are contained Incidents are eradicated [Withdrawn: Incorporated into ID.RA-06]

SCF Controls: IRO-01, IRO-02, IRO-04

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support an organization's incident response operations, though it does not govern organization-wide incident response processes or maintain incident response documentation. VCF Operations is the primary platform for detecting, tracking, and investigating infrastructure-level incidents across the VCF environment.

VCF Operations includes a dedicated incident management system that displays all incidents with their current status and key metadata. Each incident record tracks state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation. Operators can edit, share, and delete incidents directly from the incident list interface, and the system maintains an audit trail of who created each incident and when. This structured tracking provides the documentation trail that incident response processes require.

For incident investigation, VCF Operations provides root cause analysis tooling through its Troubleshooting Incident Page. This interface displays information about the affected entity, including traffic and flow data, any past incidents created for the same entity, and root cause metrics. Investigators can flag individual metrics and mark specific metrics as the root cause of an incident. The system also allows drill-down into related entities to view detailed metrics for problem investigation, supporting a methodical approach to identifying the source and scope of an issue. A summary view displays the count of in-progress incidents, entity counts, and top root causes, which supports situational awareness during active incident response and helps teams prioritize efforts across multiple concurrent issues.

For detection, VCF Operations performs event correlation across monitored systems, correlating a subset of published events and delivering them as faults. The platform maps events from target systems into the VCF Operations severity model, with event severity ranked from Info to Immediate. This automated correlation and severity classification helps operations teams identify incidents that require immediate response. Notification rules can be configured to trigger actions based on incident state changes, with configurable fields including incident state, resolution code, on-hold reason, impact, urgency, priority, assignment group, assigned-to person, severity, approval actions, related problems, and change cause. VCF Operations also supports defining fault symptoms and metric event symptoms based on thresholds and conditions reported by monitored systems, which can be combined into alert definitions that surface conditions requiring operator attention.

At the VMware vCenter level, alarms can execute scripts, send SNMP traps, or call APIs when infrastructure conditions match defined thresholds. The SNMP agent included with vCenter sends traps when alarms are triggered, and VCF PowerCLI provides programmatic access to alarm management through cmdlets that support creation of script-based and SNMP alarm actions. These capabilities provide automated event detection and alerting that feed into broader incident response processes.

To integrate with broader organizational incident response workflows, VCF Operations supports a ServiceNow Notifications plug-in that creates incidents directly in a ServiceNow ticketing system. The integration is configurable with fields including caller ID, incident category, sub-category, business service, contact type, and propagation settings for alert updates. This integration enables VCF-detected incidents to flow into an organization's established incident response and ticketing processes.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a physical machine failure. Proactive HA integrates with hardware vendor health monitoring to evacuate workloads before failures occur. vSphere cluster HA configuration supports multiple remediation modes, including quarantine mode, maintenance mode, and mixed mode. These recovery capabilities can be exercised ad hoc or incorporated into existing playbooks and runbooks.

VMware vDefend (a separate product that extends VCF's networking foundation) adds automated threat detection and containment through IDS/IPS and network detection features, including quarantine policies that isolate affected VMs while preserving forensic access.

This control requires organization-wide incident response governance, documented processes, and cross-functional coordination that go beyond what any infrastructure platform provides on its own. VCF delivers incident tracking, investigation tooling, event correlation, automated alerting, ITSM integration, and infrastructure recovery capabilities that form a technical foundation for incident response, but organizations must build their own incident response plans, escalation procedures, communication protocols, and training programs around these capabilities.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads.

After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.MI-01

Incidents are contained

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

Control RS.MI-02

Incidents are eradicated

SCF Controls: IRO-02

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides technical capabilities that support several phases of the incident handling lifecycle, though the organizational preparation, process governance, and manual intake elements require processes and structures outside the platform.

For preparation, VCF Operations supports the configuration of notification rules with detailed incident field mappings, including incident state, resolution codes, impact, urgency, priority, severity levels, and assignment groups. The ServiceNow Management Pack can be configured with parameters such as callerId, propagateAlertUpdates, retrieveIncidentUpdates, and incidentReopenState, allowing organizations to establish incident handling workflows before events occur. These configuration options allow teams to define how incidents are categorized, prioritized, and routed in advance of any actual incident.

For automated event detection, VCF Operations correlates events from monitored infrastructure components and delivers them as faults. Events are ranked by severity from Info through Warning, Critical, and Immediate, and notification rules trigger actions based on incident state changes. VCF Operations can automatically create incidents in ServiceNow through the Service-Now Notifications plug-in, with structured information including the caller, category, subcategory, and business service. This integration bridges the gap between infrastructure monitoring and organizational incident tracking systems. VCF Operations also combines Diagnostic Findings with VCF Health to detect and predict issues, which helps reduce mean time to resolution. VMware vCenter alarms provide additional automated detection, triggering script execution, SNMP traps, email notifications, or API calls when infrastructure conditions exceed defined thresholds.

For analysis, the Troubleshooting Incident Page displays information related to the entity under investigation, including traffic and flows on the entity, past incidents created for that entity, status, root cause metrics, and closing remarks. Operators can flag metrics and mark specific metrics as root cause during investigation. The Notes section on each incident allows users to add observations that are visible to anyone who opens the session, which supports collaborative analysis across team members. vCenter Events record user and system actions on inventory objects and can be used for forensic analysis and auditing of activity in the virtual environment, providing an audit trail for incident investigation. Diagnostic Findings consolidates log-based and property-based findings with specific resolution recommendations and links to knowledge base articles, helping analysts identify known issues by matching log patterns and property-based signatures against a library of diagnostic rules. Log Assist can generate log bundles and automatically attach property-based diagnostic findings data to support cases. VCF Operations also integrates with ServiceNow, allowing incidents to flow into existing ITSM workflows for structured triage.

For containment, vCenter supports isolating affected workloads through VM power state changes and network reconfiguration. VMware vDefend (a separate product that extends VCF's networking foundation) provides more targeted containment through quarantine policies that automatically isolate VMs based on security events while preserving forensic access for investigation. Physical containment, network isolation decisions, and cross-system coordination during active incidents depend on processes and authority structures that exist outside the platform.

For eradication, VCF Operations maps out-of-the-box workflows to recommendations and associates them with specific alerts, enabling automated remediation of known conditions. Diagnostic Findings helps operators find and resolve known issues using diagnostic rules and signatures, with recommended fixes based on industry-standard best practices.

For recovery, vSphere HA automatically restarts VMs on healthy hosts after a host failure, with admission control policies that reserve capacity for failover. Proactive HA integrates with hardware vendor monitoring to detect degrading components and evacuate workloads before failure occurs. vSphere Fault Tolerance provides continuous availability for workloads that require zero-downtime protection during failover. VCF Operations maintains a summary view of all incidents with status tracking, entity counts for in-progress incidents, and counts of top root causes for visibility into the overall state of incident resolution.

VCF Operations also provides a centralized incident list displaying all incidents with their status and key details, with edit, share, and delete actions for incident lifecycle management. Incident tracking captures state, resolution code, resolution notes, impact (business criticality), urgency (resolution timeframe), priority (resolution sequence), severity level, and approval workflow documentation, which is a structured audit trail for each incident. The Guided Network Troubleshooting feature automatically maintains a list of the 20 most recently modified incidents within a selected scope for continuity across investigation sessions.

While VCF Operations provides tooling for detection, analysis, and remediation of infrastructure incidents, several aspects of the six-phase incident handling lifecycle require organizational processes beyond what the platform provides. Preparation requires documented incident response plans, team roles, and communication procedures. Manual incident report intake requires organizational channels and triage processes. Containment decisions require human judgment and authority structures. A formal incident response program that incorporates VCF's technical capabilities into broader organizational processes is necessary to address all six phases.

VMware vDefend (Contributes)

VMware vDefend (VMware vDefend and Advanced Threat Protection) contributes to multiple phases of the incident handling lifecycle through network-layer detection, multi-signal analysis, and automated containment capabilities.

For detection and event intake, Security Intelligence categorizes detected suspicious traffic events by impact type, assigning Critical, High, Medium, or Low severity to help teams prioritize response. Security Intelligence also maps detections to MITRE ATT&CK tactics and techniques and records occurrence counts over configurable time windows, providing the structured event context that analysis workflows require.

For analysis, Malware Prevention generates File Analysis Reports and Process Analysis Reports that detail the types of activities detected during artifact inspection. File Analysis Reports classify detected behaviors across categories including Autostart, Disable, Evasion, File, Memory, Network, Reputation, Settings, Signature, Steal, Stealth, and Silenced, and include an ATT&CK TECHNIQUES field that records observed malicious actions or tools. Process Analysis Reports document in-memory script buffer inspection results and carry an Analyst UUID to track individual inspection events. Malware Prevention Service event logs capture file type, file size, inspection timestamp, client VM ID, submission source, detection status, verdict, and analysis status for each inspected file. The Malware Prevention Dashboard aggregates file and process event details and inspection results for operator review. Network Detection and Response (NDR) Campaign Correlation Rules correlate labeled file and process detections, including AV labels and PCAP matches, with matching IDS events on the same compute, supporting multi-signal analysis during investigation. The Security Services Platform assigns a Security Operator role dedicated to monitoring security systems and responding to security incidents.

For containment and eradication, Intelligent Assist supports remediation by allowing selection of a Targeted Strategy for surgical, focused containment or a Comprehensive Strategy for broader remediation across potentially affected workloads. The Security Segmentation Report's Overview section summarizes inter-environment policies and rules, providing traffic flow context that can inform containment scope. Security Explorer's ratio of detected versus prevented events helps operators assess how effectively controls are operating during active response.

A limitation applies to automated remediation: objects generated during Intelligent Assist or NDR remediation that encounter errors require manual cleanup, so recovery activities may require human intervention beyond automated policy actions. vDefend IDS/IPS also applies a severity-based prioritization under memory pressure, dropping lower-severity events (Low and Informational) first before Medium, High, and Critical, which operators should account for when assessing detection completeness during an investigation.

Preparation and full organizational recovery rely on processes and tooling outside vDefend's scope.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) provides technical mechanisms that support the recovery, containment, and detection phases of incident handling through recovery plans, isolated cyber-recovery workflows, structured event logging, and integration with security monitoring platforms.

Recovery plans define ordered procedures for recovering protected workloads at a recovery site, including custom recovery steps. PNR handles custom command failures in recovery plans based on the type of command, allowing operators to control how the plan continues when steps fail. When a disaster event affects the management domain containing VCF Automation and VCF Operations, PNR enables service recovery in another management domain so that users can recover workloads. After execution, PNR provides the ability to view and export reports about each run of a recovery plan, test of a recovery plan, or test cleanup, producing documented evidence for after-action review.

For containment and eradication, the Clean Room Orchestrator enables triage and analysis of recovered workloads in an isolated environment. PNR monitors a global collection of clean room events, tasks, and alarms for recovery operations, with Clean Room Orchestrator events classified at severity levels of Info, Warning, Error, and Emergency. This isolated environment supports analysis of suspect workloads in parallel to site-level recovery actions.

For detection and analysis, PNR logs events and triggers corresponding alarms to track system health, with event records including timestamp, priority level, message content, component name, severity level, configuration ID, component ID, and event type. PNR tracks Site Status events that provide information about the status of protected and recovery sites and the connection between them. PNR can forward Clean Room Orchestrator events to VCF Log Management, Microsoft Sentinel, or Splunk Cloud, supporting integration with broader security monitoring and incident response platforms.

PNR Health findings classify status into Error, Warning, and Info categories and are visible through Protection and Recovery dashboards in VCF Operations. Deployment topology with separate management domains for each region is designed to contain the impact of a disaster event to one particular region, supporting preparation by limiting blast radius.

VMware Avi Load Balancer (Contributes)

Avi Load Balancer contributes to the incident handling lifecycle by providing application-layer detection, analysis, automated alerting, and recovery capabilities within its role as an application delivery controller.

For preparation, the Controller's alert and event framework supports pre-configured response actions. ControlScripts, defined under Alert Actions in the Controller UI, allow administrators to specify automated responses that fire when defined alert conditions are met. The Alert feature processes system events and metrics against user-defined rules and generates notifications via email, syslog message, or SNMP trap. The Syslog-Audit-Persistence alert action streams audit compliance events to external syslog servers, enabling incident response tooling to receive Avi event data in real time.

For automated event detection, the Controller's System Events Overlay records event codes that provide high-level definitions of system status, including SERVER_HEALTH_DEGRADED, POOL_HEALTH_DEGRADED, and VS_UP. The Avi Service Engine logs events when WAF matches a transaction, and logs audit record failures to Events, Syslog, and Splunk, covering initiation and termination of trusted channels, certificate validation failures, client authentication failures, and SSH session establishment failures. The Application Security Report provides an executive summary alongside WAF statistics, including ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking source IP addresses, and trend summaries of total and flagged request volumes.

For analysis, Avi Service Engine health monitoring records failure details for each monitored server, including failure type, failure count, average response time, and minimum and maximum response times. The Service Engine analytics page displays the list of failed health monitors per server in a pool, enabling investigation of health patterns. WAF Log Analytics supports creation of exceptions at the group or rule level for false positive remediation, enabling more accurate signal analysis during an investigation. Support bundles collect diagnostic data, logs, and configuration information from the system to assist in troubleshooting and resolving issues.

For containment, WAF policies block application-layer requests that match defined rules or anomaly score thresholds, and WAF Policies can attach a Positive Security group to apply learned data and define hit/miss actions for fine-grained control. ControlScripts can trigger automated containment actions in response to alert events.

For recovery, the Avi for VCF rollback procedure supports validation of the operational status of all VIPs and pools, followed by end-to-end health checks on the VS-App environment. GSLB services with the priority algorithm support a manual resume option for controlled failover and recovery management.

The full incident handling program, including organizational preparation procedures, eradication processes for removing attacker footholds across the broader environment, cross-team coordination, and end-to-end recovery governance, requires processes and tooling beyond what Avi provides within its application delivery scope.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

